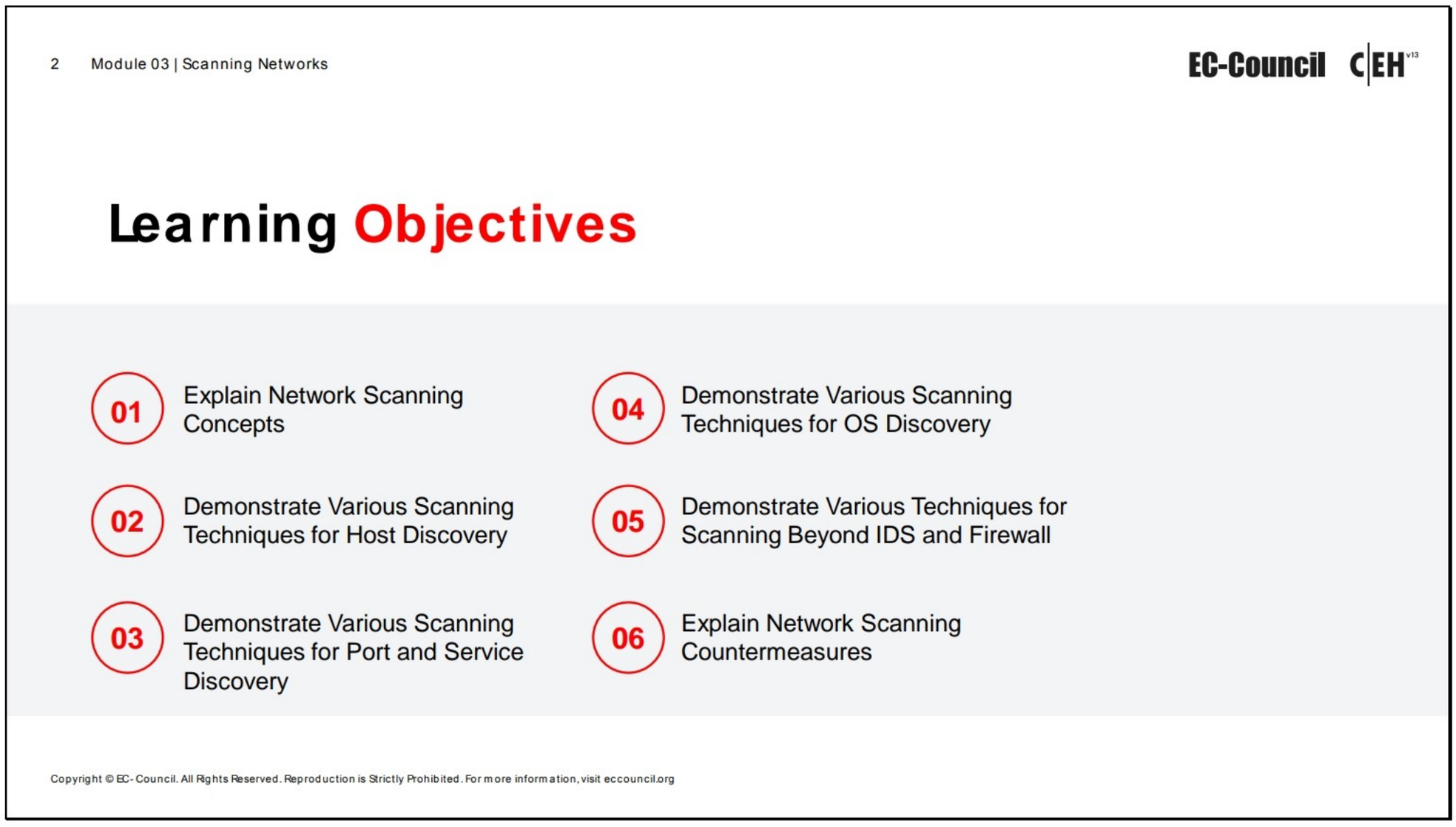
Module 03

Scanning Networks

EC-Council
Official Curricula

EC-Council C|EH v13 Certified Ethical Hacker

This page is intentionally left blank.



Learning Objectives

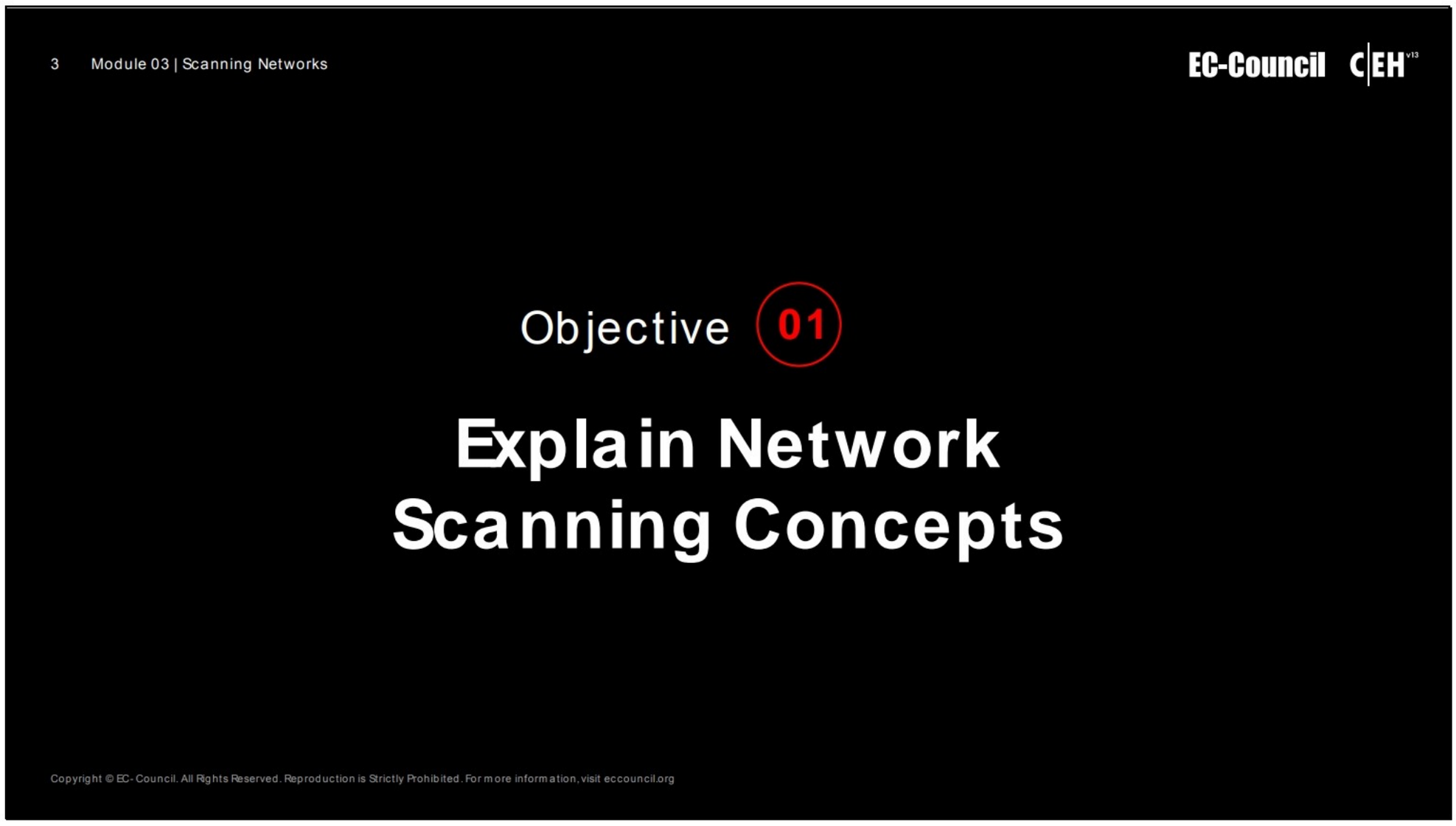
After identifying the target and performing the initial reconnaissance, as discussed in the Footprinting and Reconnaissance module, attackers begin to search for an entry point into the target system. Attackers should determine whether the target systems are active or inactive to reduce the time spent on scanning. Notably, the scanning itself is not the actual intrusion but an extended form of reconnaissance in which the attacker learns more about his/her target, including information about OSs, services, and any configuration lapses. The information gleaned from such reconnaissance helps the attacker select strategies for attacking the target system or network.

This module starts with an overview of network scanning and provides insights into various host discovery techniques that can be used to check for live and active systems. Furthermore, it discusses various port and service discovery techniques, operating system discovery techniques, and techniques for scanning beyond IDS and firewalls. Finally, it ends with an overview of drawing network diagrams.

At the end of this module, you will be able to:

- Describe the network scanning concepts
- Use various scanning tools
- Perform host discovery to check for live systems
- Perform port and service discovery using various scanning techniques
- Perform operating system (OS) discovery
- Scan beyond intrusion detection systems (IDS) and firewalls
- Explain various network scanning countermeasures

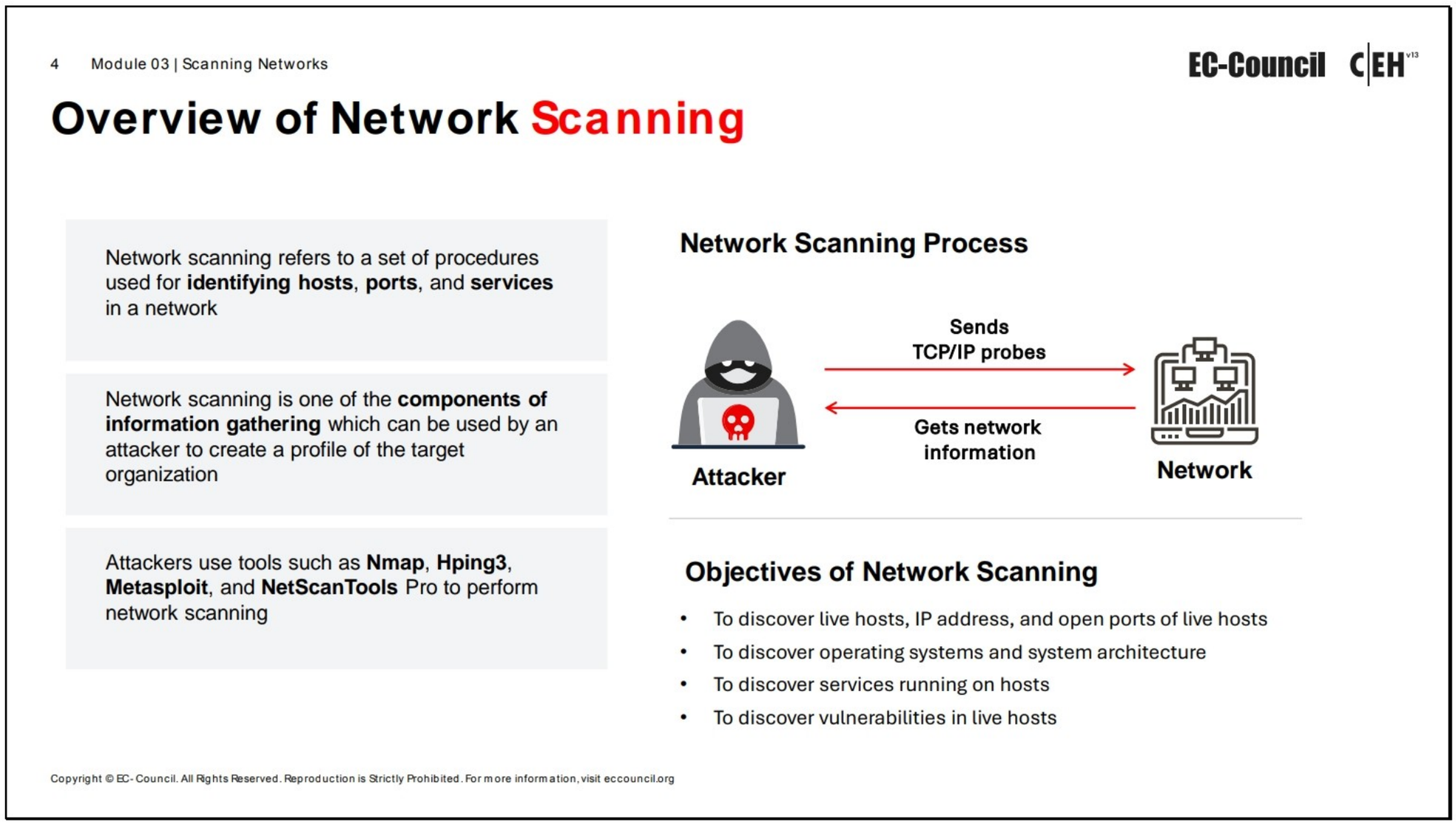
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Network Scanning Concepts

As already discussed, footprinting is the first phase of hacking, in which the attacker gains primary information about a potential target. He/she then uses this information in the scanning phase to gather more details about the target.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Overview of Network Scanning

Scanning is the process of gathering additional detailed information about the target using highly complex and aggressive reconnaissance techniques. Network scanning refers to a set of procedures used for identifying hosts, ports, and services in a network. Network scanning is also used for discovering active machines in a network and identifying the OS running on the target machine. It is one of the most important phases of information gathering for an attacker, which enables him/her to create a profile of the target organization. In the process of scanning, the attacker tries to gather information, including the specific IP addresses that can be accessed over the network, the target's OS and system architecture, and the ports along with their respective services running on each computer.

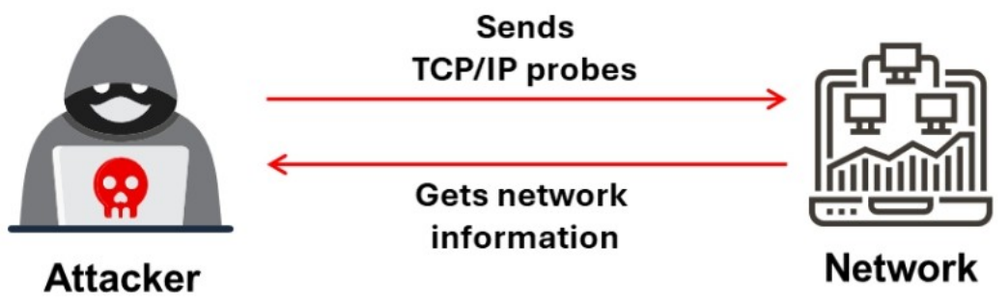


Figure 3.1: Network scanning process

The purpose of scanning is to discover exploitable communications channels, probe as many listeners as possible, and track the ones that are responsive or useful to an attacker's particular needs. In the scanning phase of an attack, the attacker tries to find various ways to intrude into a target system. The attacker also tries to discover more information about the target system to determine the presence of any configuration lapses. The attacker then uses the information obtained to develop an attack strategy.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Types of Scanning

- **Port Scanning** – Lists the open ports and services. Port scanning is the process of checking the services running on the target computer by sending a sequence of messages in an attempt to break in. Port scanning involves connecting to or probing TCP and UDP ports of the target system to determine whether the services are running or are in a listening state. The listening state provides information about the OS and the application currently in use. Sometimes, active services that are listening may allow unauthorized users to misconfigure systems or to run software with vulnerabilities.
- **Network Scanning** – Lists the active hosts and IP addresses. Network scanning is a procedure for identifying active hosts on a network, either to attack them or assess the security of the network.
- **Vulnerability Scanning** – Shows the presence of known weaknesses. Vulnerability scanning is a method for checking whether a system is exploitable by identifying its vulnerabilities. A vulnerability scanner consists of a scanning engine and a catalog. The catalog includes a list of common files with known vulnerabilities and common exploits for a range of servers. A vulnerability scanner may, for example, look for backup files or directory traversal exploits. The scanning engine maintains logic for reading the exploit list, transferring the request to the web server, and analyzing the requests to ensure the safety of the server. These tools generally target vulnerabilities that secure host configurations can fix easily through updated security patches and a clean web document.

A thief who wants to break into a house looks for access points such as doors and windows. These are usually the house's points of vulnerability, as they are easily accessible. When it comes to computer systems and networks, ports are the doors and windows of a system that an intruder uses to gain access. A general rule for computer systems is that the greater the number of open ports on a system, the more vulnerable is the system. However, there are cases in which a system with fewer open ports than another machine presents a much higher level of vulnerability.

Objectives of Network Scanning

The more the information at hand about a target organization, the higher are the chances of knowing a network's security loopholes, and, consequently, for gaining unauthorized access to it.

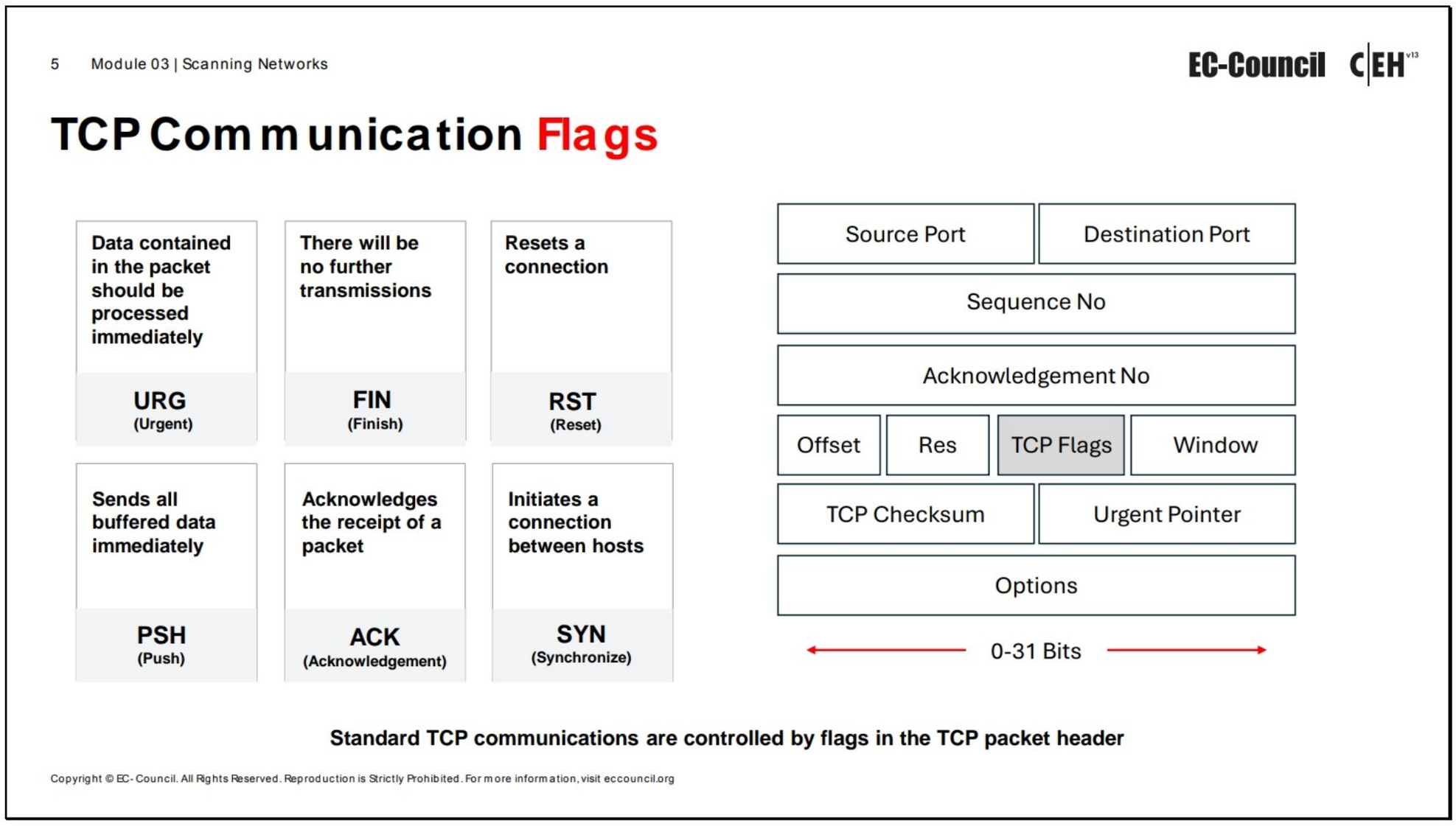
Some objectives for scanning a network are as follows:

- Discover the network's live hosts, IP addresses, and open ports of the live hosts. Using the open ports, the attacker will determine the best means of entering into the system.
- Discover the OS and system architecture of the target. This is also known as fingerprinting. An attacker can formulate an attack strategy based on the OS's vulnerabilities.
- Discover the services running/listening on the target system. Doing so gives the attacker an indication of the vulnerabilities (based on the service) that can be exploited for gaining access to the target system.
- Identify specific applications or versions of a particular service.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Identify vulnerabilities in any of the network systems. This helps an attacker to compromise the target system or network through various exploits.
- Map out the topology of the network, including devices, routers, switches, and their interconnections.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



TCP Communication Flags

The TCP header contains various flags that control the transmission of data across a TCP connection. Six TCP control flags manage the connection between hosts and give instructions to the system. Four of these flags (SYN, ACK, FIN, and RST) govern the establishment, maintenance, and termination of a connection. The other two flags (PSH and URG) provide instructions to the system. The size of each flag is 1 bit. As there are six flags in the TCP Flags section, the size of this section is 6 bits. When a flag value is set to "1," that flag is automatically turned on.

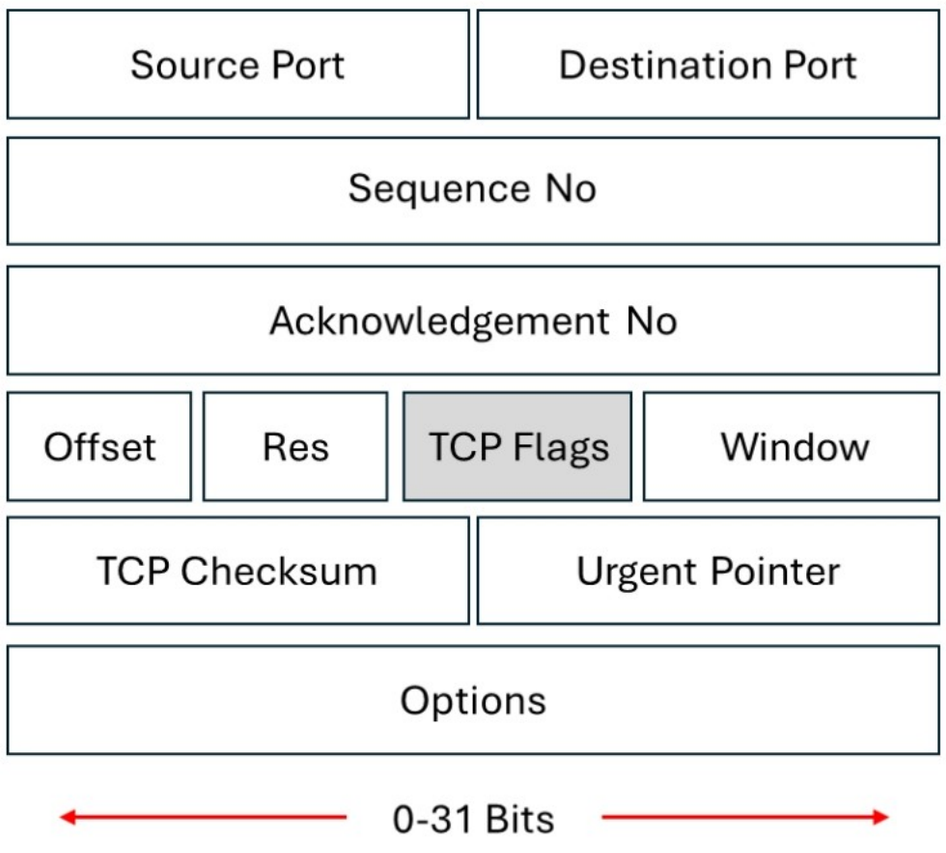


Figure 3.2: TCP header format

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

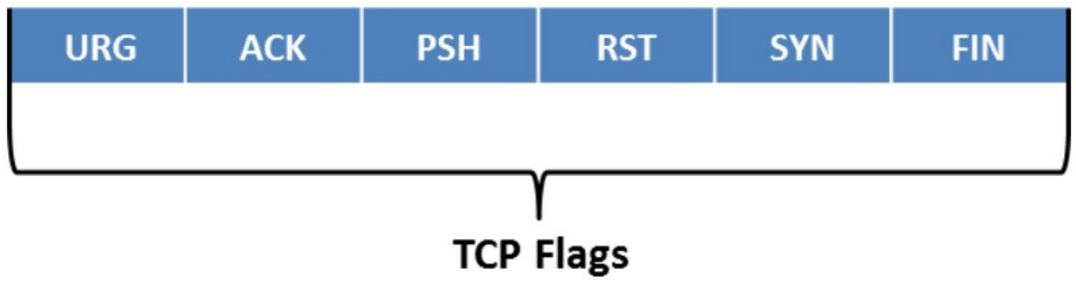


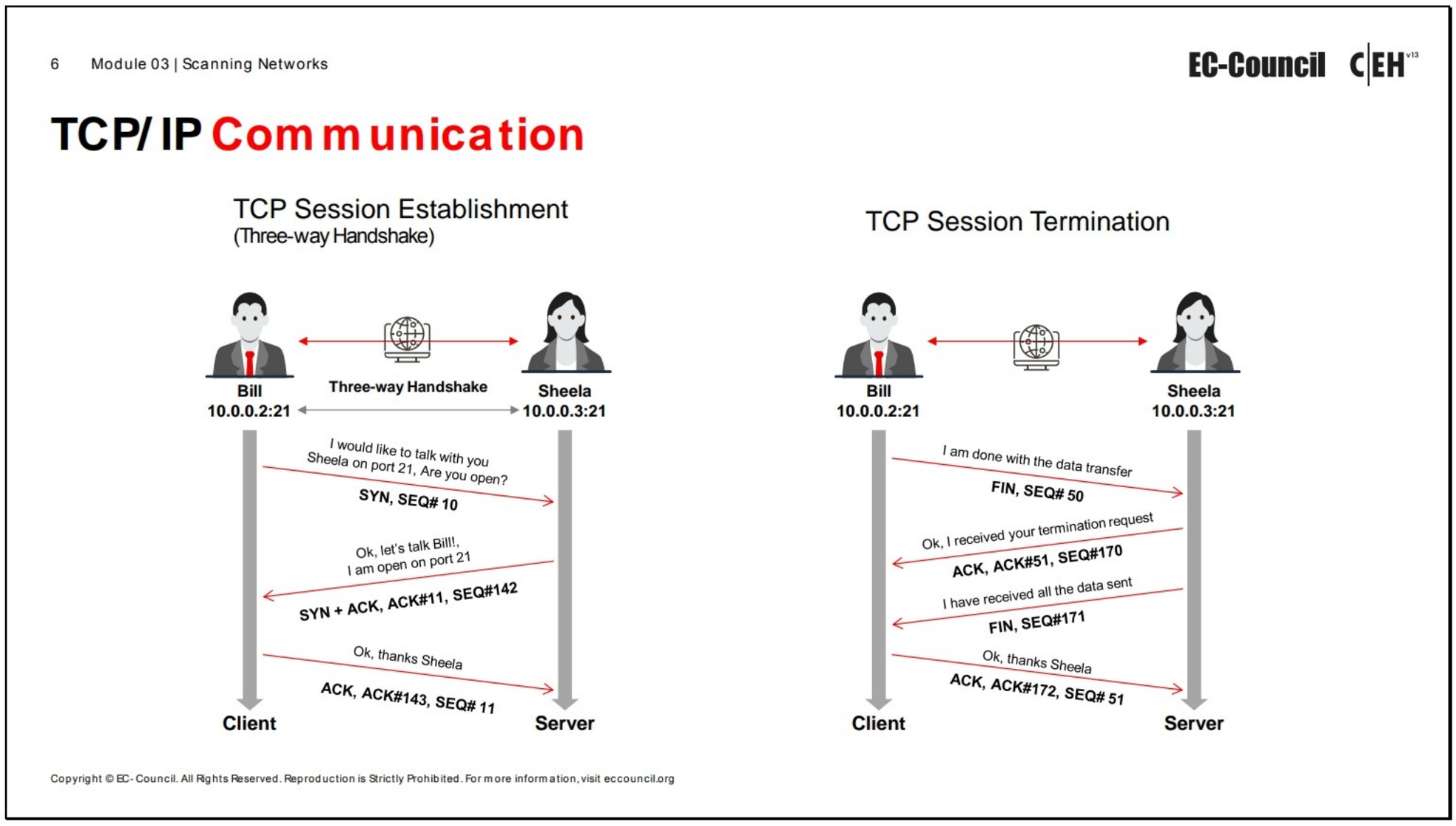
Figure 3.3: TCP communication flags

The following are the TCP communication flags:

- **Synchronize or "SYN":** It notifies the transmission of a new sequence number. This flag generally represents the establishment of a connection (three-way handshake) between two hosts.
- **Acknowledgement or "ACK":** It confirms the receipt of the transmission and identifies the next expected sequence number. When the system successfully receives a packet, it sets the value of its flag to "1," thus implying that the receiver should pay attention to it.
- **Push or "PSH":** When it is set to "1," it indicates that the sender has raised the push operation to the receiver; this implies that the remote system should inform the receiving application about the buffered data coming from the sender. The system raises the PSH flag at the start and end of data transfer and sets it on the last segment of a file to prevent buffer deadlocks.
- **Urgent or "URG":** It instructs the system to process the data contained in packets as soon as possible. When the system sets the flag to "1," priority is given to processing the urgent data first and all the other data processing is stopped.
- **Finish or "FIN":** It is set to "1" to announce that no more transmissions will be sent to the remote system and the connection established by the SYN flag is terminated.
- **Reset or "RST":** When there is an error in the current connection, this flag is set to "1" and the connection is aborted in response to the error. Attackers use this flag to scan hosts and identify open ports.

SYN scanning mainly deals with three flags: SYN, ACK, and RST. You can use these three flags for gathering illegitimate information from servers during enumeration.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



TCP/IP Communication

TCP is connection oriented, i.e., it prioritizes connection establishment before data transfer between applications. This connection between protocols is possible through the three-way handshake.

A TCP session initiates using a three-way handshake mechanism:

- To launch a TCP connection, the source (10.0.0.2:21) sends a SYN packet to the destination (10.0.0.3:21).
- On receiving the SYN packet, the destination responds by sending a SYN/ACK packet back to the source.
- The ACK packet confirms the arrival of the first SYN packet to the source.
- Finally, the source sends an ACK packet for the ACK/SYN packet transmitted by the destination.
- This triggers an "OPEN" connection, thereby allowing communication between the source and destination, which continues until one of them issues a "FIN" or "RST" packet to close the connection.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

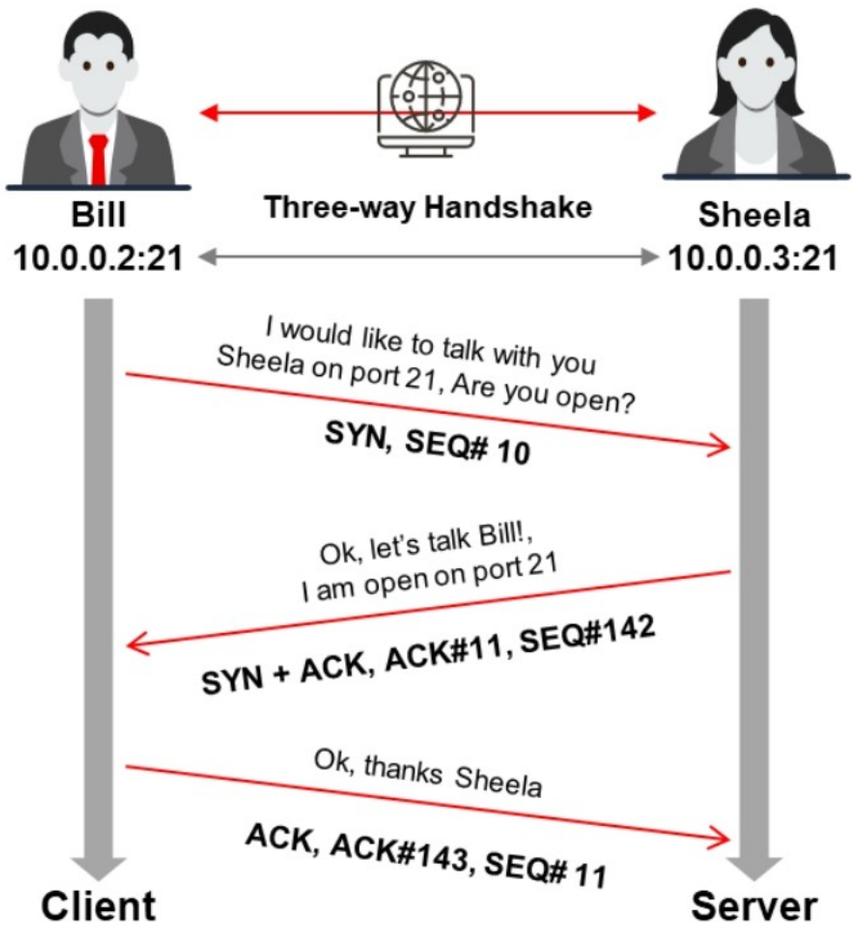


Figure 3.4: TCP session establishment

The TCP protocol maintains stateful connections for all connection-oriented protocols throughout the Internet and works similarly to ordinary telephone communication, in which one picks up a telephone receiver, hears a dial tone, and dials a number that triggers ringing at the other end until someone picks up the receiver and says, "Hello."

The system terminates the established TCP session as follows:

After completing all the data transfers through the established TCP connection, the sender sends the connection termination request to the receiver through a FIN or RST packet. Upon receiving the connection termination request, the receiver acknowledges the termination request by sending an ACK packet to the sender and finally sends its own FIN packet. Then, the system terminates the established connection.

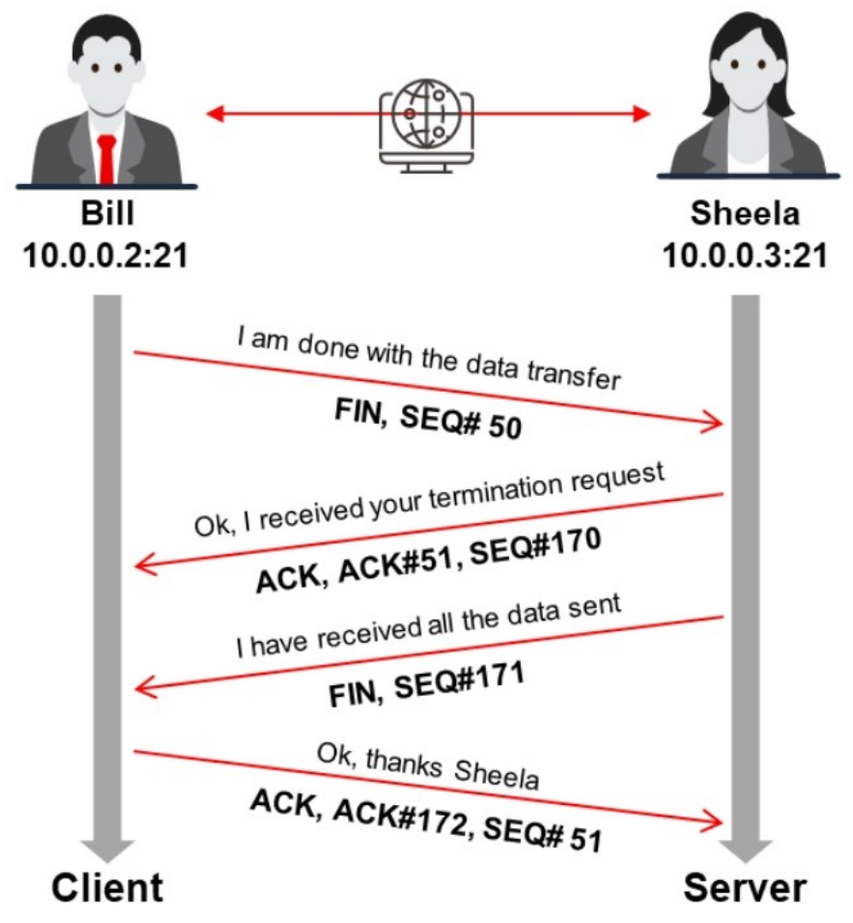


Figure 3.5: TCP session termination

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Scanning Tools

Scanning tools are used to scan and identify live hosts, open ports, running services on a target network, location info, NetBIOS info, and information about all TCP/IP and UDP open ports. The information obtained from these tools will help an ethical hacker in creating the profile of the target organization and scanning the network for open ports of the devices connected.

- **Nmap**

  Source: *https://nmap.org*

  Nmap ("Network Mapper") is a security scanner for network exploration and hacking. It allows you to discover hosts, ports, and services on a computer network, thus creating a "map" of the network. It sends specially crafted packets to the target host and then analyzes the responses to accomplish its goal. It scans vast networks of literally hundreds of thousands of machines. Nmap includes many mechanisms for port scanning (TCP and UDP), OS detection, version detection, ping sweeps, and so on.

  Either a network administrator or an attacker can use this tool for their specific needs. Network administrators can use Nmap for network inventory, managing service upgrade schedules, and monitoring host or service uptime. Attackers use Nmap to extract information such as live hosts on the network, open ports, services (application name and version), type of packet filters/firewalls, MAC details, and OSs along with their versions.

  Syntax: **`# nmap <options> <Target IP address>`**

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

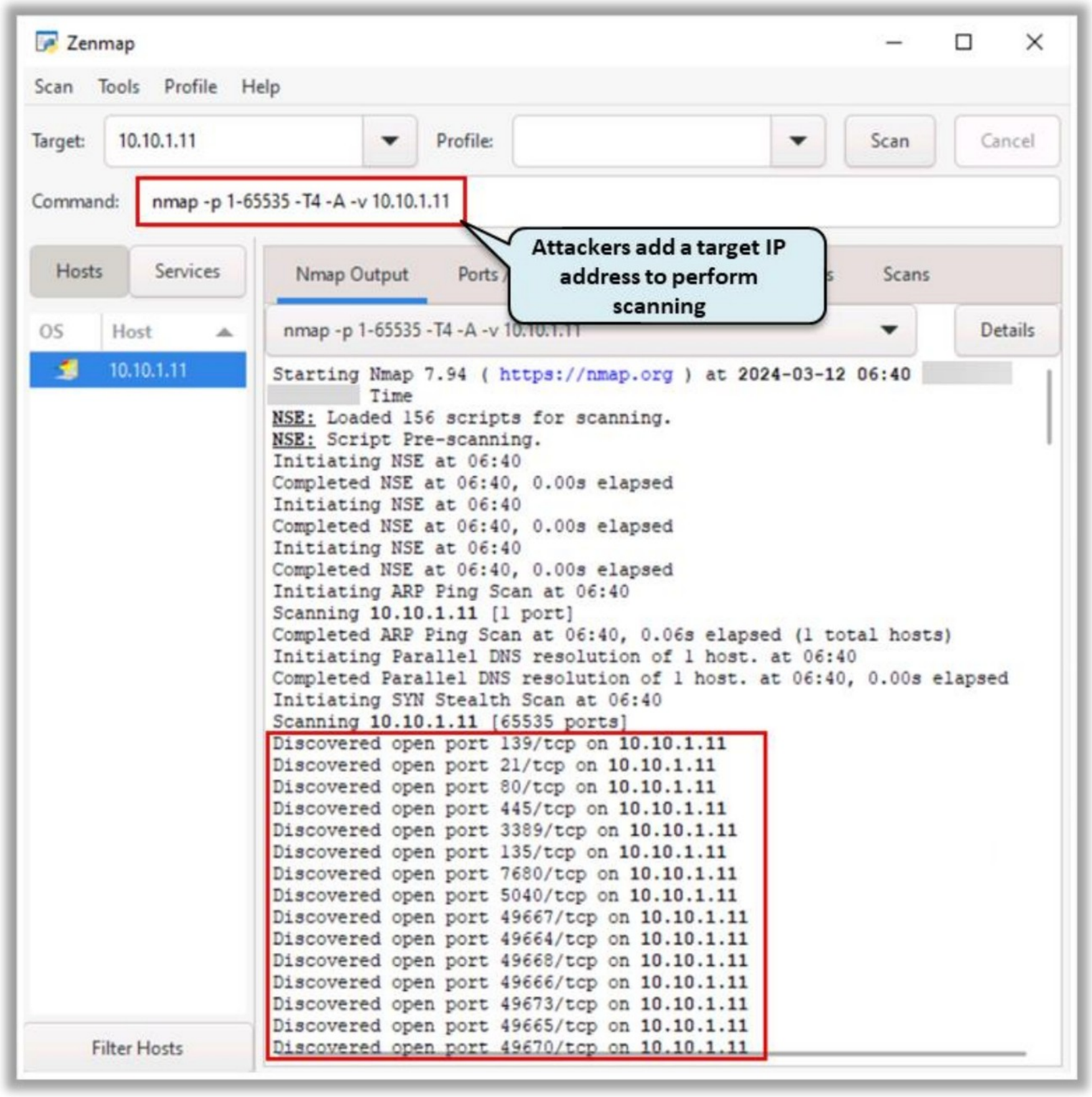


Figure 3.6: Screenshot displaying Nmap scan

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

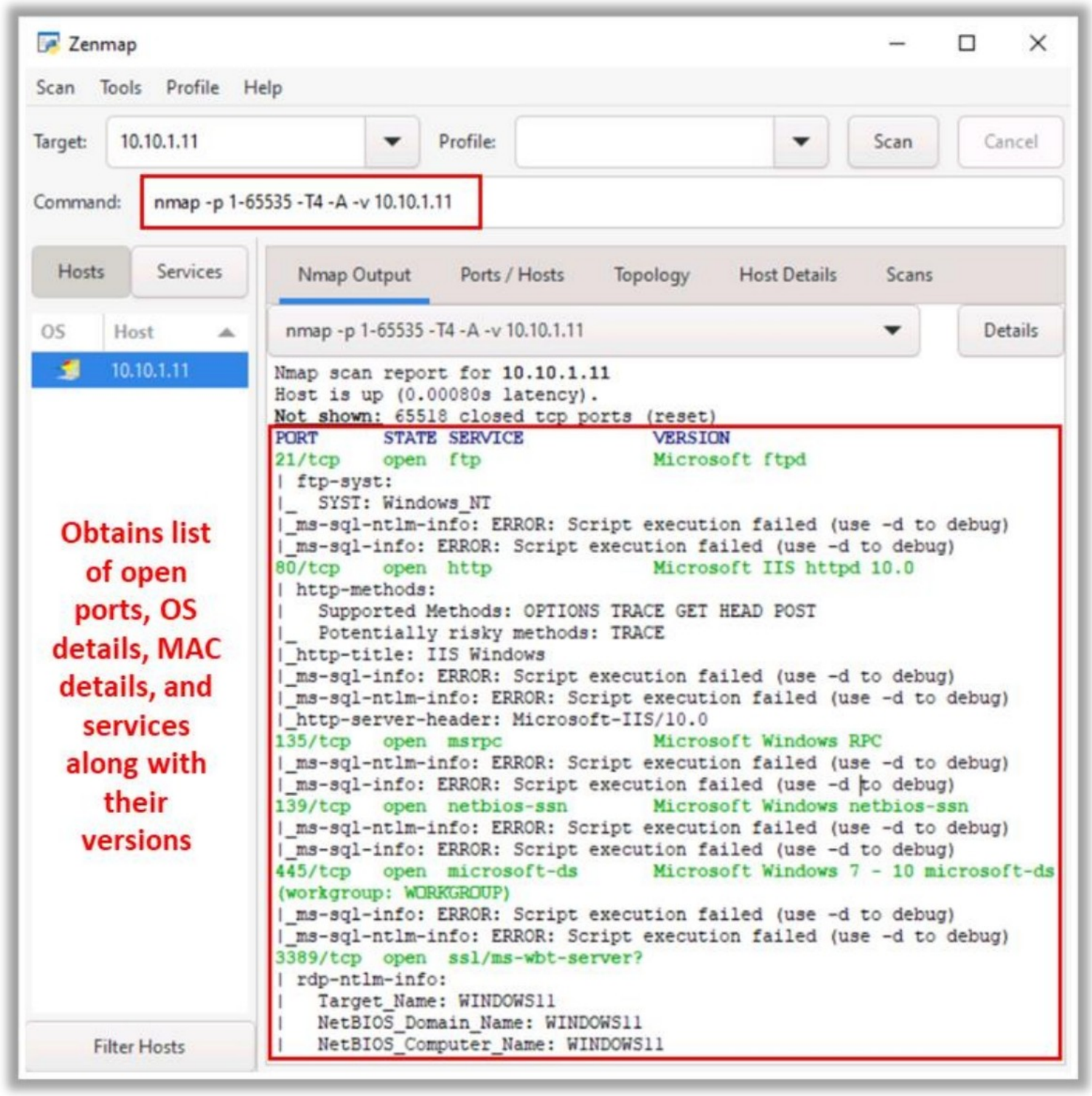


Figure 3.7: Screenshot displaying Nmap scan result

- **Hping3**

  Source: *https://salsa.debian.org*

  Hping3 is a command-line-oriented network scanning and packet crafting tool for the TCP/IP protocol that sends ICMP echo requests and supports TCP, UDP, ICMP, and raw-IP protocols. It performs network security auditing, firewall testing, manual path MTU discovery, advanced traceroute, remote OS fingerprinting, remote uptime guessing, TCP/IP stacks auditing, and other functions. It can send custom TCP/IP packets and display target replies similarly to a ping program with ICMP replies. It handles fragmentation as well as arbitrary packet body and size, and it can be used to transfer encapsulated files under the supported protocols. It also supports idle host scanning. IP spoofing and network/host scanning can be used to perform an anonymous probe for services. Hping3 also has a Traceroute mode, which enables attackers to send files between covert channels. It also determines whether the host is up even when the host blocks ICMP packets. Its firewalk-like usage allows the discovery of open ports behind firewalls. It performs manual path MTU discovery and enables attackers to perform remote OS fingerprinting.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Using Hping, an attacker can study the behavior of an idle host and gain information about the target, such as the services that the host offers, the ports supporting the services, and the OS of the target. This type of scan is a predecessor to either heavier probing or outright attacks.

Syntax: **# hping3 <options> <Target IP address>**

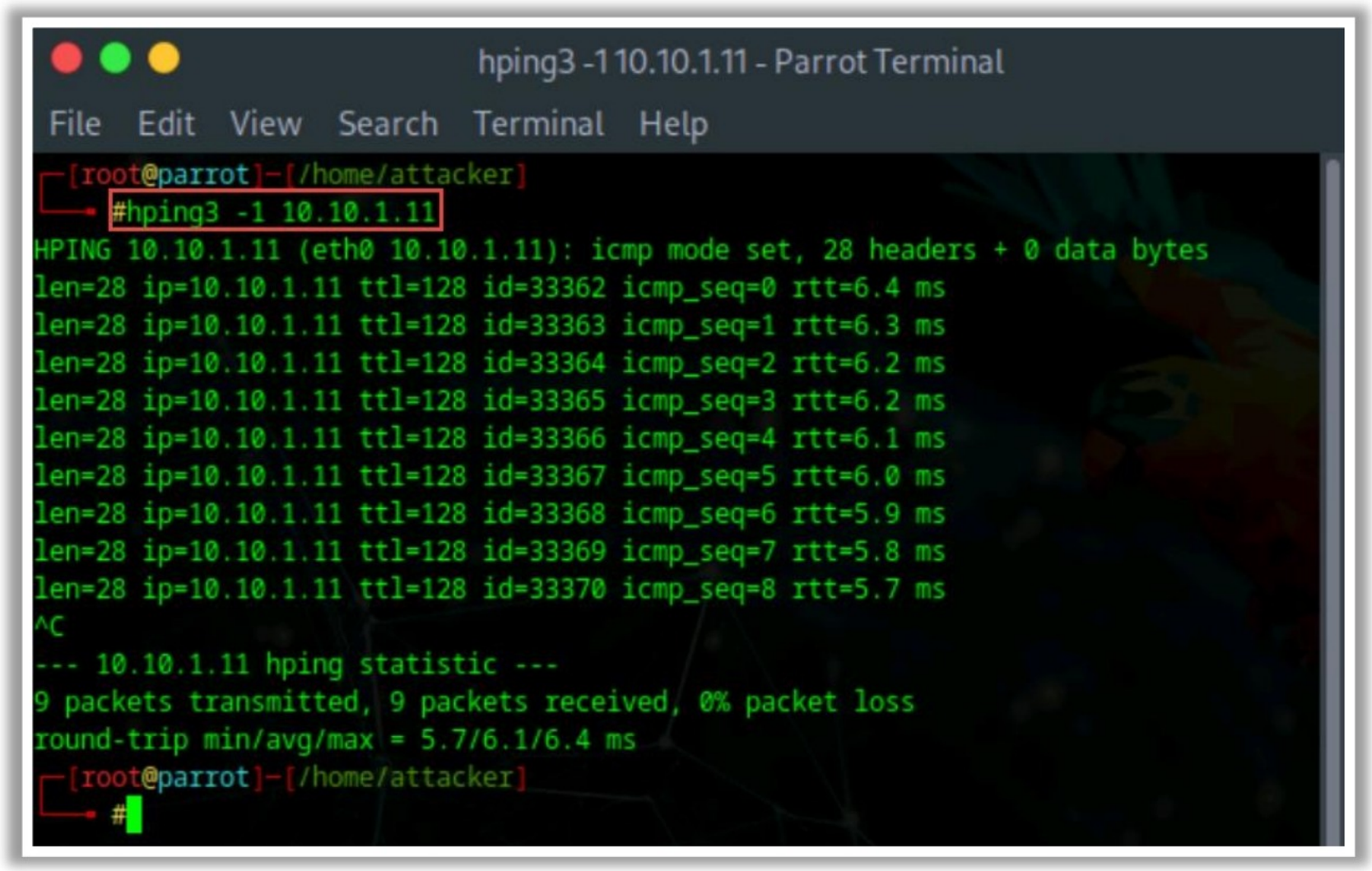


Figure 3.8: ICMP scanning

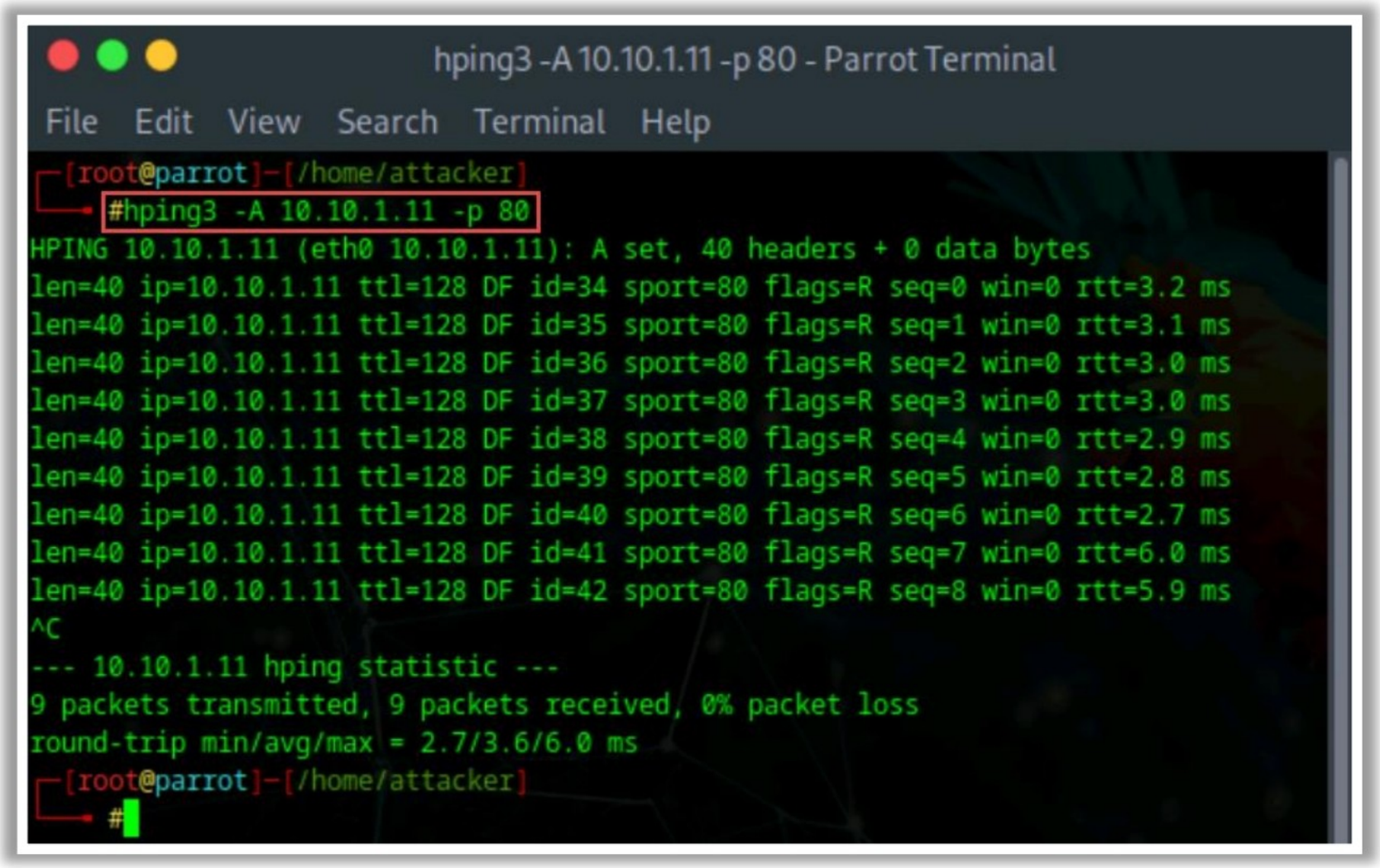


Figure 3.9: ACK scanning on port 80

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Hping Commands

The various Hping commands are as follows:

- **ICMP ping**

  Ex. **`hping3 -1 10.0.0.25`**

  A ping sweep or Internet Control Message Protocol (ICMP) scanning is a process of sending an ICMP request or ping to all the hosts on the network to determine the ones that are up.

  The OS, router, switch, and IP-based devices use this protocol via the ping command for echo request and echo response as a connectivity tester between different hosts.

  Hping performs an ICMP ping scan by specifying the argument -1 in the command line. You may use --ICMP or -1 as the argument in the command line. By issuing the above command, hping sends an ICMP echo request to 10.0.0.25 and receives an ICMP reply similarly to a ping utility.

- **ACK scan on port 80**

  Ex. **`hping3 –A 10.0.0.25 –p 80`**

  This scanning technique can be used to probe the existence of a firewall and its rule sets. Simple packet filtering allows the establishment of a connection (packets with the ACK bit set), whereas a sophisticated stateful firewall does not allow the establishment of a connection.

  Hping can be configured to perform an ACK scan by specifying the argument -A in the command line. Here, you set the ACK flag in the probe packets and perform the scan. You perform this scan when a host does not respond to a ping request. By issuing this command, Hping checks if a host is alive on a network. If it finds a live host and an open port, it returns an RST response.

- **UDP scan on port 80**

  Ex. **`hping3 -2 10.0.0.25 –p 80`**

  Hping uses TCP as its default protocol. Using the argument -2 in the command line specifies that Hping operates in the UDP mode. You may use either --udp or -2 as the argument in the command line.

  By issuing the above command, Hping sends UDP packets to port 80 on the host (10.0.0.25). It returns an ICMP port unreachable message if it finds the port closed and does not return a message if the port is open.

- **Collecting Initial Sequence Number**

  Ex. **`hping3 192.168.1.103 –Q –p 139`**

  Using the argument -Q in the command line, Hping collects all the TCP sequence numbers generated by the target host (192.168.1.103).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Firewalls and Timestamps**

  Ex. **`hping3 -S 72.14.207.99 -p 80 --tcp-timestamp`**

  Many firewalls drop those TCP packets that do not have the TCP Timestamp option set. By adding the --tcp-timestamp argument in the command line, you can enable the TCP timestamp option in Hping and try to guess the timestamp update frequency and uptime of the target host (72.14.207.99).

- **SYN scan on port 50-60**

  Ex. **`hping3 -8 50-60 –S 10.0.0.25 –V`**

  Using the argument -8 or --scan in the command line, you are operating Hping in the scan mode to scan a range of ports on the target host. Adding the argument -S allows you to perform a SYN scan.

  Therefore, the above command performs a SYN scan on ports 50–60 on the target host.

- **FIN, PUSH and URG scan on port 80**

  Ex. **`hping3 –F –P –U 10.0.0.25 –p 80`**

  By adding the arguments –F, –P, and –U in the command line, you are setting FIN, PUSH, and URG packets in the probe packets. By issuing this command, you are performing FIN, PUSH, and URG scans on port 80 on the target host (10.0.0.25). If port 80 is open, you will not receive a response. If the port is closed, Hping will return an RST response.

- **Scan entire subnet for live host**

  Ex. **`hping3 -1 10.0.1.x --rand-dest –I eth0`**

  By issuing this command, Hping performs an ICMP ping scan on the entire subnet 10.0.1.x; in other words, it sends an ICMP echo request randomly (--rand-dest) to all the hosts from 10.0.1.0 to 10.0.1.255 that are connected to the interface eth0. The hosts whose ports are open will respond with an ICMP reply. In this case, you have not set a port; hence, Hping sends packets to port 0 on all IP addresses by default.

- **Intercept all traffic containing HTTP signature**

  Ex. **`hping3 -9 HTTP –I eth0`**

  The argument -9 will set the Hping to the listen mode. Hence, by issuing the command -9 HTTP, Hping starts listening on port 0 (of all the devices connected in the network to interface eth0), intercepts all the packets containing the HTTP signature, and dumps from the signature end to the packet's end.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **SYN flooding a victim**

  Ex. **`hping3 -S 192.168.1.1 -a 192.168.1.254 -p 22 --flood`**

  The attacker employs TCP SYN flooding techniques using spoofed IP addresses to perform a DoS attack.

- **Hping Scan with AI**

Attackers can leverage AI-powered technologies to enhance and automate their network scanning tasks. With the aid of AI, attackers can effortlessly perform network scanning using the Hping3 tool to acquire valuable insights about their target.

Example #1:

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Use Hping3 to perform ICMP scanning on the target IP address 10.10.1.11 and stop after 10 iterations"

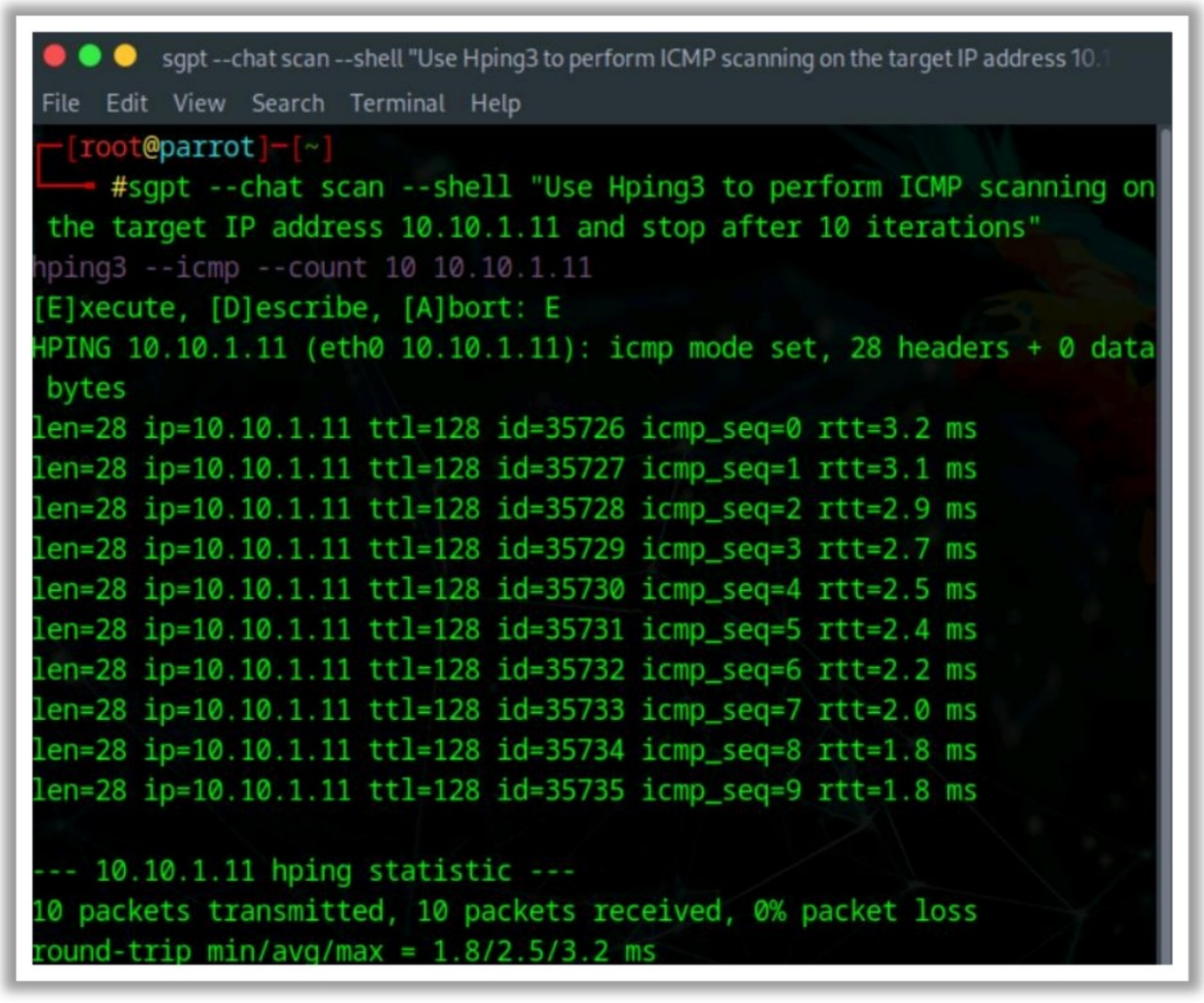


Figure 3.10: "Use Hping3 to perform ICMP scanning on the target IP"

The command **`hping3 --icmp --count 10 10.10.1.11`** is used to execute the Hping3 tool with specific parameters. Here is an explanation:

`Hping3 --icmp --count 10.10.1.11`

- **`hping3`**: This is the command to invoke the Hping3 tool, which is a network scanning utility.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- `` `--icmp` ``: This parameter specifies the type of packet to send, in this case, ICMP packets. Internet control message protocol (ICMP) packets are commonly used for network troubleshooting and diagnostics.
- `` `--count 10` ``: This parameter specifies the number of ICMP packets to send. In this case, it is set to 10, meaning that Hping3 will send 10 ICMP packets to the specified target IP address.
- `` `10.10.1.11` ``: This is the target IP address to which the ICMP packets will be sent.

Overall, this command instructs Hping3 to send 10 ICMP packets to the IP address **10.10.1.11** for network diagnostics or testing purposes.

Example #2:

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Run an hping3 ACK scan on port 80 of target IP 10.10.1.11"

```
┌─[attacker@parrot]─[~]
└──╼ $sgpt --chat hping --shell "Run a hping3 ACK scan on port 80 of target IP 10.10.1.11"
sudo hping3 --ack -p 80 10.10.1.11
[E]xecute, [D]escribe, [A]bort: E
HPING 10.10.1.11 (eth0 10.10.1.11): A set, 40 headers + 0 data bytes
len=40 ip=10.10.1.11 ttl=128 DF id=50 sport=80 flags=R seq=0 win=0 rtt=6.4 ms
len=40 ip=10.10.1.11 ttl=128 DF id=51 sport=80 flags=R seq=1 win=0 rtt=6.4 ms
len=40 ip=10.10.1.11 ttl=128 DF id=52 sport=80 flags=R seq=2 win=0 rtt=6.3 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53 sport=80 flags=R seq=3 win=0 rtt=2.9 ms
len=40 ip=10.10.1.11 ttl=128 DF id=54 sport=80 flags=R seq=4 win=0 rtt=2.9 ms
len=40 ip=10.10.1.11 ttl=128 DF id=55 sport=80 flags=R seq=5 win=0 rtt=6.1 ms
len=40 ip=10.10.1.11 ttl=128 DF id=56 sport=80 flags=R seq=6 win=0 rtt=6.1 ms
len=40 ip=10.10.1.11 ttl=128 DF id=57 sport=80 flags=R seq=7 win=0 rtt=9.3 ms
len=40 ip=10.10.1.11 ttl=128 DF id=58 sport=80 flags=R seq=8 win=0 rtt=2.6 ms
len=40 ip=10.10.1.11 ttl=128 DF id=59 sport=80 flags=R seq=9 win=0 rtt=2.5 ms
len=40 ip=10.10.1.11 ttl=128 DF id=60 sport=80 flags=R seq=10 win=0 rtt=2.4 ms
len=40 ip=10.10.1.11 ttl=128 DF id=61 sport=80 flags=R seq=11 win=0 rtt=9.0 ms
len=40 ip=10.10.1.11 ttl=128 DF id=62 sport=80 flags=R seq=12 win=0 rtt=2.3 ms
len=40 ip=10.10.1.11 ttl=128 DF id=63 sport=80 flags=R seq=13 win=0 rtt=2.2 ms
len=40 ip=10.10.1.11 ttl=128 DF id=64 sport=80 flags=R seq=14 win=0 rtt=2.1 ms
len=40 ip=10.10.1.11 ttl=128 DF id=65 sport=80 flags=R seq=15 win=0 rtt=5.4 ms
len=40 ip=10.10.1.11 ttl=128 DF id=66 sport=80 flags=R seq=16 win=0 rtt=1.9 ms
len=40 ip=10.10.1.11 ttl=128 DF id=67 sport=80 flags=R seq=17 win=0 rtt=5.2 ms
len=40 ip=10.10.1.11 ttl=128 DF id=68 sport=80 flags=R seq=18 win=0 rtt=5.1 ms
len=40 ip=10.10.1.11 ttl=128 DF id=69 sport=80 flags=R seq=19 win=0 rtt=5.0 ms
```

Figure 3.11: Run a hping3 ACK scan on port 80 of target IP

The command `` `sudo hping3 --ack -p 80 10.10.1.11` `` is used to execute the Hping3 tool with specific parameters.

Sudo hping3 --ack -p 80 10.10.1.11

- `` `sudo` ``: This command is used to run the following command with administrative privileges.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- `hping3`: This is the command to invoke the Hping3 tool, which is a network scanning and testing utility.
- `--ack`: This parameter specifies the TCP ACK scan mode. In this mode, Hping3 sends TCP packets with the ACK flag set.
- `-p 80`: This parameter specifies the destination port to which the TCP packets will be sent. In this case, it is set to port 80, which is commonly used for HTTP (web) traffic.
- `10.10.1.11`: This is the target IP address to which the TCP packets will be sent.

Overall, this command instructs Hping3 to send TCP ACK packets to port 80 of the IP address `10.10.1.11` for network scanning or testing purposes. The use of `sudo` ensures that the command is executed with the necessary privileges.

- **Metasploit**

Source: *https://www.metasploit.com*

Metasploit is an open-source project that provides the infrastructure, content, and tools to perform penetration tests and extensive security auditing. It provides information about security vulnerabilities and aids in penetration testing and IDS signature development. It facilitates the tasks of attackers, exploits writers, and payload writers. A major advantage of the framework is the modular approach, i.e., allowing the combination of any exploit with any payload.

It enables you to automate the process of discovery and exploitation and provides you with the necessary tools to perform the manual testing phase of a penetration test. You can use Metasploit Pro to scan for open ports and services, exploit vulnerabilities, pivot further into a network, collect evidence, and create a report of the test results.

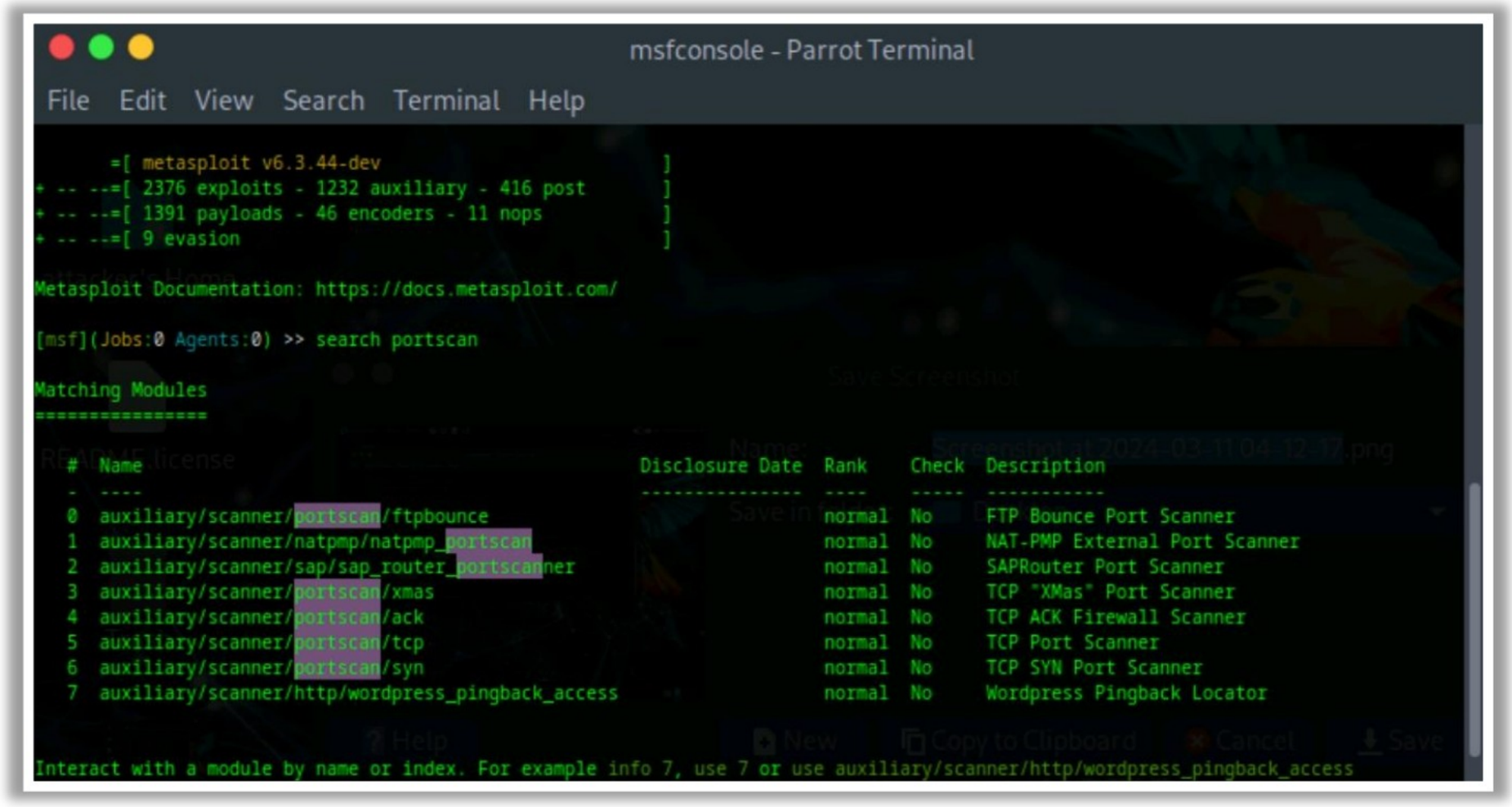


Figure 3.12: Screenshot displaying various Metasploit port scan modules

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **NetScanTools Pro**

  Source: *https://www.netscantools.com*

  NetScanTools Pro is an investigation tool that allows you to troubleshoot, monitor, discover, and detect devices on your network. Using this tool, you can easily gather information about the local LAN as well as Internet users, IP addresses, ports, and so on. Attackers can find vulnerabilities and exposed ports in the target system. It helps the attackers to list IPv4/IPv6 addresses, hostnames, domain names, email addresses, and URLs automatically or manually (using manual tools). NetScanTools Pro combines many network tools and utilities categorized by their functions, such as active, passive, DNS, and local computer.

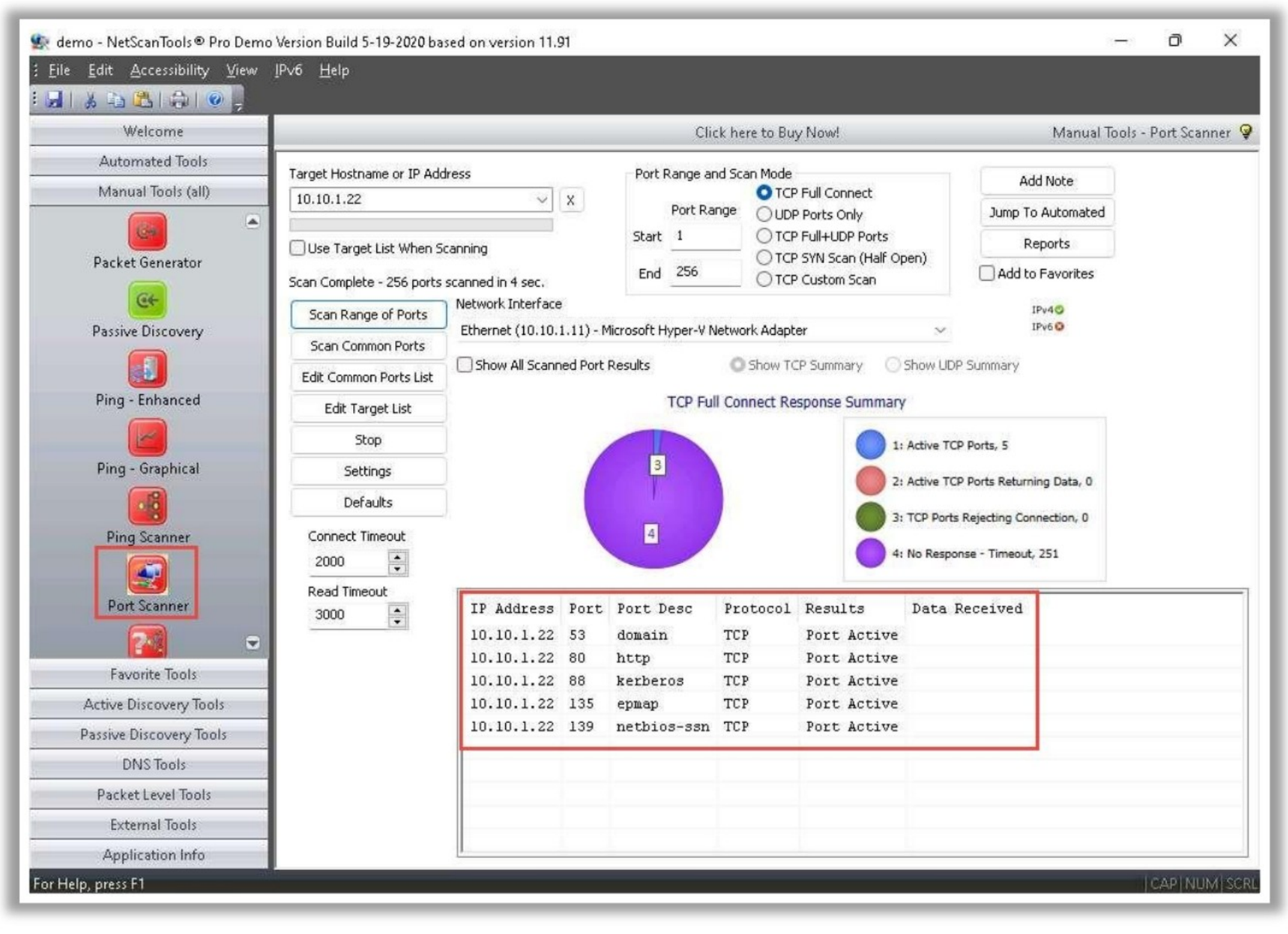
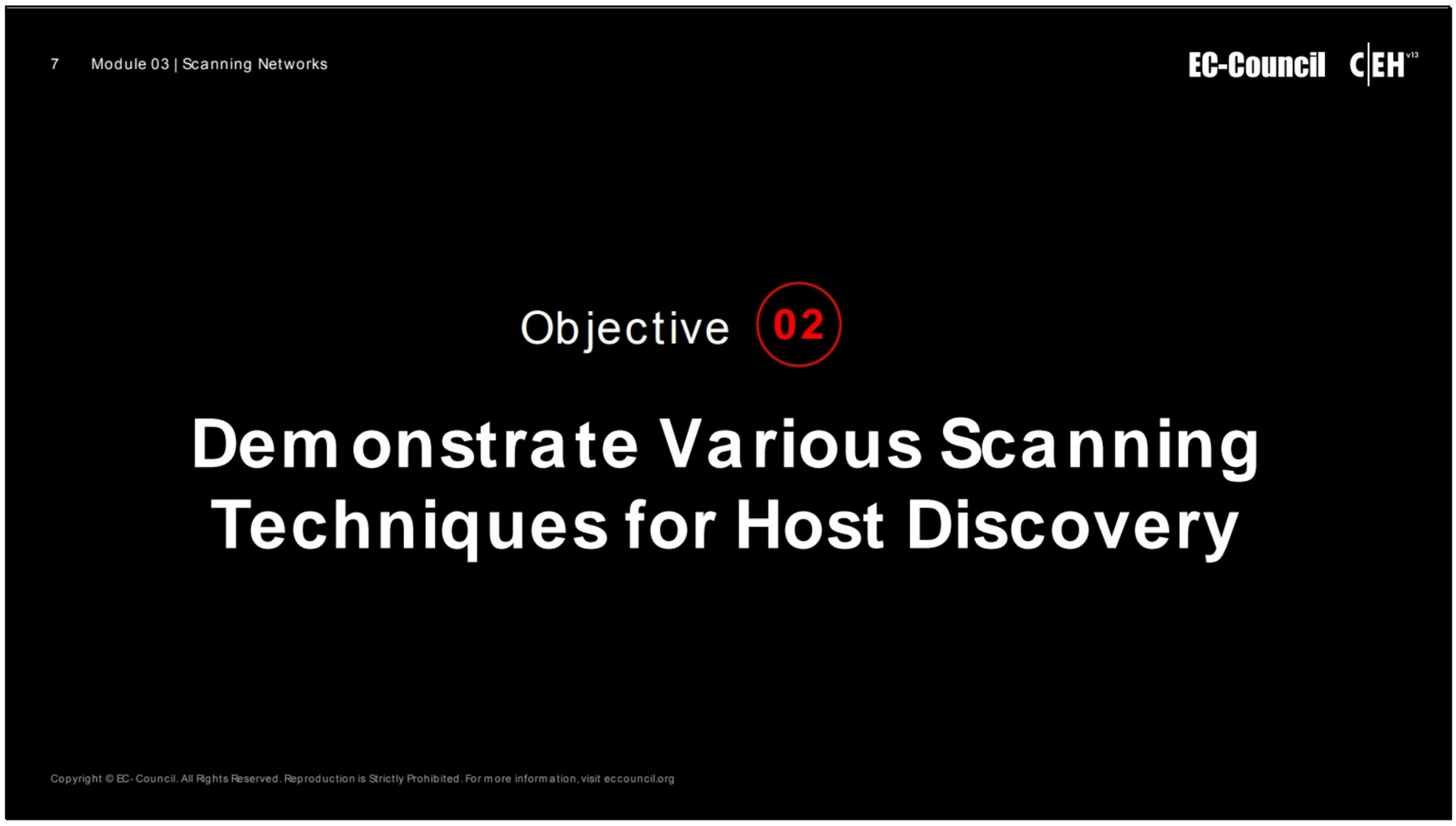


Figure 3.13: Screenshot of NetScanTools Pro

Some additional scanning tools are listed below:

- sx (*https://github.com*)
- RustScan (*https://github.com*)
- MegaPing (*http://magnetosoft.com*)
- SolarWinds® Engineer's Toolset (*https://www.solarwinds.com*)
- PRTG Network Monitor (*https://www.paessler.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

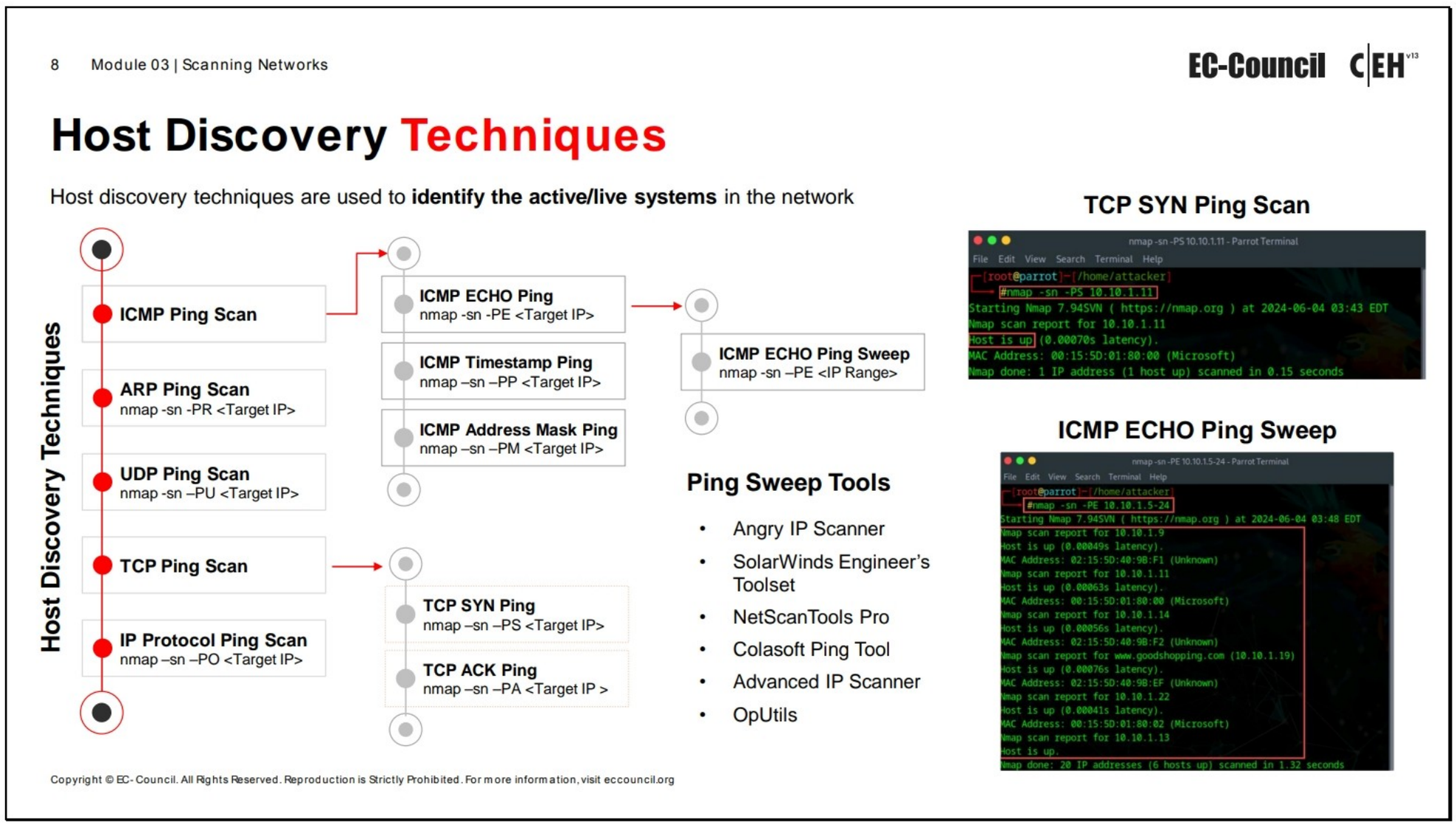


Host Discovery

Scanning is the process of gathering information about systems that are "alive" and responding on the network. Host discovery is considered as the primary task in the network scanning process. To perform a complete scan and identify open ports and services, it is necessary to check for live systems. Host discovery provides an accurate status of the systems in the network, which enables an attacker to avoid scanning every port on every system in a list of IP addresses to identify whether the target host is up.

Host discovery is the first step in network scanning. This section highlights how to check for live systems in a network using various ping scan techniques. It also discusses how to ping sweep a network to detect live hosts/systems along with various ping sweep tools.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Host Discovery Techniques

Host discovery techniques can be adopted to discover the active/live hosts in the network. As an ethical hacker, you must be aware of the various types of host discovery techniques. Some host discovery techniques are listed below:

- ARP Ping Scan
- UDP Ping Scan
- ICMP Ping Scan
  - ICMP ECHO Ping
    - ICMP ECHO Ping Sweep
  - ICMP Timestamp Ping
  - ICMP Address Mask Ping
- TCP Ping Scan
  - TCP SYN Ping
  - TCP ACK Ping
- IP Protocol Scan

ARP Ping Scan

In the ARP ping scan, the ARP packets are sent for discovering all active devices in the IPv4 range even though the presence of such devices is hidden by restrictive firewalls. In most networks, many IP addresses are unused at any given time, specifically in the private address ranges of the LAN. Hence, when the attackers try to send IP packets such as ICMP echo request to the target

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

host, the OS must determine the hardware destination address (ARP) corresponding to the target IP for addressing the ethernet frame correctly. For this purpose, a series of ARP requests are issued. ARP scan is used to show the MAC address of the network interface on the device, and it can also show the MAC addresses of all devices sharing the same IPv4 address on the LAN. If the host IP with the respective hardware destination address is active, then the ARP response will be generated by the host; otherwise, after a certain number of ping attempts, the original OS gives up on the host. In other words, when attackers send ARP request probes to the target host, if they receive any ARP response, then the host is active. In case the destination host is found to be unresponsive, the source host adds an incomplete entry to the destination IP in its kernel ARP table.

Attackers use the Nmap tool to perform ARP ping scan for discovering live hosts in the network. In Zenmap, the **`-PR`** option is used to perform ARP ping scan.

Note: **`-sn`** is the Nmap command to disable the port scan. Since Nmap uses ARP ping scan as the default ping scan, to disable it and perform other desired ping scans, you can use **`--disable-arp-ping`**.

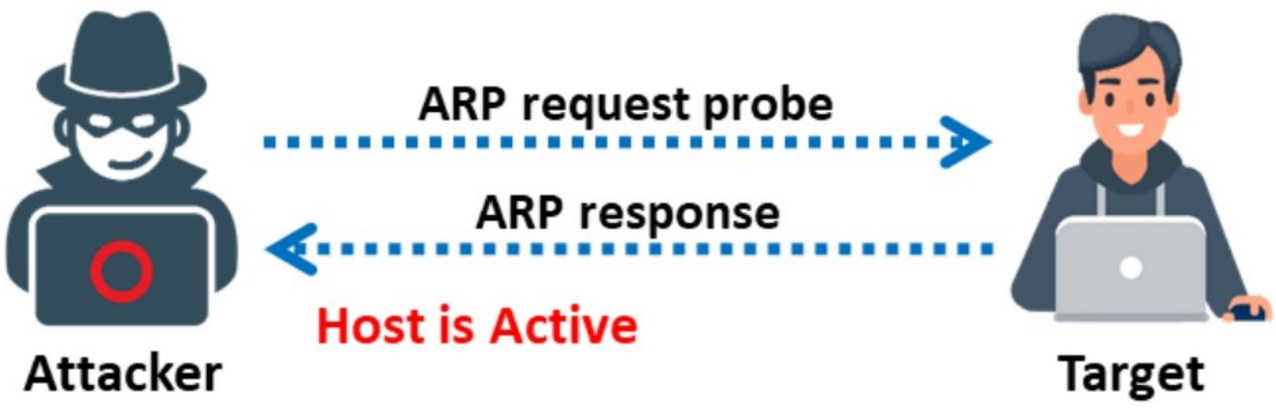


Figure 3.14: ARP ping scan

Advantages:

- ARP ping scan is considered to be more efficient and accurate than other host discovery techniques
- ARP ping scan automatically handles ARP requests, retransmission, and timeout at its own discretion
- ARP ping scan is useful for system discovery, where you may need to scan large address spaces
- ARP ping scan can display the response time or latency of a device to an ARP packet

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

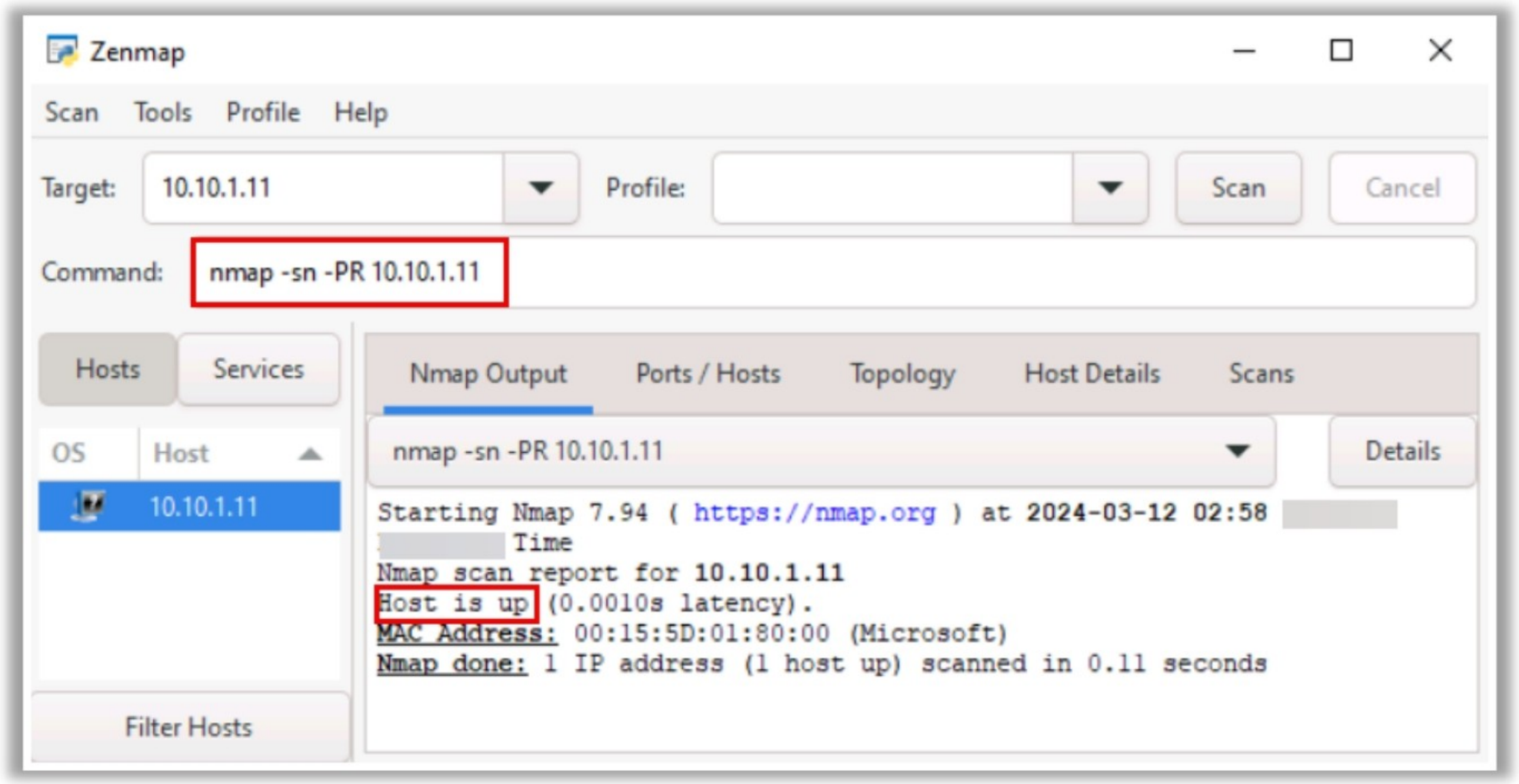


Figure 3.15: ARP scan in Zenmap

UDP Ping Scan

UDP ping scan is similar to TCP ping scan; however, in the UDP ping scan, Nmap sends UDP packets to the target host. The default port number used by Nmap for the UDP ping scan is 40,125. This highly uncommon port is used as the default for sending UDP packets to the target. This default port number can be configured using **DEFAULT_UDP_PROBE_PORT_SPEC** during compile time in Nmap.

Attackers send UDP packets to the target host, and a UDP response means that the target host is active. If the target host is offline or unreachable, various error messages such as host/network unreachable or TTL exceeded could be returned. In Zenmap, the **-PU** option is used to perform the UDP ping scan.

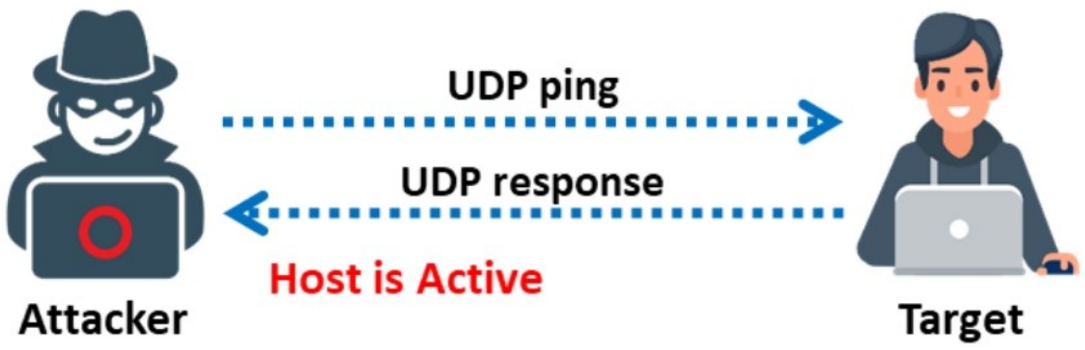


Figure 3.16: UDP ping scan to determine if the host is active

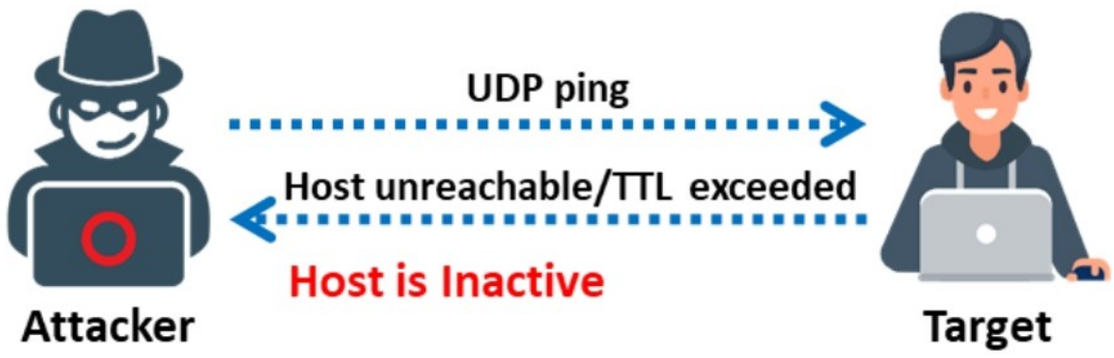


Figure 3.17: UDP ping scan to determine if the host is offline

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Advantages:

- UDP ping scans have the advantage of detecting systems behind firewalls with strict TCP filtering, leaving the UDP traffic forgotten.

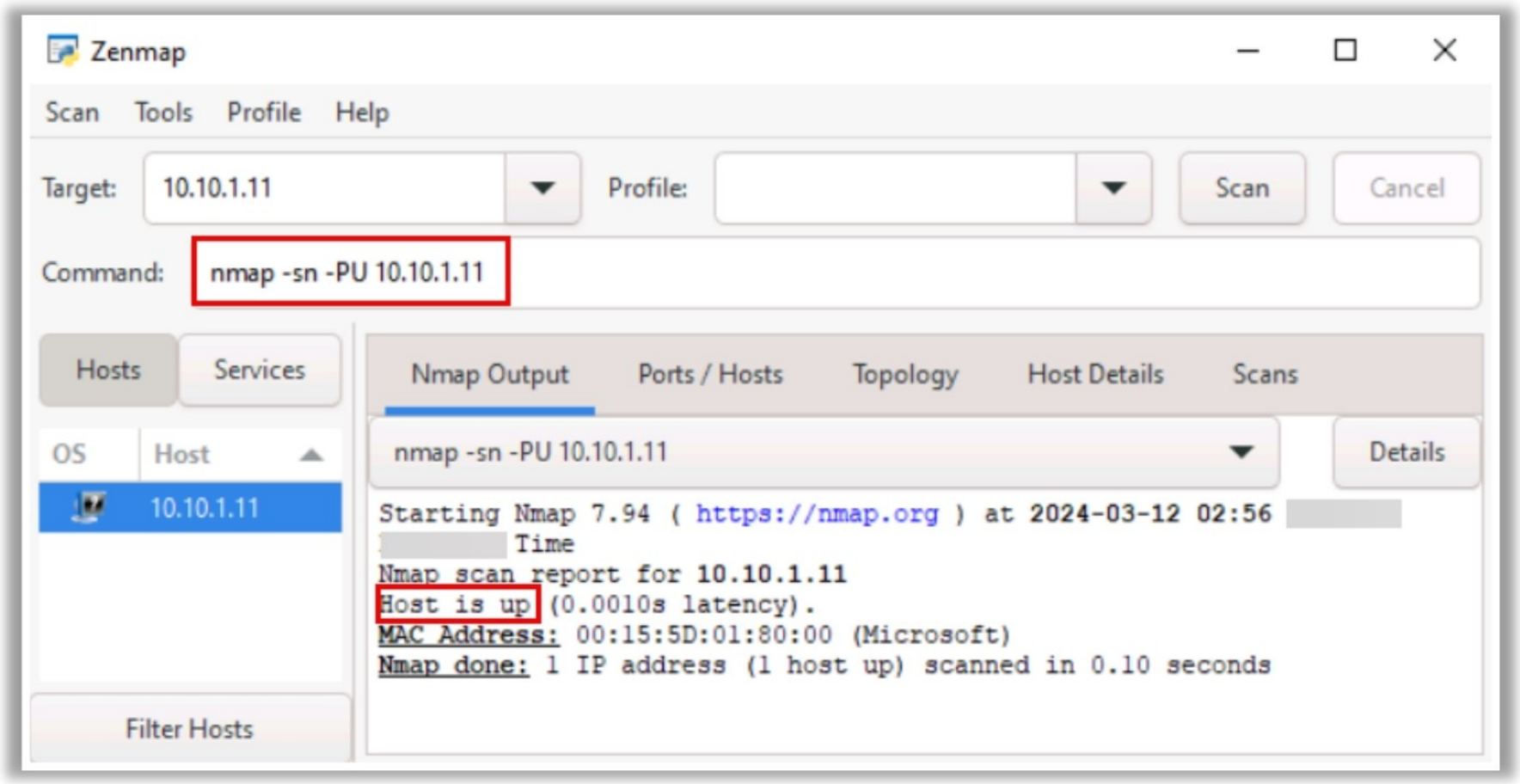


Figure 3.18: UDP ping scan in Zenmap

ICMP ECHO Ping Scan

Attackers use the ICMP ping scan to send ICMP packets to the destination system to gather all necessary information about it. This is because ICMP does not include port abstraction, and it is different from port scanning. However, it is useful to determine what hosts in a network are running by pinging them all.

ICMP ECHO ping scan involves sending ICMP ECHO requests to a host. If the host is alive, it will return an ICMP ECHO reply. This scan is useful for locating active devices or determining if ICMP is passing through a firewall.

Figure 3.19: ICMP echo request and reply

UNIX/Linux and BSD-based machines use ICMP echo scanning; the TCP/IP stack implementations in these OSs respond to the ICMP echo requests to the broadcast addresses. This technique does not work on Windows-based networks, as their TCP/IP stack implementation does not reply to ICMP probes directed at the broadcast address.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Nmap uses the **-P** option to ICMP scan the target. The user can also increase the number of pings in parallel using the **-L** option. It may also be useful to tweak the ping timeout value using the **-T** option.

In Zenmap, the **-PE** option is used to perform the ICMP ECHO ping scan. Active hosts are displayed as "**Host is up,**" as shown in the screenshot.

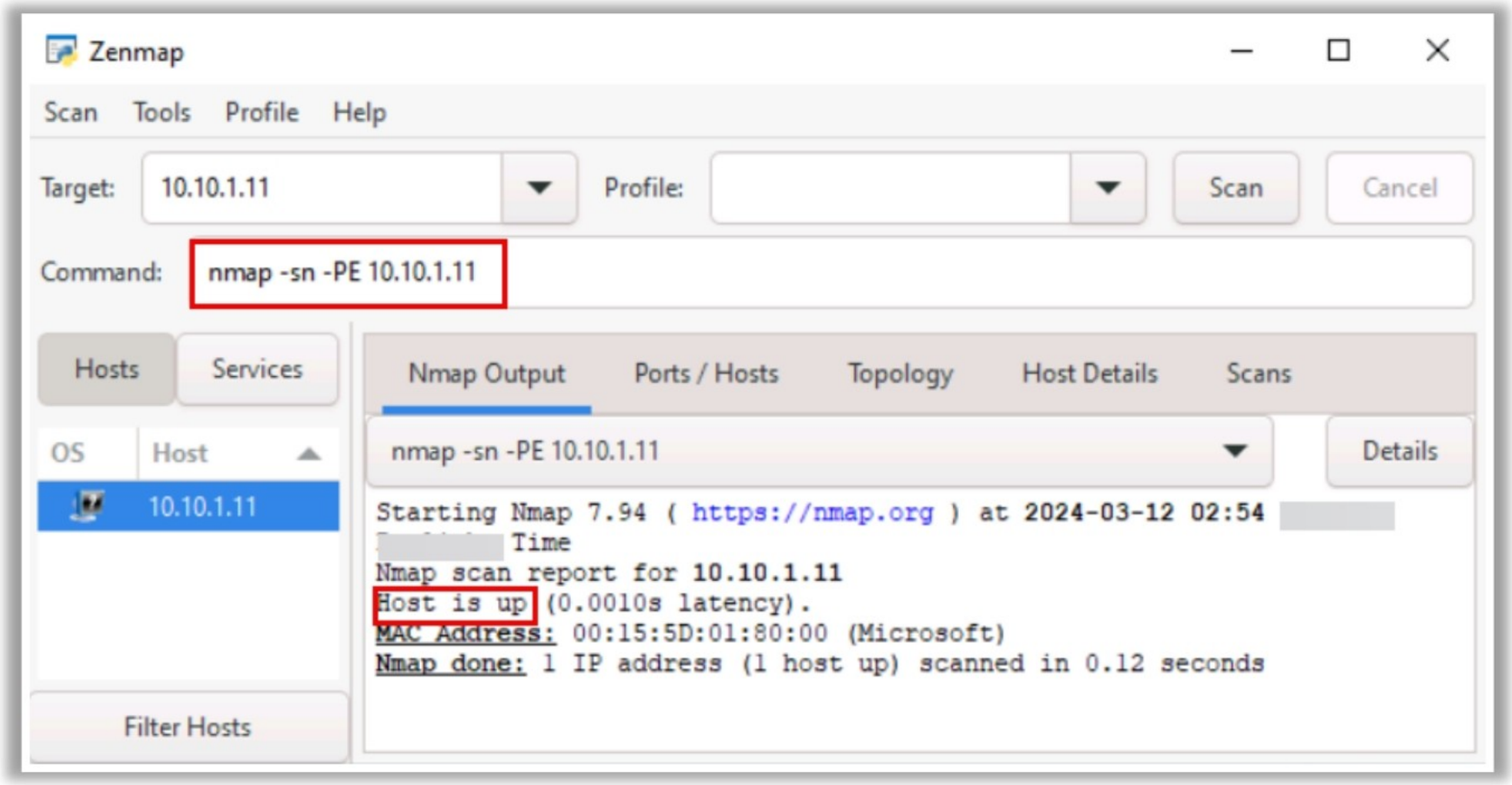


Figure 3.20: ICMP Echo ping scan output using Zenmap

ICMP ECHO Ping Sweep

A ping sweep (also known as an ICMP sweep) is a basic network scanning technique that is adopted to determine the range of IP addresses that map to live hosts (computers). Although a single ping will tell the user whether a specified host computer exists on the network, a ping sweep consists of ICMP ECHO requests sent to multiple hosts. If a specified host is active, it will return an ICMP ECHO reply.

Ping sweeps are among the oldest and slowest methods used to scan a network. This utility is distributed across nearly all platforms, and it acts as a roll call for systems; a system that is active on the network answers the ping query that another system sends out.

ICMP echo scanning pings all the machines in the target network to discover live machines. Attackers send ICMP probes to the broadcast or network address, which relays to all the host addresses in the subnet. The live systems will send the ICMP echo reply message to the source of the ICMP echo probe.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

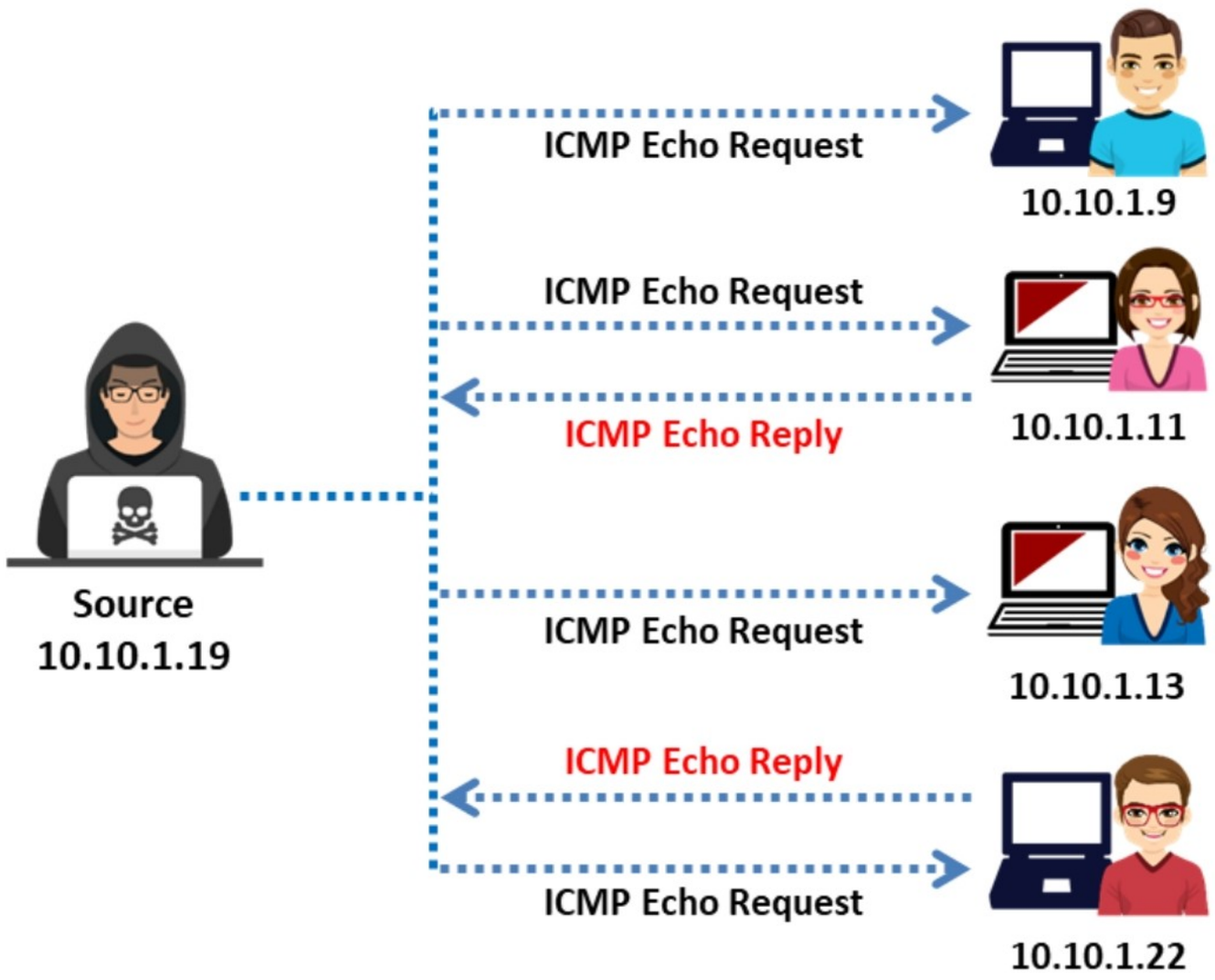


Figure 3.21: ICMP ECHO Ping Sweep

To understand pings better, one should be able to understand the TCP/IP packet. When a system pings, it sends a single packet across the network to a specific IP address. This packet contains 64 bytes (56 data bytes and 8 bytes of protocol header information). The sender then waits or listens for a return packet from the target system. If the connections are good and the target computer is "alive," a good return packet is expected. However, this will not be the case if there is a disruption in communication. Pings also detail the time taken for a packet to make a complete trip, called the "round-trip time." They also help in resolving hostnames. In this case, if the packet bounces back when sent to the IP address, but not when sent to the name, then the system is unable to reconcile the name with the specific IP address.

Attackers calculate subnet masks using subnet mask calculators to identify the number of hosts that are present in the subnet. They subsequently use ping sweep to create an inventory of live systems in the subnet.

ICMP ECHO Ping Sweep Using Nmap

Source: *https://nmap.org*

Nmap helps an attacker to perform a ping sweep that determines live hosts from a range of IP addresses. In Zenmap, the **`-PE`** option with a list of IP addresses is used to perform ICMP ECHO ping sweep.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

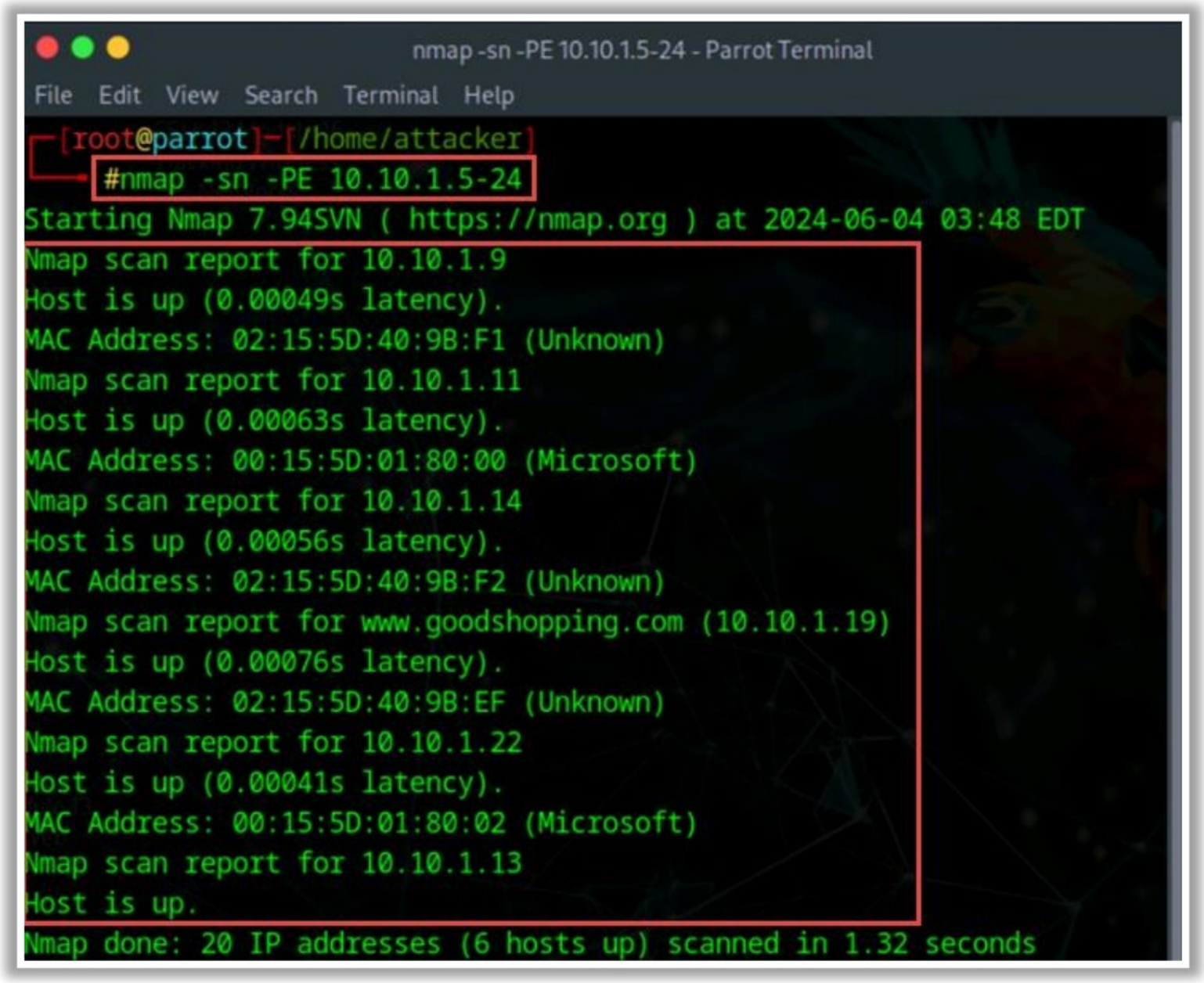


Figure 3.22: Ping Sweep output using Zenmap

ICMP Timestamp Ping Scan

Besides the traditional ICMP ECHO ping, there are some other types of ICMP pinging techniques such as ICMP timestamp ping scan and ICMP address mask ping scan, which an attacker can adopt in specific conditions.

ICMP timestamp ping is an optional and additional type of ICMP ping whereby the attackers query a timestamp message to acquire the information related to the current time from the target host machine. The target machine responds with a timestamp reply to each timestamp query that is received. However, the response from the destination host is conditional, and it may or may not respond with the time value depending on its configuration by the administrator at the target's end. This ICMP timestamp pinging is generally used for time synchronization. Such a ping method is effective in identifying whether the destination host machine is active, specifically in the condition where the administrator blocks the traditional ICMP ECHO ping requests. In Zenmap, the **`-PP`** option is used to perform an ICMP timestamp ping scan.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

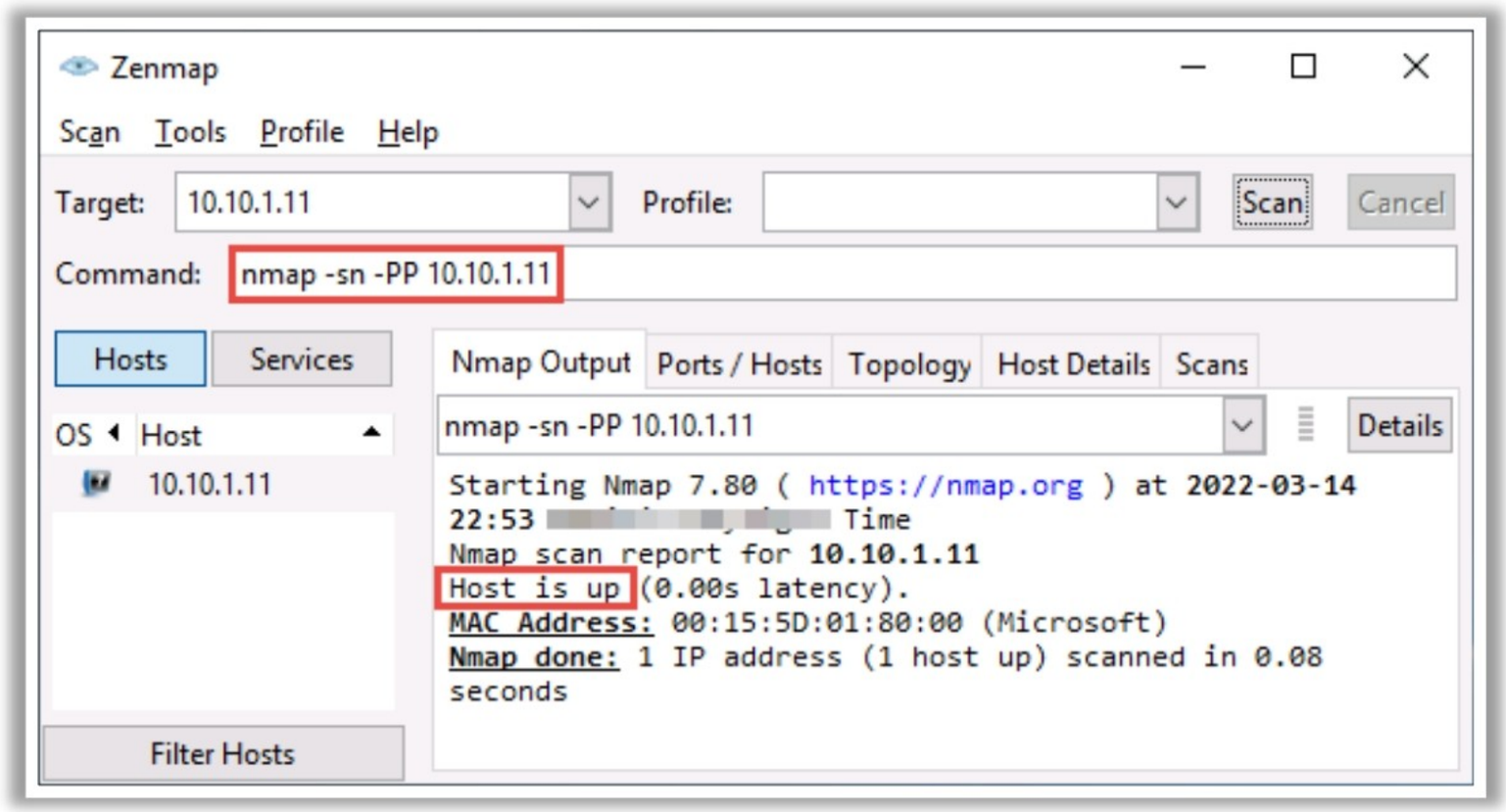


Figure 3.23: ICMP timestamp ping in Zenmap

ICMP Address Mask Ping Scan

ICMP address mask ping is another alternative to the traditional ICMP ECHO ping, where the attackers send an ICMP address mask query to the target host to acquire information related to the subnet mask. However, the address mask response from the destination host is conditional, and it may or may not respond with the appropriate subnet value depending on its configuration by the administrator at the target's end. This type of ping method is also effective in identifying the active hosts similarly to the ICMP timestamp ping, specifically when the administrator blocks the traditional ICMP Echo ping. In Zenmap, the **-PM** option is used to perform an ICMP address mask ping scan.

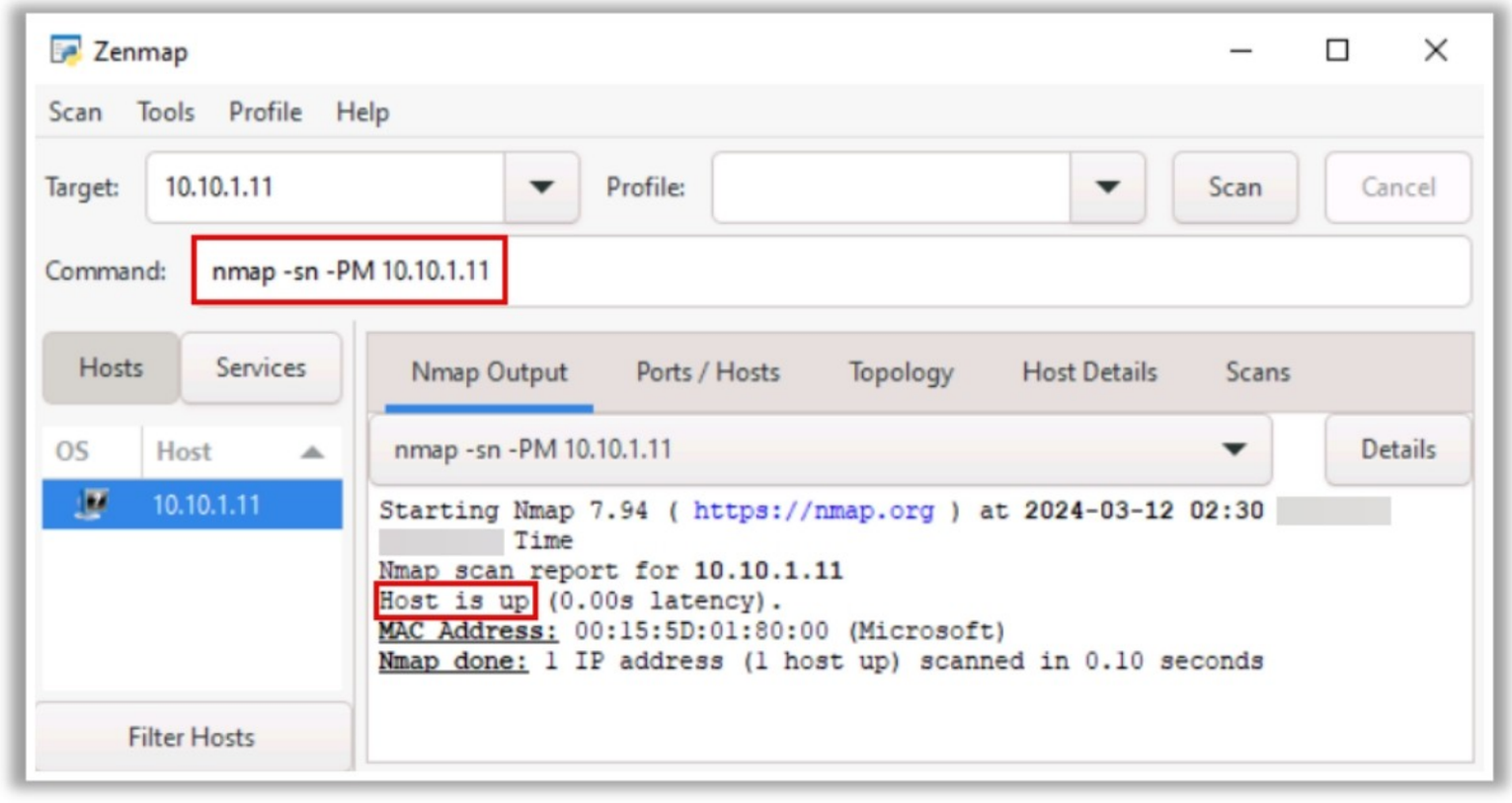


Figure 3.24: ICMP address mask ping in Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

TCP SYN Ping Scan

TCP SYN ping is a host discovery technique for probing different ports to determine if the port is online and to check if it encounters any firewall rule sets. In this type of host discovery technique, an attacker uses the Nmap tool to initiate the three-way handshake by sending the empty TCP SYN flag to the target host. After receiving SYN, the target host acknowledges the receipt with an ACK flag. After reception of the ACK flag, the attacker confirms that the target host is active and terminates the connection by sending an RST flag to the target host machine (since his/her objective of host discovery is accomplished). Port 80 is used as the default destination port. A range of ports can also be specified in this type of pinging format without inserting a space between -PS and the port number (e.g., **PS22-25,80,113,1050,35000**), where the probe will be performed against each port parallelly. In Zenmap, the **-PS** option is used to perform a TCP SYN ping scan.

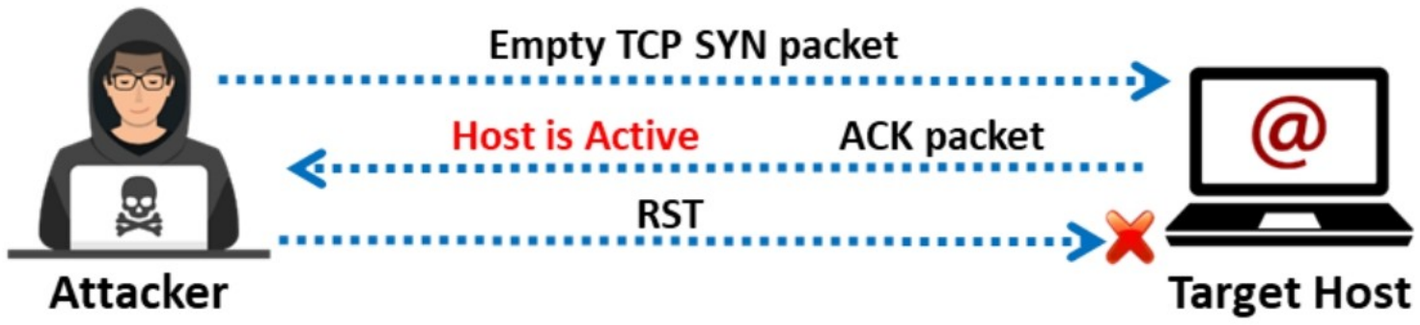


Figure 3.25: TCP SYN ping scan for host discovery

Advantages:

- As the machines can be scanned parallelly, the scan never gets the time-out error while waiting for the response.
- TCP SYN ping can be used to determine if the host is active without creating any connection. Hence, the logs are not recorded at the system or network level, enabling the attacker to leave no traces for detection.

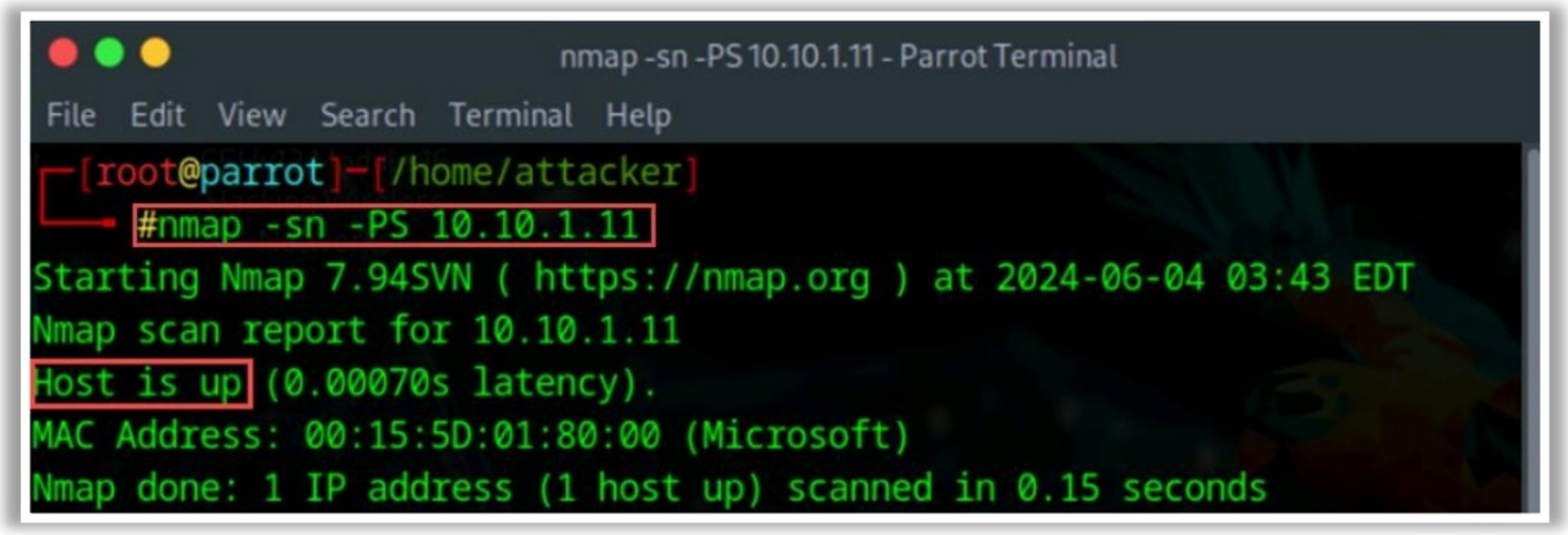


Figure 3.26: TCP SYN ping scan in Zenmap

TCP ACK Ping Scan

TCP ACK ping is similar to TCP SYN ping, albeit with minor variations. TCP ACK ping also uses the default port 80. In the TCP ACK ping technique, the attackers send an empty TCP ACK packet to the target host directly. Since there is no prior connection between the attacker and the target host, after receiving the ACK packet, the target host responds with an RST flag to terminate the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

request. The reception of this RST packet at the attacker's end indicates that the host is active. In Zenmap, the **-PA** option is used to perform a TCP ACK ping scan.

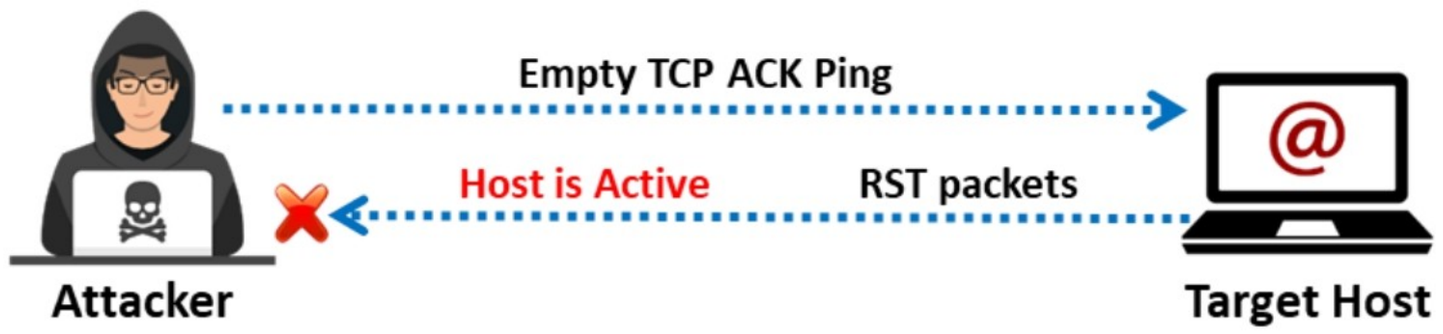


Figure 3.27: TCP ACK ping scan for host discovery

Advantages:

- Both the SYN and the ACK packet can be used to maximize the chances of bypassing the firewall. However, firewalls are mostly configured to block the SYN ping packets, as they are the most common pinging technique. In such cases, the ACK probe can be effectively used to bypass these firewall rule sets easily.

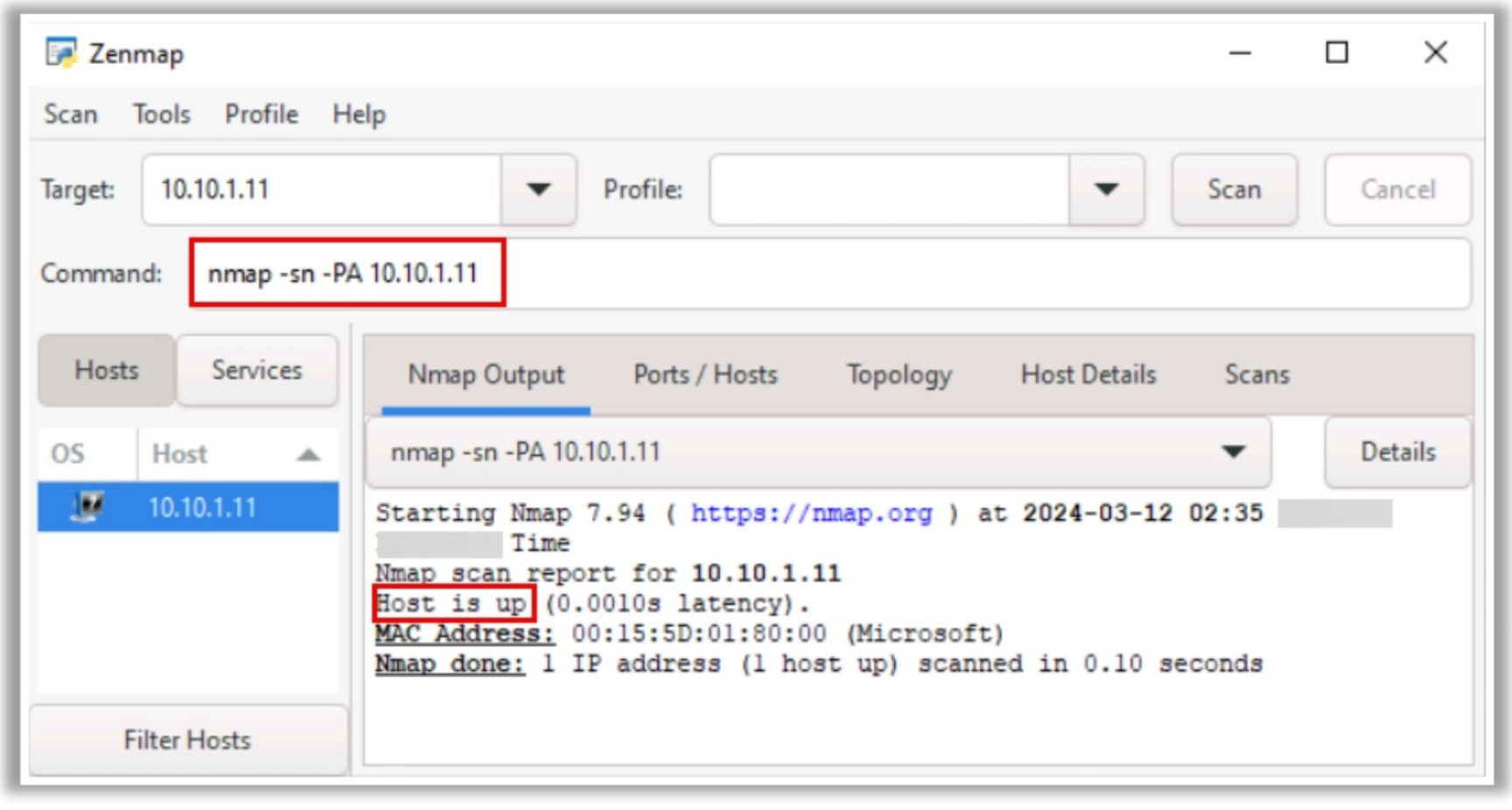


Figure 3.28: TCP ACK ping scan in Zenmap

IP Protocol Ping Scan

IP protocol ping is the latest host discovery option that sends IP ping packets with the IP header of any specified protocol number. It has the same format as the TCP and UDP ping. This technique tries to send different packets using different IP protocols, hoping to get a response indicating that a host is online.

Multiple IP packets for ICMP (protocol 1), IGMP (protocol 2), and IP-in-IP (protocol 4) are sent by default when no protocols are specified. For configuring the default protocols, change **DEFAULT_PROTO_PROBE_PORT_SPEC** in **nmap.h** during compile time. For specific protocols such as ICMP, IGMP, TCP (protocol 6), and UDP (protocol 17), the packets are to be sent with proper protocol headers, and for the remaining protocols, only the IP header data is to be sent with the packets.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

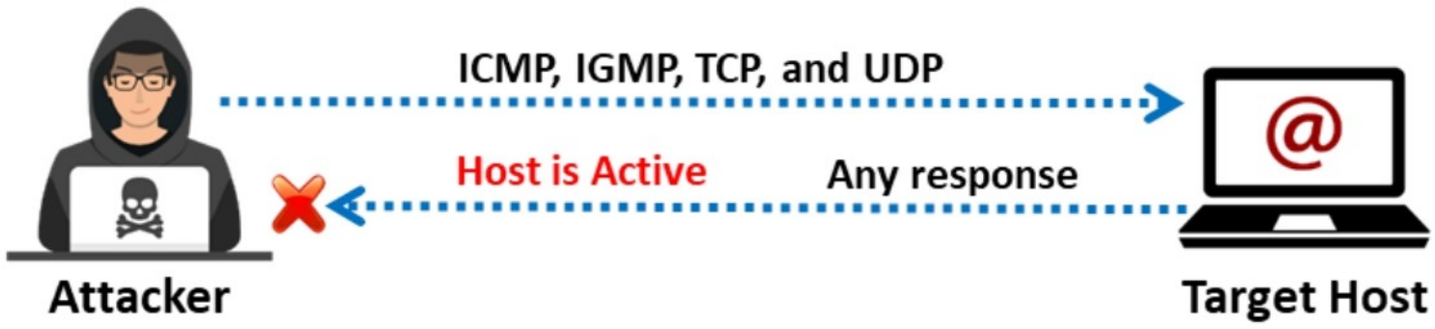


Figure 3.29: IP protocol ping scan for host discovery

In a nutshell, attackers send different probe packets of different IP protocols to the target host; any response from any probe indicates that a host is online. In Zenmap, the **-PO** option is used to perform an IP protocol ping scan.

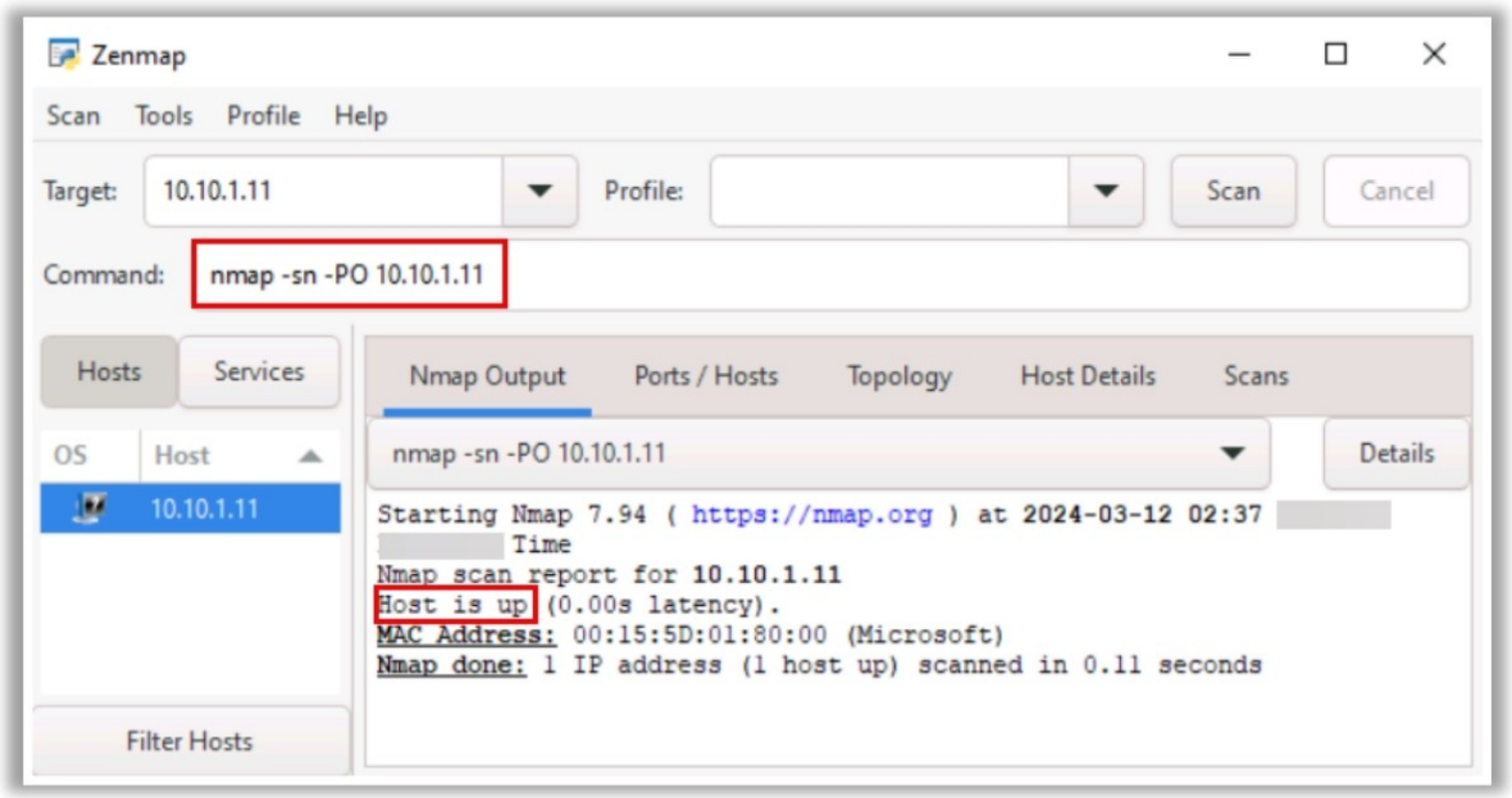
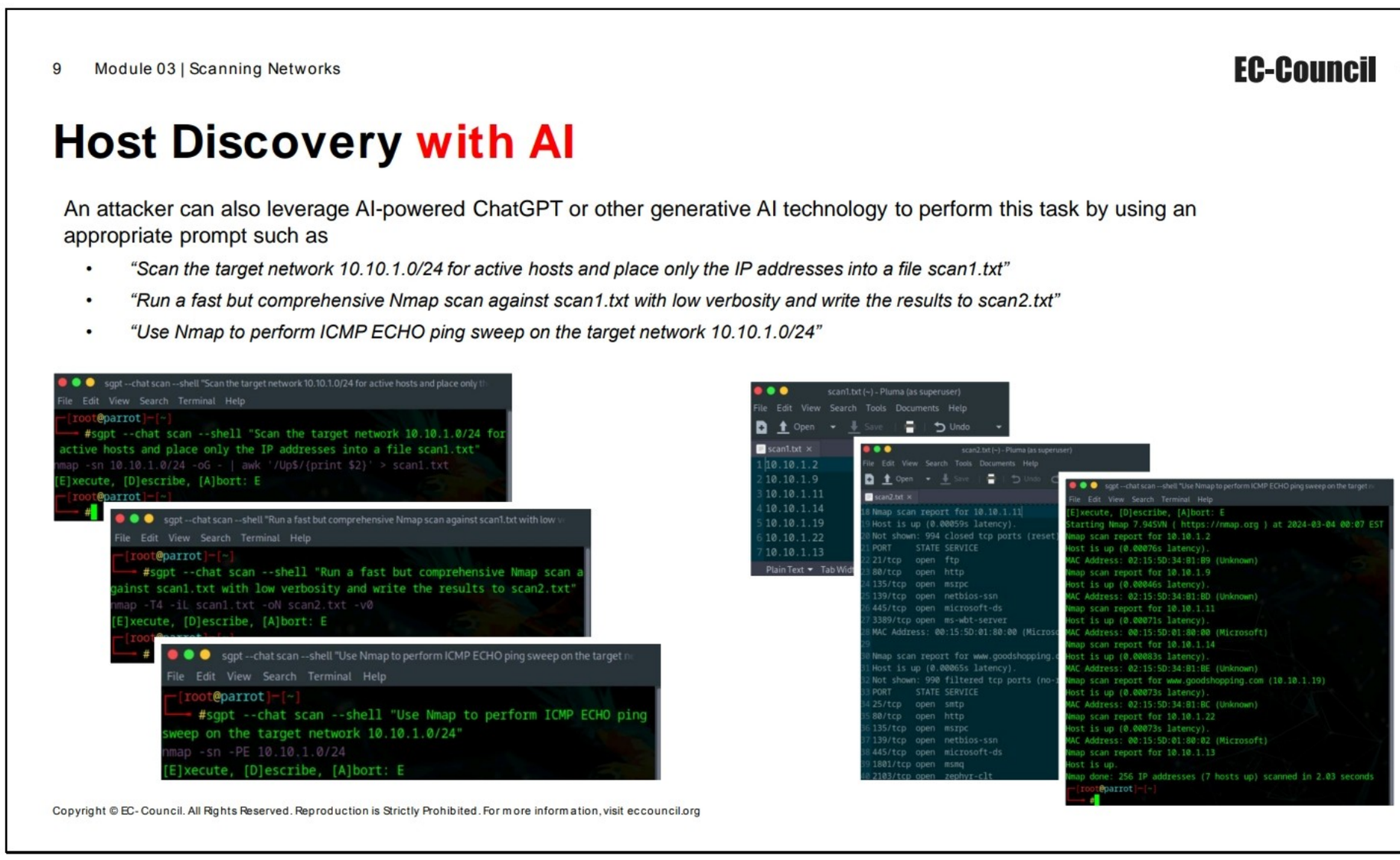


Figure 3.30: IP protocol ping scan in Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Host Discovery with AI

Attackers can leverage AI-powered technologies to enhance and automate host discovery tasks. With the aid of AI, attackers can effortlessly find out the live hosts on a target.

Example #1:

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Scan the target network 10.10.1.0/24 for active hosts and place only the IP addresses into a file scan1.txt"

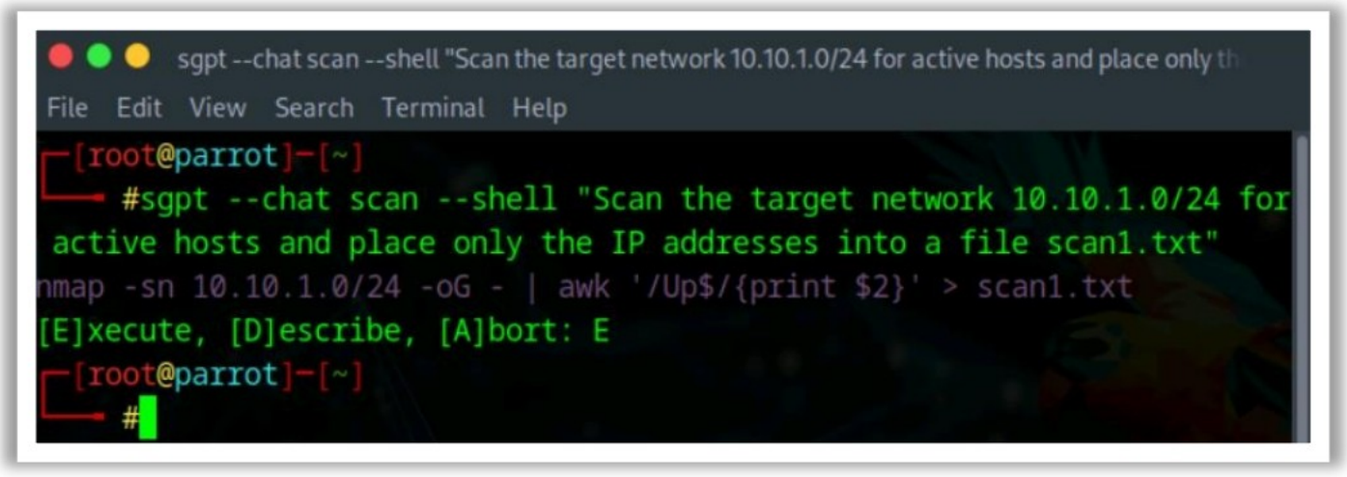


Figure 3.31: Scan the target network for active hosts

The command `` `nmap -sn 10.10.1.0/24 -OG- | awk '/Up$/{print $2}' > scan1.txt` `` is used to perform a ping scan using Nmap, extract the IP addresses of hosts that are found to be up, and save the results to a text file named "scan1.txt".

`` `nmap -sn 10.10.1.0/24 -OG- | awk '/Up$/{print $2}' > scan1.txt` ``

- `` `nmap` ``: This is the command to invoke Nmap, a powerful network scanning tool.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- `-sn`: This option specifies a ping scan, also known as a "ping sweep", where Nmap sends ICMP echo requests to discover live hosts without further probing ports.
- `10.10.1.0/24`: This specifies the target IP range to scan, using CIDR notation (/24) to denote all IP addresses within the range from 10.10.1.0 to 10.10.1.255.
- `-oG-`: This option outputs the scan results in a grepable format, which can be processed by the subsequent `awk` command.
- `| awk '/Up$/{print $2}'`: This pipes the output of the Nmap scan to the `awk` command, which filters lines containing the string "Up" (indicating that the host is up) and prints the second field, which corresponds to the IP address of the host.
- `> scan1.txt`: This redirects the output of the `awk` command to a text file named "scan1.txt", saving the list of IP addresses of live hosts discovered during the scan.

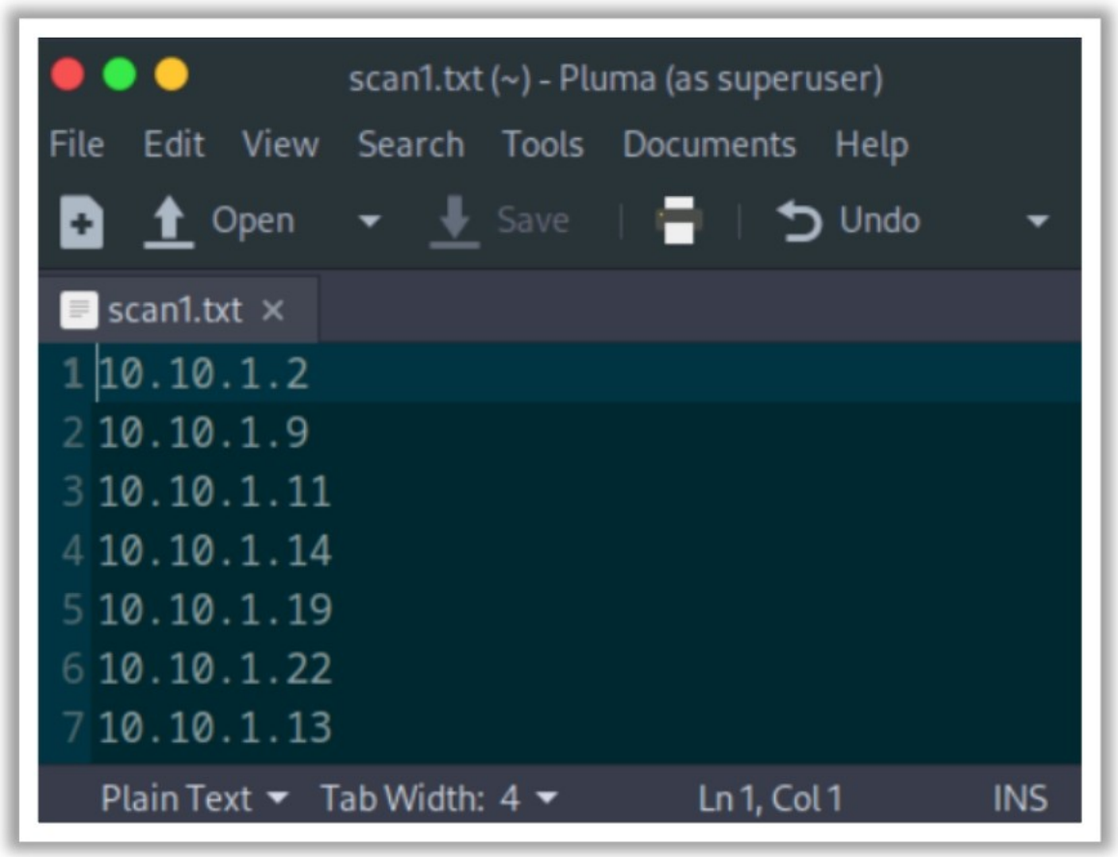


Figure 3.32: Output of the `awk` command to a text file named "scan1.txt

Example #2:

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Run a fast but comprehensive Nmap scan against scan1.txt with low verbosity and write the results to scan2.txt"

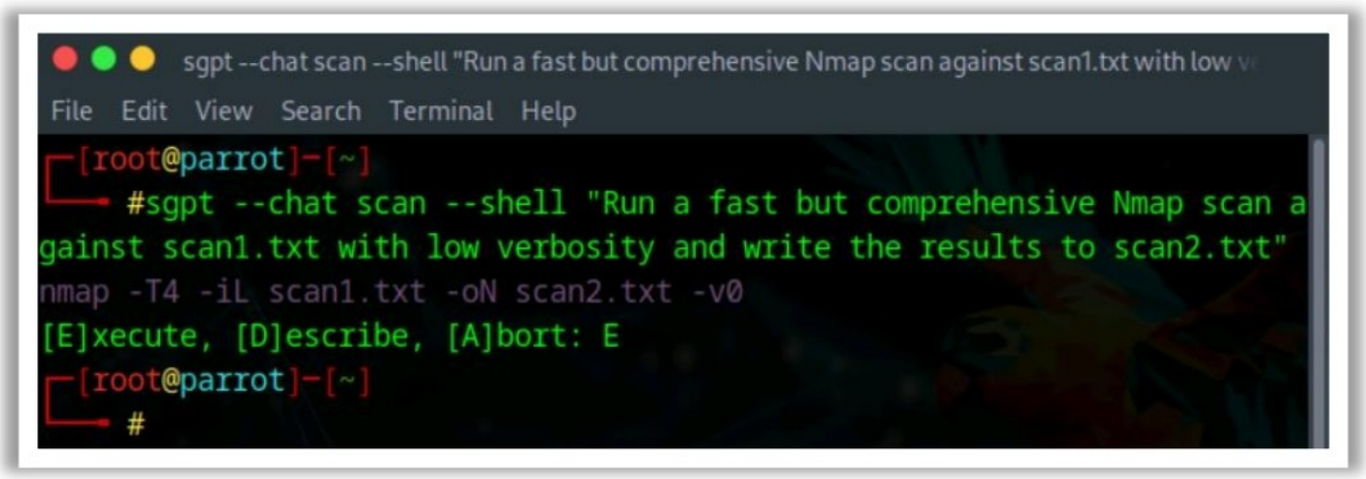


Figure 3.33: Comprehensive Nmap scan against scan1.txt with low verbosity

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The command `**nmap -T4 -iL scan.txt -oN scan2.txt -v0**` is used to perform an Nmap scan with specific options. Here is an explanation:

nmap -T4 -iL scan.txt -oN scan2.txt -v0

- `**nmap**`: This is the command to invoke Nmap, a powerful network scanning tool.
- `**-T4**`: This option sets the timing template to "aggressive," instructing Nmap to execute the scan with faster timing and performance.
- `**-iL scan.txt**`: This option specifies the input file containing a list of target IP addresses or hostnames to scan. In this case, the file is named "scan.txt".
- `**-oN scan2.txt**`: This option specifies the file where the scan results will be saved. In this case, the results will be saved in a file named "scan2.txt".
- `**-v0**`: This option sets the verbosity level to 0, meaning that Nmap will not display any output except for errors. This reduces the amount of output produced during the scan, making it more concise.

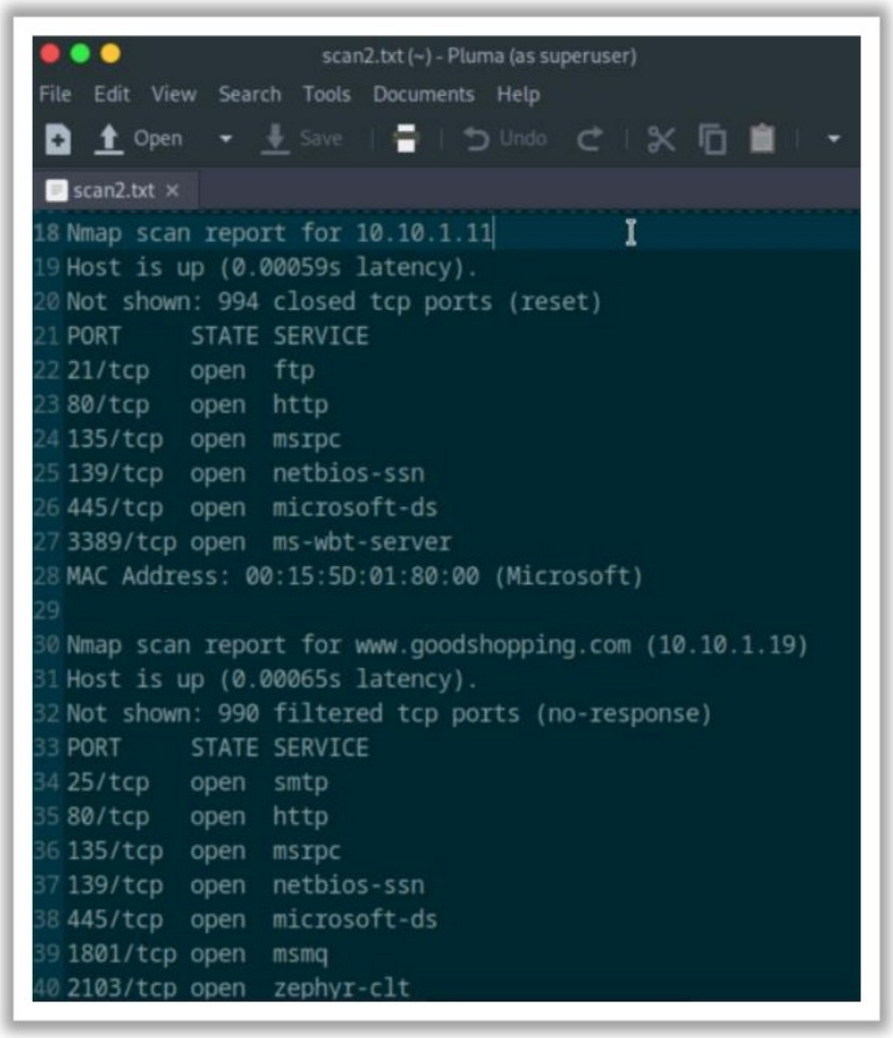


Figure 3.34: Output

Overall, this command executes an Nmap scan using aggressive timing against the targets listed in "scan.txt", saves the results to "scan2.txt", and suppresses all non-error output to maintain a low verbosity level.

Example #3:

Attackers can leverage AI-powered technologies to enhance and automate host discovery tasks. With the aid of AI, attackers can effortlessly find out the live hosts on a target with the help of Nmap.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

For instance,

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Use Nmap to perform ICMP ECHO ping sweep on the target network 10.10.1.0/24"

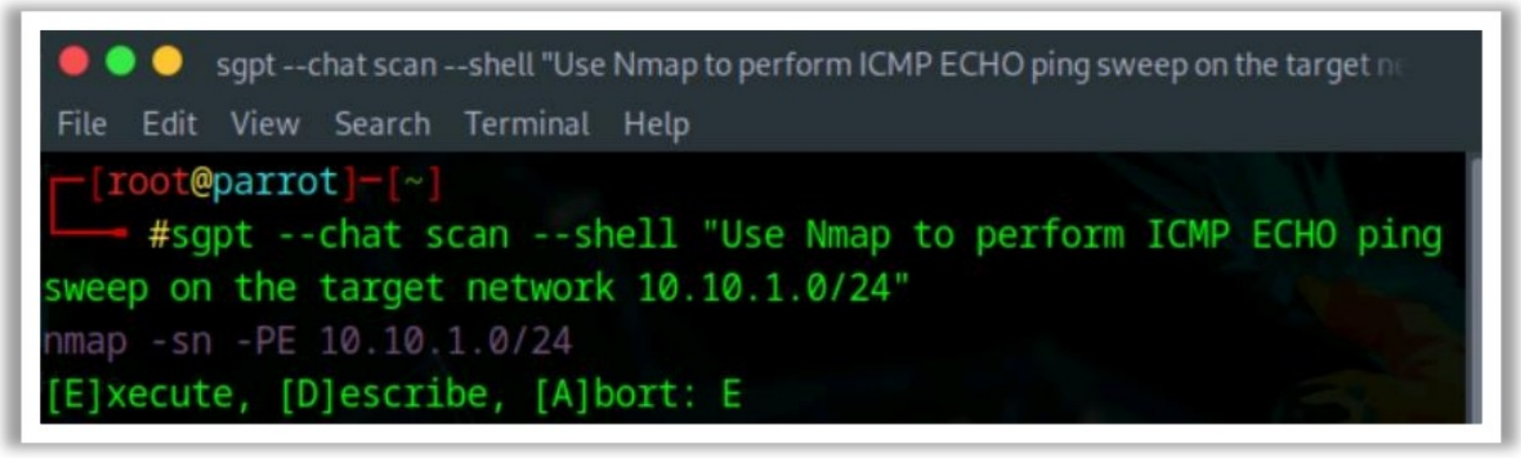


Figure 3.35: Use Nmap to perform ICMP ECHO ping sweep

The command `**nmap -sn -PE 10.10.1.0/24**` is used to perform a ping scan using Nmap on the specified IP range (10.10.1.0/24). Here is an explanation of the options used:

nmap -sn -PE 10.10.1.0/24

- `**nmap**`: This is the command to invoke Nmap, a powerful network scanning tool.
- `**-sn**`: This option specifies a ping scan, also known as a "ping sweep", where Nmap sends ICMP echo requests to discover live hosts without further probing ports.
- `**-PE**`: This option specifies that ICMP echo requests should be used for host discovery during the ping scan.
- `**10.10.1.0/24**`: This specifies the target IP range to scan, using CIDR notation (/24) to denote all IP addresses within the range from 10.10.1.0 to 10.10.1.255.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

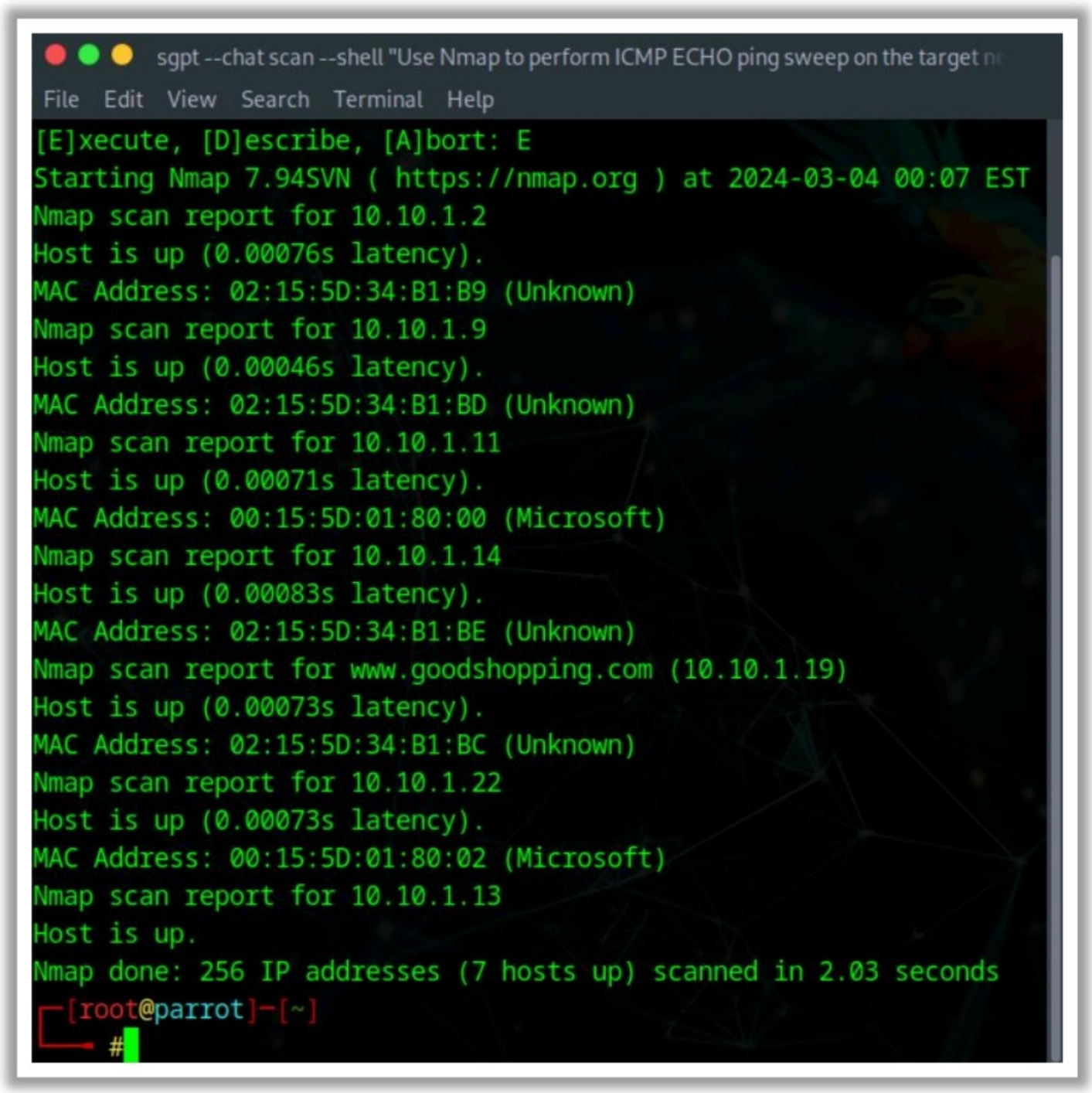


Figure 3.36: Ping scan using Nmap on the specified IP range

Overall, this command instructs Nmap to perform a ping scan on the IP range 10.10.1.0/24 using ICMP echo requests to discover live hosts.

Ping Sweep Tools

Ping sweep tools ping an entire range of network IP addresses to identify the live systems. The following are ping sweep tools that enable one to determine live hosts on the target network by sending multiple ICMP ECHO requests to various hosts on the network at a time.

- **Angry IP Scanner**

  Source: *https://angryip.org*

  Angry IP scanner is an IP address and port scanner. It can scan IP addresses in any range as well as any of their ports. It pings each IP address to check if it is alive; then, it optionally resolves its hostname, determines the MAC address, scans ports, and so on. The amount of data gathered about each host increases with plugins. Angry IP scanner has additional features, such as NetBIOS information (computer name, workgroup name, and currently logged in Windows user), favorite IP address ranges, web server detection, and customizable openers. The tool allows the user to save the scanning results to CSV, TXT, XML, or IP-Port list files. To increase the scanning speed, it uses a multithreaded approach: a separate scanning thread is created for each scanned IP address.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

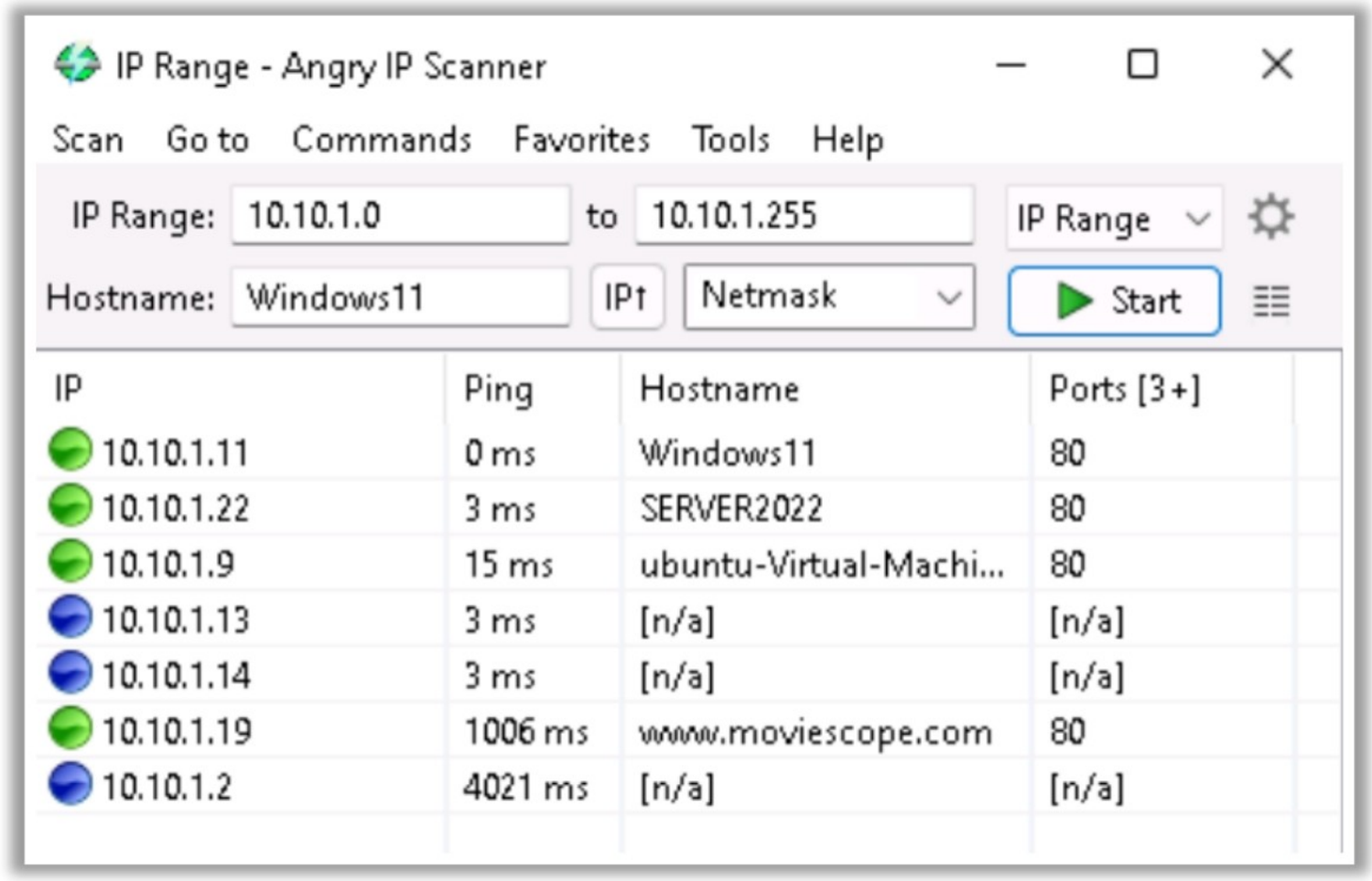


Figure 3.37: Screenshot of Angry IP Scanner showing live hosts

Some additional ping sweep tools that an attacker uses to determine live hosts on the target network are listed below:

- SolarWinds Engineer's Toolset (*https://www.solarwinds.com*)
- NetScanTools Pro (*https://www.netscantools.com*)
- Colasoft Ping Tool (*https://www.colasoft.com*)
- Advanced IP Scanner (*https://www.advanced-ip-scanner.com*)
- OpUtils (*https://www.manageengine.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Port and Service Discovery

The next step in the network scanning process involves checking the open ports and services in live systems. This discovery of open ports and services can be performed via various port scanning techniques. Administrators often use port scanning techniques to verify the security policies of their networks, whereas attackers use them to identify open ports and running services on a host with the intent of compromising the network. Moreover, sometimes, users unknowingly keep unnecessary open ports on their systems. An attacker takes advantage of such open ports to launch attacks.

This section describes the common ports and corresponding services along with various port scanning techniques and tools used by the attacker to perform port scanning.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

List of Common Ports and Services

The important reserved ports are listed below:

Name	Port/Protocol	Description
echo	7/tcp, udp	
discard	9/ tcp, udp	sink null
systat	11/tcp	Users
daytime	13/ tcp, udp	
netstat	15/tcp, udp	
qotd	17/tcp, udp	Quote
chargen	19/tcp, udp	ttytst source
ftp-data	20/tcp	ftp data transfer
ftp	21/tcp	ftp command
ssh	22/tcp	Secure Shell
telnet	23/tcp	
SMTP	25/tcp	Email server
time	37/tcp, udp	Timeserver
rlp	39/tcp, udp	resource location
domain	53/tcp, udp	domain name server
sql*net	66/tcp, udp	Oracle SQL*net
bootps	67/udp	bootp server
bootpc	68/udp	bootp client
tftp	69/udp	Trivial File Transfer
gopher	70/tcp	gopher server
finger	79/tcp	Finger
www-http	80/tcp, udp	WWW
www-https	80/tcp	WWW
kerberos	88/tcp, udp	Kerberos
pop2	109/tcp	PostOffice V.2
Pop3	110/tcp	PostOffice V.3
sunrpc	111/tcp, udp	RPC 4.0 portmapper
auth/ident	113/tcp, udp	Authentication Service
audionews	114/tcp, udp	Audio News Multicast
nntp	119/tcp	Usenet Network News Transfer
ntp	123/udp	Network Time Protocol
netbios-ns	137/tcp, udp	NETBIOS Name Service

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Name	Port/Protocol	Description
netbios-dgm	138/tcp, udp	NETBIOS Datagram Service
netbios-ssn	139/tcp, udp	NETBIOS Session Service
imap	143/tcp, udp	Internet Message Access Protocol
sql-net	150/tcp, udp	SQL-NET
sqlsrv	156/tcp, udp	SQL Service
snmp	161/tcp, udp	SNMP
snmp-trap	162/tcp, udp	
cmip-man	163/tcp, udp	CMIP/TCP Manager
cmip-agent	164/tcp, udp	CMIP/TCP Agent
irc	194/tcp, udp	Internet Relay Chat
at-rtmp	201/tcp, udp	AppleTalk Routing Maintenance
at-nbp	202/tcp, udp	AppleTalk Name Binding
at-3	203/tcp, udp	AppleTalk
at-echo	204/tcp, udp	AppleTalk Echo
at-5	205/tcp, udp	AppleTalk
at-zis	206/tcp, udp	AppleTalk Zone Information
at-7	207/tcp, udp	AppleTalk
at-8	208/tcp, udp	AppleTalk
ipx	213/tcp, udp	Novell
imap3	220/tcp, udp	Interactive Mail Access Protocol v3
aurp	387/tcp, udp	AppleTalk Update-Based Routing
netware-ip	396/tcp, udp	Novell Netware over IP
rmt	411/tcp, udp	Remote mt
kerberos-ds	445/tcp, udp	Microsoft DS
isakmp	500/udp	ISAKMP/IKE
fcp	510/tcp	First Class Server
exec	512/tcp	BSD rexecd(8)
comsat/biff	512/udp	Used by mail system to notify users
login	513/tcp	BSD rlogind(8)
who	513/udp	whod BSD rwhod(8)
shell	514/tcp	cmd BSD rshd(8)
syslog	514/udp	BSD syslogd(8)
printer	515/tcp, udp	spooler BSD lpd(8)
talk	517/tcp, udp	BSD talkd(8)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Name	Port/Protocol	Description
ntalk	518/udp	SunOS talkd(8)
netnews	532/tcp, udp	Readnews
uucp	540/tcp, udp	uucpd BSD uucpd(8)
klogin	543/tcp, udp	Kerberos Login
kshell	544/tcp, udp	Kerberos Shell
ekshell	545/tcp	krcmd Kerberos encrypted remote shell –kfall
pcserver	600/tcp	ECD Integrated PC board srvr
mount	635/udp	NFS Mount Service
pcnfs	640/udp	PC-NFS DOS Authentication
bwnfs	650/udp	BW-NFS DOS Authentication
flexlm	744/tcp, udp	Flexible License Manager
kerberos-adm	749/tcp, udp	Kerberos Administration
kerberos	750/tcp, udp	kdc Kerberos authentication
kerberos_master	751/tcp, udp	Kerberos authentication
krb_prop	754/tcp	Kerberos slave propagation
applix	999/udp	Applixware
socks	1080/tcp, udp	Socks Proxy
kpop	1109/tcp	Pop with Kerberos
ms-sql-s	1433/tcp, udp	Microsoft SQL Server
ms-sql-m	1434/tcp, udp	Microsoft SQL Monitor
pptp	1723/tcp, udp	Pptp
nfs	2049/tcp, udp	Network File System
eklogin	2105/tcp	Kerberos encrypted rlogin
rkinit	2108/tcp	Kerberos remote kinit
kx	2111/tcp	X over Kerberos
kauth	2120/tcp	Remote kauth
lyskom	4894/tcp	LysKOM (conference system)
sip	5060/tcp	Session Initiation Protocol
sip	5060/udp	Session Initiation Protocol
x11	6000-6063/tcp, udp	X Window System
irc	6667/tcp	Internet Relay Chat

Table 3.1: Reserved ports table

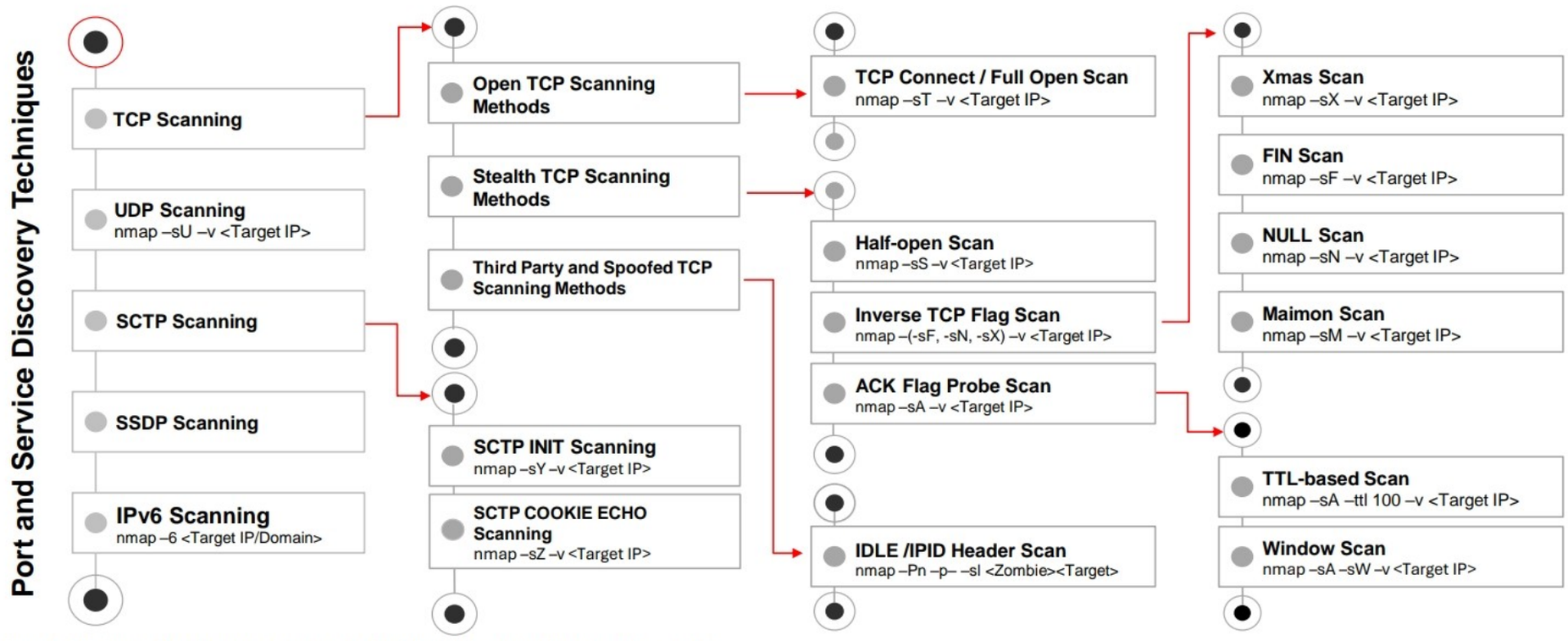
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

11 Module 03 | Scanning Networks

EC-Council CEH v13

Port Scanning Techniques

The port scanning techniques are **categorized according to the type of protocol** used for communication



Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

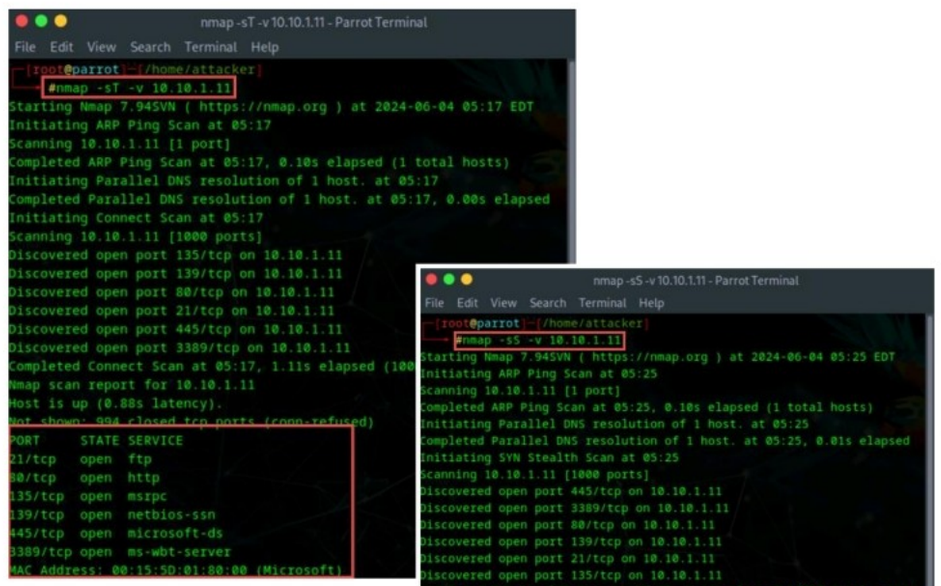
12 Module 03 | Scanning Networks

EC-Council CEH v13

Port Scanning Techniques (Cont'd)

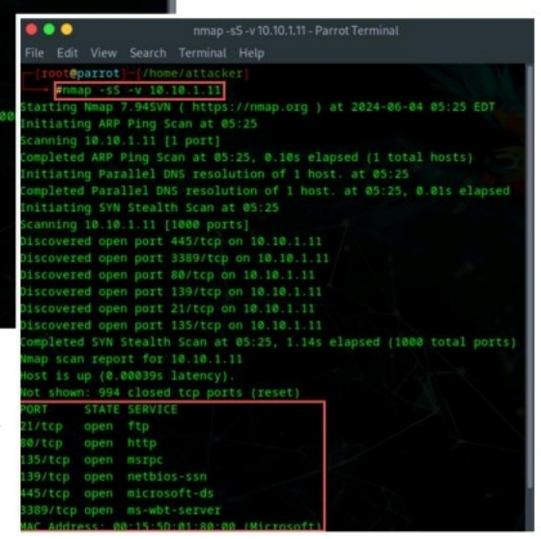
TCP Connect/ Full-Open Scan

- The TCP Connect scan detects when a port is open after completing the **three-way handshake**
- TCP Connect scan **establishes a full connection** and then closes the connection by sending an **RST packet**



Stealth Scan (Half-Open Scan)

- Stealth scanning involves abruptly resetting the TCP connection between the client and server before the completion of **three-way handshake signals**, thus leaving the connection half-open
- Attackers use stealth scanning techniques to **bypass firewall rules** as well as **logging mechanisms**, and hide themselves under the appearance of regular network traffic



Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Port Scanning Techniques

Port scanning techniques are further categorized as described below. This categorization is based on the type of protocol used for communication in the network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

TCP Scanning:

- Open TCP Scanning Methods
  - TCP Connect/Full-open Scan
- Stealth TCP Scanning Methods
  - Half-open Scan
  - Inverse TCP Flag Scan
    - Xmas Scan
    - FIN Scan
    - NULL Scan
    - Maimon Scan
  - ACK Flag Probe Scan
    - TTL-Based Scan
    - Window-Based Scan
- Third Party and Spoofed TCP Scanning Methods
  - IDLE/IP ID Header Scan

UDP Scanning:

- UDP Scanning

SCTP Scanning:

- SCTP INIT Scanning
- SCTP COOKIE/ECHO Scanning

SSDP Scanning:

- SSDP and List Scanning

IPv6 Scanning:

- IPv6 Scanning

TCP Connect/Full-Open Scan

Source: *https://insecure.org*

TCP Connect/Full Open Scan is one of the most reliable forms of TCP scanning. In TCP Connect scanning, the OS's TCP **`connect()`** system call tries to open a connection to every port of interest on the target machine. If the port is listening, the **`connect()`** call will result in a successful connection with the host on that particular port; otherwise, it will return an error message stating that the port is not reachable.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

TCP Connect scan completes a three-way handshake with the target machine. In the TCP three-way handshake, the client sends a SYN packet, which the recipient acknowledges with a SYN+ACK packet. Then, the client acknowledges the SYN+ACK packet with an ACK packet to complete the connection. Once the handshake is completed, the scanner sends an RST packet to end the connection.

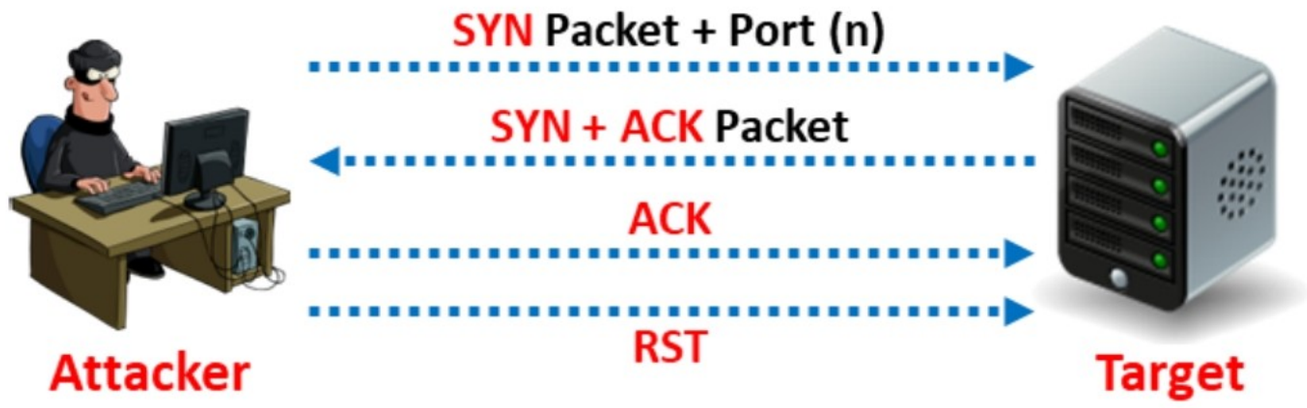


Figure 3.38: Scan result when a port is open

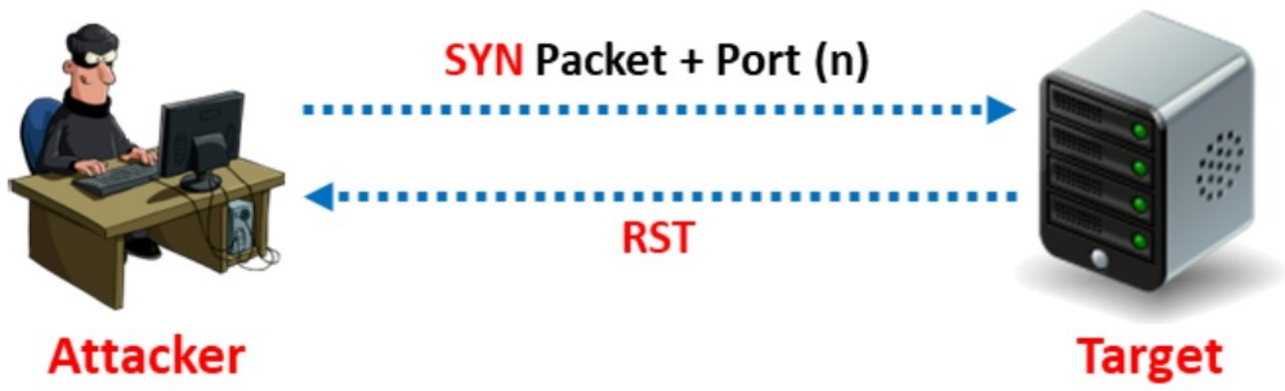


Figure 3.39: Scan result when a port is closed

Making a separate **`connect()`** call for every targeted port in a linear manner would take a long time over a slow connection. The attacker can accelerate the scan using many sockets in parallel. Using non-blocking, I/O allows the attacker to set a short time-out period and watch all the sockets simultaneously. In Zenmap, the **`-sT`** option is used to perform TCP Connect/full open scan.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

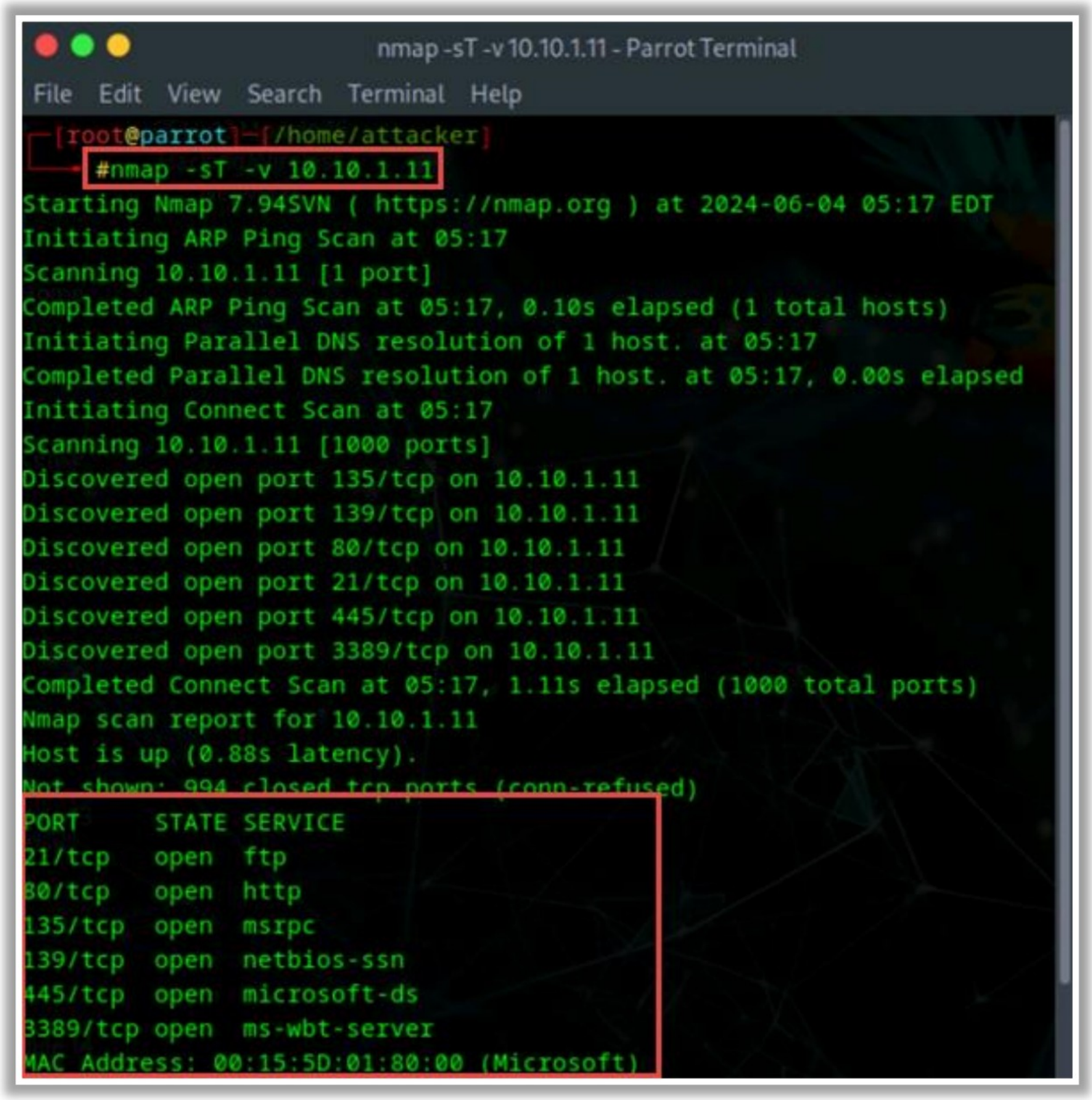


Figure 3.40: TCP Connect/Full Open scan using Zenmap

The drawback of this type of scan is that it is easily detectable and filterable. The logs in the target system will disclose the connection. Such scanning does not require superuser privileges.

Stealth Scan (Half-Open Scan)

The stealth scan involves resetting the TCP connection between the client and the server abruptly before completion of the three-way handshake signals, hence making the connection half-open. A stealth scan sends a single frame to a TCP port without any TCP handshaking or additional packet transfers. This type of scan sends a single frame with the expectation of a single response. The half-open scan partially opens a connection but stops halfway through. The stealth scan is also called a "SYN scan," because it only sends the SYN packet. This prevents the service from notifying the incoming connection. TCP SYN or half-open scanning is a stealth method of port scanning.

The stealth scan also implements the three-way handshake methodology. In the last stage, it examines the packets entering the interface and terminates the connection before triggering a new initialization to identify remote ports. The stealth scan process is described below.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- The client sends a single SYN packet to the server on the appropriate port.
- If the port is open, the server subsequently responds with a SYN/ACK packet.
- If the server responds with an RST packet, then the remote port is in the "closed" state.
- The client sends the RST packet to close the initiation before a connection can be established.

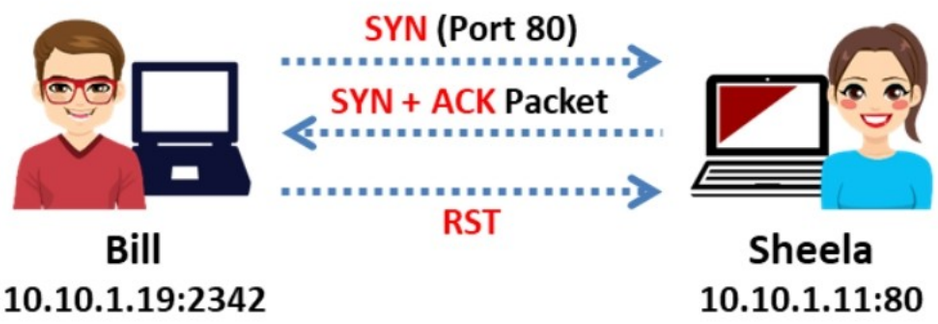


Figure 3.41: Port is open

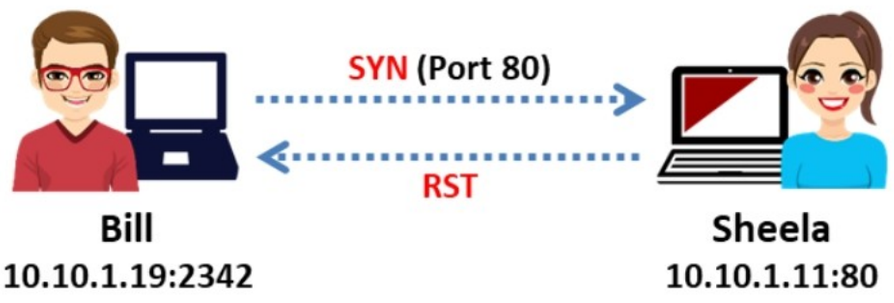


Figure 3.42: Port is closed

Attackers use stealth scanning techniques to bypass firewall rules and logging mechanisms, and they hide themselves as usual under network traffic. In Zenmap, the **`-sS`** option is used to perform a stealth scan/TCP half-open scan.

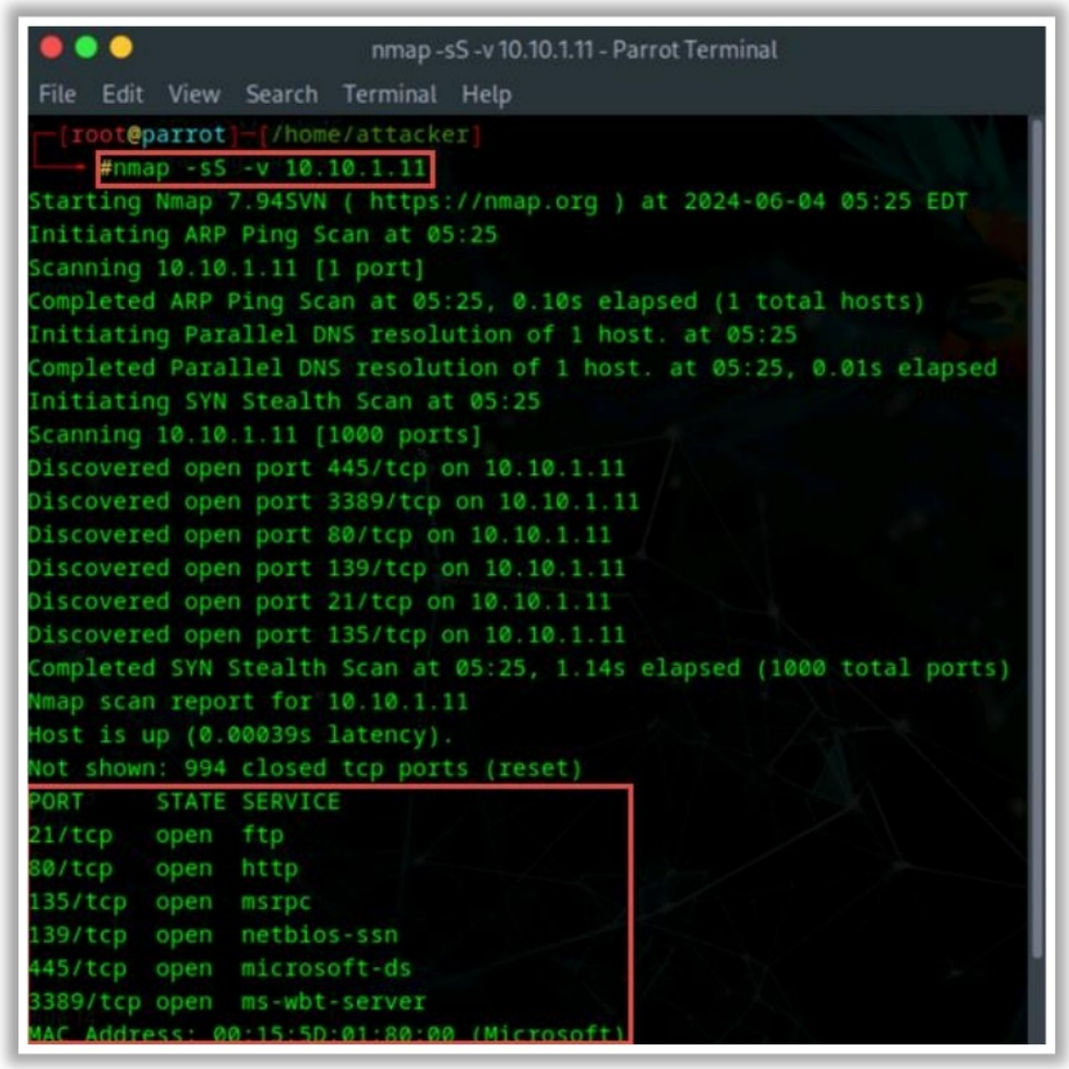


Figure 3.43: TCP Stealth/Half Open scan using Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Inverse TCP Flag Scan

Attackers send TCP probe packets with a TCP flag (FIN, URG, PSH) set or with no flags. When the port is open, the attacker does not get any response from the host, whereas when the port is closed, he or she receives the RST from the target host.

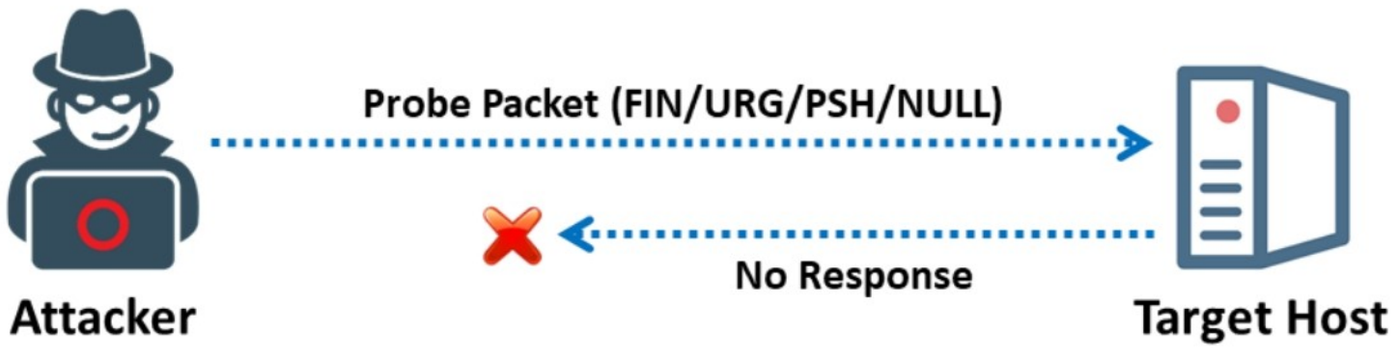


Figure 3.44: Inverse TCP flag scan when port is open

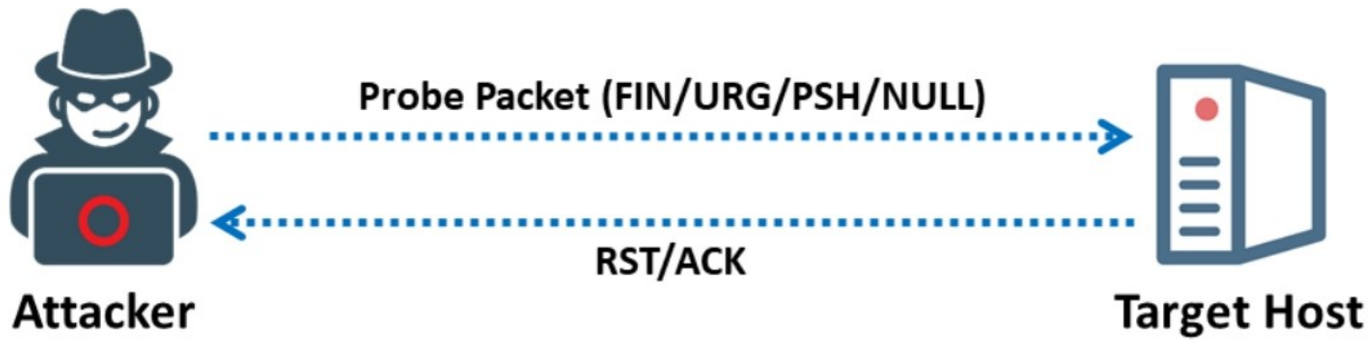


Figure 3.45: Inverse TCP flag scan when port is closed

Security mechanisms such as firewalls and IDS detect the SYN packets sent to the sensitive ports of the targeted hosts. Programs such as Syslog are available to log half-open SYN flag scan attempts. At times, the probe packets enabled with TCP flags can pass through filters undetected, depending on the security mechanisms installed.

An inverted technique involves probing a target using a half-open SYN flag because the closed ports can only send the response back. According to RFC 793, an RST/ACK packet is sent for connection reset when the host closes a port. Attackers take advantage of this feature to send TCP probe packets to each port of the target host with various TCP flags set.

Common flag configurations used for a probe packet include:

- A FIN probe with the FIN TCP flag set
- An Xmas probe with the FIN, URG, and PUSH TCP flags set
- A NULL probe with no TCP flags set
- A SYN/ACK probe

All closed ports on the targeted host will send an RST/ACK response. Since OSs such as Windows completely ignore the RFC 793 standard, you cannot see the RST/ACK response when connected to a closed port on the target host. However, this technique is effective when used with UNIX-based OSs.

Advantages

- Avoids many IDS and logging systems; highly stealthy

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Disadvantages

- Requires raw access to network sockets and super-user privileges
- Mostly effective against hosts using a BSD-derived TCP/IP stack (not effective against Microsoft Windows hosts, in particular).

Note: Inverse TCP flag scanning is known as FIN, URG, and PSH scanning based on the flag set in the probe packet. If there is no flag set, it is known as NULL scanning. If only the FIN flag is set, it is known as FIN scanning, and if all of FIN, URG, and PSH are set, it is known as Xmas scanning.

Xmas Scan

Xmas scan is a type of inverse TCP scanning technique with the FIN, URG, and PUSH flags set to send a TCP frame to a remote device. If the target has opened the port, then you will receive no response from the remote system. If the target has closed the port, then you will receive a remote system reply with an RST. You can use this port scanning technique to scan large networks and find which host is up and what services it is offering. This technique describes all TCP flag sets. When all flags are set, some systems hang; hence, the flags are often set in the nonsense pattern URG-PSH-FIN. Attackers use the TCP Xmas scan to determine if ports are closed on the target machine via the RST packet. This scan only works when systems are compliant with RFC 793-based TCP/IP implementation. It will not work against any current version of Microsoft Windows.

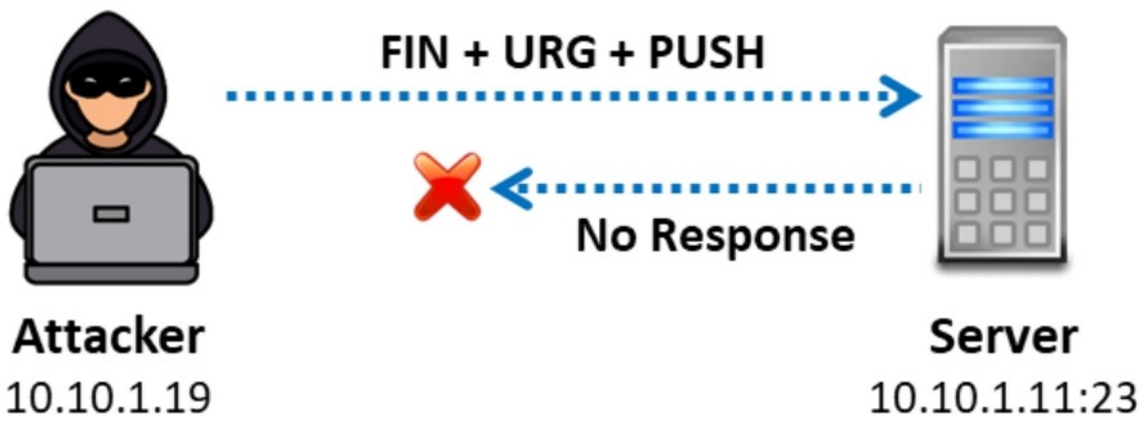


Figure 3.46: Xmas scan when the port is open

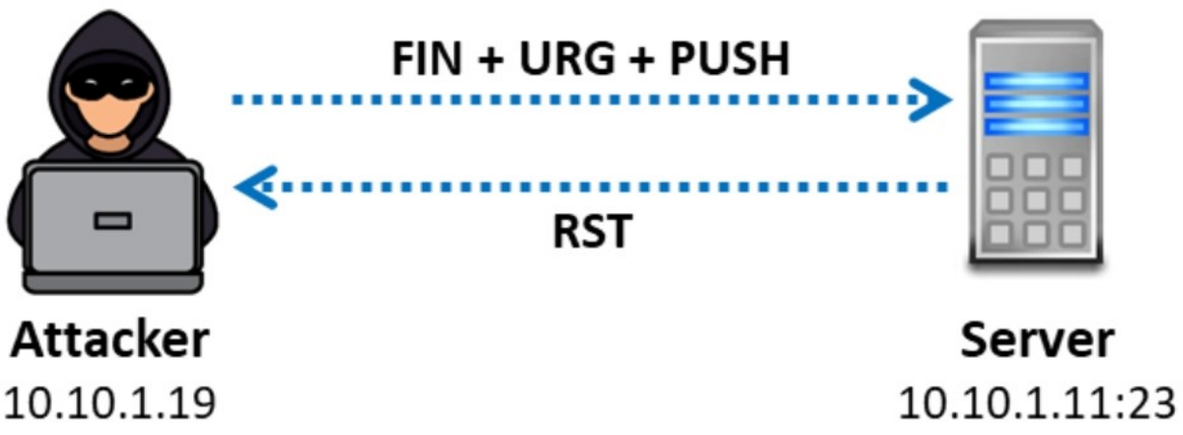


Figure 3.47: Xmas scan when the port is closed

BSD Networking Code

This method relies on the BSD networking code. Thus, you can use this only for UNIX hosts; it does not support Windows NT. If the user scans any Microsoft system, it will show that all the ports on the host are open.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Transmitting Packets

You can initialize all the flags when transmitting the packet to a remote host. If the target system accepts the packet and does not send any response, it means that the port is open. If the target system sends an RST flag, then it implies that the port is closed.

Advantages

- It avoids IDS and TCP three-way handshake.

Disadvantages

- It works on the UNIX platform only.

In Zenmap, the **-sX** option is used to perform Xmas scan whereas the **-sF** and **-sN** options are used to perform FIN scan and NULL scan, respectively.

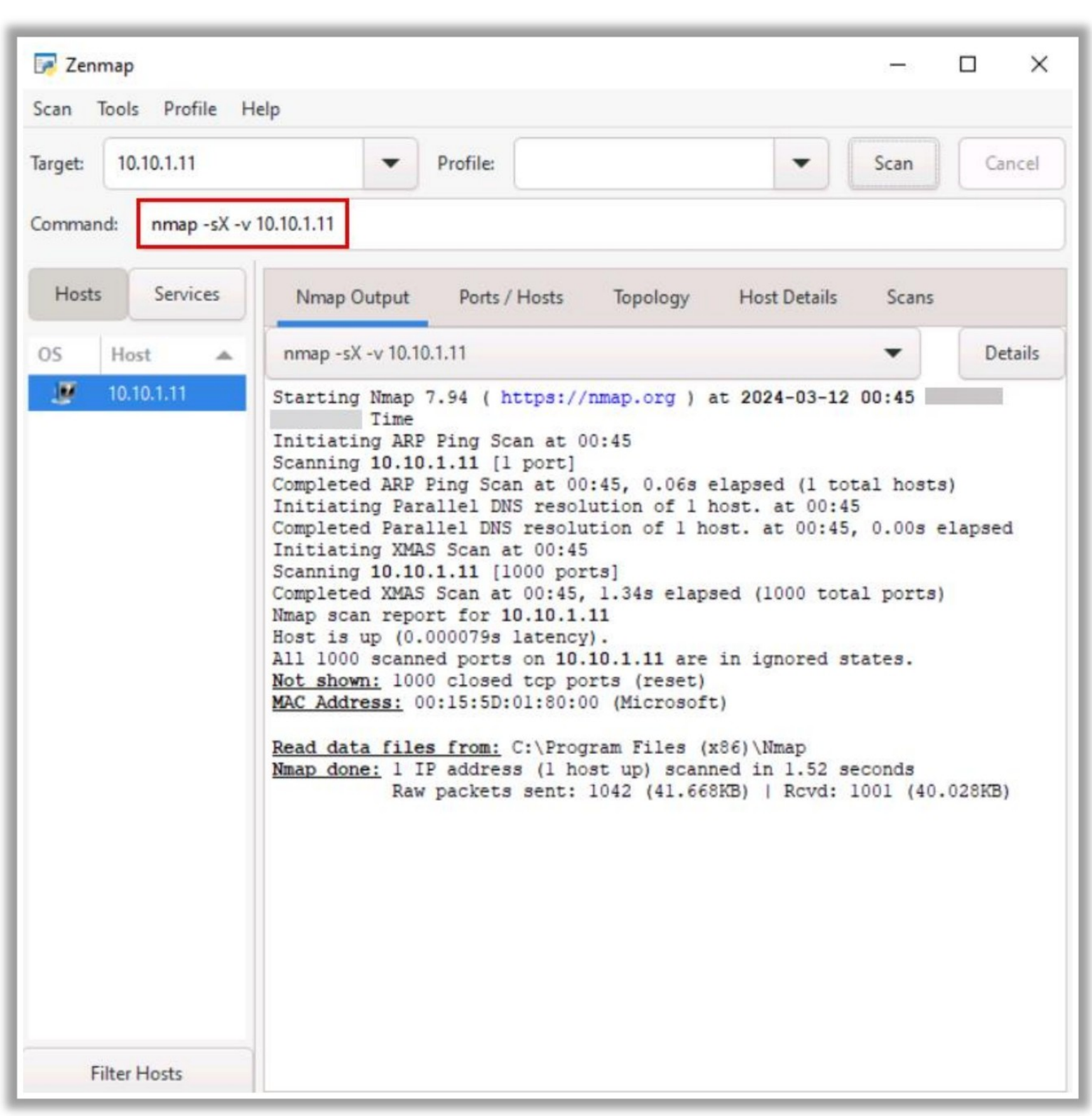


Figure 3.48: Xmas scan output using Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

TCP Maimon Scan

This scan technique is very similar to NULL, FIN, and Xmas scan, but the probe used here is FIN/ACK. In most cases, to determine if the port is open or closed, the RST packet should be generated as a response to a probe request. However, in many BSD systems, the port is open if the packet gets dropped in response to a probe.

Nmap interprets a port as open|filtered when there is no response from the Maimon scan probe even after many retransmissions. The port is closed if the probe gets a response as an RST packet. The port is filtered when the ICMP unreachable error (type 3, code 1, 2, 3, 9, 10, or 13) is returned from the target host. In Zenmap, the **-sM** option is used to perform the TCP Maimon scan.

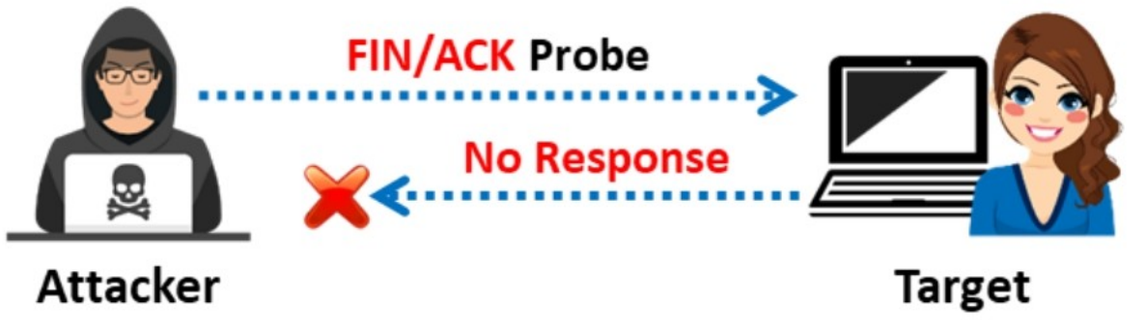


Figure 3.49: TCP Maimon scan result of open port

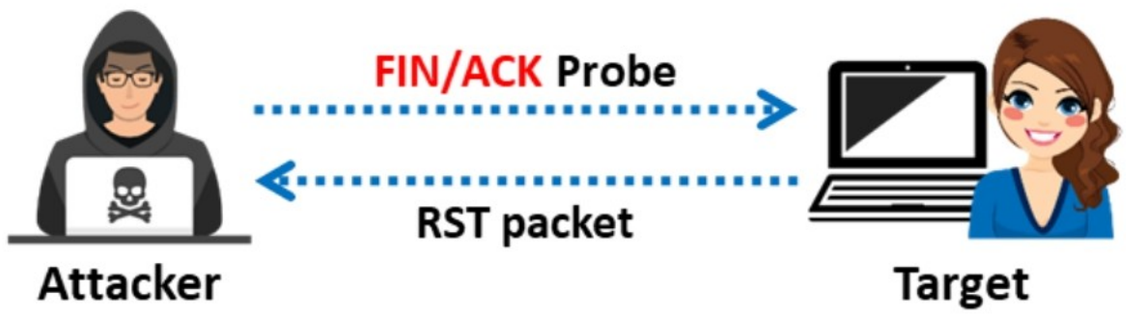


Figure 3.50: TCP Maimon scan result of closed port

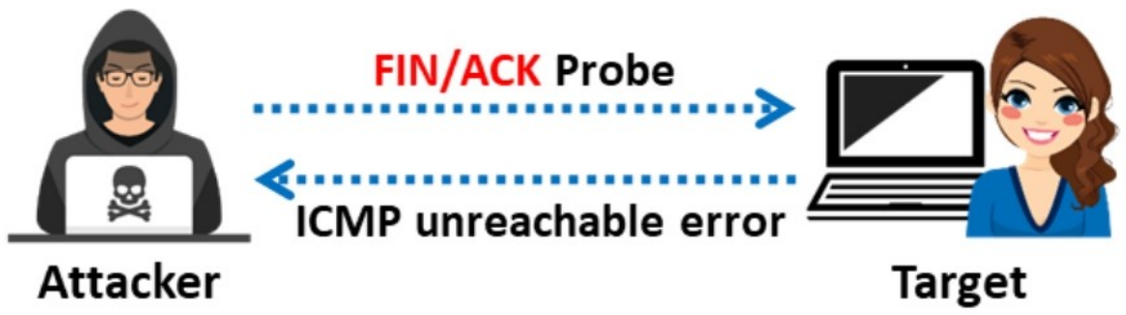


Figure 3.51: TCP Maimon scan result of filtered port

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

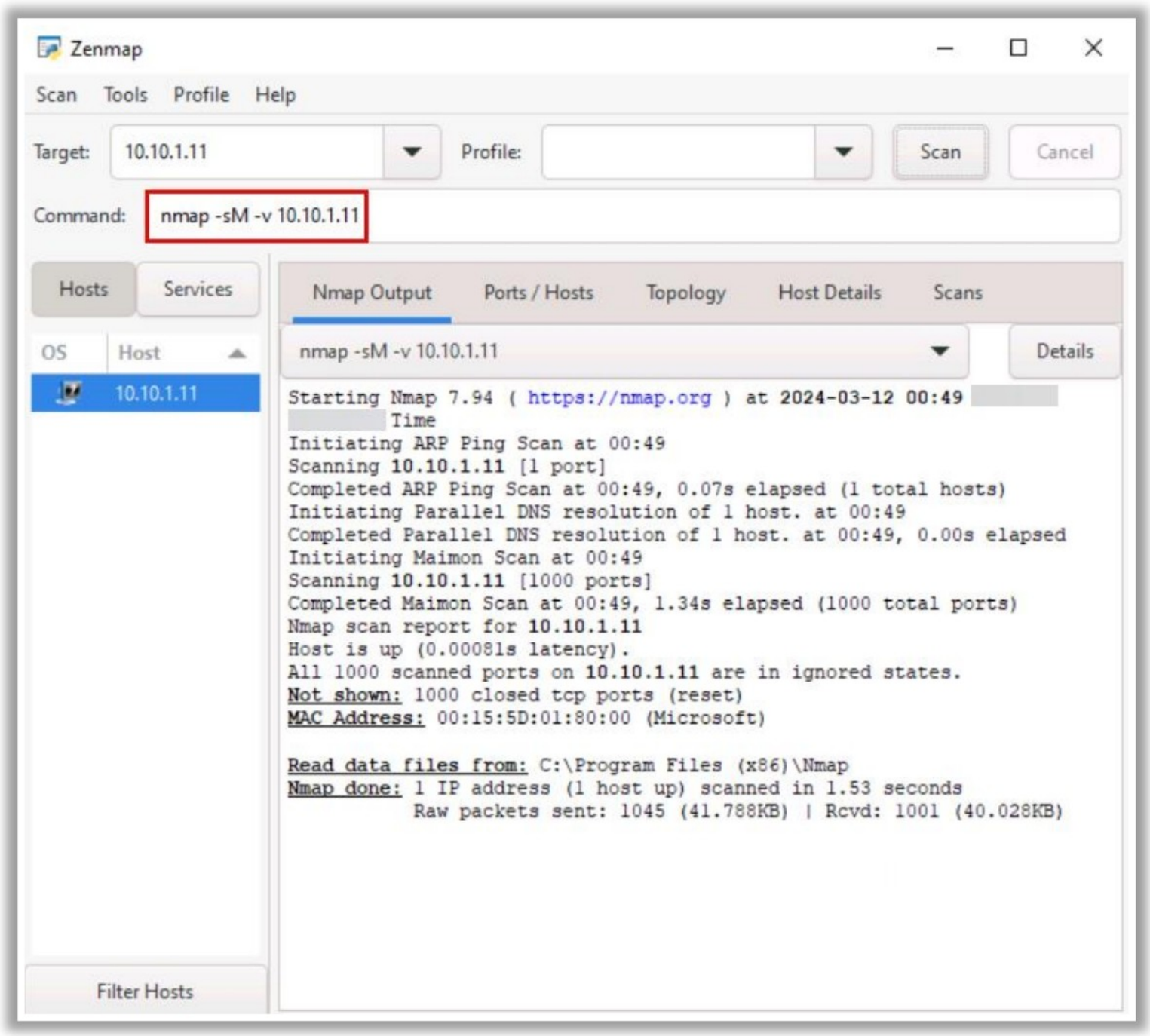


Figure 3.52: TCP Maimon scan displaying port state in Zenmap

ACK Flag Probe Scan

Attackers send TCP probe packets with the ACK flag set to a remote device and then analyze the header information (TTL and WINDOW field) of the received RST packets to find out if the port is open or closed. The ACK flag probe scan exploits the vulnerabilities within the BSD-derived TCP/IP stack. Thus, such scanning is effective only on those OSs and platforms on which the BSD derives TCP/IP stacks.

Categories of ACK flag probe scanning include:

- **TTL-Based ACK Flag Probe scanning**

  In this scanning technique, you will first need to send ACK probe packets (several thousands) to different TCP ports and then analyze the TTL field value of the RST packets received. In Zenmap, the syntax **`nmap –ttl [time] [target]`** is used to perform TTL-based scan.

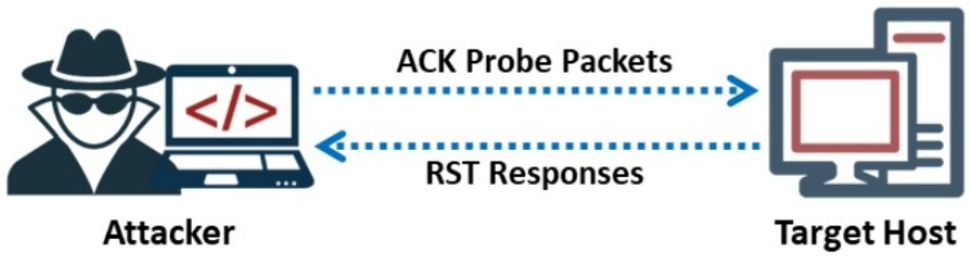


Figure 3.53: TTL-based ACK flag probe scanning

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

If the TTL value of the RST packet on a particular port is less than the boundary value of 64, then that port is open. An example showing a log of the first four RST packets received is presented below:

```
1: host 10.2.2.11 port 20: F:RST -> tt1: 80 win: 0
2: host 10.2.2.11 port 21: F:RST -> tt1: 80 win: 0
3: host 10.2.2.11 port 22: F:RST -> tt1: 50 win: 0
4: host 10.2.2.11 port 23: F:RST -> tt1: 80 win: 0
```

Figure 3.54: Screenshot showing the open port based on the TTL value of the RST packet

In this example, port 22 returned a TTL value of 50, which is less than 64; all other ports returned a TTL value of 80, which is greater than 64. Therefore, port 22 is open.

- **Window-Based ACK Flag Probe scanning**

In this scanning technique, you will first need to send ACK probe packets (several thousands) to different TCP ports and then analyze the window field value of the received RST packets. The user can use this scanning technique when all the ports return the same TTL value. In Zenmap, the **`-sW`** option is used to perform a window scan.

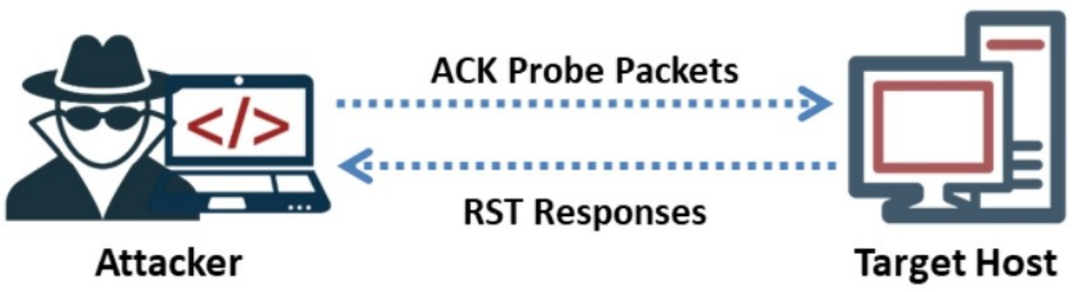


Figure 3.55: Window-based ACK flag probe scanning

If the window value of the RST packet on a particular port is non-zero, then that port is open. An example showing a log of the first four RST packets received is presented below:

```
1: host 10.2.2.12 port 20: F:RST -> tt1: 64 win: 0
2: host 10.2.2.12 port 21: F:RST -> tt1: 64 win: 0
3: host 10.2.2.12 port 22: F:RST -> tt1: 64 win: 512
4: host 10.2.2.12 port 23: F:RST -> tt1: 64 win: 0
```

Figure 3.56: Screenshot showing the open port based on the window value of the RST packet

The above figure shows that the TTL value returned for each packet is the same; hence, you cannot perform TTL-based ACK flag probe scanning to find the open ports. Therefore, when you observe the window value, the third packet has a non-zero window value, which means that the port is open. When the returned RST value is zero, then the port is closed. If there is no response even after many retransmissions and an ICMP unreachable error (type 3, code 1, 2, 3, 9, 10, or 13) is returned, then the port is inferred to be a filtered port.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

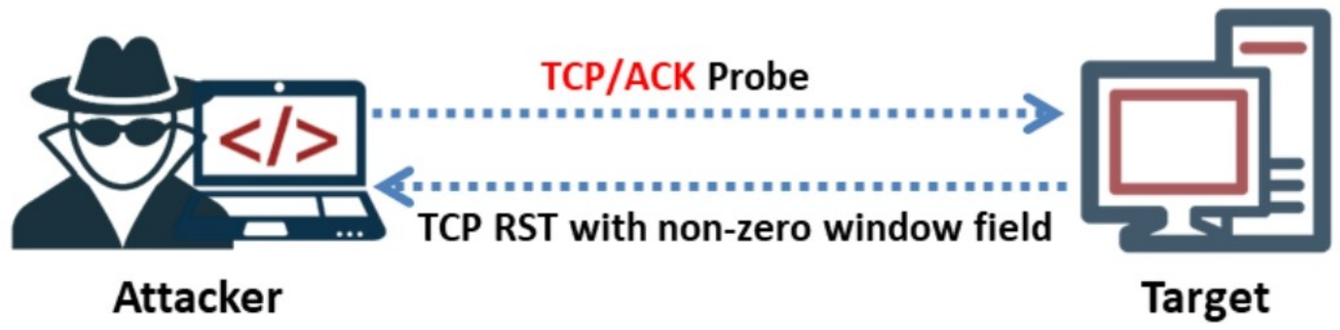


Figure 3.57: TCP Window scan result of an open port

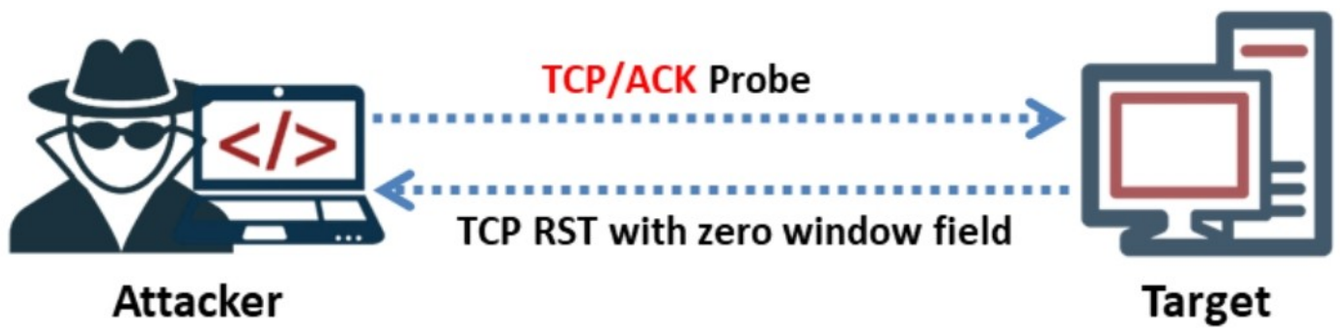


Figure 3.58: TCP Window scan result of a closed port

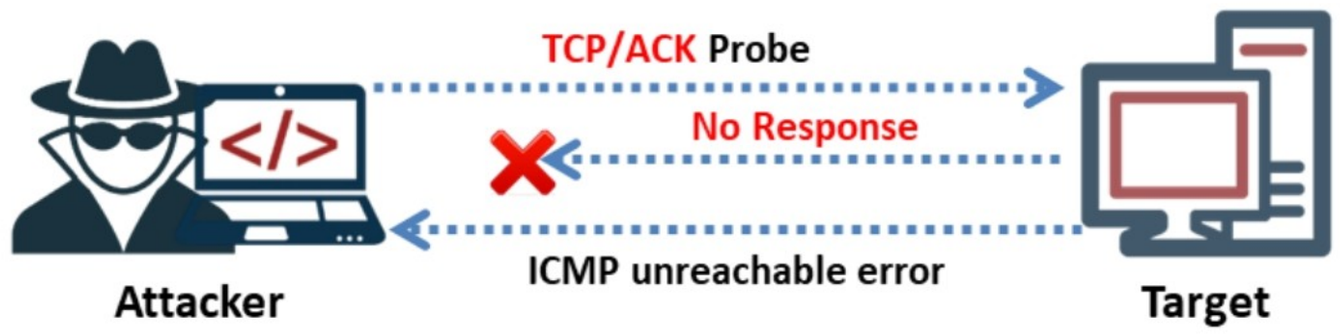


Figure 3.59: TCP Window scan result of a filtered port

Advantages:

- This type of scan can evade IDS in most cases.

Disadvantages:

- It is extremely slow and can exploit only older OSs with vulnerable BSD-derived TCP/IP stacks.

Checking the Filtering Systems of Target Networks

The ACK flag probe scanning technique also helps in checking the filtering systems of target networks. The attacker sends an ACK probe packet to check the filtering mechanism (firewalls) of packets employed by the target network.

Sending an ACK probe packet with a random sequence number and getting no response from the target means that the port is filtered (stateful firewall is present); an RST response from the target means that the port is not filtered (no firewall is present).

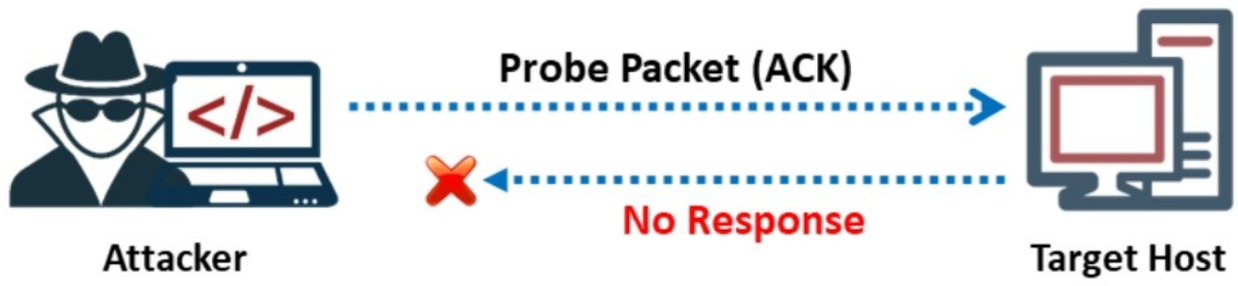


Figure 3.60: Stateful Firewall is present

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

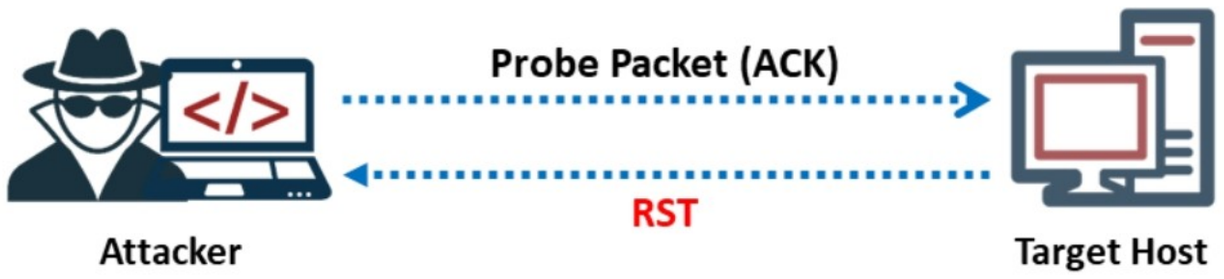


Figure 3.61: No Firewall

ACK Flag Probe Scanning using Nmap

In Zenmap, the **-sA** option is used to perform an ACK flag probe scan.

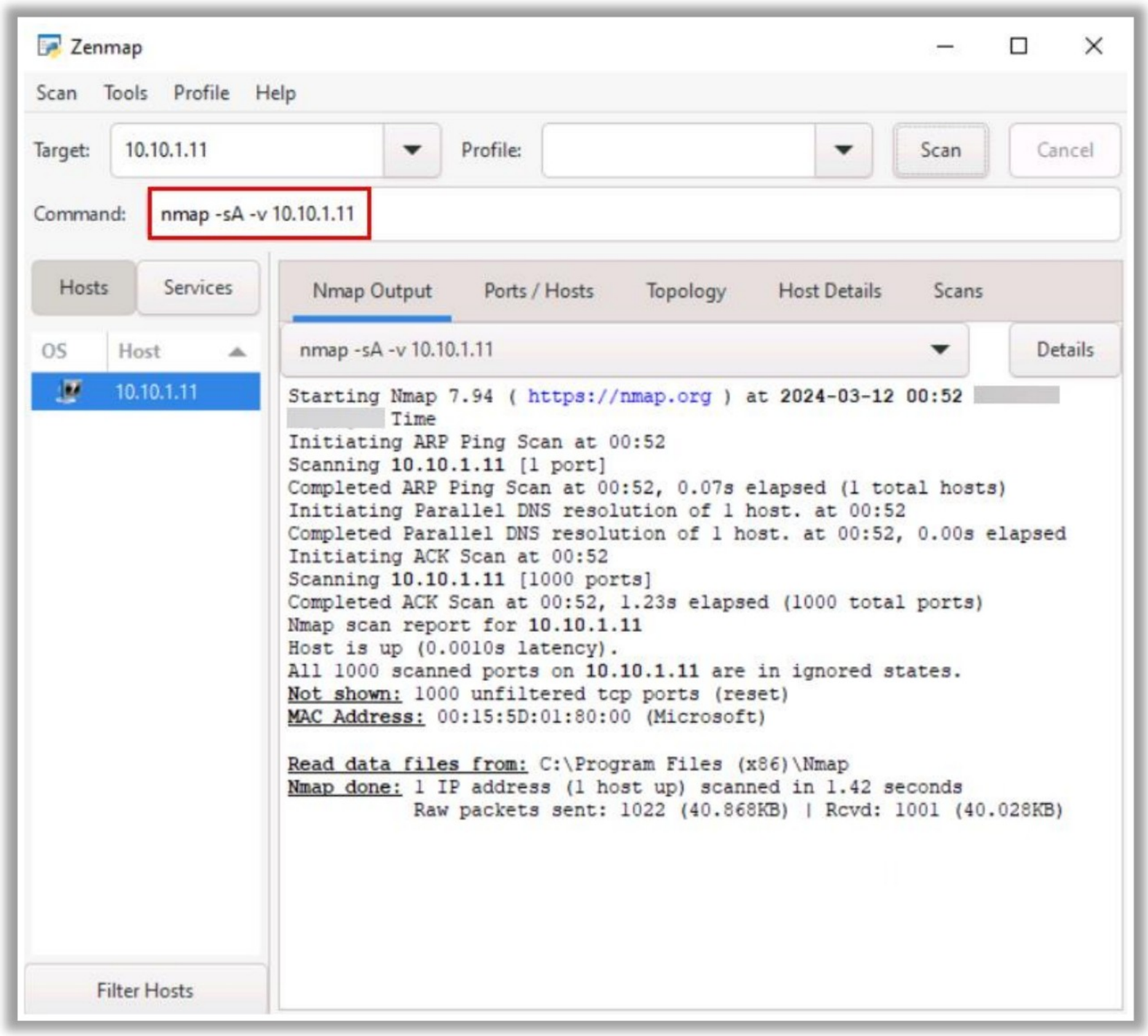


Figure 3.62: ACK Flag Probe scanning using Zenmap

IDLE/IPID Header Scan

The IDLE/IPID header scan is a TCP port scan method that can be used to send a spoofed source address to a computer to determine what services are available. It offers the complete blind scanning of a remote host. Most network servers listen on TCP ports; for example, web servers listen on port 80, and mail servers listen on port 25. A port is considered "open" if an application is listening on the port. One way to determine whether a port is open is to send a "SYN" (session establishment) packet to the port. The target machine returns a "SYN|ACK" (session request acknowledgement) packet if the port is open or an "RST" (reset) packet if the port is closed. A

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

machine that receives an unsolicited SYN|ACK packet responds with an RST. An unsolicited RST is ignored. Every IP packet on the Internet has an "IP identifier" (IPID) that uniquely identifies fragments of an original IP datagram. The OS increases the IPID for each packet sent. Thus, probing an IPID reveals to an attacker the number of packets sent since the last probe. In Zenmap, the **-sI** option is used to perform an IDLE scan.

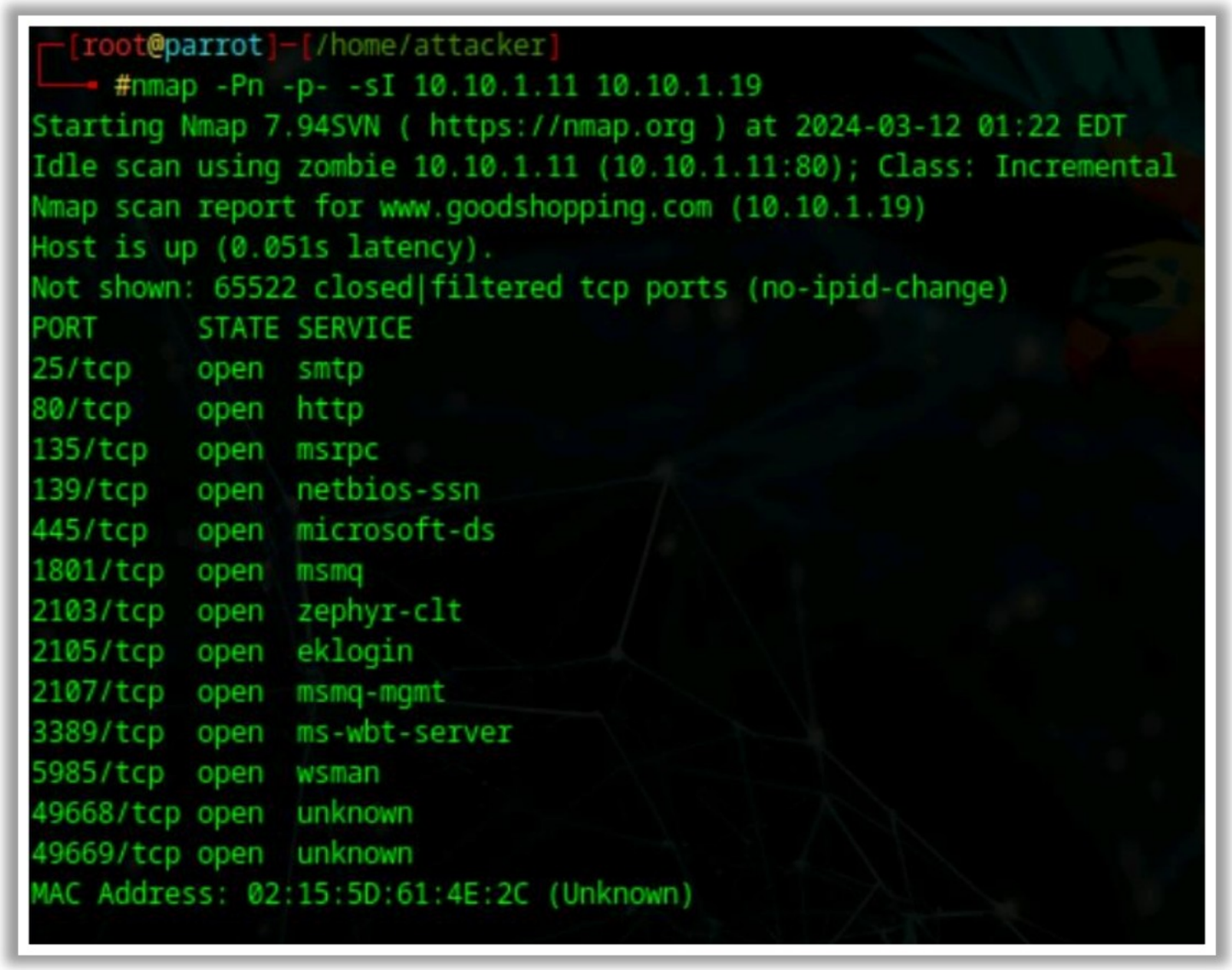


Figure 3.63: IDLE/IPID Header scan using Nmap

The attacker performs this scan by impersonating another computer via spoofing. The attacker does not send a packet from their IP address; instead, they use another host, often called a "zombie," to scan the remote host and identify open ports. In this attack, the attacker expects the sequence numbers of the zombie host, and if the remote host checks the IP of the scanning party, the IP of the zombie machine is displayed.

IDLE Scan

- **Step 1**

  The first step in an idle scan is to determine an appropriate zombie. A zombie that incrementally assigns IPID packets on a global basis is an appropriate or idle zombie for performing idle scans. The shorter the time interval for request/response between the attacker-zombie and zombie-target, the faster is the scan.

  Choose a "Zombie" and Probe Its Current IP Identification (IPID) Number

  In the first step, the SYN+ACK packet is sent to the zombie machine to probe its IPID number. Here, the SYN+ACK packet is sent to probe the IPID number and not to establish a TCP connection (three-way handshake).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

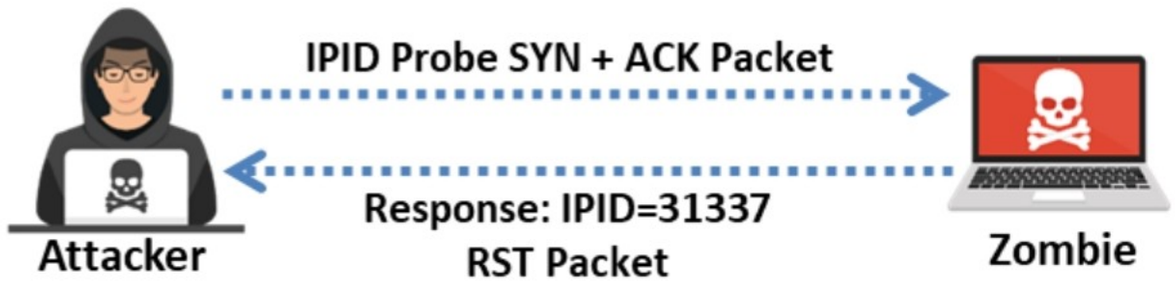


Figure 3.64: IDLE scan: step 1

As the zombie does not expect a SYN+ACK packet, it denies the connection by returning an RST packet. The RST packet sent by the zombie machine is analyzed to extract the IPID. As shown in figure, we assume that the zombie responds with **`IPID=31337`**. Furthermore, we assume that the IPID is X.

- **Step 2**

The attacker sends a SYN packet to the target machine on port 80, spoofing the IP address of the zombie.

Idle Scan: Step 2.1 (Open Port)

If the port is open, the target sends the SYN+ACK packet to the zombie (as the IP address was spoofed) to proceed with the three-way handshake. Because the zombie did not expect a SYN+ACK packet from the target machine, it responds with an RST packet.

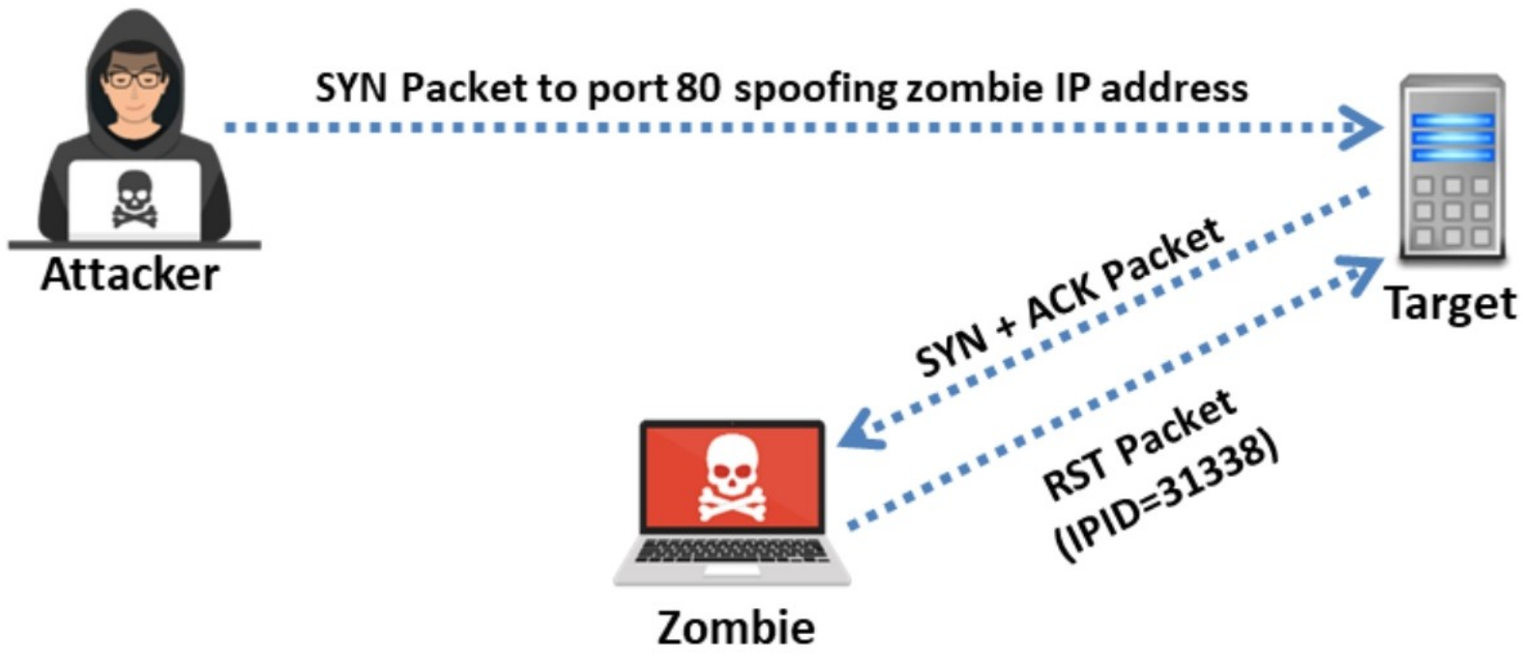


Figure 3.65: Port is open

Because every IP packet has an IPID, which increases by one for every packet transmission, the zombie now uses the next available IPID, i.e., 31338 (X + 1).

Idle Scan: Step 2.2 (Closed Port)

Assume that the port on the target is closed. Subsequently, upon receiving the SYN packet from the attacker, the target responds with an RST packet, and the zombie remains idle thereafter.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

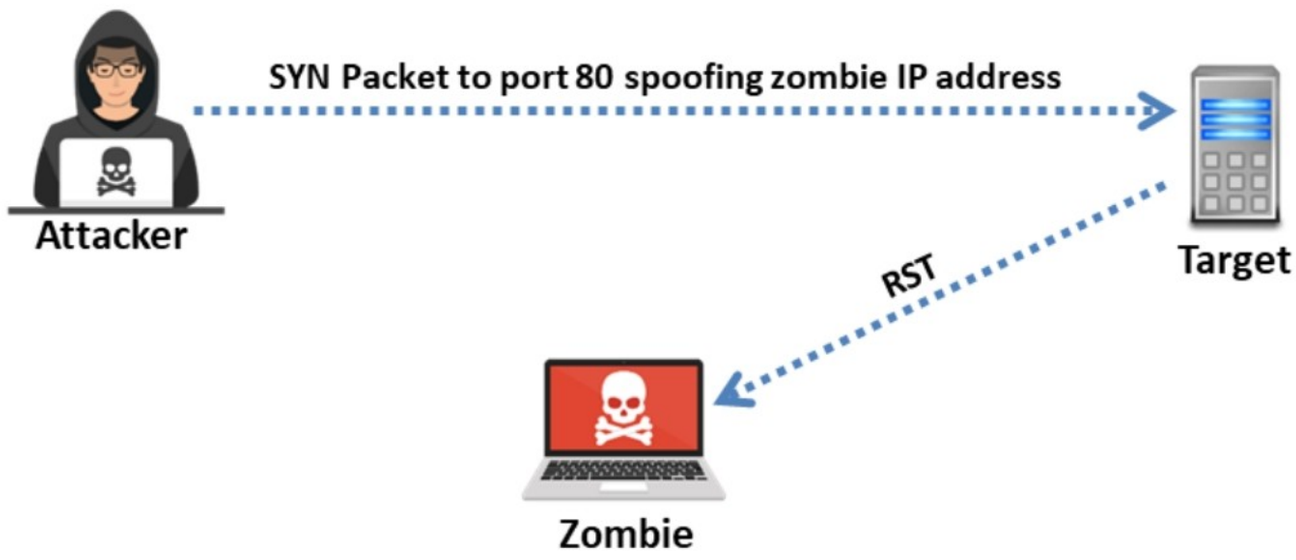


Figure 3.66: Port is closed

- **Step 3**

  Now, follow step 1 again to probe the IPID number.

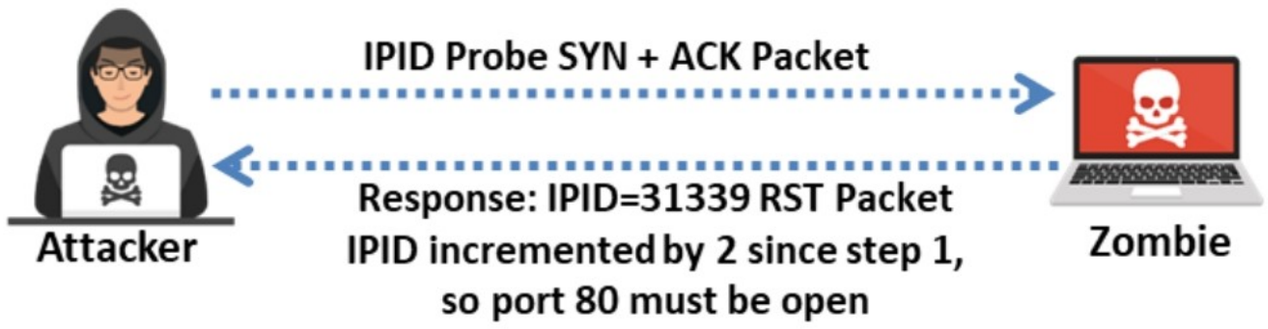


Figure 3.67: Idle scan: step 3

  Send a SYN+ACK packet to the zombie, and it responds with an RST packet containing the IPID. Assuming that the port on the target was open and that the zombie has already sent an RST packet to the target, the IPID number is increased by 1. Now, the zombie responds with an RST packet to the attacker using its next IPID, i.e., 31339 (X + 2). Consequently, the IPID is increased by 2, which implies that the port on the target machine was open. Thus, using an idle scan, an attacker can identify the open ports and services on the target machine by spoofing their IP address with a zombie's IP address.

UDP Scan

UDP Raw ICMP Port Unreachable Scanning

UDP port scanners use the UDP protocol instead of TCP. There is no three-way handshake for the UDP scan. The UDP protocol can be more challenging to use than TCP scanning because you can send a packet but you cannot determine whether the host is alive, dead, or filtered. However, you can use one ICMP that checks for open or closed ports. If you send a UDP packet to a port without an application bound to it, the IP stack will return an ICMP port unreachable packet. If any port returns an ICMP error, it will be closed, leaving the ports that did not answer if they are open or filtered through the firewall.

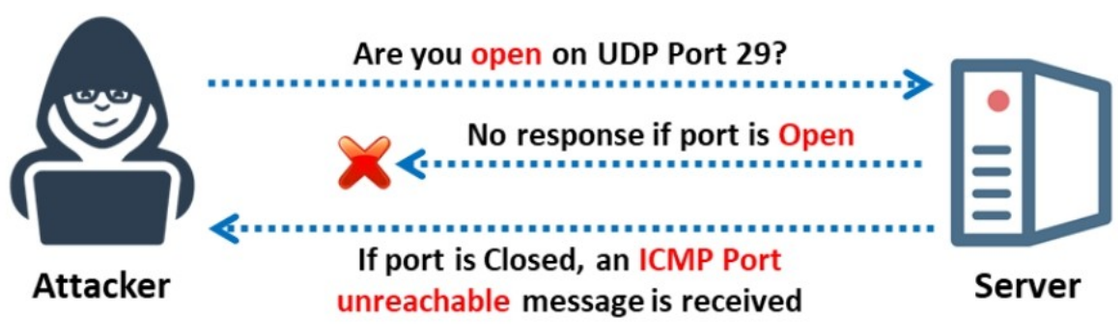


Figure 3.68: UDP scanning

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This happens because open ports do not have to send an acknowledgement in response to a probe, and closed ports are not even required to send an error packet.

UDP Packets

Source: *https://nmap.org*

When you send a packet to a closed UDP port, most of the hosts send an **ICMP_PORT_UNREACH** error. Thus, you can determine whether a port is open if UDP packets or ICMP errors are not guaranteed to arrive. Thus, UDP scanners of this type must implement retransmission of packets that appear lost. UDP scanners interpret lost traffic as open ports. In Zenmap, the **-sU** option is used to perform a UDP scan.

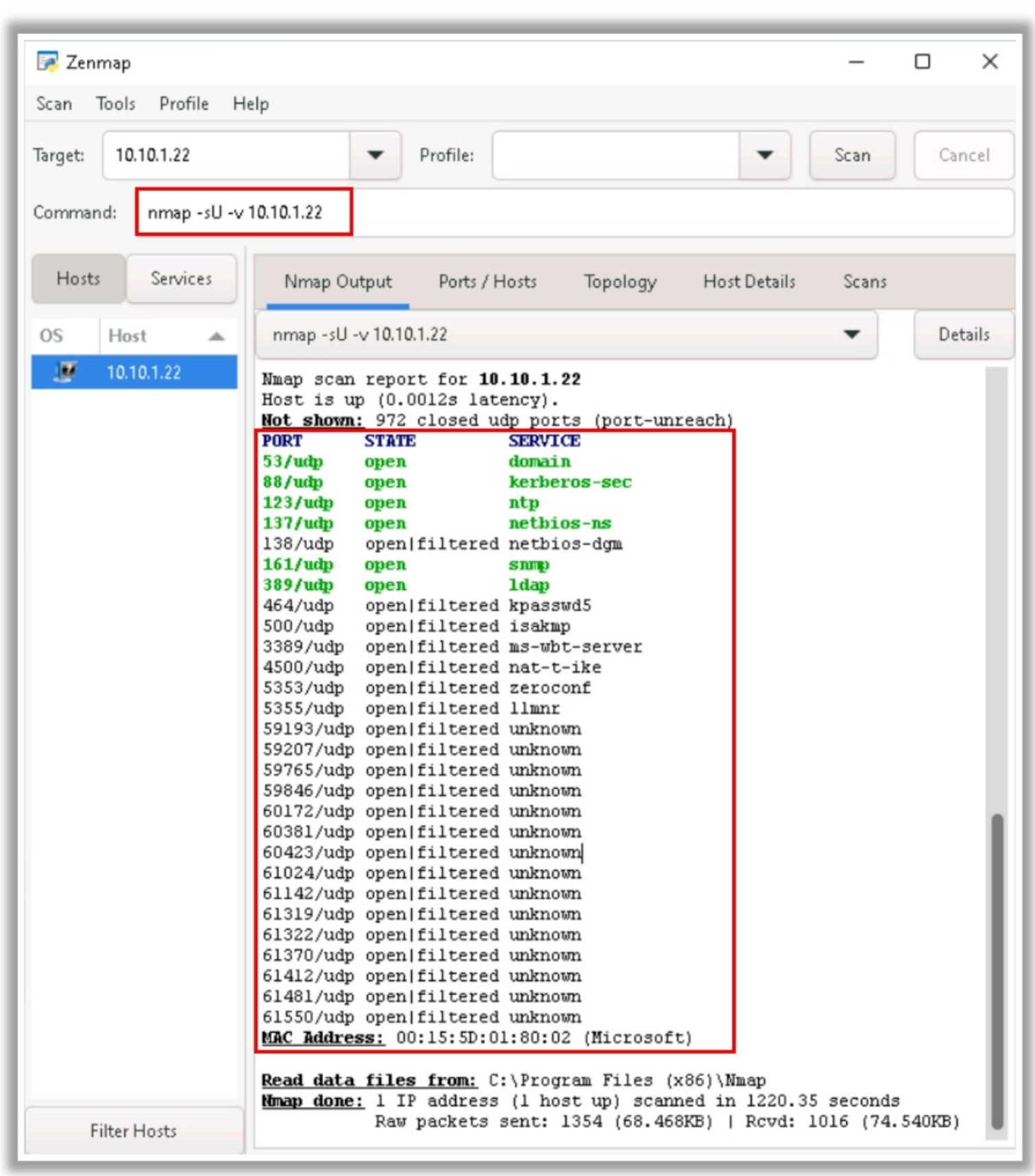


Figure 3.69: UDP scanning using Zenmap

In addition, this scanning technique is slow because it limits the ICMP error message rate as a form of compensation to machines that apply RFC 1812 section 4.3.2.8. A remote host will require access to the raw ICMP socket to distinguish closed ports from unreachable ports.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

UDP RECVFROM () and WRITE () Scanning

Although non-root users cannot read unreachable port errors directly, Linux informs you indirectly when it receives messages.

- **Example:**

  For example, a second **`write ()`** call to a closed port will usually fail. Various scanners, such as Netcat and Pluvial **`pscan.c`**, perform **`recvfrom ()`** on non-blocking UDP sockets, and they usually return **`EAGAIN`** ("**`Try Again`**," **`errno 13`**) if the ICMP error has not been received or **`ECONNREFUSED`** ("**`Connection refused`**," **`errno 111`**) otherwise. This technique is used for determining open ports when non-root users use **`-u`** (UDP). Root users can also use the **`-l`** (lamer UDP scan) option to force this process.

Advantage:

The UDP scan is less informal with regard to an open port because there is no overhead of a TCP handshake. However, if ICMP is responding to each unavailable port, the total number of frames can exceed that from a TCP scan. Microsoft-based OSs do not usually implement any ICMP rate limiting; hence, this scan operates very efficiently on Windows-based devices.

Disadvantage:

The UDP scan provides port information only. If additional information of the version is needed, the scan must be supplemented with a version detection scan **`(-sV`**) or the OS fingerprinting option (**`-O`**).

The UDP scan requires privileged access; hence, this scan option is only available on systems with the appropriate user permissions.

Most networks have massive amounts of TCP traffic; as a result, the efficiency of the UDP scan is low. The UDP scan will locate open ports and provide the security manager with valuable information for identifying successful attacker invasions on open UDP ports owing to spyware applications, Trojan horses, and other malicious software.

SCTP INIT Scan

Stream Control Transport Protocol (SCTP) is a reliable message-oriented transport layer protocol. It is used as an alternative to the TCP and UDP protocols, as its characteristics are similar to those of TCP and UDP. SCTP is specifically used to perform multi-homing and multi-streaming activities. Some SCTP applications include discovering VoIP, IP telephony, and Signaling System 7/SIGnaling TRANsport (SS7/SIGTRAN)-related services. SCTP association comprises a four-way handshake method, as shown in the screenshot below.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

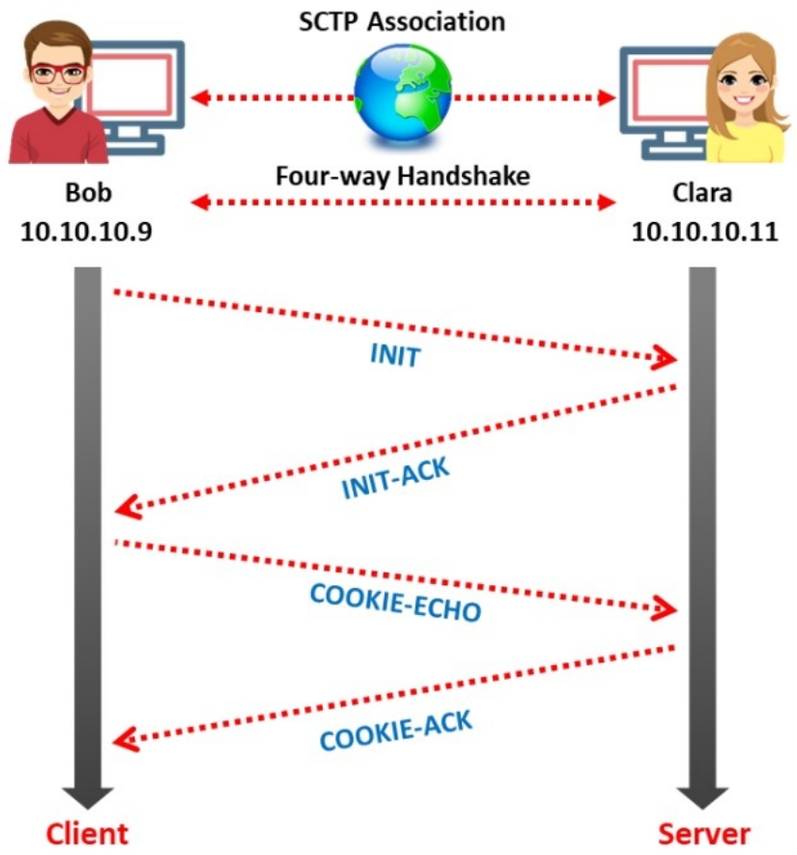


Figure 3.70: SCTP Association four-way handshake

In SCTP, the INIT scan is performed quickly by scanning thousands of ports per second on a fast network not obstructed by a firewall offering a stronger sense of security. The SCTP INIT scan is very similar to the TCP SYN scan; comparatively, it is also stealthy and unobtrusive, as it cannot complete SCTP associations, hence making the connection half-open.

Attackers send INIT chunk to the target host. If the port is listening or open, it sends an acknowledgement as an INIT+ACK chunk.

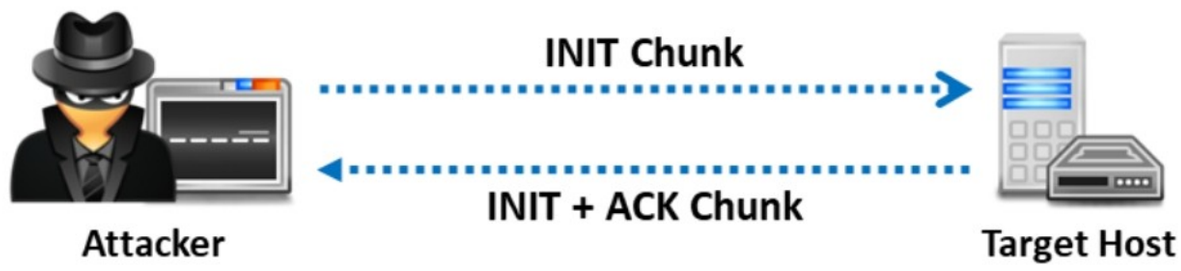


Figure 3.71: SCTP INIT scan result when a port is listening (Open)

If the target is inactive and it is not listening, then it sends an acknowledgement as an ABORT chunk.

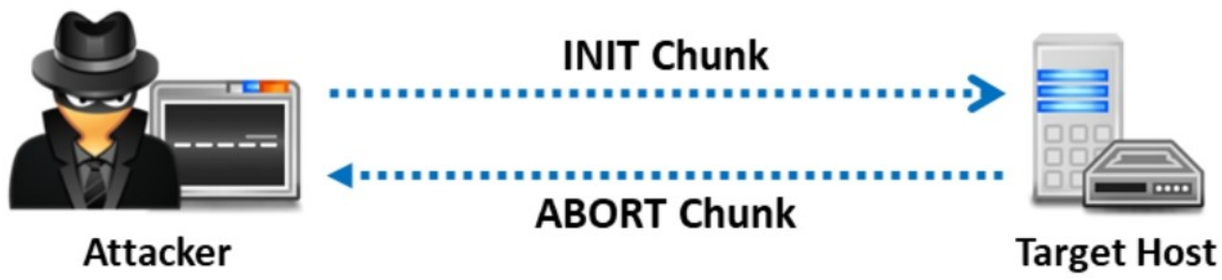


Figure 3.72: SCTP INIT scan result when a port is not listening (Closed)

After several retransmissions, if there is no response, then the port is indicated as a filtered port. The port is also indicated as a filtered port if the target server responds with an ICMP unreachable exception (type 3, code 0, 1, 2, 3, 9, 10, or 13). In Zenmap, the **`-sY`** option is used to perform the SCTP INIT scan.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Advantages:

- INIT scan can clearly differentiate between various ports such as open, closed, and filtered states

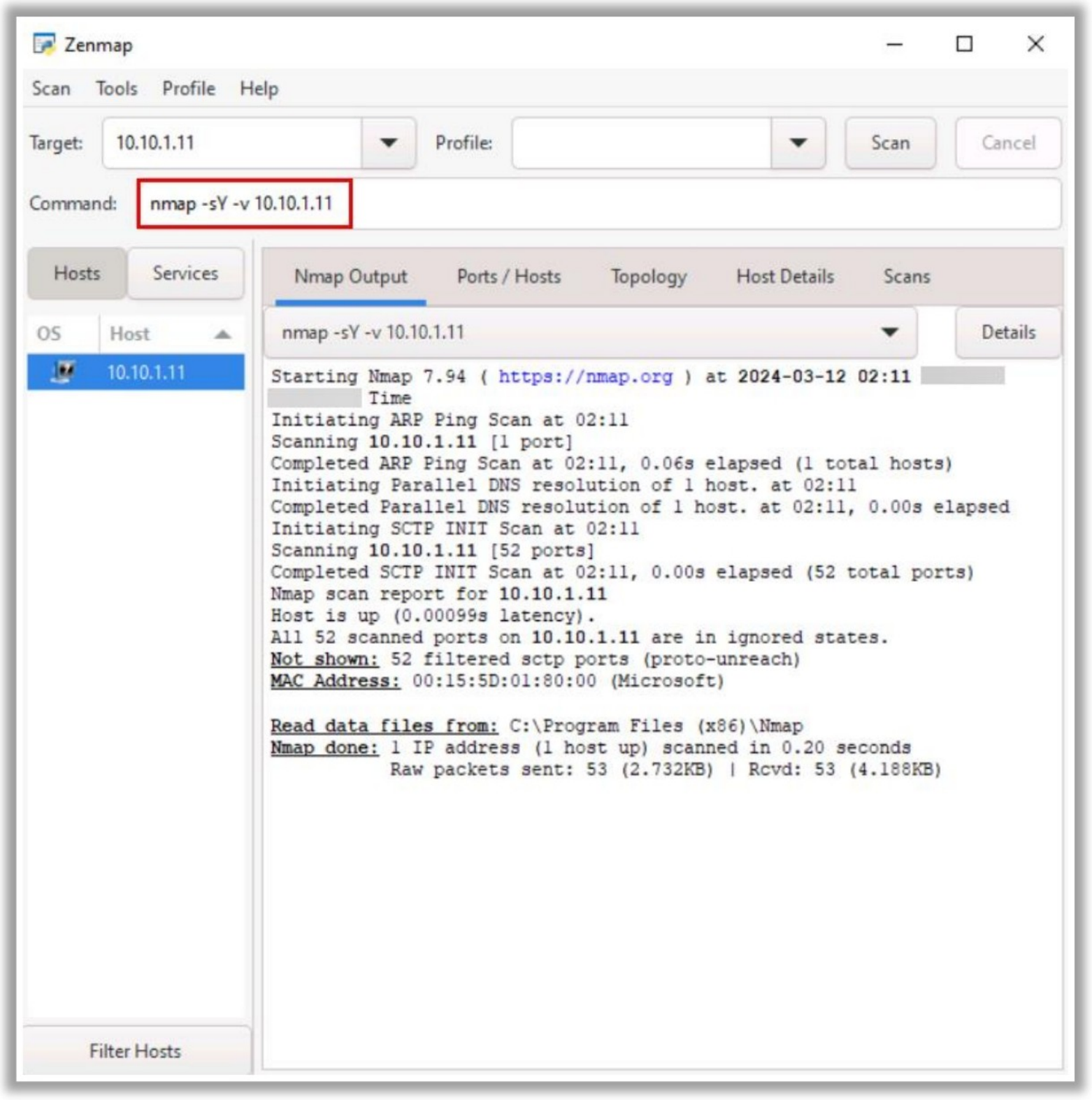


Figure 3.73: SCTP INIT scan in Zenmap

SCTP COOKIE ECHO Scan

SCTP COOKIE ECHO scan is a more advanced type of scan. In this type of scan, attackers send the COOKIE ECHO chunk to the target, and if the target port is open, it will silently drop the packets onto the port and you will not receive any response from the target. If the target sends back the ABORT chunk response, then the port is considered as a closed port. The COOKIE ECHO chunk is not blocked by non-stateful firewall rule sets as in the INIT scan. Only an advanced IDS can detect the SCTP COOKIE ECHO scan. In Zenmap, the **`-sZ`** option is used to perform the SCTP COOKIE ECHO scan.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

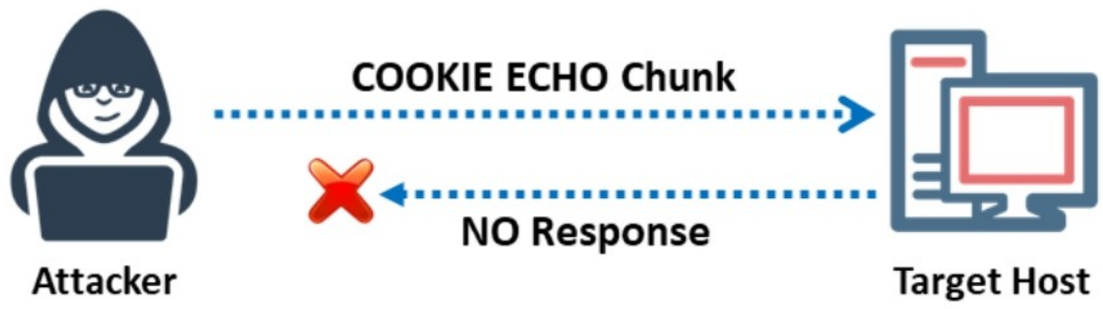


Figure 3.74: SCTP COOKIE ECHO scan result when port is open

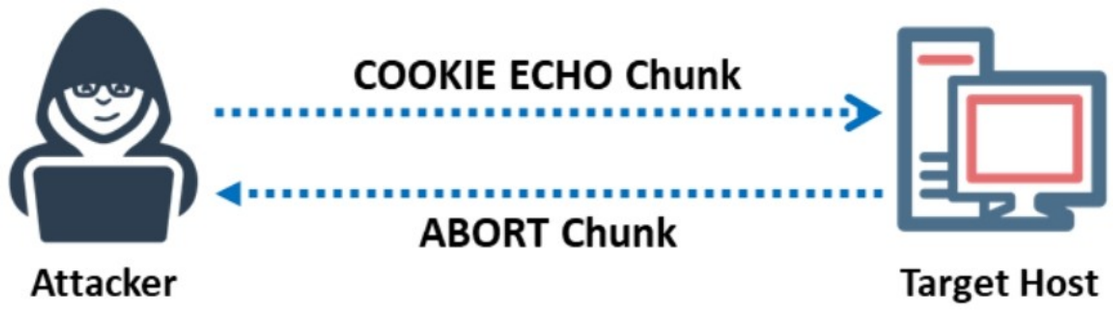


Figure 3.75: SCTP COOKIE ECHO scan result when port is closed

Advantages:

- The port scan is not as conspicuous as the INIT scan.

Disadvantages:

- SCTP COOKIE ECHO scan cannot differentiate clearly between open and filtered ports, and it shows the output as open|filtered in both cases.

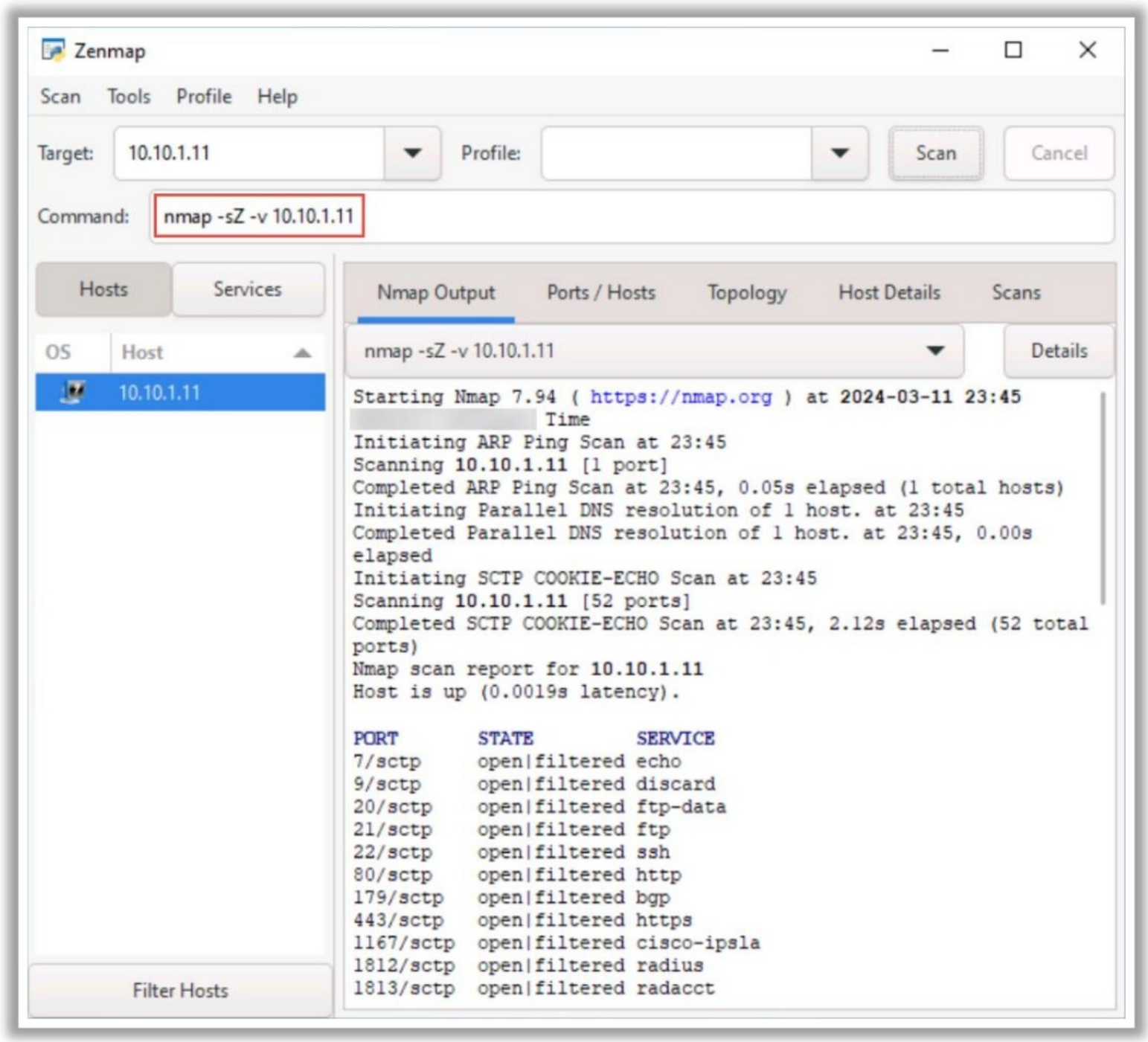


Figure 3.76: SCTP COOKIE-ECHO scan in Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

SSDP and List Scan

SSDP Scan

Simple Service Discovery Protocol (SSDP) is a network protocol that generally communicates with machines when querying them with routable IPv4 or IPv6 multicast addresses. The SSDP service controls communication for the Universal Plug and Play (UPnP) feature. It generally works when the machine is not firewalled; however, it can sometimes work through a firewall. The SSDP service will respond to a query sent over IPv4 or IPv6 broadcast addresses. This response includes information about the UPnP feature associated with it. The attacker uses SSDP scanning to detect UPnP vulnerabilities that may allow him/her to launch buffer overflow or DoS attacks.

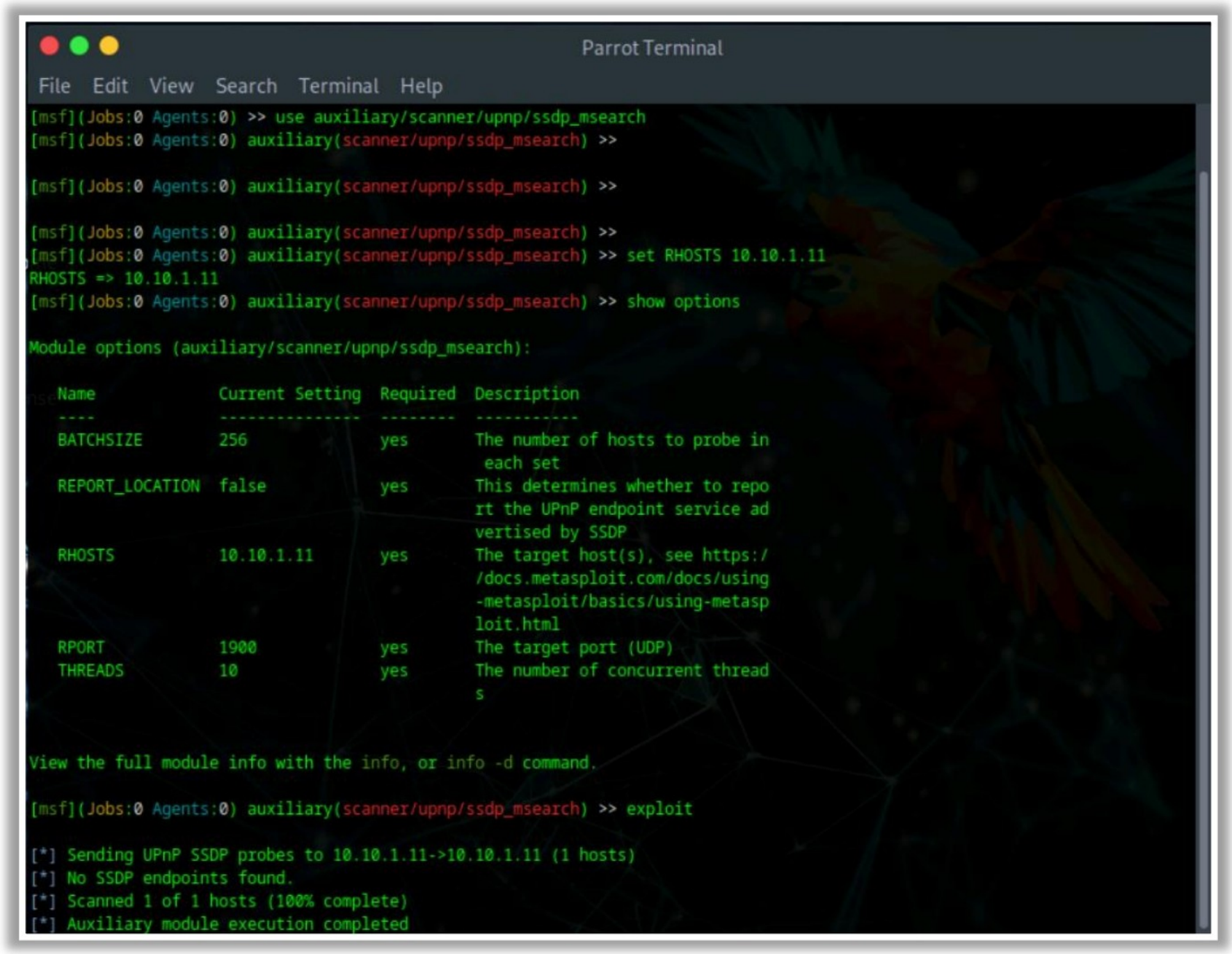


Figure 3.77: UPnP SSDP M-SEARCH in Parrot Security

The attacker may use the UPnP SSDP M-SEARCH information discovery tool to check whether the machine is vulnerable to UPnP exploits. The UPnP SSDP M-SEARCH information discovery tool gleans information from UPnP-enabled systems, as shown in the figure.

List Scan

In a list scan, the discovery of the active network host is indirect. A list scan simply generates and prints a list of IPs/Names without actually pinging or scanning the hosts. As a result, the list scan shows all IP addresses as “not scanned” (0 hosts up). By default, a reverse DNS resolution is still

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

carried out on each host by Nmap to learn their names. In Zenmap, the **-sL** option is used to perform a list scan.

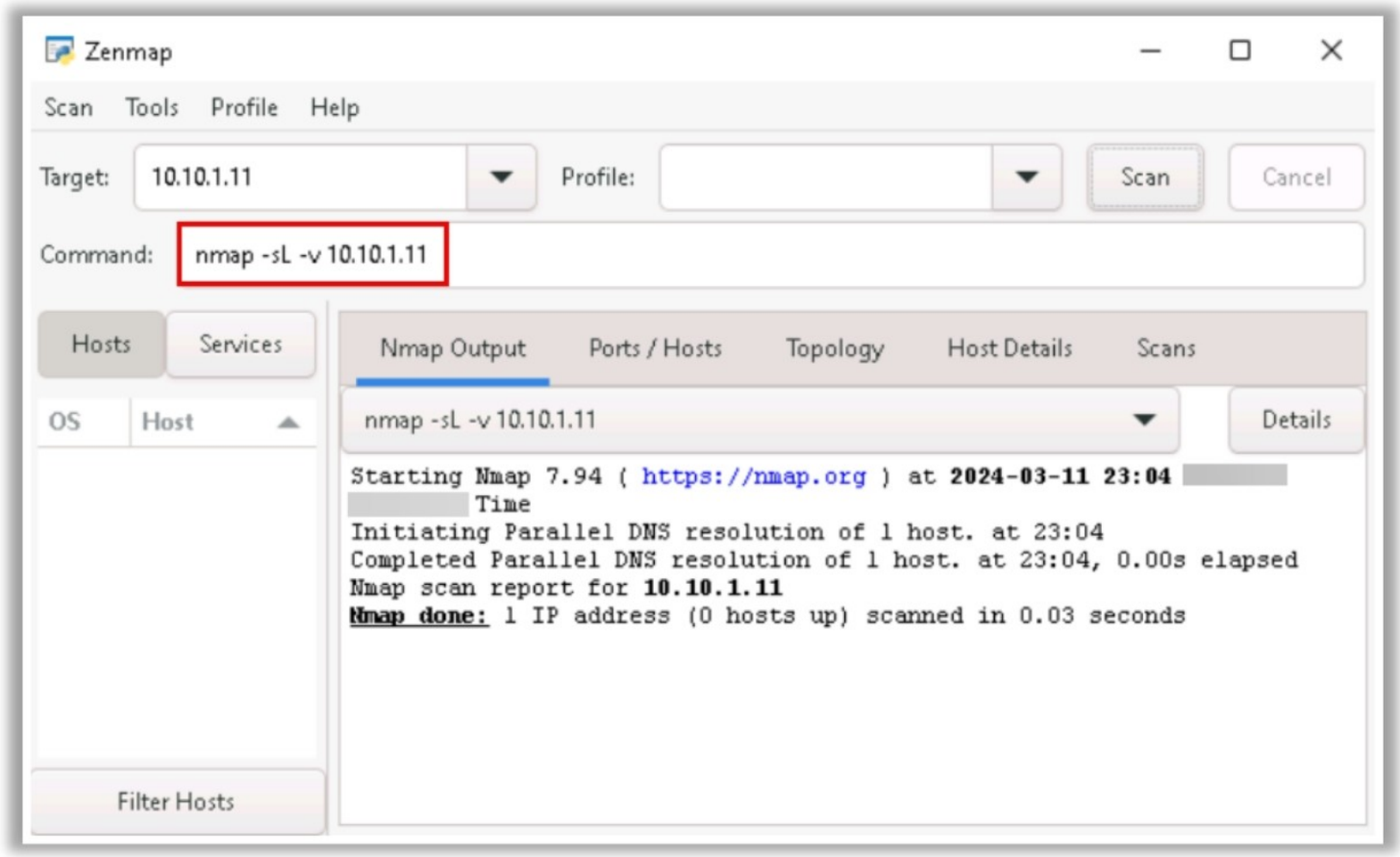


Figure 3.78: List scan using Zenmap

Advantages:

- A list scan can perform a good sanity check.
- The list scan detects incorrectly defined IP addresses in the command line or in an option file. It primarily repairs the detected errors to run any "active" scan.

IPv6 Scan

IPv6 increases the size of the IP address space from 32 bits to 128 bits to support higher levels of the addressing hierarchy. Traditional network scanning techniques are computationally less feasible because of the larger search space (64 bits of host address space, or 2^{64} addresses) provided by IPv6 in a subnet. Scanning the IPv6 network is more difficult and complex compared to IPv4. Additionally, a number of scanning tools do not support ping sweeps on IPv6 networks. Attackers need to harvest IPv6 addresses from network traffic, recorded logs, or "Received from" and other header lines in archived email or Usenet news messages to identify IPv6 addresses for subsequent port scanning. However, scanning an IPv6 network provides a large number of hosts in a subnet; if an attacker can compromise one subnet host, he/she can probe the "all hosts" link local multicast address if the hosts numbers are sequential or use any regular scheme. An attacker needs to analyze 2^{64} addresses to verify if a particular open service is running on a host in that subnet. At a conservative rate of one probe per second, such a scan would take about 5 billion years to complete. Attackers can use Nmap to perform IPv6 scanning. In Zenmap, the **-6** option is used to perform the IPv6 scan.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

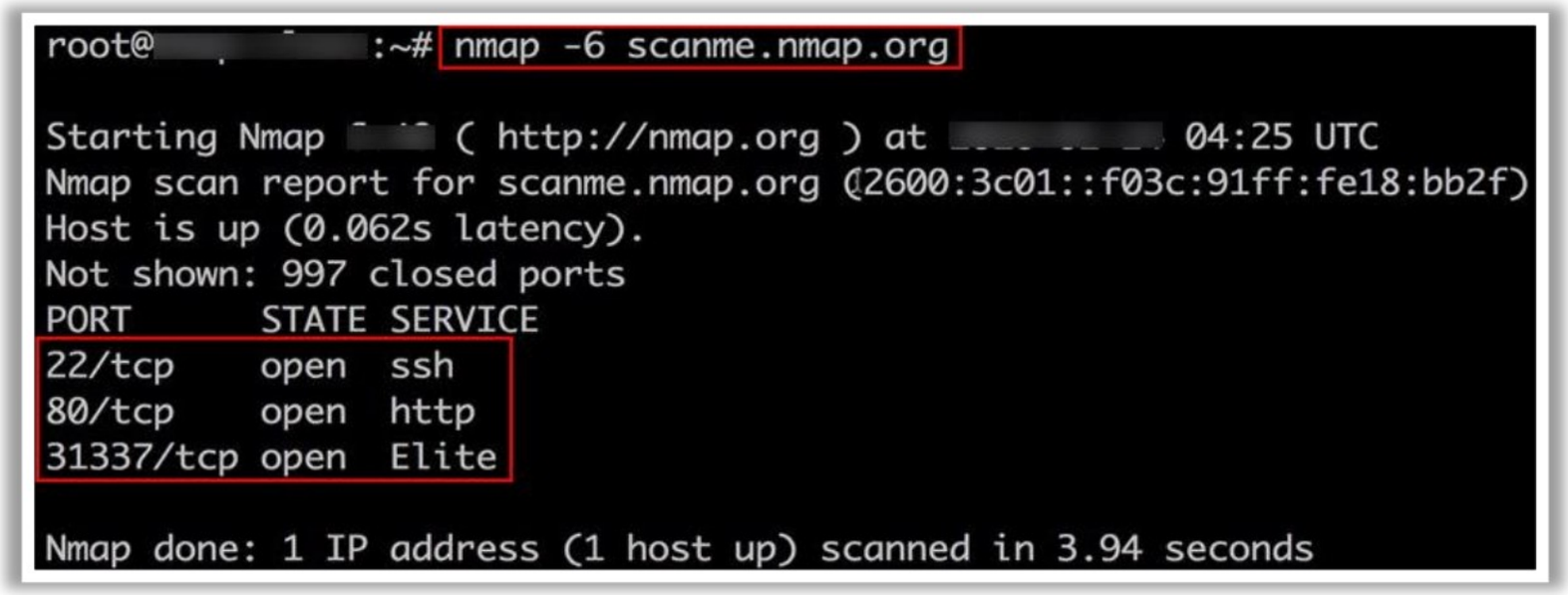


Figure 3.79: IPv6 Scan using nmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

13 Module 03 | Scanning Networks

EC-Council C|EH v13

Port Scanning with AI

An attacker can also leverage AI-powered ChatGPT or other generative AI technology to perform this task by using an appropriate prompt such as

- "*Use Nmap to find open ports on target IP 10.10.1.11*"
- *"Perform stealth scan on target IP 10.10.1.11 and display the results*"
- "*Perform an XMAS scan on target IP 10.10.1.11"*

```
┌─[attacker@parrot]─[~]
└──╼ $sgpt --chat sn --shell " Use Nmap to find open ports on target IP 10.10.1.11"
nmap 10.10.1.11
[E]xecute, [D]escribe, [A]bort: E
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-14 08:16 EDT
Nmap scan report for 10.10.1.11
Host is up (0.00076s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT     STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
```

```
┌─[root@parrot]─[/home/attacker]
└──╼ #sgpt --shell "Perform stealth scan on target IP 10.10.1.11 and display the results"
nmap -sS -Pn 10.10.1.11 && echo "Stealth scan completed on 10.10.1.11"
[E]xecute, [D]escribe, [A]bort: E
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-01 06:12 EDT
Nmap scan report for 10.10.1.11
Host is up (0.00066s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:15:5D:01:80:00 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 17.97 seconds
Stealth scan completed on 10.10.1.11
```

```
┌─[root@parrot]─[/home/attacker]
└──╼ #sgpt --shell "Perform an XMAS scan on target IP 10.10.1.11"
nmap -sX 10.10.1.11
[E]xecute, [D]escribe, [A]bort: E
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-01 06:22 EDT
Nmap scan report for 10.10.1.11
Host is up (0.00044s latency).
All 1000 scanned ports on 10.10.1.11 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 00:15:5D:01:80:00 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 1.52 seconds
```

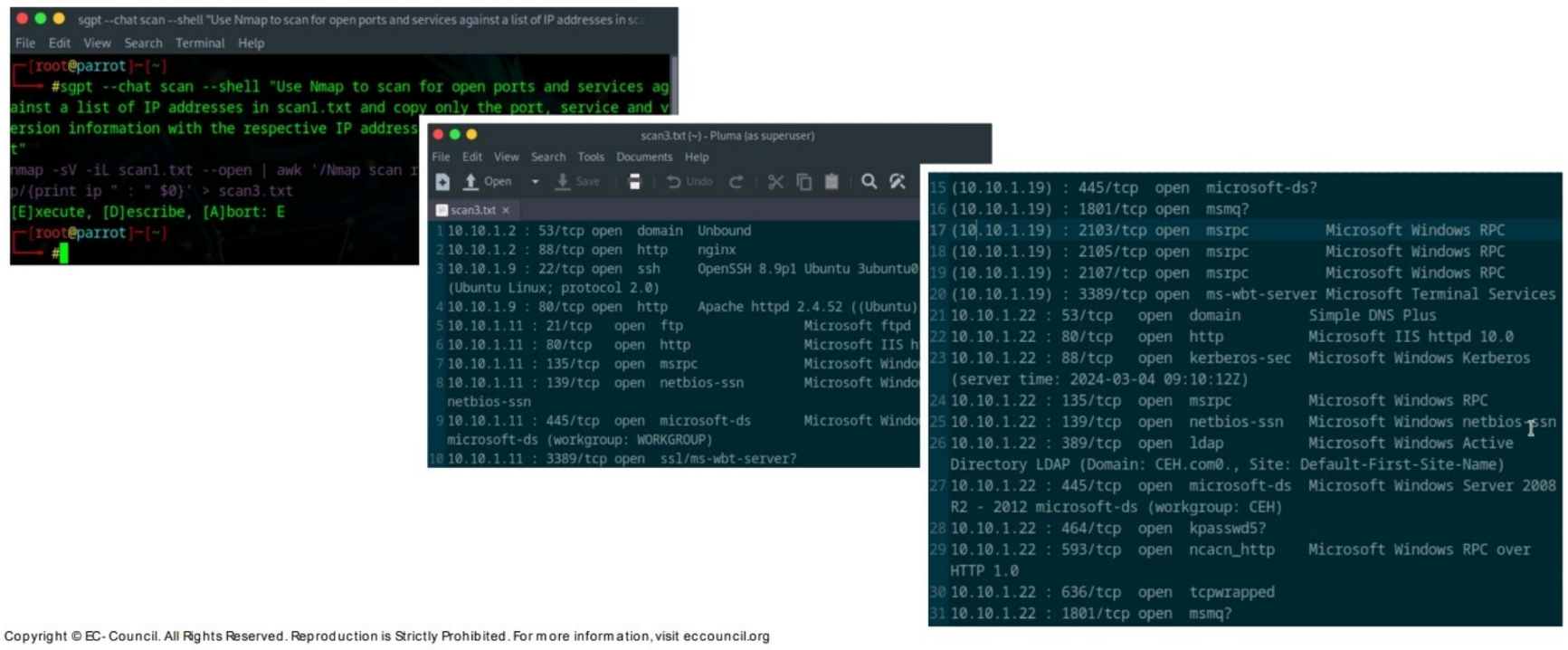
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

14 Module 03 | Scanning Networks

EC-Council C|EH v13

Port Scanning with AI (Cont'd)

- "Use Nmap to scan for open ports and services against a list of IP addresses in scan1.txt and copy only the port, service and version information with the respective IP address to a new file called scan3.txt"



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Port Scanning with AI

Attackers can leverage AI-powered technologies to enhance and automate port scanning tasks. With the aid of AI, attackers can effortlessly find out the open ports on a target network with the help of Nmap.

Example #1:

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

"Use Nmap to find open ports on target IP 10.10.1.11"

```
┌─[attacker@parrot]─[~]
└──╼ $sgpt --chat sn --shell " Use Nmap to find open ports on target IP 10.10.1.11"
nmap 10.10.1.11
[E]xecute, [D]escribe, [A]bort: E
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-14 08:16 EDT
Nmap scan report for 10.10.1.11
Host is up (0.00076s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT     STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
```

Figure 3.80: Nmap to find open ports on target IP

Example #2:

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Perform stealth scan on target IP 10.10.1.11 and display the results"

```
┌─[root@parrot]─[/home/attacker]
└──╼ #sgpt --shell "Perform stealth scan on target IP 10.10.1.11 and display the results"
nmap -sS -Pn 10.10.1.11 && echo "Stealth scan completed on 10.10.1.11"
[E]xecute, [D]escribe, [A]bort: E
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-01 06:12 EDT
Nmap scan report for 10.10.1.11
Host is up (0.00066s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:15:5D:01:80:00 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 17.97 seconds
Stealth scan completed on 10.10.1.11
```

Figure 3.81: Perform stealth scan on the target IP

Example #3:

An attacker can use AI to perform port scanning by using an appropriate prompt such as:

"Perform an XMAS scan on target IP 10.10.1.11"

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

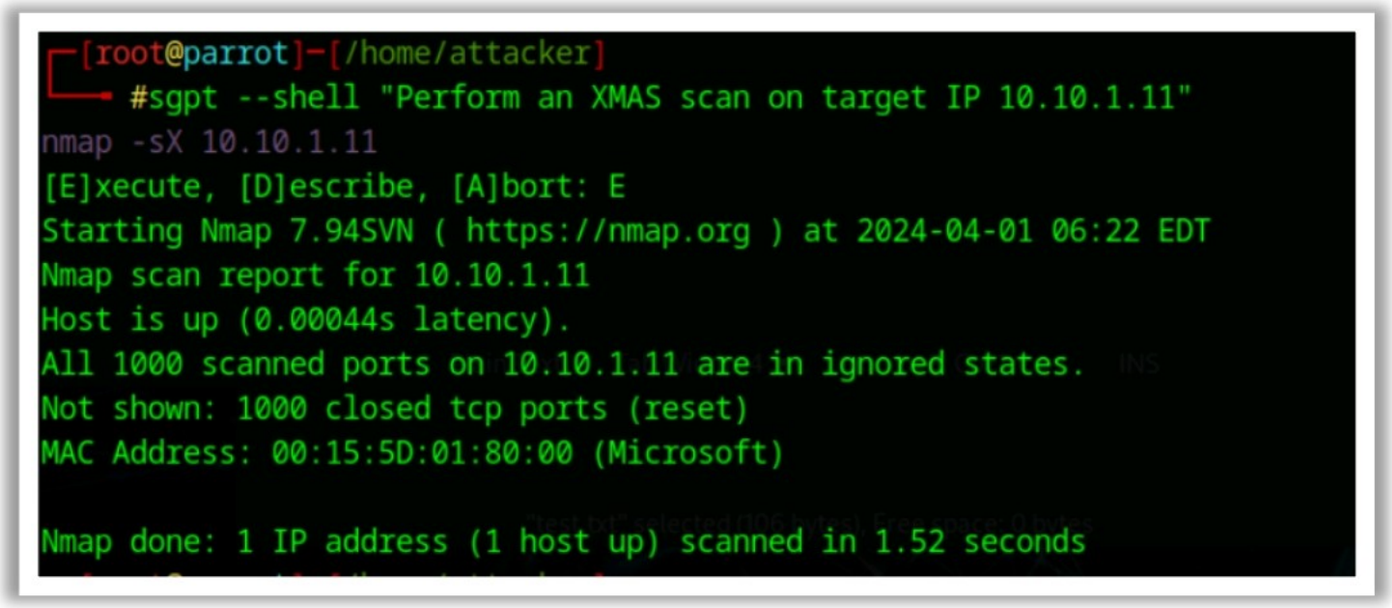


Figure 3.82: Perform XMAS scan on the target IP

To perform an XMAS scan on the target IP 10.10.1.11 using Nmap, you can use the following command:

```
nmap -sX 10.10.1.11
```

- `nmap`: This is the command to invoke Nmap, a powerful network scanning tool.
- `-sX`: This option specifies an XMAS scan, which sends packets with the FIN, URG, and PSH flags set, essentially probing the target to see how it responds to unusual TCP packet flags.
- `10.10.1.11`: This is the target IP address to scan.

Overall, this command instructs Nmap to perform an XMAS scan on the target IP address 10.10.1.11.

Example #4:

An attacker can use ChatGPT to perform this task by using an appropriate prompt such as:

"Use Nmap to scan for open ports and services against a list of IP addresses in scan1.txt and copy only the port, service and version information with the respective IP address to a new file called scan3.txt"

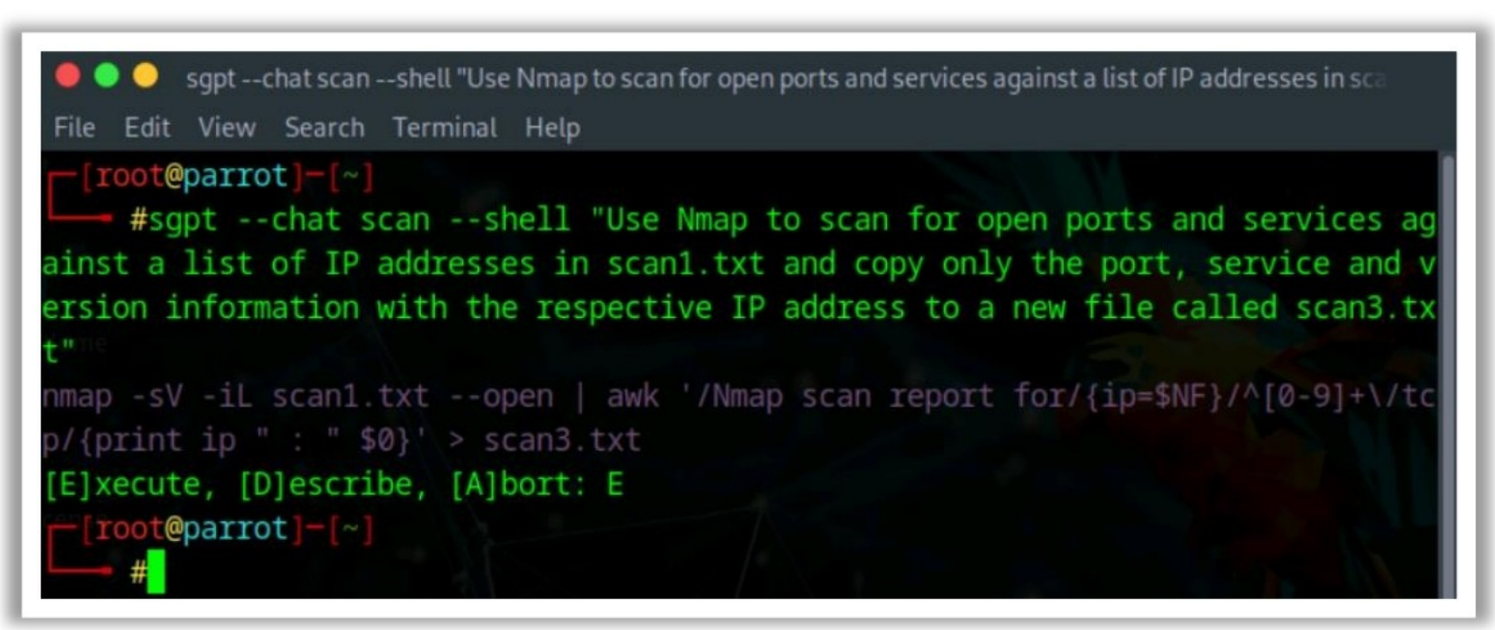


Figure 3.83: Nmap to scan for open ports and services

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following command is designed to perform a version detection scan on the hosts listed in "scan1.txt" using Nmap, extract relevant information, and save the results to "scan3.txt".

```
nmap -sv -il scan1.txt --open | awk '/Nmap scan report for/{ip=$NF}/^[0-9]+\/tcp/{print ip " : " $0}' > scan3.txt
```

- `nmap`: This is the command to invoke Nmap, a network scanning tool.
- `-sV`: This option enables version detection during the scan, attempting to determine the version of services running on the target ports.
- `-il scan1.txt`: This option specifies the input file containing a list of target IP addresses or hostnames to scan. In this case, it is "scan1.txt".
- `--open`: This option tells Nmap to only display open ports and hosts.
- `| awk '/Nmap scan report for/{ip=$NF}/^[0-9]+\/tcp/{print ip " : " $0}'`: This part of the command pipes the output of Nmap to `awk` to extract the IP addresses and relevant port information. It uses regular expressions to match lines containing the scan report for each host and lines describing open ports, then prints the IP address and port information accordingly.
- `> scan3.txt`: This redirects the final processed output to a text file named "scan3.txt" for further analysis.

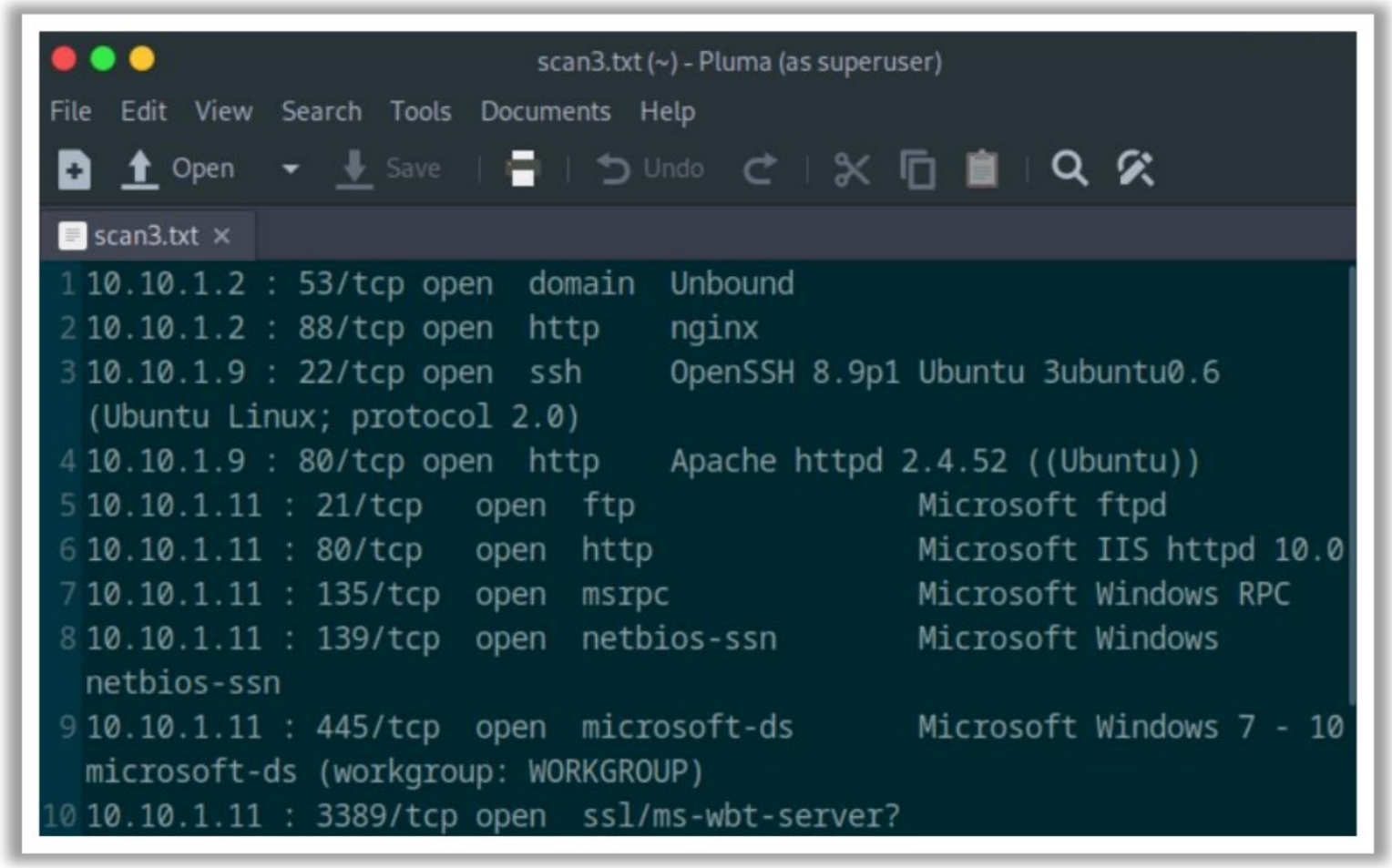


Figure 3.84: Final processed output to a text file named "scan3.txt"

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
15 (10.10.1.19) : 445/tcp  open  microsoft-ds?
16 (10.10.1.19) : 1801/tcp open  msmq?
17 (10.10.1.19) : 2103/tcp open  msrpc          Microsoft Windows RPC
18 (10.10.1.19) : 2105/tcp open  msrpc          Microsoft Windows RPC
19 (10.10.1.19) : 2107/tcp open  msrpc          Microsoft Windows RPC
20 (10.10.1.19) : 3389/tcp open  ms-wbt-server Microsoft Terminal Services
21 10.10.1.22 : 53/tcp   open  domain        Simple DNS Plus
22 10.10.1.22 : 80/tcp   open  http          Microsoft IIS httpd 10.0
23 10.10.1.22 : 88/tcp   open  kerberos-sec  Microsoft Windows Kerberos
   (server time: 2024-03-04 09:10:12Z)
24 10.10.1.22 : 135/tcp  open  msrpc         Microsoft Windows RPC
25 10.10.1.22 : 139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
26 10.10.1.22 : 389/tcp  open  ldap          Microsoft Windows Active
   Directory LDAP (Domain: CEH.com0., Site: Default-First-Site-Name)
27 10.10.1.22 : 445/tcp  open  microsoft-ds  Microsoft Windows Server 2008
   R2 - 2012 microsoft-ds (workgroup: CEH)
28 10.10.1.22 : 464/tcp  open  kpasswd5?
29 10.10.1.22 : 593/tcp  open  ncacn_http    Microsoft Windows RPC over
   HTTP 1.0
30 10.10.1.22 : 636/tcp  open  tcpwrapped
31 10.10.1.22 : 1801/tcp open  msmq?
```

Figure 3.85: Final processed output to a text file named "scan3.txt"

Overall, this command executes a version detection scan on the hosts listed in "scan1.txt", extracts and formats the relevant information, and saves the results to "scan3.txt".

Example #5:

Attackers can use ChatGPT to guide the use of Metasploit by using an appropriate prompt such as:

"Use Metasploit to discover open ports on the IP address 10.10.1.22"

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

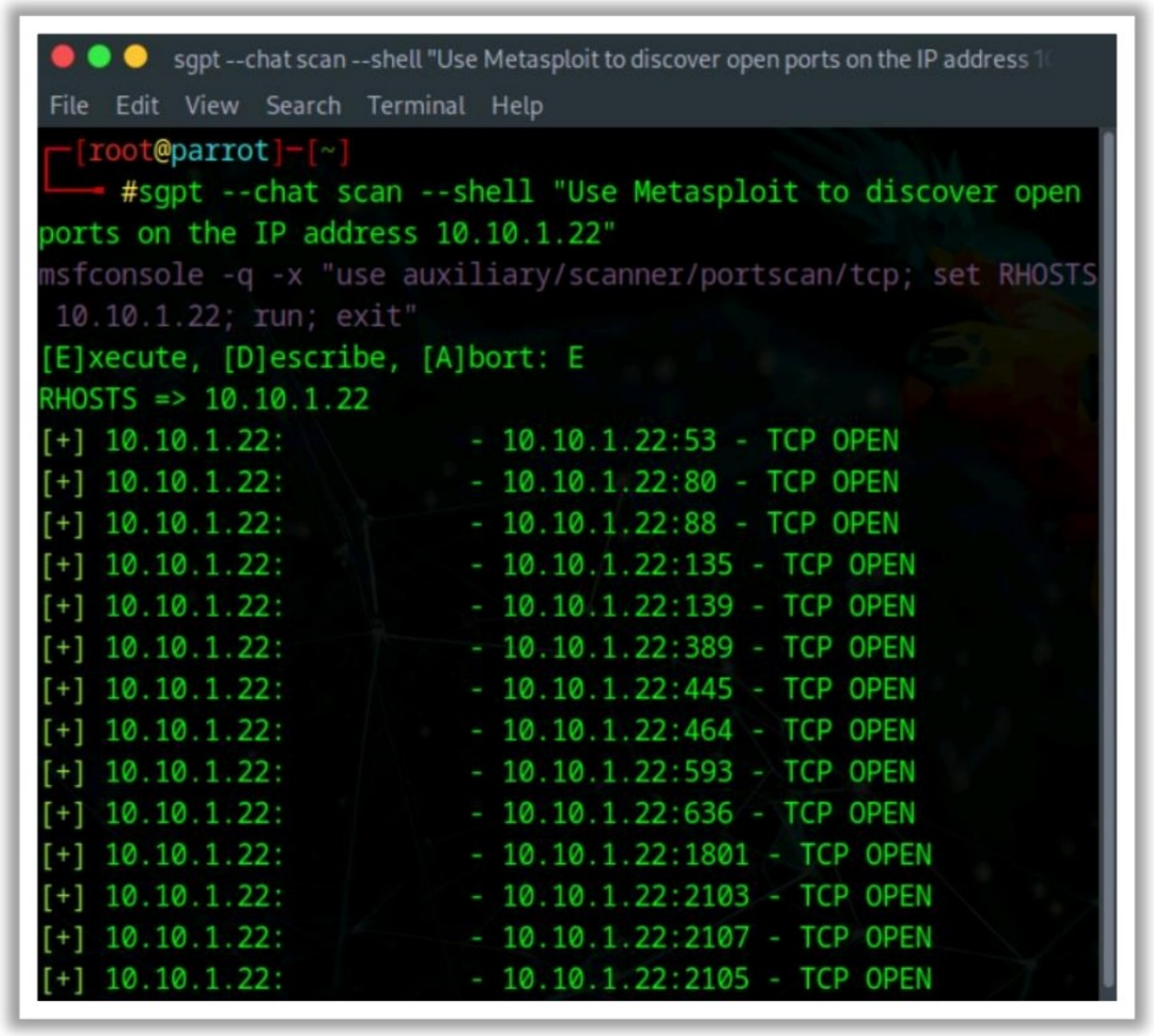


Figure 3.86: Prompt and Output of port scanning with AI

The following command is designed to execute port scanning using Metasploit to discover open ports on the specified IP address:

```
msfconsole -q -x "use auxiliary/scanner/portscan/tcp; set RHOSTS 10.10.1.22; run; exit"
```

Explanation of the command:

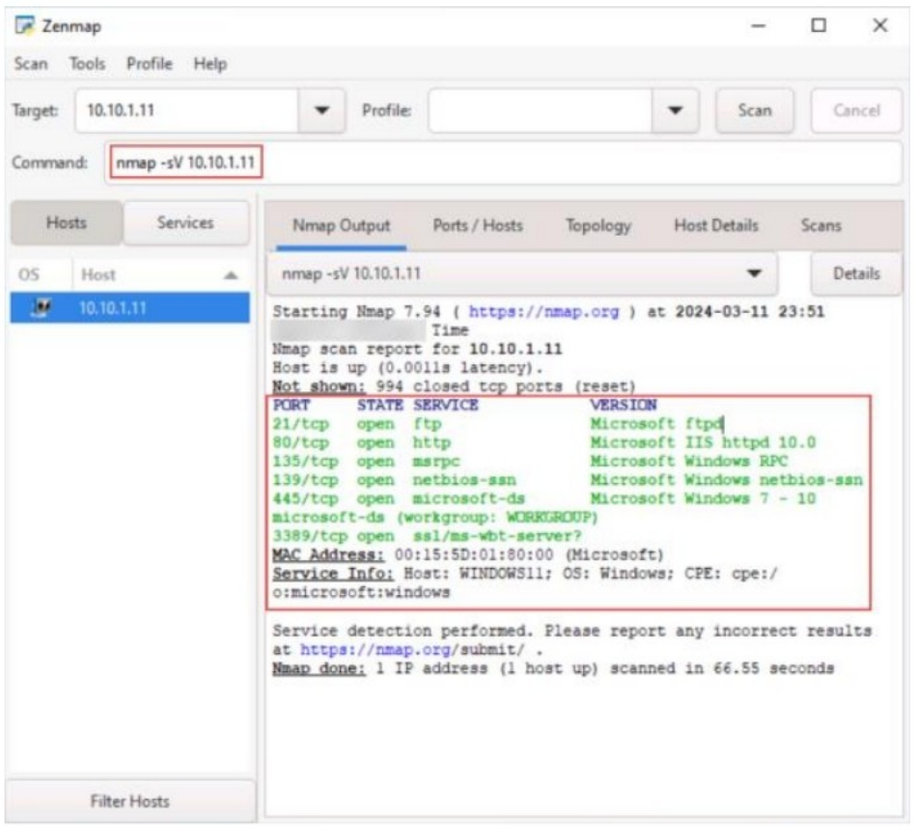
- **`msfconsole`**: Initiates the Metasploit console.
- **`-q`**: Runs Metasploit in quiet mode, suppressing banners and other non-essential output.
- **`-x "use auxiliary/scanner/portscan/tcp; set RHOSTS 10.10.1.22; run; exit"`**: Executes the specified Metasploit commands in sequence.
  - **`use auxiliary/scanner/portscan/tcp`**: Selects the TCP port scanning module in Metasploit.
  - **`set RHOSTS 10.10.1.22`**: Sets the target IP address to 10.10.1.22.
  - **`run`**: Executes the port scan.
  - **`exit`**: Exits the Metasploit console after the scan is completed.

This command conducts a port scan on the IP address 10.10.1.22 and provides information about any open ports discovered.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Service Version Discovery

- Service version detection helps attackers to obtain information about running **services and their versions** on a target system
- Obtaining an accurate service version number allows attackers to **determine the vulnerability of target system to particular exploits**
- In Zenmap, the **-sV** option is used to detect service versions



https://nmap.org

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Service Version Discovery

Every port is assigned a specific service, and every service has its own version. Some versions of the protocols are insecure, and they can allow attackers to compromise the machine by exploiting this vulnerability. Service version detection helps attackers to obtain information about the running services and their versions on a target system. By obtaining accurate service version numbers, an attacker can determine which exploits the target system is vulnerable to.

The version detection technique is nothing but examination of the TCP and UDP ports. The probes from the Nmap **`service-probes`** database are used for querying various services and matching expressions for recognizing and parsing responses. In Zenmap, the **`-sV`** option is used to detect service versions.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

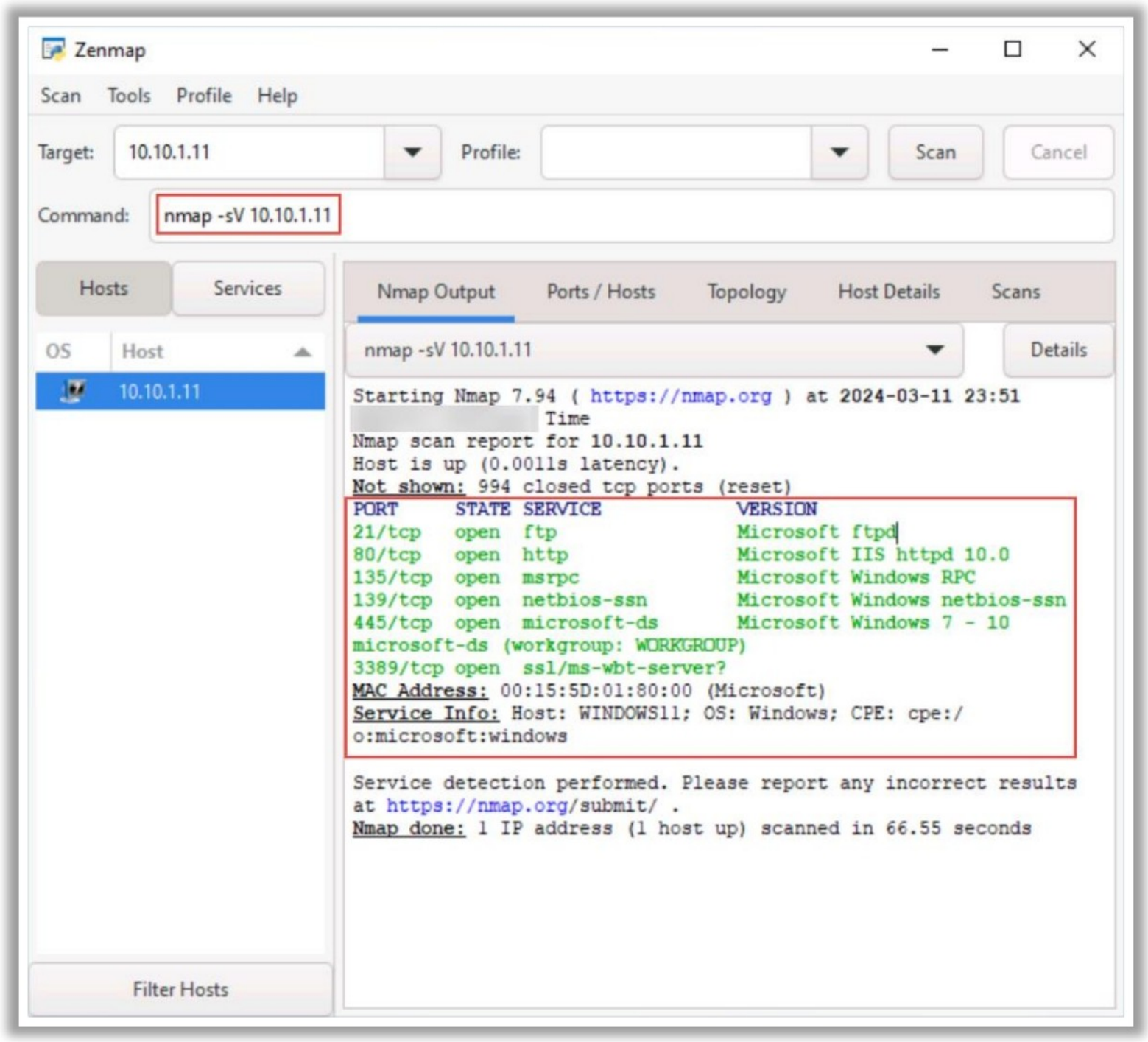
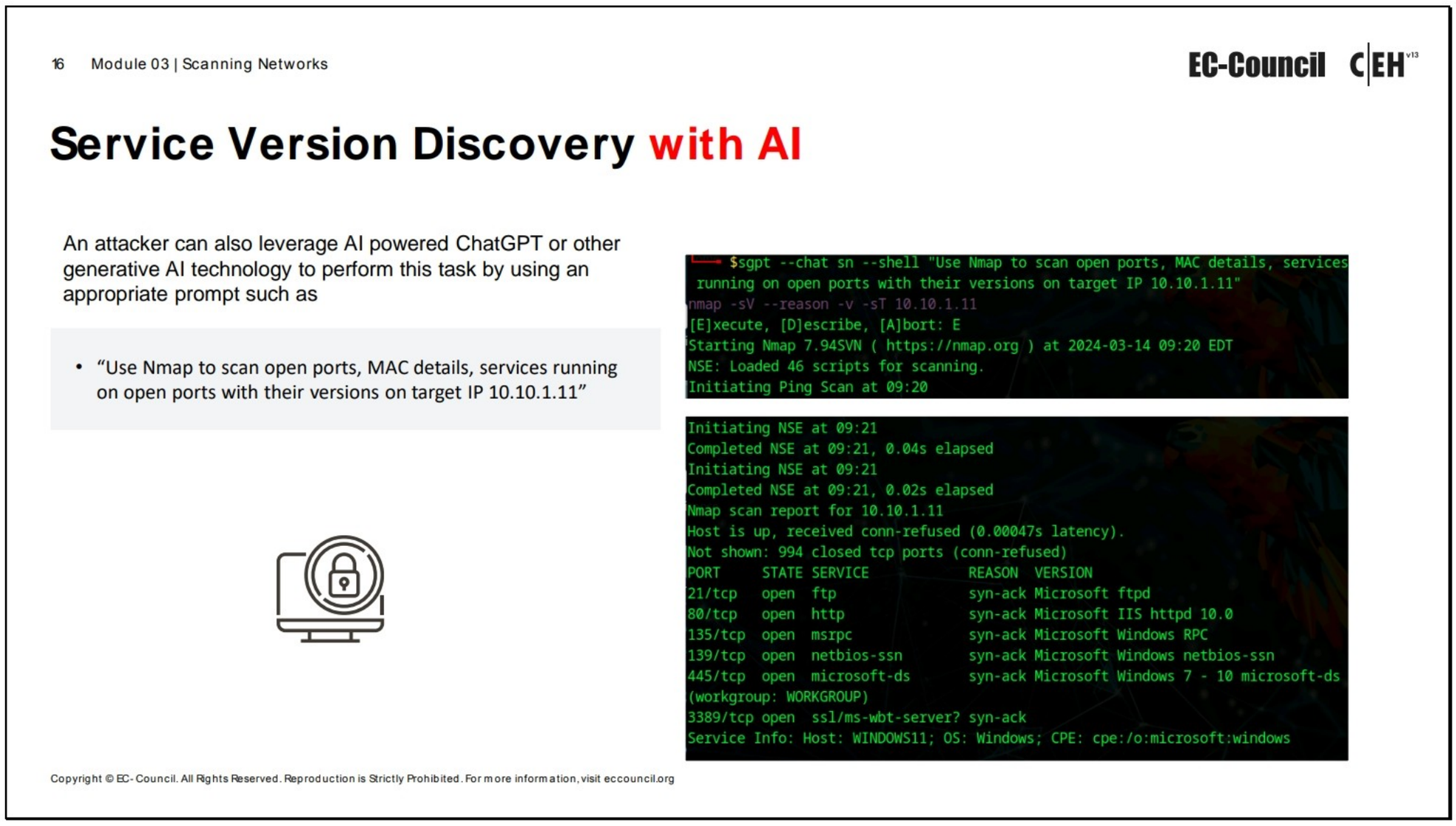


Figure 3.87: Service version discovery in Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Service Version Discovery with AI

Attackers can leverage AI-powered technologies to enhance and automate service discovery tasks. With the aid of AI, attackers can effortlessly find live systems, open ports, and services along with their versions on target IP addresses on a network.

Attackers can use ChatGPT to guide the use of Nmap by using an appropriate prompt such as:

"Use Nmap to scan open ports, MAC details, services running on open ports with their versions on target IP 10.10.1.11"

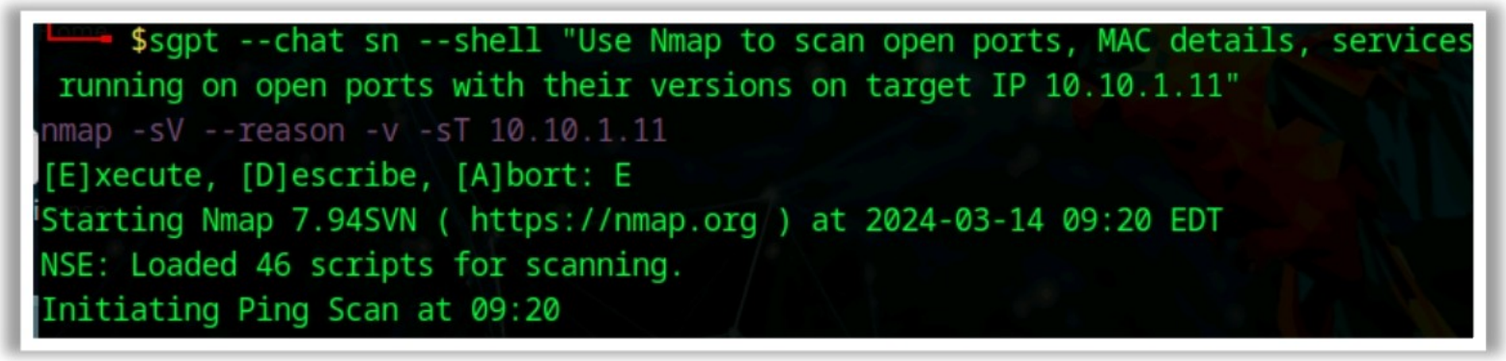


Figure 3.88: Prompt for nmap port scanning service versions and MAC details with AI

The following command is designed to execute port scanning and service enumeration using Nmap on the specified IP address:

```
nmap -sV --reason -v -sT 10.10.1.11
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Initiating NSE at 09:21
Completed NSE at 09:21, 0.04s elapsed
Initiating NSE at 09:21
Completed NSE at 09:21, 0.02s elapsed
Nmap scan report for 10.10.1.11
Host is up, received conn-refused (0.00047s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT     STATE SERVICE            REASON  VERSION
21/tcp   open  ftp                syn-ack Microsoft ftpd
80/tcp   open  http               syn-ack Microsoft IIS httpd 10.0
135/tcp  open  msrpc              syn-ack Microsoft Windows RPC
139/tcp  open  netbios-ssn        syn-ack Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds       syn-ack Microsoft Windows 7 - 10 microsoft-ds
(workgroup: WORKGROUP)
3389/tcp open  ssl/ms-wbt-server? syn-ack
Service Info: Host: WINDOWS11; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Figure 3.89: Output for nmap port scanning service versions and MAC details with AI

Explanation of the command:

- **`nmap`**: Initiates the Nmap tool.
- **`-sV`**: Enables service version detection to determine service and application versions.
- **`--reason`**: Displays the reason for the port state (open, closed, filtered, etc.).
- **`-v`**: Increases verbosity level to provide more detailed output.
- **`-sT`**: Performs TCP connect scanning, which involves establishing a full TCP connection to each port being scanned.
- **`10.10.1.11`**: Specifies the target IP address to scan.

This command conducts a comprehensive scan on the IP address 10.10.1.11, providing detailed information about open ports, MAC details, and services along with their versions.

Nmap Scan Time Reduction Techniques

In Nmap, performance and accuracy take high priority, and this only be achieved only by reducing the long scan time. The important techniques for reducing the scan time are as follows:

- **Omit Non-critical Tests**

  While performing the Nmap scan, the time complexity can be reduced by the following methods:

  - Avoiding an intense scan if only a minimal amount of information is required.
  - The number of ports scanned can be limited using specific commands.
  - The port scan (**`-sn`**) can be skipped if and only if one has to check whether the hosts are online or not.
  - Advanced scan types (**`-sC`**, **`-sV`**, **`-O`**, **`--traceroute`**, and **`-A`**) can be avoided.
  - The DNS resolution should be turned on only when it is necessary.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Optimize Timing Parameters**

  To control the scan activity, Nmap provides the **-T** option for scanning ranging from high-level to low-level timing aggressiveness. This can be extremely useful for scanning highly filtered networks.

- **Separate and Optimize UDP Scans**

  As many vulnerable services use the UDP protocol, scanning the UDP protocol is vital, and it should be scanned separately, as TCP scans have different performance requirements and timing characteristics. Moreover, the UDP scan is more affected by the ICMP error rate-limiting compared to the TCP scan.

- **Upgrade Nmap**

  It is always advisable to use the upgraded version of Nmap as it contains many bug fixes, important algorithmic enhancements, and high-performance features such as local network ARP scanning.

- **Execute Concurrent Nmap Instances**

  Running Nmap against the whole network usually makes the system slower and less efficient. Nmap supports parallelization and it can also be customized according to specific needs. It becomes very efficient by getting an idea of the network reliability while scanning a larger group. The overall speed of the scan can be improved by dividing it into many groups and running them simultaneously.

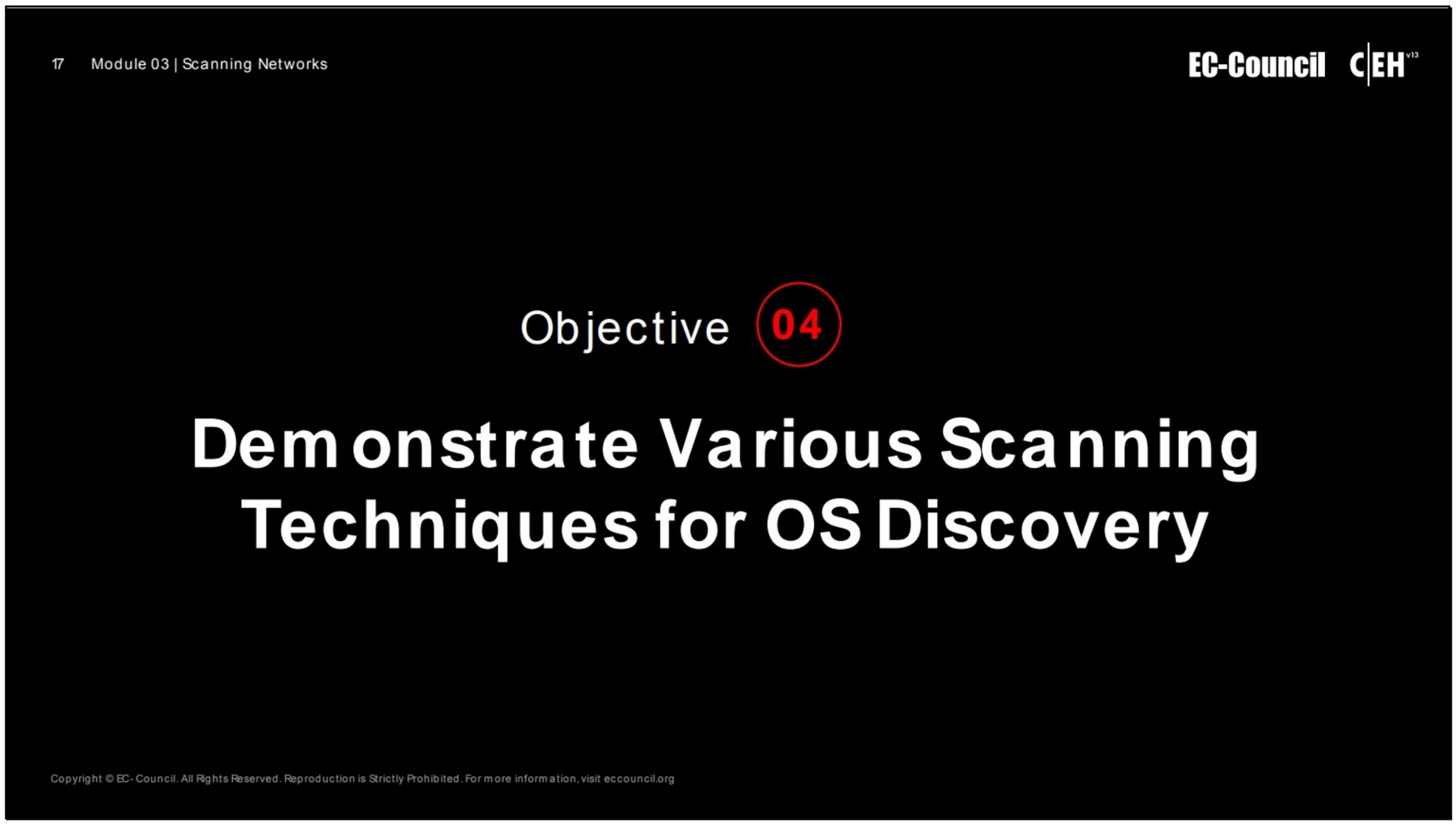
- **Scan from a Favorable Network Location**

  It is always advisable to run Nmap from the host's local network to the target while in the internal network, as it offers defense-in-depth security. External scanning is obligatory when performing firewall testing or when the network should be monitored from the external attacker's viewpoint.

- **Increase Available Bandwidth and CPU Time**

  By increasing the available bandwidth or CPU power, the Nmap scan time can be reduced. This can be done by installing a new data line or stopping any running applications. Nmap is controlled by its own congestion control algorithms, so that network flooding can be prevented. This improves its accuracy. The Nmap bandwidth usage can be tested by running it in the verbose mode **-v**.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



OS Discovery (Banner Grabbing/OS Fingerprinting)

An attacker uses OS discovery or banner grabbing techniques to identify network hosts running applications and OS versions with known exploits. This section introduces you to banner grabbing, its types, and banner grabbing tools.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

OS Discovery/ Banner Grabbing

Banner grabbing or OS fingerprinting is the method used to **determine the operating system running on a remote target system**. There are two types of banner grabbing: active and passive

Identifying the OS used on the target host allows an attacker to **figure out the vulnerabilities possessed by the system** and the exploits that might work on a system to further **carry out additional attacks**

Active Banner Grabbing

- **Specially crafted packets** are sent to the remote OS and the responses are noted
- The responses are then compared with a database to **determine the OS**
- Responses from different OSes vary due to differences in the **TCP/IP stack implementation**

Passive Banner Grabbing

- **Banner grabbing from error messages**

Error messages provide information such as the type of server, type of OS, and SSL tool used by the target remote system.

- **Sniffing the network traffic**

Capturing and analyzing packets from the target enables an attacker to determine the OS used by the remote system.

- **Banner grabbing from page extensions**

Looking for an extension in the URL may assist in determining the application's version.

- Example: .aspx => IIS server and Windows platform

Note: We will discuss passive banner grabbing in later modules.

Copyright © EC- Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

OS Discovery/Banner Grabbing

Banner grabbing, or "OS fingerprinting," is a method used to determine the OS that is running on a remote target system. It is an important scanning method, as the attacker will have a higher probability of success if the OS of the target system is known (many vulnerabilities are OS-specific). The attacker can then formulate an attack strategy based on the OS of the target system.

There are two methods for banner grabbing: spotting the banner while trying to connect to a service, such as an FTP site, and downloading the binary file/bin/ls to check the system architecture.

A more advanced fingerprinting technique depends on stack querying, which transfers the packets to the network host and evaluates them by the reply. The first stack-querying method designed with regard to the TCP mode of communication evaluates the response to connection requests.

The next method, known as initial sequence number (ISN) analysis, identifies the differences in random number generators found in the TCP stack. ICMP response analysis is another method used to fingerprint an OS. It consists of sending ICMP messages to a remote host and evaluating the reply.

Two types of banner grabbing techniques are described below:

- **Active Banner Grabbing**

  Active banner grabbing applies the principle that an OS's IP stack has a unique way of responding to specially crafted TCP packets. This happens because of different interpretations that vendors apply while implementing the TCP/IP stack on a particular OS. In active banner grabbing, the attacker sends a variety of malformed packets to the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

remote host, and the responses are compared with a database. Responses from different OS vary because of differences in TCP/IP stack implementation.

For instance, the scanning utility Nmap uses a series of nine tests to determine an OS fingerprint or banner grabbing. The tests listed below provide some insights into an active banner grabbing attack, as described at *https://nmap.org/book/osdetect-methods.html#osdetect-probes*:

- **Test 1:** A TCP packet with the SYN and ECN-Echo flags enabled is sent to an open TCP port.
- **Test 2:** A TCP packet with no flags enabled is sent to an open TCP port. This type of packet is a NULL packet.
- **Test 3:** A TCP packet with the URG, PSH, SYN, and FIN flags enabled is sent to an open TCP port.
- **Test 4:** A TCP packet with the ACK flag enabled is sent to an open TCP port.
- **Test 5:** A TCP packet with the SYN flag enabled is sent to a closed TCP port.
- **Test 6:** A TCP packet with the ACK flag enabled is sent to a closed TCP port.
- **Test 7:** A TCP packet with the URG, PSH, and FIN flags enabled is sent to a closed TCP port.
- **Test 8 PU (Port Unreachable):** A UDP packet is sent to a closed UDP port. The objective is to extract an "ICMP port unreachable" message from the target machine.
- **Test 9 TSeq (TCP Sequence ability test):** This test tries to determine the sequence generation patterns of the TCP initial sequence numbers (also known as TCP ISN sampling), the IP identification numbers (also known as IPID sampling), and the TCP timestamp numbers. It sends six TCP packets with the SYN flag enabled to an open TCP port.

The objective of these tests is to find patterns in the initial sequence of numbers that the TCP implementations chose while responding to a connection request. They can be categorized into groups, such as traditional 64K (many old UNIX boxes), random increments (newer versions of Solaris, IRIX, FreeBSD, Digital UNIX, Cray, and many others), or true random (Linux 2.0.*, OpenVMS, newer AIX, etc.). Windows boxes use a "time-dependent" model in which the ISN is incremented by a fixed amount for each occurrence.

- **Passive Banner Grabbing**

  Source: *https://www.broadcom.com*

  Like active banner grabbing, passive banner grabbing also depends on the differential implementation of the stack and the various ways in which an OS responds to packets. However, instead of relying on scanning the target host, passive fingerprinting captures packets from the target host via sniffing to study telltale signs that can reveal an OS.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Passive banner grabbing includes:

- **Banner grabbing from error messages**: Error messages provide information, such as type of server, type of OS, and SSL tools used by the target remote system.
- **Sniffing the network traffic**: Capturing and analyzing packets from the target enables an attacker to determine the OS used by the remote system.
- **Banner grabbing from page extensions**: Looking for an extension in the URL may help in determining the application version. For example, .aspx => IIS server and Windows platform.

The four areas that typically determine the OS are given below:

- TTL (time to live) of the packets: What does the OS sets as the Time To Live on the outbound packet?
- Window Size: What is the Window size set by the OS?
- Whether the DF (Don't Fragment) bit is set: Does the OS set the DF bit?
- TOS (Type of Service): Does the OS set the TOS, and if so, what setting is it?

Passive fingerprinting is neither fully accurate nor limited to these four signatures. However, one can improve its accuracy by looking at several signatures and combining the information.

The following is an analysis of a sniffed packet for passive fingerprinting:

```
2024-03-15 11:5.330465 10.10.1.11 -> 10.10.1.22
Time To Live:128
Protocol: ICMP(1)
Fragment Offset: 0
Differentiated Service Field: 0x00 (DSC, CSO, ECN, NOT-ECT
Ack: 0xE3C65D7 Win: 0x7D78
```

According to the four criteria, the following are identified:

- TTL: 45
- Window Size: 0x7D78 (or 32120 in decimal)
- DF: The DF bit is set
- TOS: 0x0

Compare this information with a database of signatures.

TTL: The TLL from the analysis is 45. The original packet went through 19 hops to get to the target, so it sets the original TTL to 64. Based on this TTL, it appears that the user sent the packet from a Linux or FreeBSD box (however, more system signatures need to be added to the database). This TTL confirms it by implementing a traceroute to the remote host. If the trace needs to be performed stealthily, the traceroute TTL (default 30 hops)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

can be set to one or two hops fewer than the remote host (-m option). Setting the traceroute in this manner reveals the path information (including the upstream provider) without actually contacting the remote host.

Window Size: In this step, the window sizes are compared. The window size is another effective tool for determining precisely what window size is used and how often it is changed. In the previous signature, the window size is set at 0x7D78, which is the default window size used by Linux. In addition, FreeBSD and Solaris tend to maintain the same window size throughout a session. However, Cisco routers and Microsoft Windows NT window sizes constantly change. The window size is more accurate when measured after the initial three-way handshake (due to TCP slow start).

DF bit: Most systems use the DF bit set; hence, this is of limited value. However, this makes it easier to identify a few systems that do not use the DF flag (such as SCO or OpenBSD).

TOS: TOS is also of limited value, as it seems to be more session-based than OS-based. In other words, it is not so much the OS as the protocol used that determines the TOS to a large extent.

Using the information obtained from the packet, specifically the TTL and the window size, one can compare the results with the database of signatures and determine the OS with some degree of confidence (in this case, Linux kernel 2.2.x).

Passive fingerprinting, like active fingerprinting, has some limitations. First, applications that build their own packets (e.g., Nmap, Hunt, Nemesis, etc.) will not use the same signatures as the OS. Second, it is relatively simple for a remote host to adjust the TTL, window size, DF, or TOS setting on the packets.

Passive fingerprinting has several other uses. For example, attackers can use stealthy fingerprinting to determine the OS of a potential target such as a web server. A user only needs to request a web page from the server and then analyze the sniffer traces. This bypasses the need for using an active tool that various IDS systems can detect. Passive fingerprinting also helps in identifying remote proxy firewalls. It may be possible to ID proxy firewalls from the signatures as discussed above, simply because proxy firewalls rebuild connections for clients. Similarly, passive fingerprinting can be used to identify rogue systems.

Note: We will discuss passive banner grabbing in later modules.

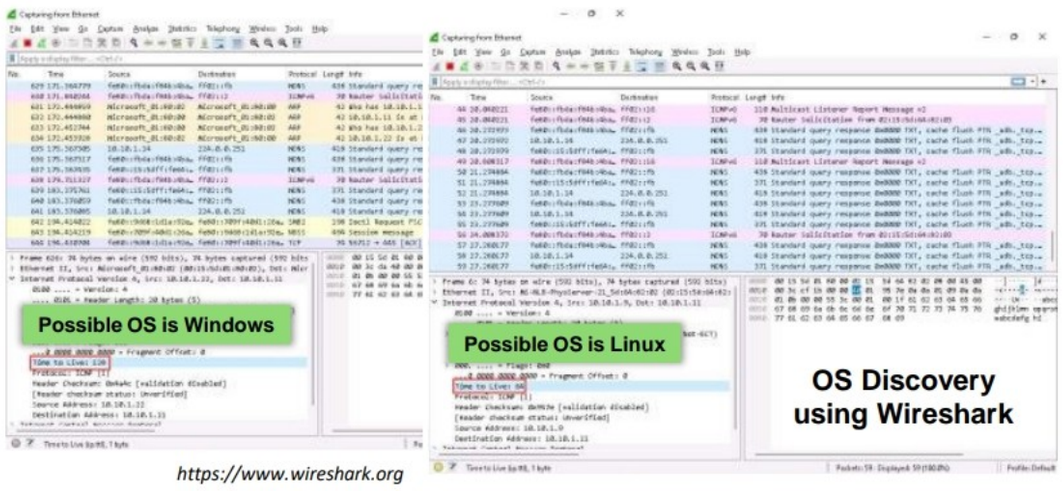
Why Banner Grabbing?

An attacker uses banner grabbing to identify the OS used on the target host and thus determine the system vulnerabilities and exploits that might work on that system to carry out further attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How to Identify Target System OS

- Attackers can identify the OS running on the target machine by looking at the **Time To Live (TTL)** and **TCP window size** in the IP header of the first packet in a TCP session
- **Sniff/capture the response** generated from the target machine using packet-sniffing tools like Wireshark and observe the TTL and TCP window size fields



https://www.wireshark.org

Window size values for OS

Operating System	Time To Live	TCP Window Size
Linux	64	5840
FreeBSD	64	65535
OpenBSD	255	16384
Windows	128	65,535 bytes to 1 Gigabyte
Cisco Routers	255	4128
Solaris	255	8760
AIX	255	16384

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

How to Identify Target System OS

Identifying the target OS is one of the important tasks for an attacker to compromise the target network/machine. In a network, various standards are implemented to allow different OSs to communicate with each other. These standards govern the functioning of various protocols such as IP, TCP, UDP, etc. By analyzing certain parameters/fields in these protocols, one can reveal the details of the OS. Parameters such as Time to Live (TTL) and TCP window size in the IP header of the first packet in a TCP session help identify the OS running on the target machine. The TTL field determines the maximum time that a packet can remain in a network, and the TCP window size determines the length of the packet reported. These values vary among OSs, as described in the following table:

Operating System	Time To Live	TCP Window Size
Linux	64	5840
FreeBSD	64	65535
OpenBSD	255	16384
Windows	128	65,535 bytes to 1 Gigabyte
Cisco Routers	255	4128
Solaris	255	8760
AIX	255	16384

Table 3.2: TTL and TCP Window size values for OS

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers can use various tools to perform OS discovery on the target machine, including Wireshark, Nmap, Unicornscan, and Nmap Script Engine. Attackers can also adopt the IPv6 fingerprinting method to grab the target OS details.

OS Discovery using Wireshark

Source: *https://www.wireshark.org*

To identify the target OS, sniff/capture the response generated from the target machine to the request-originated machine using packet-sniffing tools such as Wireshark, etc., and observe the TTL and TCP window size fields in the first captured TCP packet. By comparing these values with those in the above table, you can determine the target OS that has generated the response.

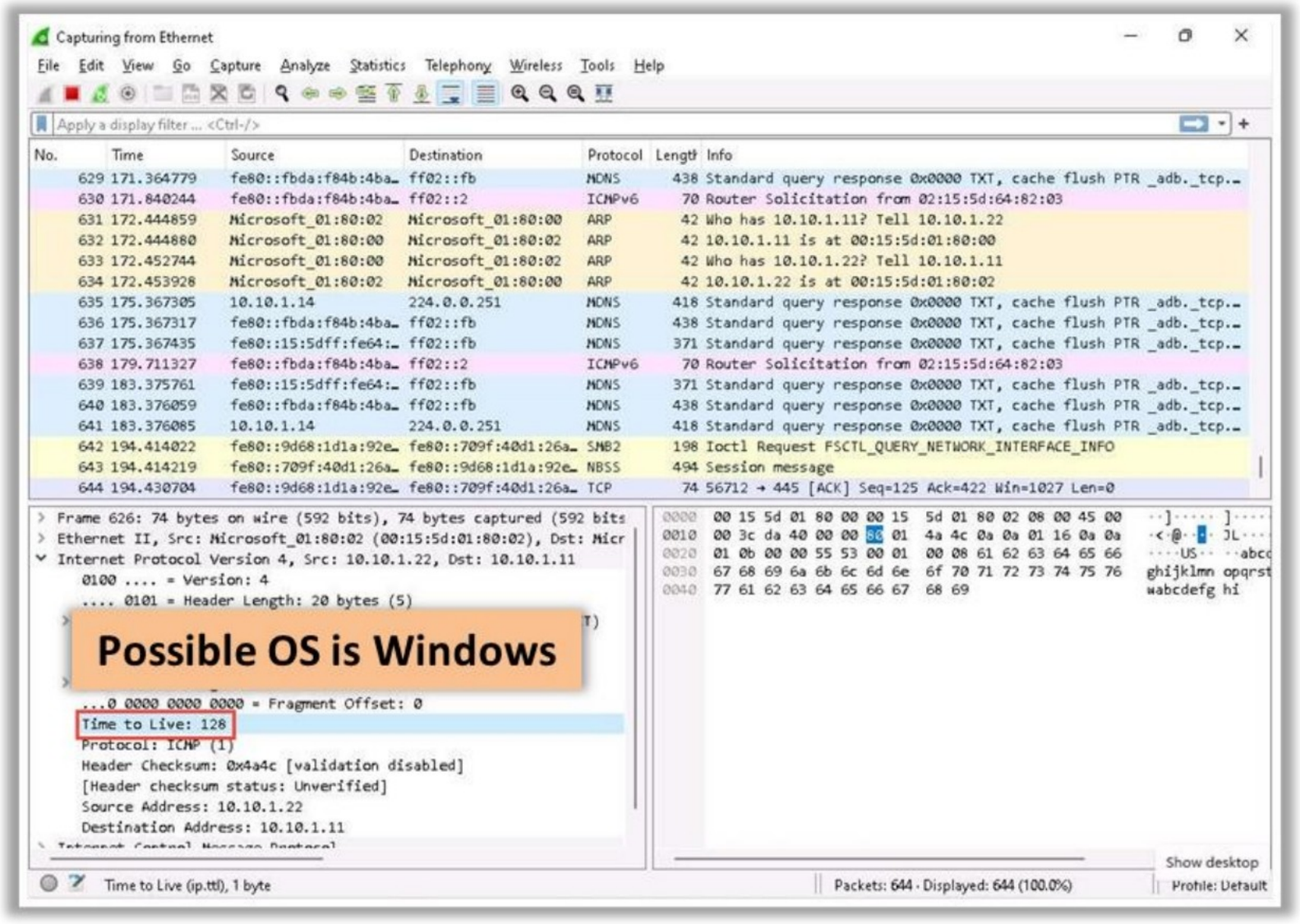


Figure 3.90: Wireshark screenshot showing TTL value (Possible OS is Windows)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

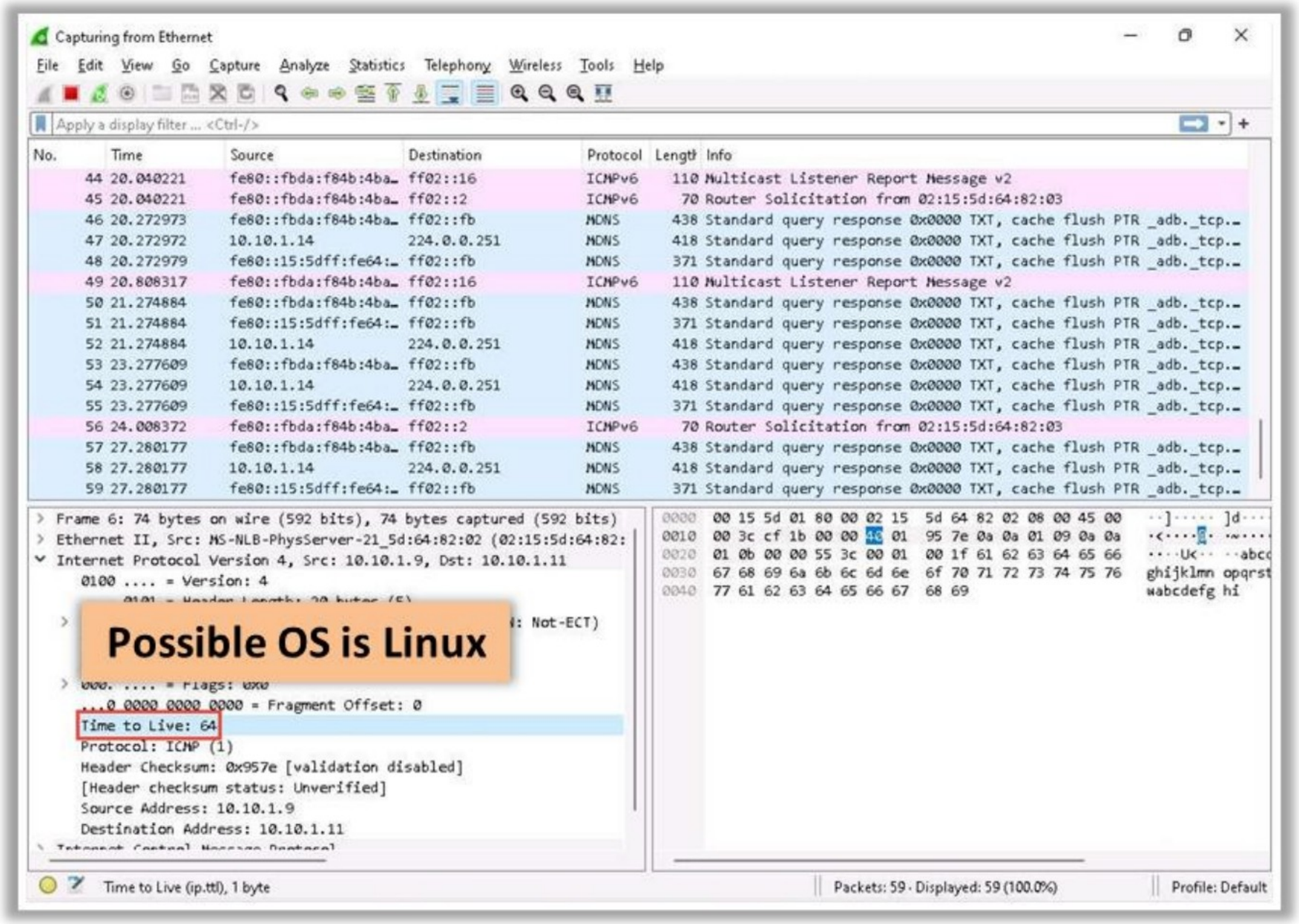
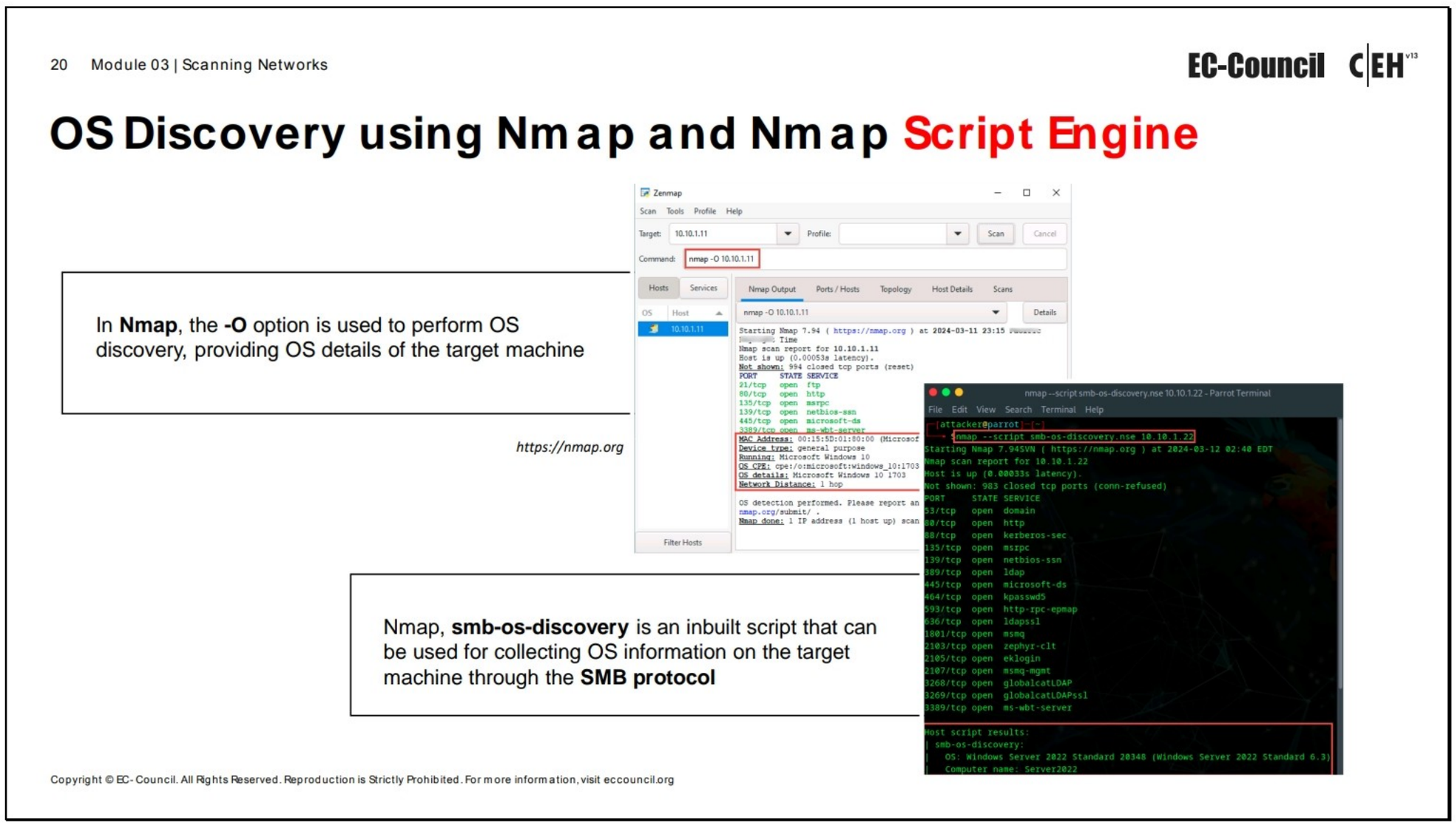


Figure 3.91: Wireshark screenshot showing TTL value (Possible OS is Linux)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



OS Discovery using Nmap and Unicornscan

OS Discovery using Nmap

Source: *https://nmap.org*

To exploit the target, it is highly essential to identify the OS running on the target machine. Attackers can employ various tools to acquire the OS details of the target. Nmap is one of the effective tools for performing OS discovery activities. In Zenmap, the **-O** option is used to perform OS discovery, which displays the OS details of the target machine.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

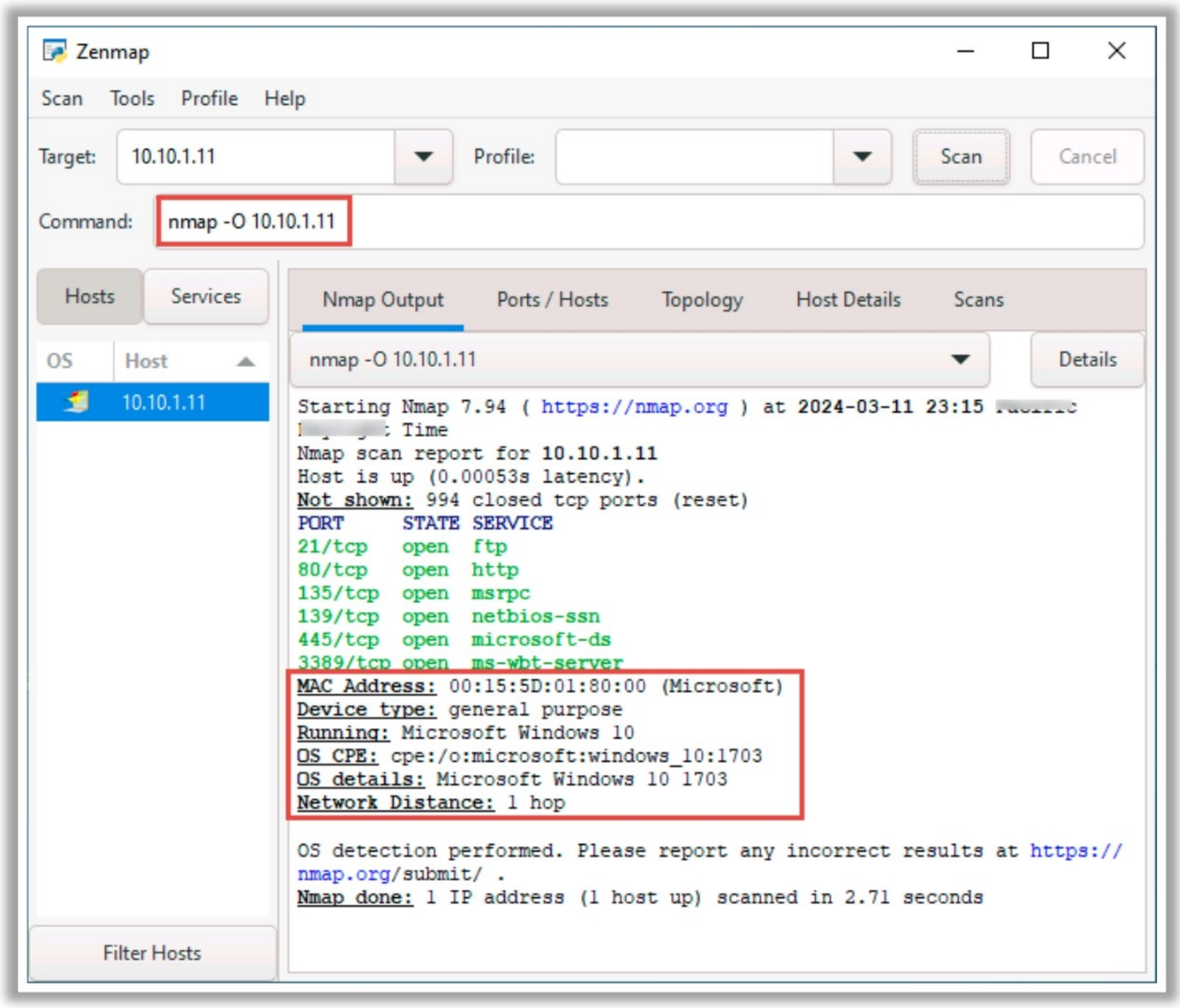


Figure 3.92: OS Discovery using Zenmap

OS Discovery using Unicornscan

Source: *https://sourceforge.net*

In Unicornscan, the OS of the target machine can be identified by observing the TTL values in the acquired scan result. To perform Unicornscan, the syntax **#unicornscan <target IP address>** is used. As shown in the screenshot, the **ttl** value acquired after the scan is **128**; hence, the OS is possibly Microsoft Windows.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

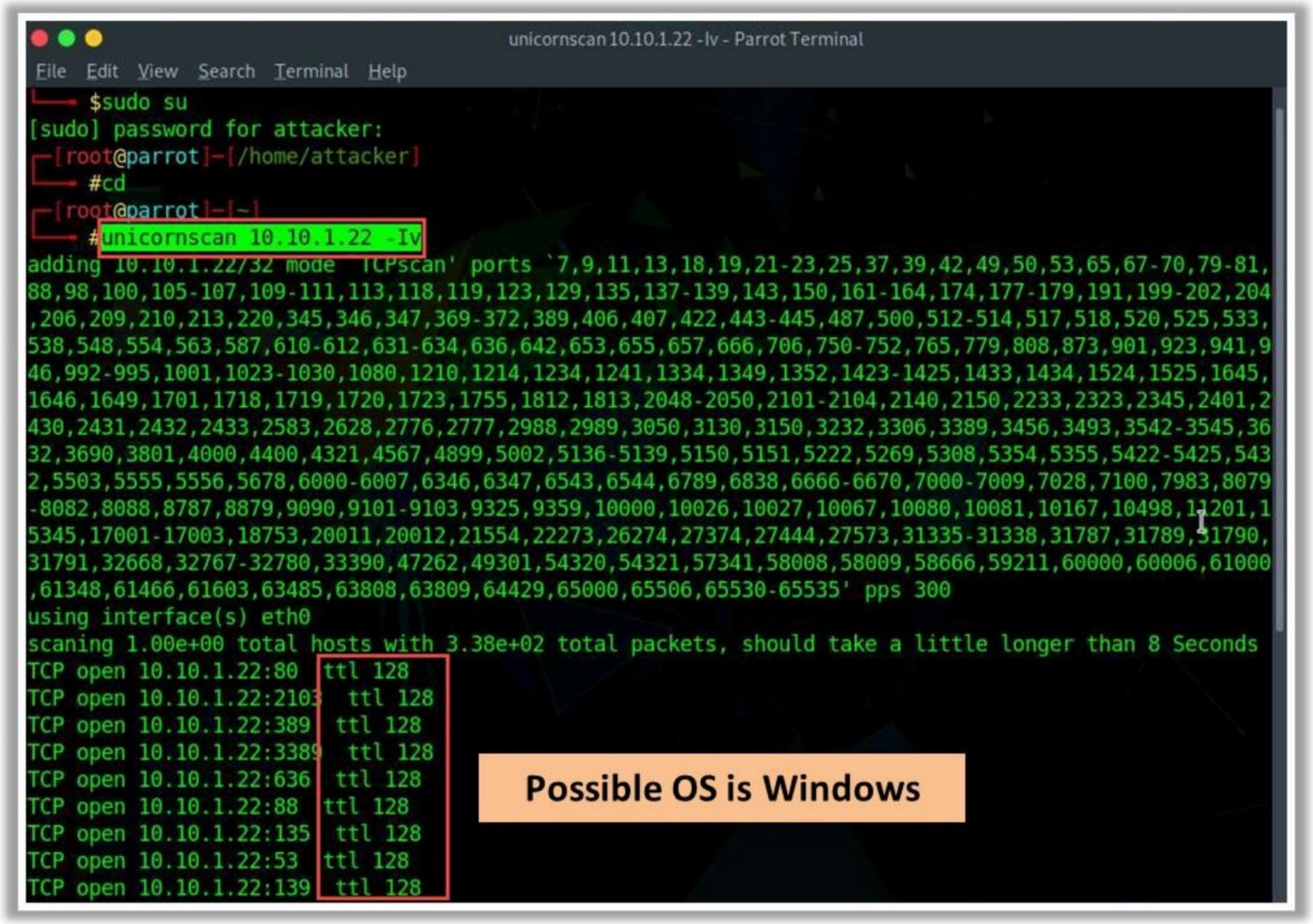


Figure 3.93: OS Discovery using Unicornscan

OS Discovery using Nmap Script Engine

Source: *https://nmap.org*

Nmap Scripting Engine (NSE) in Nmap can be used to automate a wide variety of networking tasks by allowing users to write and share scripts. These scripts can be executed parallelly with the same efficiency and speed as Nmap. Attackers can also use various scripts in the Nmap Script Engine for performing OS discovery on the target machine. For example, in Nmap, **`smb-os-discovery`** is an inbuilt script used for collecting OS information on the target machine through the SMB protocol.

In Zenmap, NSE can be generally activated using the **`-sC`** option. If the custom scripts are to be specified, then attackers can use the **`--script`** option. The NSE results will be displayed with both the Nmap normal and XML outputs.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

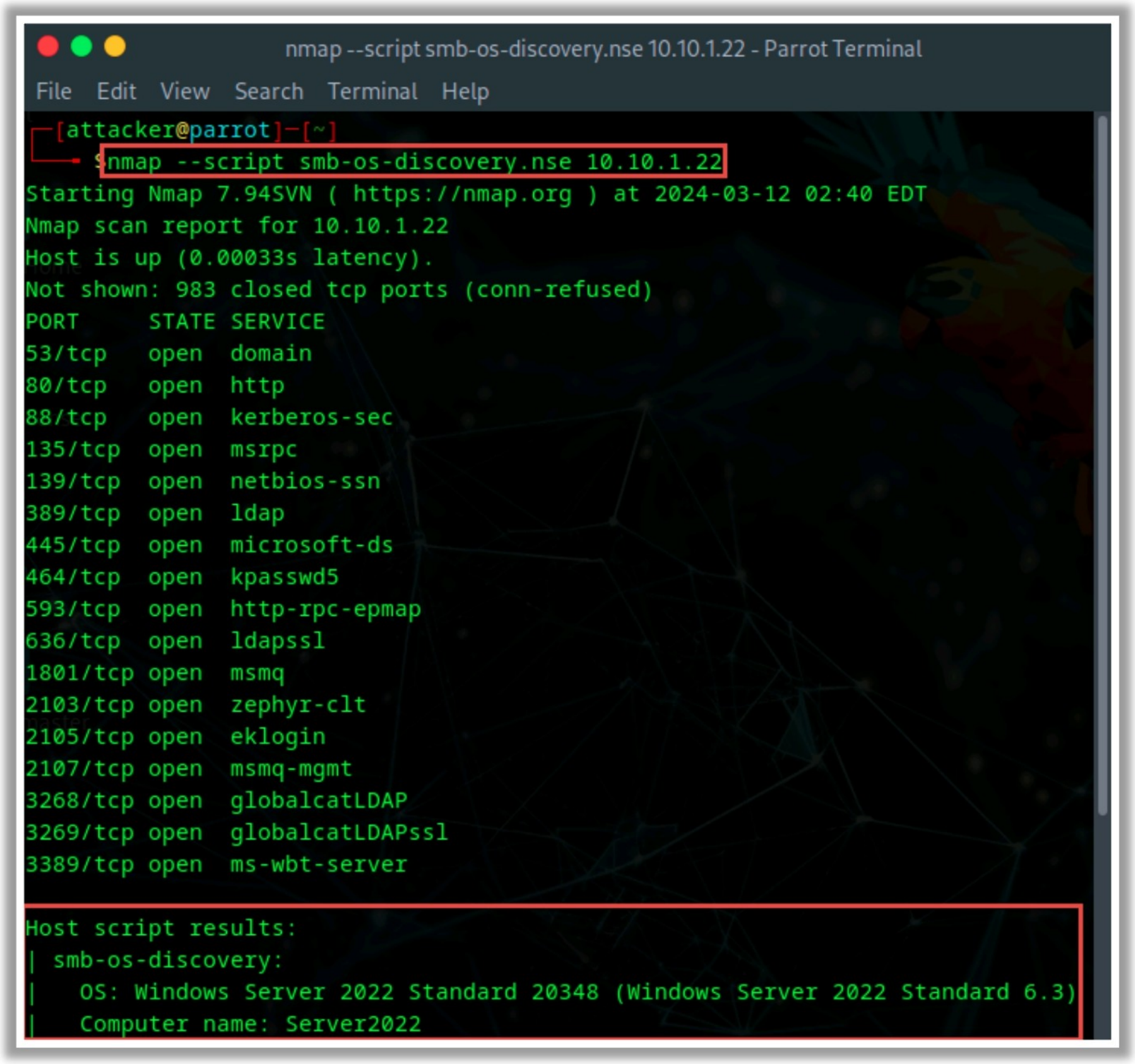


Figure 3.94: OS Discovery using Nmap Script Engine

OS Discovery using IPv6 Fingerprinting

Source: *https://nmap.org*

IPv6 Fingerprinting is another technique used to identify the OS running on the target machine. It has the same functionality as IPv4, such as sending probes, waiting and collecting the responses, and matching them with the database of fingerprints. The difference between IPv6 and IPv4 fingerprinting is that IPv6 uses several additional advanced IPv6-specific probes along with a separate IPv6-specifc OS detection engine. Nmap sends nearly 18 probes in the following order to identify the target OS using the IPv6 fingerprinting method.

- Sequence generation (S1–S6)
- ICMPv6 echo (IE1)
- ICMPv6 echo (IE2)
- Node Information Query (NI)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Neighbor Solicitation (NS)
- UDP (U1)
- TCP explicit congestion notification (TECN)
- TCP (T2–T7)

In Zenmap, the **-6** option along with **-O** option is used to perform OS discovery using the IPv6 fingerprinting method.

Syntax: **# nmap -6 -O <target>**

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

21 Module 03 | Scanning Networks

EC-Council C|EH v13

OS Discovery with AI

An attacker can also leverage AI-powered ChatGPT or other generative AI technology to perform this task by using an appropriate prompt such as

- *"Use TTL to identify the operating system running on the target IP address 10.10.1.11"*
- *"Use TTL to identify the operating system running on the target IP address 10.10.1.9"*

```
└─→ $sgpt --chat sn --shell "Use TTL to identify the operating system running o
n the target IP address 10.10.1.11"
ping -c 1 10.10.1.11 && echo "Check the TTL value from the response to infer the
 OS (Linux/Unix: 64, Windows: 128)"
[E]xecute, [D]escribe, [A]bort: E
PING 10.10.1.11 (10.10.1.11) 56(84) bytes of data.
64 bytes from 10.10.1.11: icmp_seq=1 ttl=128 time=0.573 ms

--- 10.10.1.11 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.573/0.573/0.573/0.000 ms
Check the TTL value from the response to infer the OS (Linux/Unix: 64, Windows:
128)
```

```
┌─[attacker@parrot]─[~]
└─→ $sgpt --chat sn --shell "Use TTL to identify the operating system running o
n the target IP address 10.10.1.9"
ping -c 1 10.10.1.9 | grep "ttl"
[E]xecute, [D]escribe, [A]bort: E
64 bytes from 10.10.1.9: icmp_seq=1 ttl=64 time=1.83 ms
```

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

22 Module 03 | Scanning Networks

EC-Council C|EH v13

OS Discovery with AI (Cont'd)

"Use Nmap script engine to perform OS discovery on the target IP addresses in scan1.txt"

pluma os_discovery_results.txt - Parrot Terminal

```
File  Edit  View  Search  Terminal  Help
┌─[root@parrot]─[~]
└──╼ #sgpt --shell "Use Nmap script engine to perform OS discovery
on the target IP addresses in scan1.txt"
nmap -iL scan1.txt -O --script=default --script-args=newtargets -oN
 os_discovery_results.txt
[E]xecute, [D]escribe, [A]bort: E
```

pluma os_discovery_results.txt - Parrot Terminal

```
File  Edit  View  Search  Terminal  Help
Nmap scan report for 10.10.1.9
Host is up (0.00084s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
| ssh-hostkey:
|   256 3b:23:12:8c:e2:d5:91:d3:e5:5a:93:82:11:b9:fb:f6 (ECDSA)
|_  256 ae:80:12:14:aa:cb:96:ea:ec:cb:5a:e1:3a:33:76:f4 (ED25519)
80/tcp open  http
|_http-title: Apache2 Ubuntu Default Page: It works
MAC Address: 02:15:5D:34:B1:BD (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
```

pluma os_discovery_results.txt - Parrot Terminal

```
File  Edit  View  Search  Terminal  Help
Host script results:
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled and required
|_clock-skew: mean: 1h36m00s, deviation: 3h34m40s, median: 0s
| smb2-time:
|   date: 2024-03-04T06:03:21
|_  start_date: N/A
| smb-os-discovery:
|   OS: Windows Server 2022 Standard 20348 (Windows Server 2022 St
andard 6.3)
|   Computer name: Server2022
|   NetBIOS computer name: SERVER2022\x00
|   Domain name: CEH.com
|   Forest name: CEH.com
|   FQDN: Server2022.CEH.com
|_  System time: 2024-03-03T22:03:22-08:00
|   NetBIOS_Computer_Name: WINDOWS11
|   DNS_Domain_Name: Windows11
|   DNS_Computer_Name: Windows11
|   Product_Version: 10.0.22000
|_  System_Time: 2024-03-04T06:03:20+00:00
MAC Address: 00:15:5D:01:80:00 (Microsoft)
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10:1703
OS details: Microsoft Windows 10 1703
Network Distance: 1 hop
```

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

OS Discovery with AI

Attackers can leverage AI-powered technologies to enhance and automate OS discovery tasks. With the aid of AI, attackers can effortlessly identify the operating systems running on target IP addresses on a network.

Attackers can leverage ChatGPT to guide the use of TTL ping to determine the target OS with the help of the following prompts:

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Example #1:

Use TTL to identify the operating system running on the target IP address 10.10.1.11

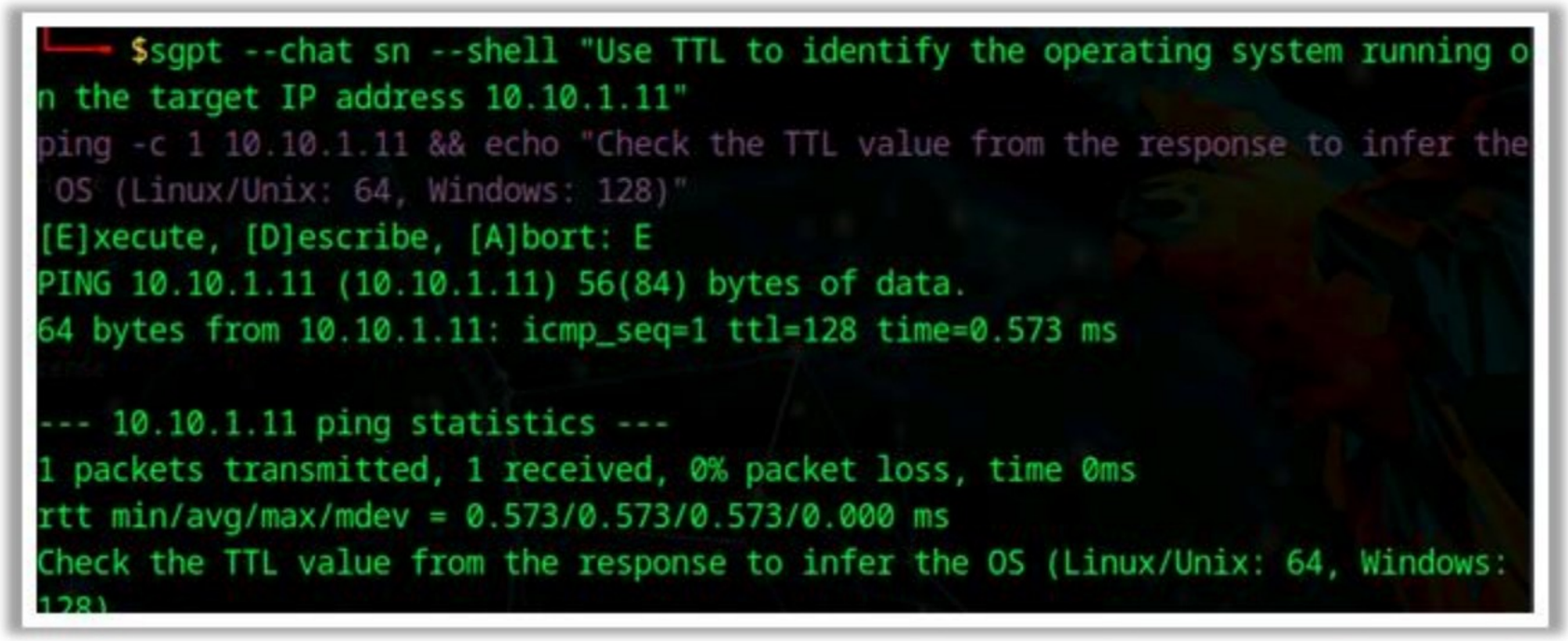


Figure 3.95: Identifying the operating system using TTL value

`ping -c 1 10.10.1.11 && echo "Check the TTL value from the response to infer the OS (Linux/Unix: 64, Windows: 128)"`

Explanation:

- **`ping -c 1 10.10.1.11`**: Initiates a single ICMP echo request to the target IP address (10.10.1.11) to determine its reachability.
- **`&&`**: Indicates that the following command will be executed if the preceding command (ping) is successful.
- **`echo "Check the TTL value from the response to infer the OS (Linux/Unix: 64, Windows: 128)"`**: Displays a message instructing to check the time-to-live (TTL) value from the response to infer the operating system. Typically, TTL values of 64 indicate Linux/Unix systems, while TTL values of 128 indicate Windows systems.

Example #2:

Use TTL to identify the operating system running on the target IP address 10.10.1.9

Figure 3.96: Identifying the operating system running on the target

`ping -c 1 10.10.1.9 | grep "ttl"`

Explanation:

- **`ping -c 1 10.10.1.9`**: Initiates a single ICMP echo request to the target IP address (10.10.1.9) to determine its reachability.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- `| grep "ttl"`: Pipes the output of the ping command to grep, a command-line utility for searching plain-text data for lines that match a regular expression. In this case, it filters the output to display lines containing "ttl", which includes the TTL value of the response packet. This allows for inferring the operating system based on the TTL value as explained earlier.

Example #3:

Attackers can leverage AI-powered technologies to enhance and automate OS discovery tasks. With the aid of AI, attackers can effortlessly identify the operating systems running on target IP addresses on a network.

Attackers can use ChatGPT to guide the use of Nmap script engine by using an appropriate prompt such as:

"Use Nmap script engine to perform OS discovery on the target IP addresses in scan1.txt"

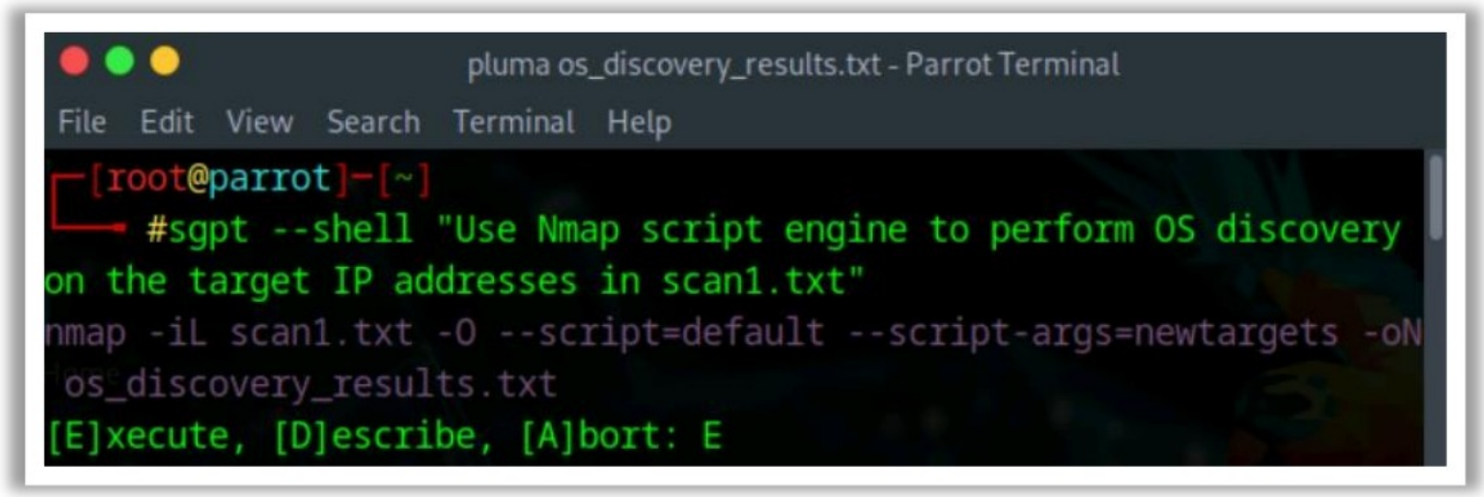


Figure 3.97: Prompt for Nmap script scanning for OS discovery with AI

The following command is designed to execute OS discovery using Nmap script engine on the IP addresses listed in the scan1.txt file:

```
nmap -iL scan1.txt -O --script=default --script-args=newtargets -oN os_discovery_results.txt
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

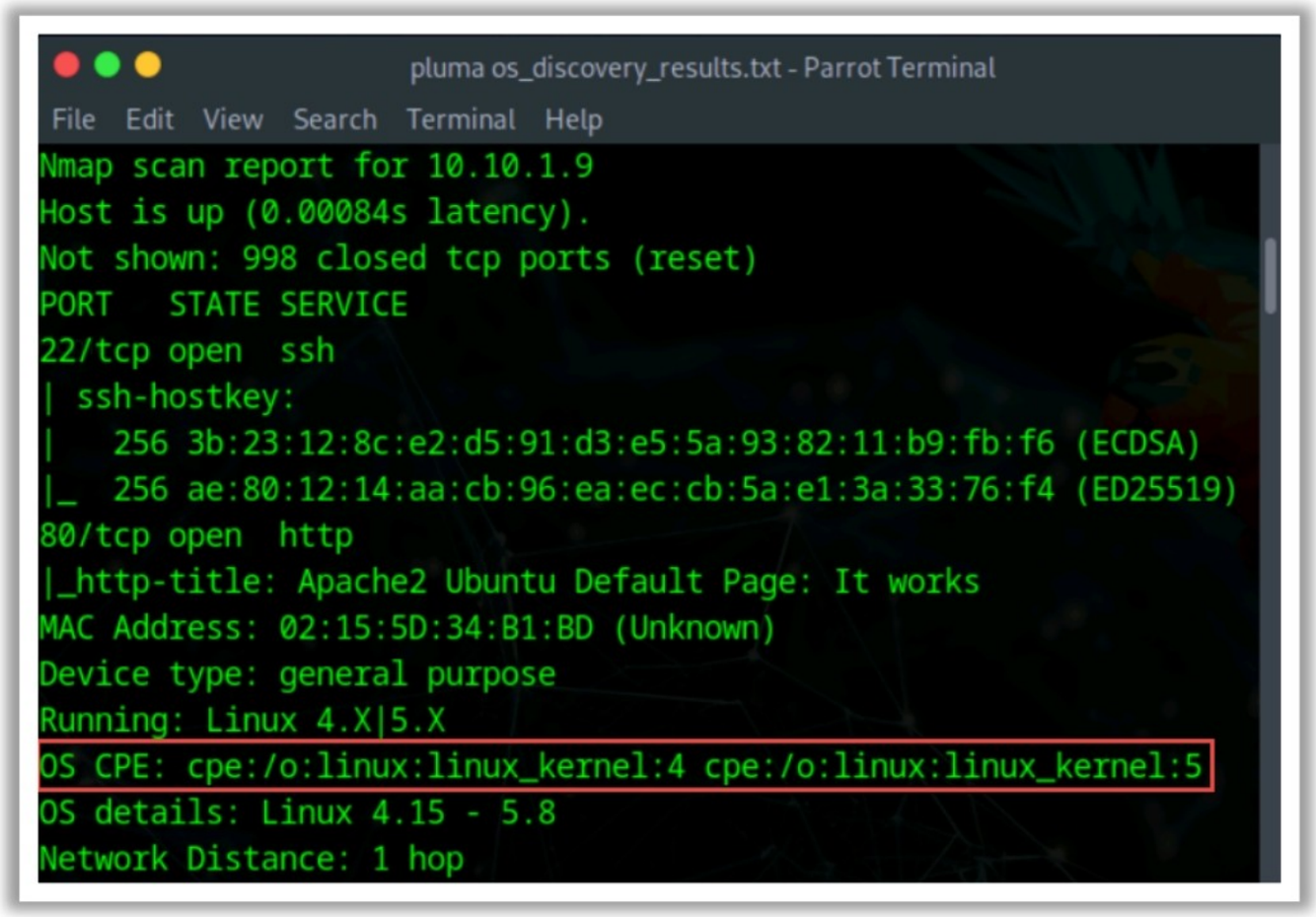


Figure 3.98: Output of nmap scanning for host discovery with AI

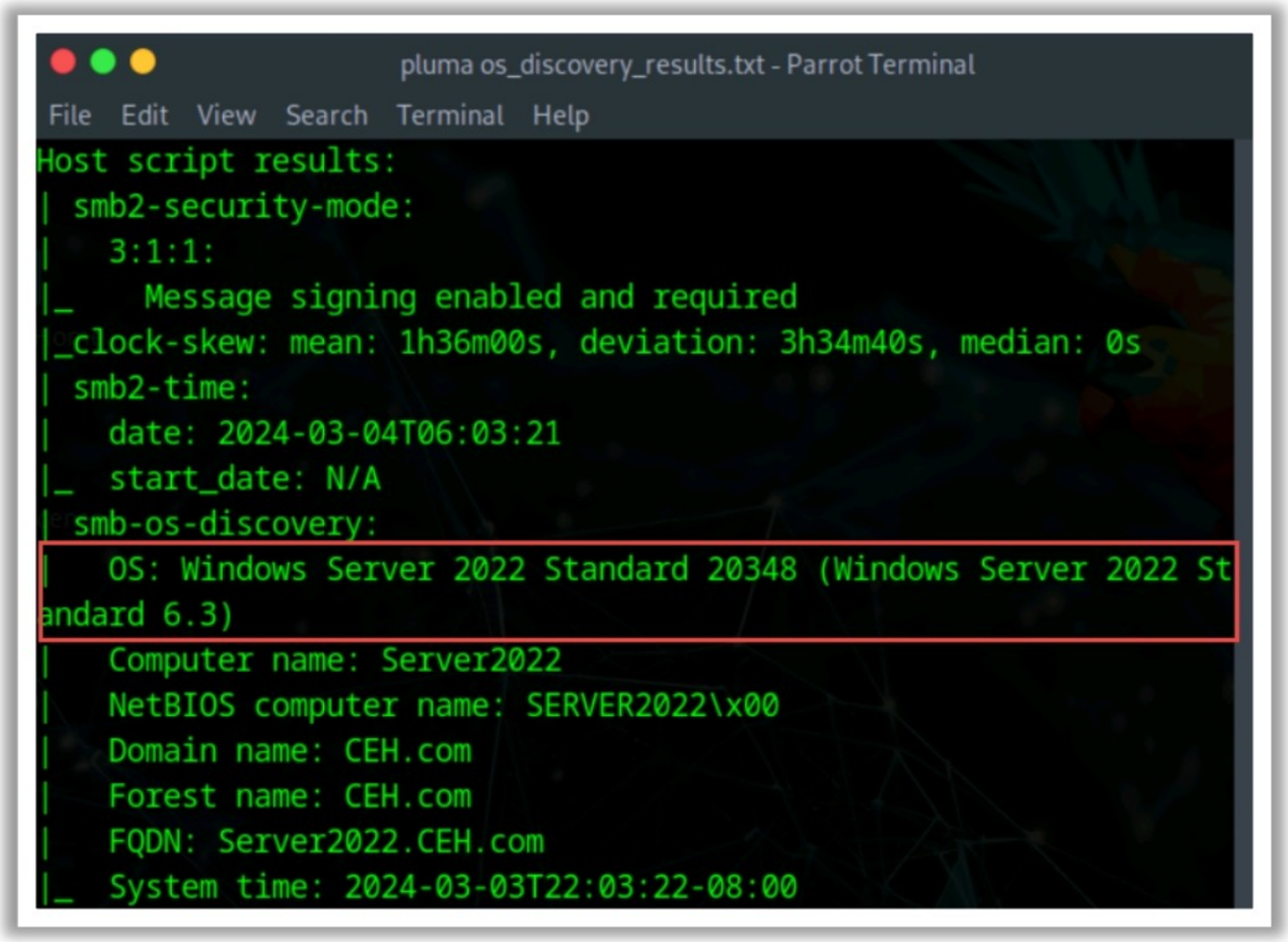


Figure 3.99: Output of nmap scanning for host discovery with AI

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

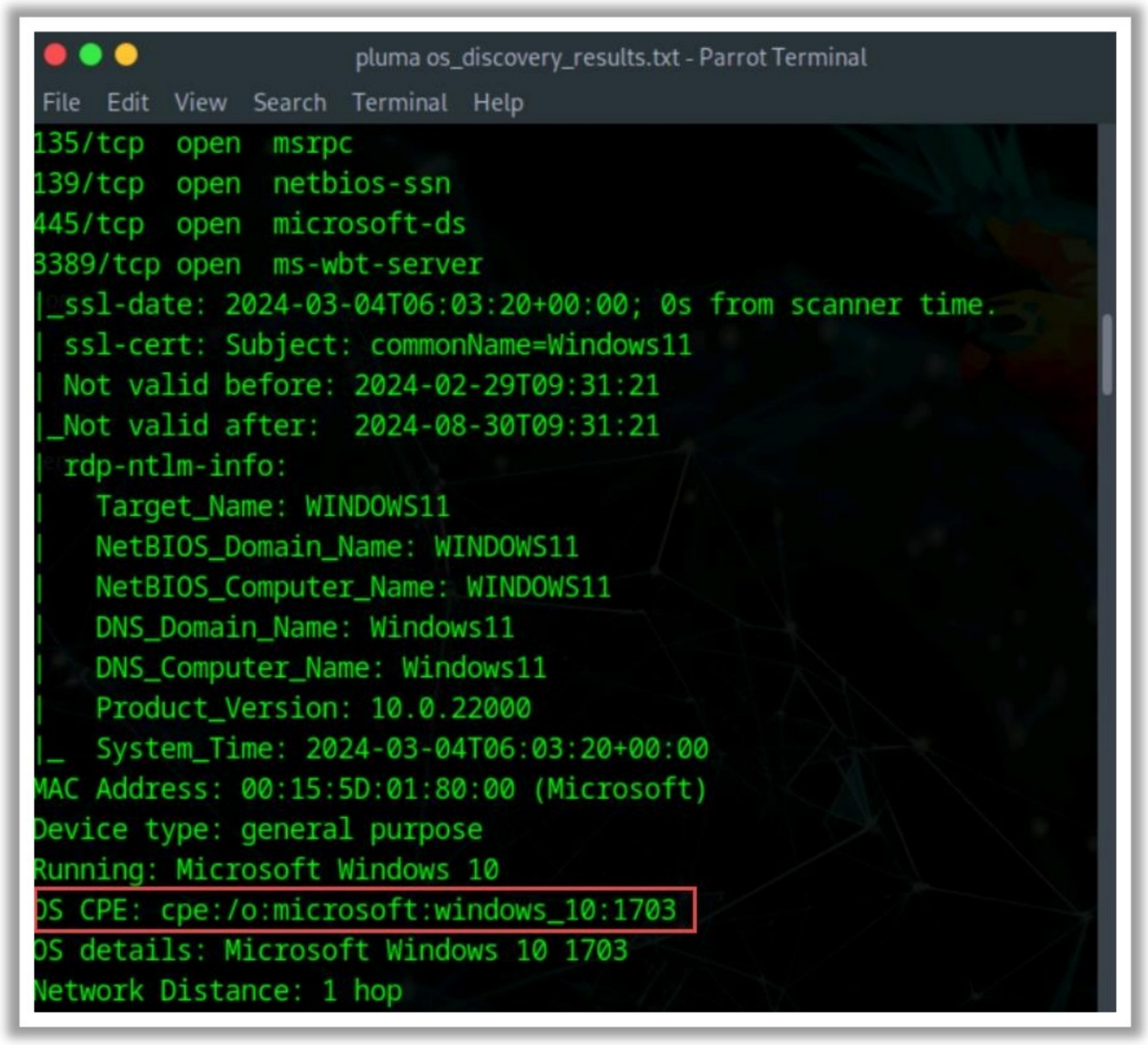


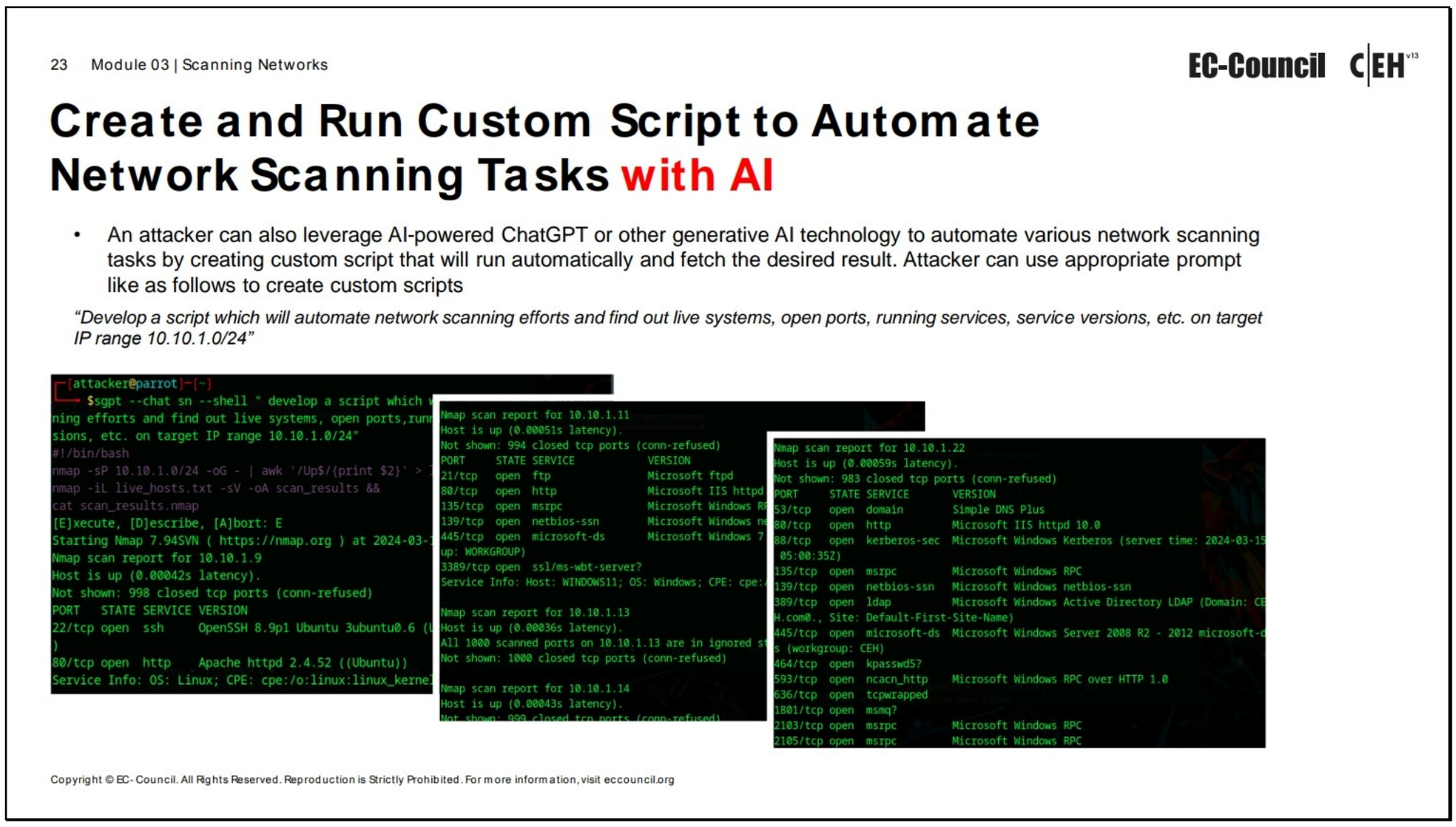
Figure 3.100: Output of nmap scanning for host discovery with AI

Explanation of the command:

- **`nmap`**: Initiates the Nmap tool.
- **`-iL scan1.txt`**: Specifies the input file containing the list of target IP addresses (scan1.txt).
- **-o**: Enables OS detection to identify the operating systems running on the target IP addresses.
- **`--script=default`**: Specifies to run default scripts provided by Nmap.
- **`--script-args=newtargets`**: Instructs Nmap to treat the targets as new and re-scan them, which may improve accuracy in OS detection.
- **`-oN os_discovery_results.txt`**: Specifies the output file to save the OS discovery results.

This command will perform OS discovery using the Nmap script engine on the target IP addresses listed in the scan1.txt file and save the results in the os_discovery_results.txt file.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Create and Run Custom Script to Automate Network Scanning Tasks With AI

Attackers can leverage AI-powered technologies to enhance and automate their network scanning tasks. With the aid of AI, attackers can effortlessly create and run custom network scanning scripts and acquire valuable insights about their targets. By developing such custom scripts, attackers can efficiently execute a series of network scanning commands to gather information about a target domain.

With this script, attackers can discover live systems, open ports, running services, service versions, and more on the target IP ranges.

For instance,

Attackers can use ChatGPT to guide the development of a script by using an appropriate prompt such as:

"Develop a script that will automate network scanning efforts and find out live systems, open ports, running services, service versions, etc. on target IP range 10.10.1.0/24"

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
┌─[attacker@parrot]─[~]
└──$sgpt --chat sn --shell " develop a script which will automate network scan
ning efforts and find out live systems, open ports,running services, service ver
sions, etc. on target IP range 10.10.1.0/24"
#!/bin/bash
nmap -sP 10.10.1.0/24 -oG - | awk '/Up$/{print $2}' > live_hosts.txt &&
nmap -iL live_hosts.txt -sV -oA scan_results &&
cat scan_results.nmap
[E]xecute, [D]escribe, [A]bort: E
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-15 01:00 EDT
Nmap scan report for 10.10.1.9
Host is up (0.00042s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 (Ubuntu Linux; protocol 2.0
)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 3.101: Prompt for nmap scanning for host discovery with AI

The following bash script is designed to automate network scanning efforts on the target IP range 10.10.1.0/24:

```
#!/bin/bash
nmap -sP 10.10.1.0/24 -oG - | awk '/Up$/{print $2}' > live_hosts.txt &&
nmap -iL live_hosts.txt -sV -oA scan_results &&
cat scan_results.nmap
```

```
Nmap scan report for 10.10.1.11
Host is up (0.00051s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT     STATE SERVICE           VERSION
21/tcp   open  ftp               Microsoft ftpd
80/tcp   open  http              Microsoft IIS httpd 10.0
135/tcp  open  msrpc             Microsoft Windows RPC
139/tcp  open  netbios-ssn       Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds      Microsoft Windows 7 - 10 microsoft-ds (workgro
up: WORKGROUP)
3389/tcp open  ssl/ms-wbt-server?
Service Info: Host: WINDOWS11; OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 10.10.1.13
Host is up (0.00036s latency).
All 1000 scanned ports on 10.10.1.13 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 10.10.1.14
Host is up (0.00043s latency).
Not shown: 999 closed tcp ports (conn-refused)
```

Figure 3.102: Output of nmap scanning for host discovery with AI

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Nmap scan report for 10.10.1.22
Host is up (0.00059s latency).
Not shown: 983 closed tcp ports (conn-refused)
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
80/tcp   open  http          Microsoft IIS httpd 10.0
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2024-03-15
 05:00:35Z)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: CE
H.com0., Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds  Microsoft Windows Server 2008 R2 - 2012 microsoft-d
s (workgroup: CEH)
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped
1801/tcp open  msmq?
2103/tcp open  msrpc         Microsoft Windows RPC
2105/tcp open  msrpc         Microsoft Windows RPC
```

Figure 3.103: Output of nmap scanning for host discovery with AI

Explanation of the script:

- The script first utilizes Nmap to perform a ping scan (-sP) on the IP range 10.10.1.0/24 to discover live hosts. The -oG - option is used to output the results in greppable format, which is then piped (|) to awk to extract the IP addresses of live hosts and save them to a file named live_hosts.txt.
- Next, the script uses Nmap again to scan the live hosts listed in live_hosts.txt for open ports and service versions (-sV). The -oA option is used to save the scan results in various formats (normal, XML, and greppable) with the prefix scan_results.
- Finally, the script displays the scan results stored in the scan_results.nmap file using cat.

This bash script automates network scanning efforts and provides detailed information about live systems, open ports, running services, and service versions on the target IP range 10.10.1.0/24.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

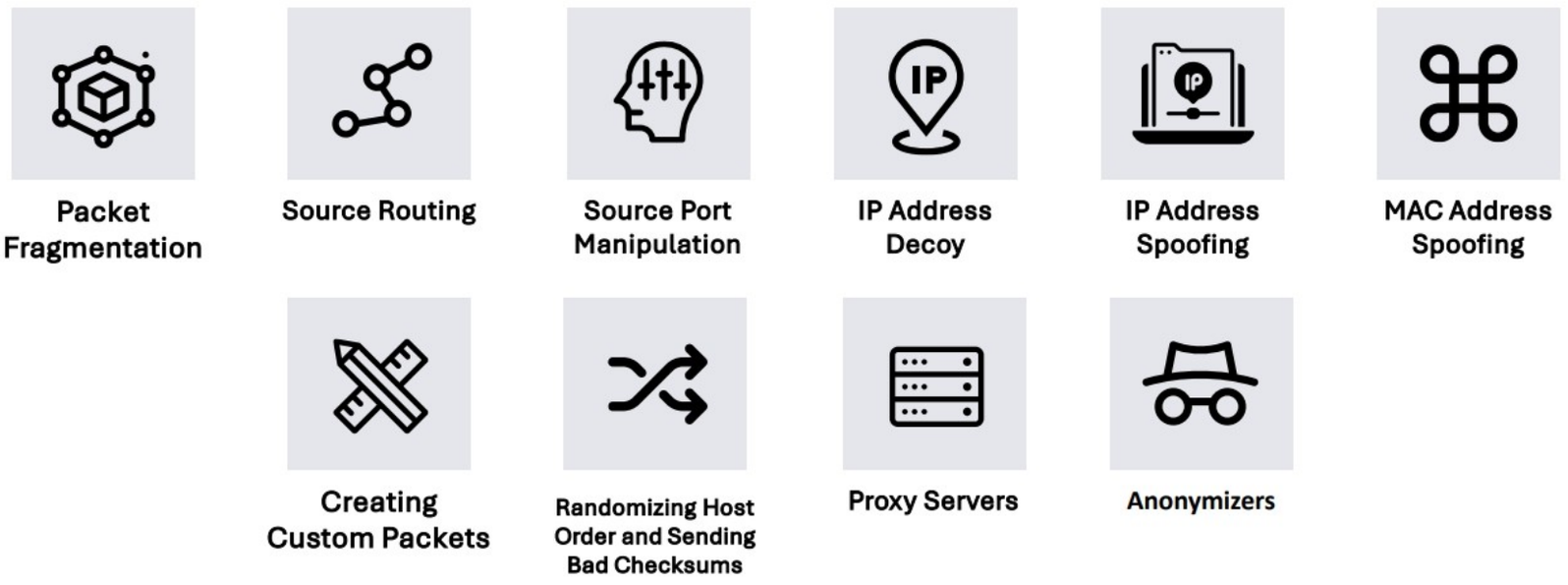
Objective 05

Demonstrate Various Techniques for Scanning Beyond IDS and Firewall

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Scanning Beyond IDS and Firewall

Though firewalls and IDSs can prevent malicious traffic (packets) from entering a network, attackers can manage to **send intended packets to the target** by **evading an IDS or firewall** through the following techniques:



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Scanning Beyond IDS and Firewall

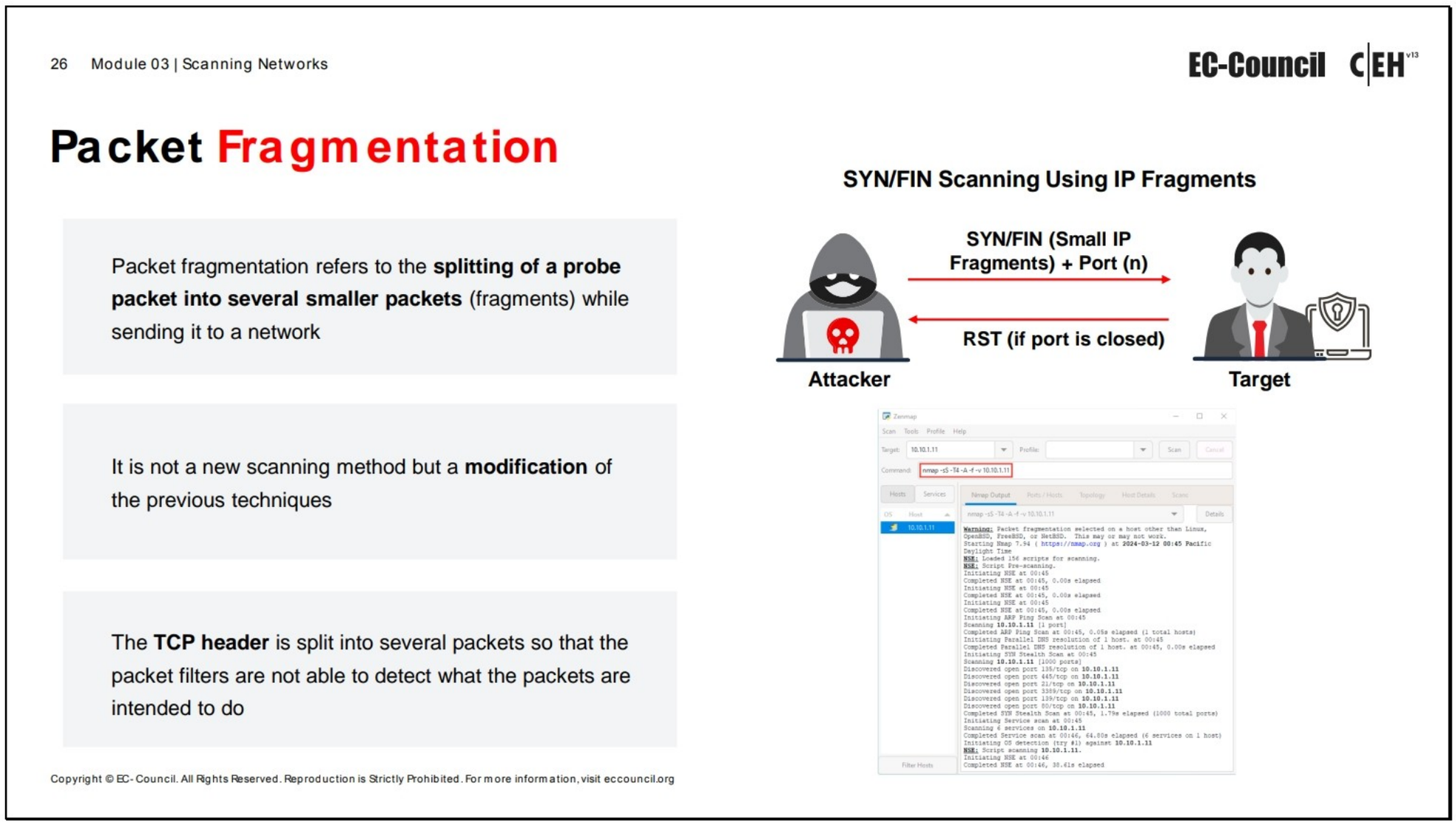
Intrusion detection systems (IDS) and firewalls are security mechanisms intended to prevent an attacker from accessing a network. However, even IDS and firewalls have some security limitations. Attackers try to launch attacks to exploit these limitations. This section highlights various IDS/firewall evasion techniques such as packet fragmentation, source routing, IP address spoofing, etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Although firewalls and IDS can prevent malicious traffic (packets) from entering a network, attackers can send intended packets to the target that evade the IDS/firewall by implementing the following techniques:

- Packet Fragmentation
- Source Routing
- Source Port Manipulation
- IP Address Decoy
- IP Address Spoofing
- MAC Address Spoofing
- Creating Custom Packets
- Randomizing Host Order
- Sending Bad Checksums
- Proxy Servers
- Anonymizers

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Packet Fragmentation

Packet fragmentation refers to the splitting of a probe packet into several smaller packets (fragments) while sending it to a network. When these packets reach a host, the IDS and firewalls behind the host generally queue all of them and process them one by one. However, since this method of processing involves greater CPU and network resource consumption, the configuration of most IDS cause them to skip fragmented packets during port scans.

Therefore, attackers use packet fragmentation tools such as Nmap to split the probe packet into smaller packets that circumvent the port-scanning techniques employed by IDS. Once these fragments reach the destined host, they are reassembled to form a single packet.

SYN/FIN Scanning Using IP Fragments

SYN/FIN scanning using IP fragments is not a new scanning method but a modification of previous techniques. This process of scanning was developed to avoid false positives generated by other scans because of a packet filtering device on the target system. The TCP header splits into several packets to evade the packet filter. For any transmission, every TCP header must have the source and destination port for the initial packet (8-octet, 64-bit). The initialized flags in the next packet allow the remote host to reassemble the packets upon receipt via an Internet protocol module that detects the fragmented data packets using field-equivalent values of the source, destination, protocol, and identification.

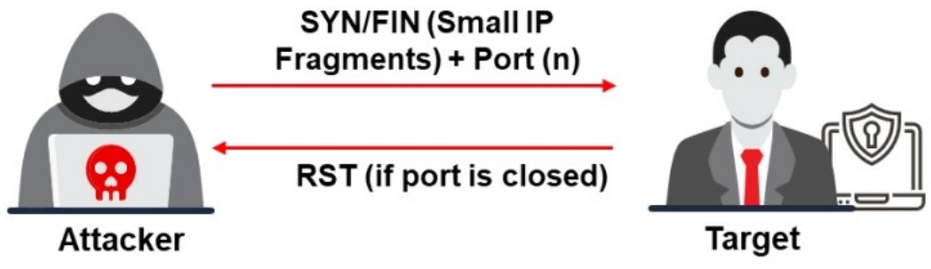


Figure 3.104: SYN/FIN scanning

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

In this scan, the system splits the TCP header into several fragments and transmits them over the network. However, IP reassembly on the server side may result in unpredictable and abnormal results, such as fragmentation of the IP header data. Some hosts may fail to parse and reassemble the fragmented packets, which may lead to crashes, reboots, or even network device monitoring dumps.

Some firewalls might have rule sets that block IP fragmentation queues in the kernel (e.g., CONFIG_IP_ALWAYS_DEFRAG option in the Linux kernel), although this is not widely implemented because of its adverse effects on performance. Since many IDS use signature-based methods to indicate scanning attempts on IP and/or TCP headers, the use of fragmentation will often evade this type of packet filtering and detection, resulting in a high probability of causing problems on the target network. Attackers use the SYN/FIN scanning method with IP fragmentation to evade this type of filtering and detection.

The screenshot below shows the SYN/FIN scan using the Zenmap tool.

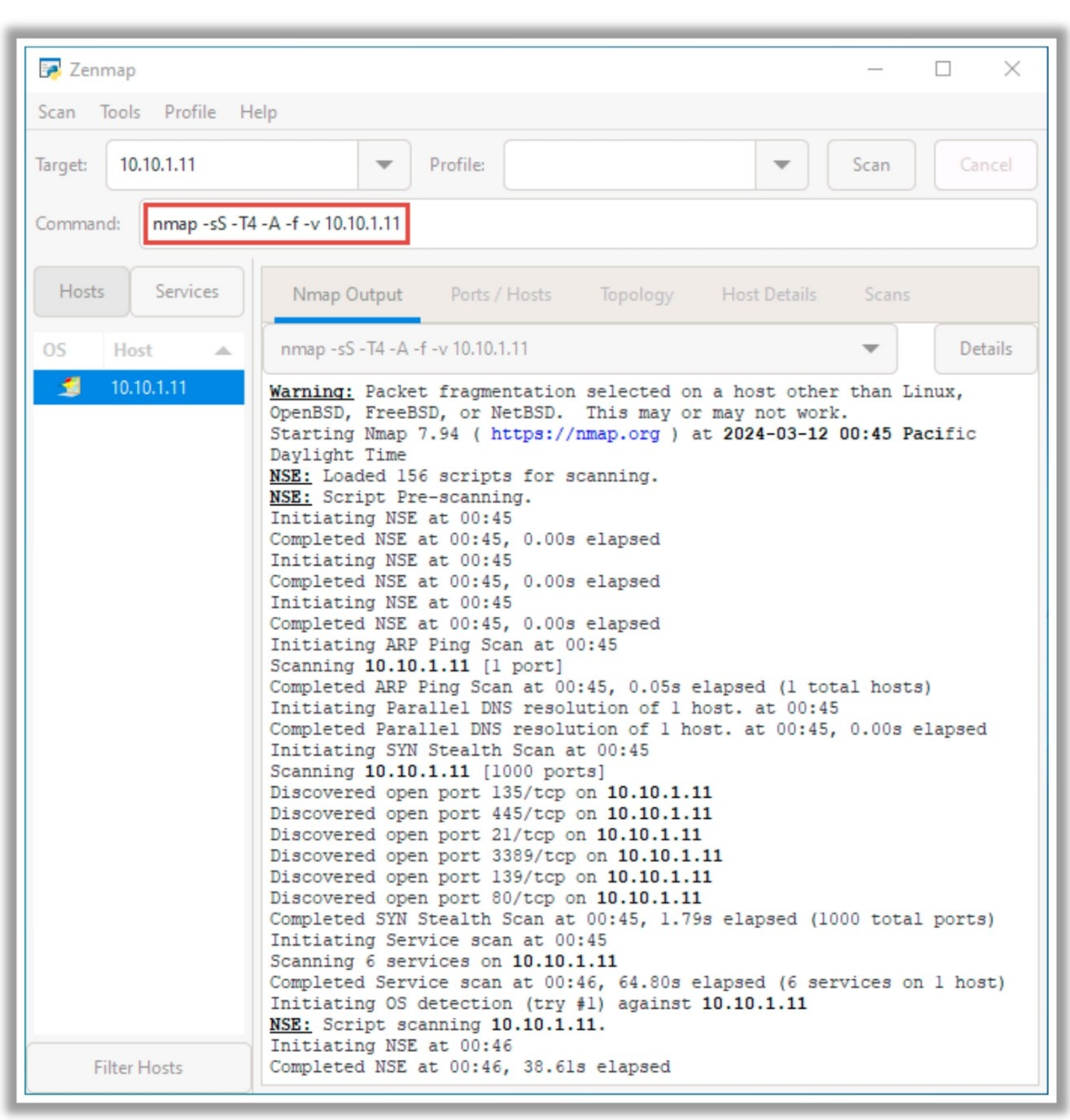


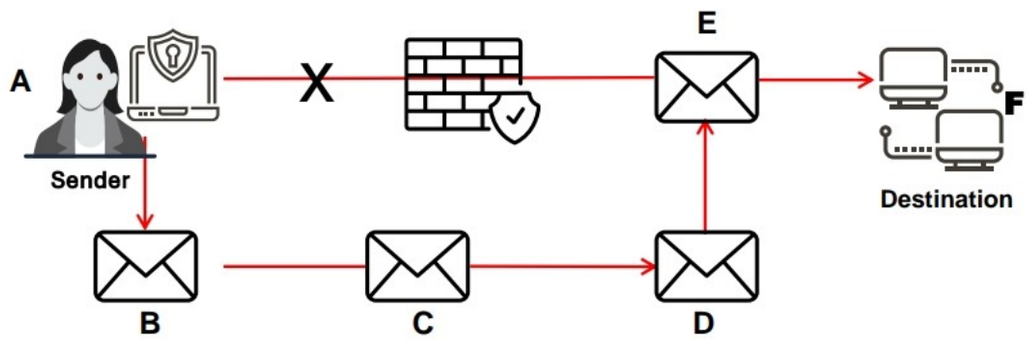
Figure 3.105: SYN/FIN scan using Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Source Routing

- As the packet travels through the nodes in the network, each **router examines** the destination IP address and **chooses the next hop** to direct the packet to the destination
- Source routing refers to sending a packet to the intended destination with a partially or completely **specified route** (without firewall-/IDS-configured routers) in order to evade an IDS or firewall
- In source routing, the **attacker** makes some or all of these decisions on the router

This figure shows source routing, where the originator dictates the eventual route of the traffic



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Source Routing

An IP datagram contains various fields, including the IP options field, which stores source routing information and includes a list of IP addresses through which the packet travels to its destination. As the packet travels through the nodes in the network, each router examines the destination IP address and chooses the next hop to direct the packet to the destination.

When attackers send malformed packets to a target, these packets hop through various routers and gateways to reach the destination. In some cases, the routers in the path might include configured firewalls and IDS that block such packets. To avoid them, attackers enforce a loose or strict source routing mechanism, in which they manipulate the IP address path in the IP options field so that the packet takes the attacker-defined path (without firewall-/IDS-configured routers) to reach the destination, thereby evading firewalls and IDS.

The figure below shows source routing, where the originator dictates the eventual route of the traffic.

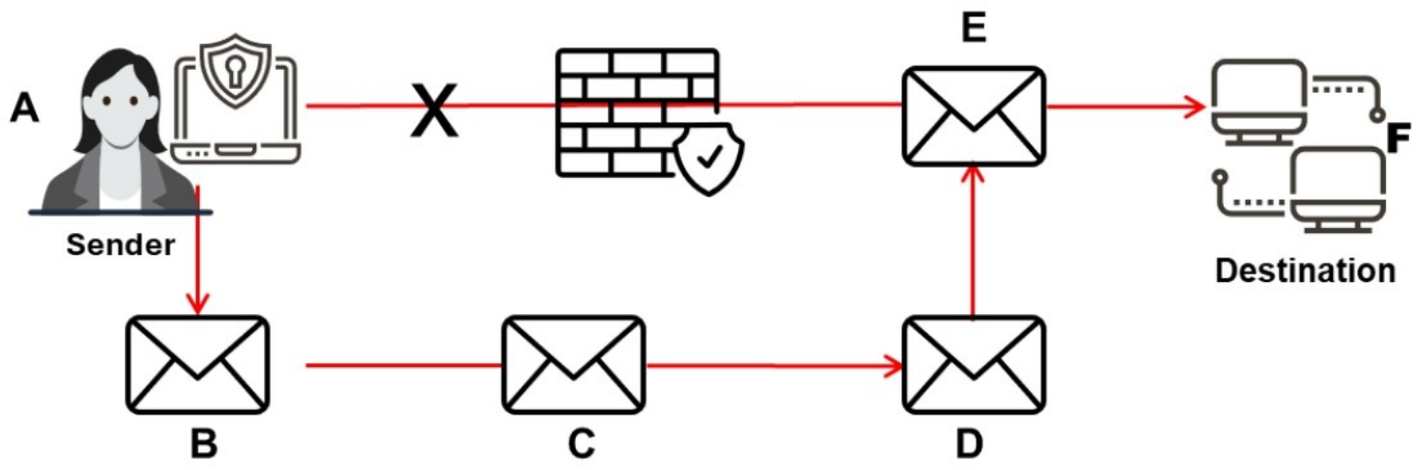
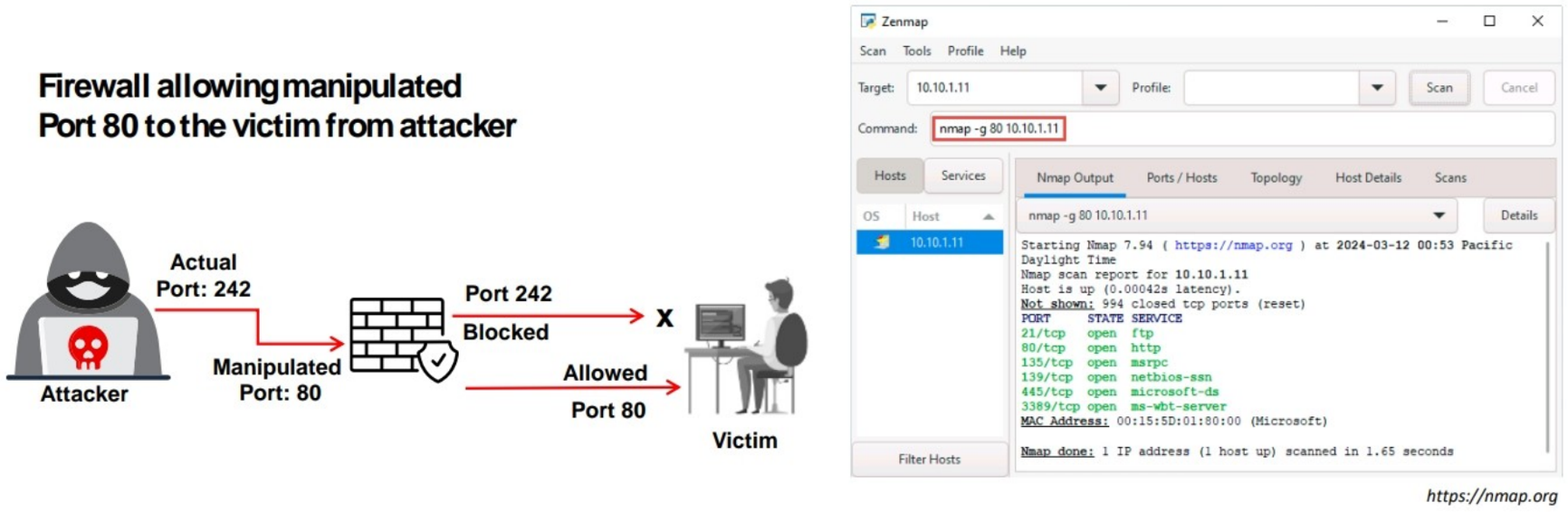


Figure 3.106: Source Routing

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Source Port Manipulation

- Source port manipulation refers to **manipulating actual port numbers with common port numbers** in order to evade an IDS or firewall
- It occurs when a firewall is **configured to allow packets** from well-known ports like HTTP, DNS, FTP, etc.
- **Nmap** uses the **-g** or **--source-port** options to perform source port manipulation



https://nmap.org

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Source Port Manipulation

Source port manipulation is a technique used for bypassing the IDS/firewall, where the actual port numbers are manipulated with common port numbers for evading certain IDS and firewall rules. The main security misconfigurations occur because of blindly trusting the source port number. The administrator mostly configures the firewall by allowing the incoming traffic from well-known ports such as HTTP, DNS, FTP, etc. The firewall can simply allow the incoming traffic from the packets sent by the attackers using such common ports.

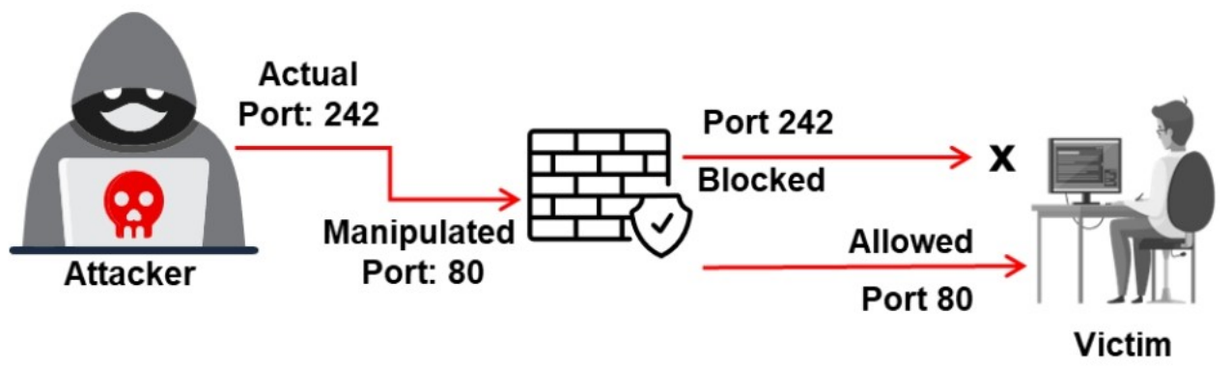


Figure 3.107: Firewall allowing manipulated port 80 to the victim from attacker

Although the firewalls can be made secure using application-level proxies or protocol-parsing firewall elements, this technique helps the attacker to bypass the firewall rules easily. The attacker tries to manipulate the original port number with the common port numbers, which can easily bypass the IDS/firewall. In Zenmap, the **`-g`** or **`--source-port`** option is used to perform source port manipulation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

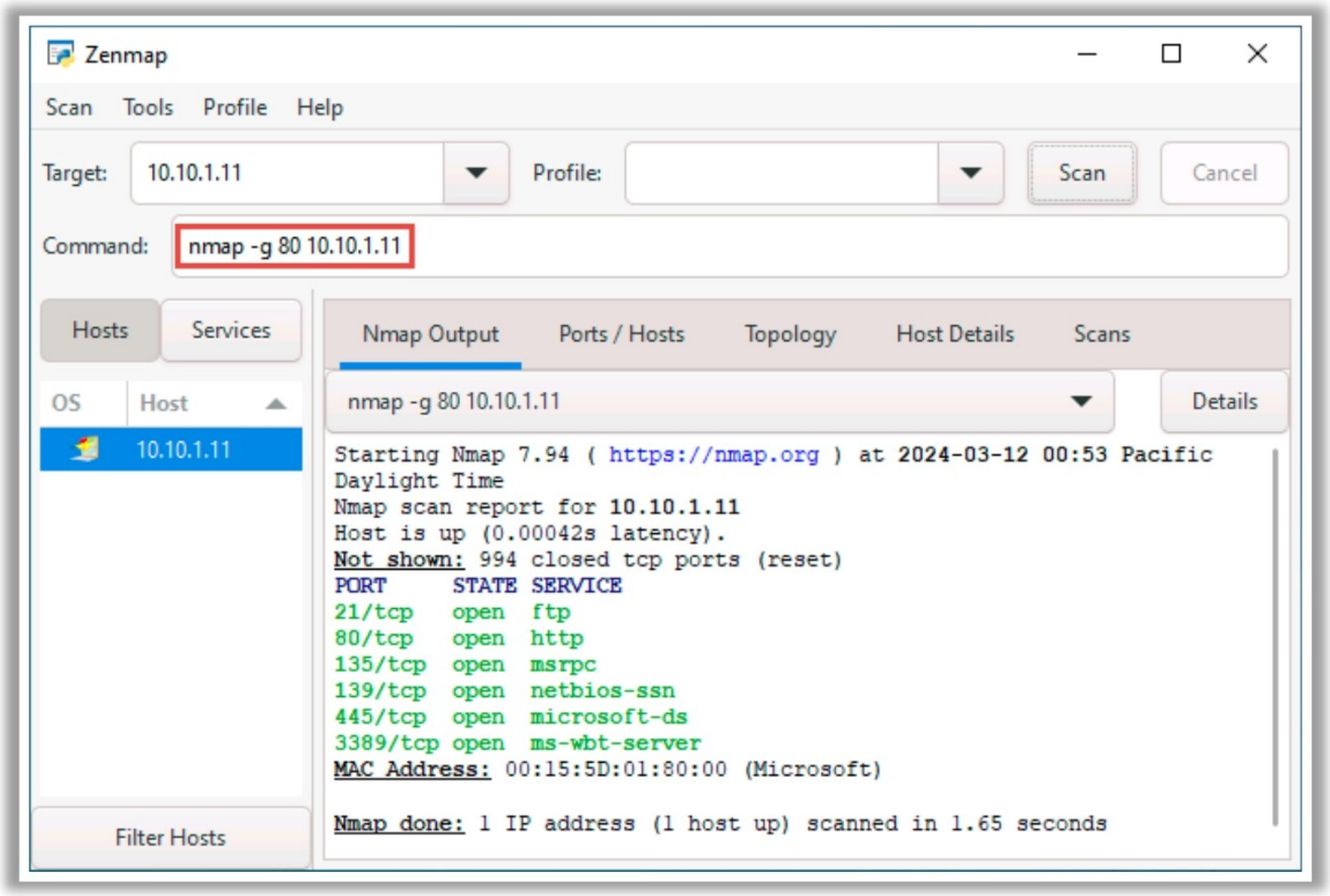


Figure 3.108: Scanning over Firewall using Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

IP Address Decoy

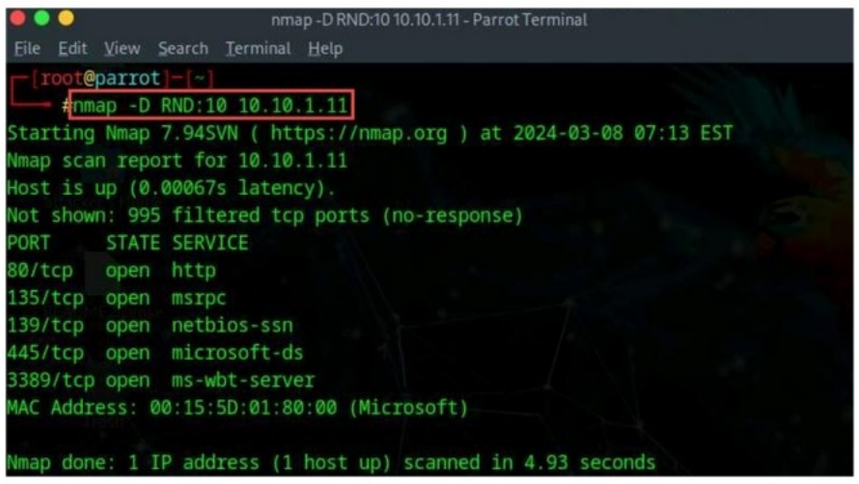
- IP address decoy technique refers to **generating or manually specifying the IP addresses of decoys** in order to evade an IDS or firewall
- It appears to the target that the **decoys as well as the host(s)** are scanning the network
- This technique makes it **difficult for the IDS or firewall to determine** which IP address was actually scanning the network and which IP addresses were decoys

Decoy Scanning using Nmap

Nmap has two options for decoy scanning:

`nmap -D RND:10 [target]`
(Generates a random number of decoys)

`nmap -D decoy1,decoy2,decoy3,..` etc.
(Manually specify the IP addresses of the decoys)



https://nmap.org

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

IP Address Decoy

The IP address decoy technique refers to generating or manually specifying IP addresses of the decoys to evade IDS/firewalls. It appears to the target that the decoys as well as the host(s) are scanning the network. This technique makes it difficult for the IDS/firewall to determine which IP address is actually scanning the network and which IP addresses are decoys.

The Nmap scanning tool comes with a built-in scan function called a decoy scan, which cloaks a scan with decoys. This technique generates multiple IP addresses to perform a scan, thus making it difficult for the target security mechanisms such as IDS, firewalls, etc., to identify the original source from the registered logs. The target IDS might report scanning from 5– 0 IP addresses; however, it cannot differentiate between the actual scanning IP address and the innocuous decoy IPs.

You can perform two types of decoy scans using Nmap:

- **nmap -D RND:10 [target]**

  Using this command, Nmap automatically generates a random number of decoys for the scan and randomly positions the real IP address between the decoy IPs.

  Ex. Assume that 10.10.10.10 is the target IP address to be scanned. Thus, the Nmap decoy scan command will be:

  `# nmap -D RND: 10 10.10.10.10`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

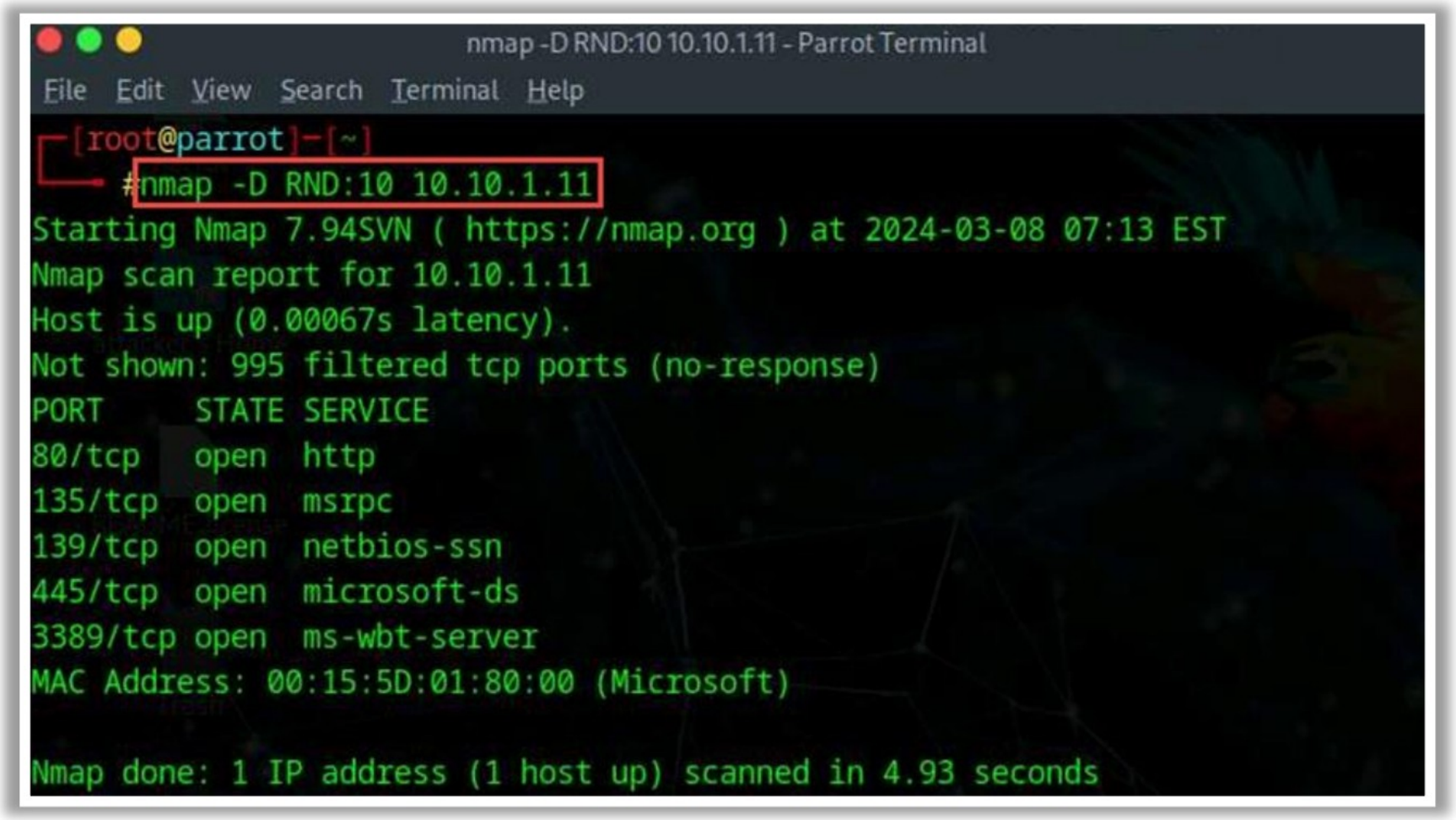


Figure 3.109: Decoy using Nmap RND option

- **nmap -D decoy1,decoy2,decoy3,...,ME,... [target]**

  Using this command, you can manually specify the IP addresses of the decoys to scan the victim's network. Here, you have to separate each decoy IP with a comma (,) and you can optionally use the ME command to position your real IP in the decoy list. If you place ME in the 4th position of the command, your real IP will be positioned at the 4th position accordingly. This is an optional command, and if you do not mention ME in your scan command, then Nmap will automatically place your real IP in any random position.

  For example, assume that 10.10.1.19 is the real source IP and 10.10.1.11 is the target IP address to be scanned. Then, the Nmap decoy command will be:

  Syntax:

  ```
  # nmap -D 192.168.0.1,172.120.2.8,192.168.2.8,10.10.1.19,10.10.1.5
  10.10.1.11
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

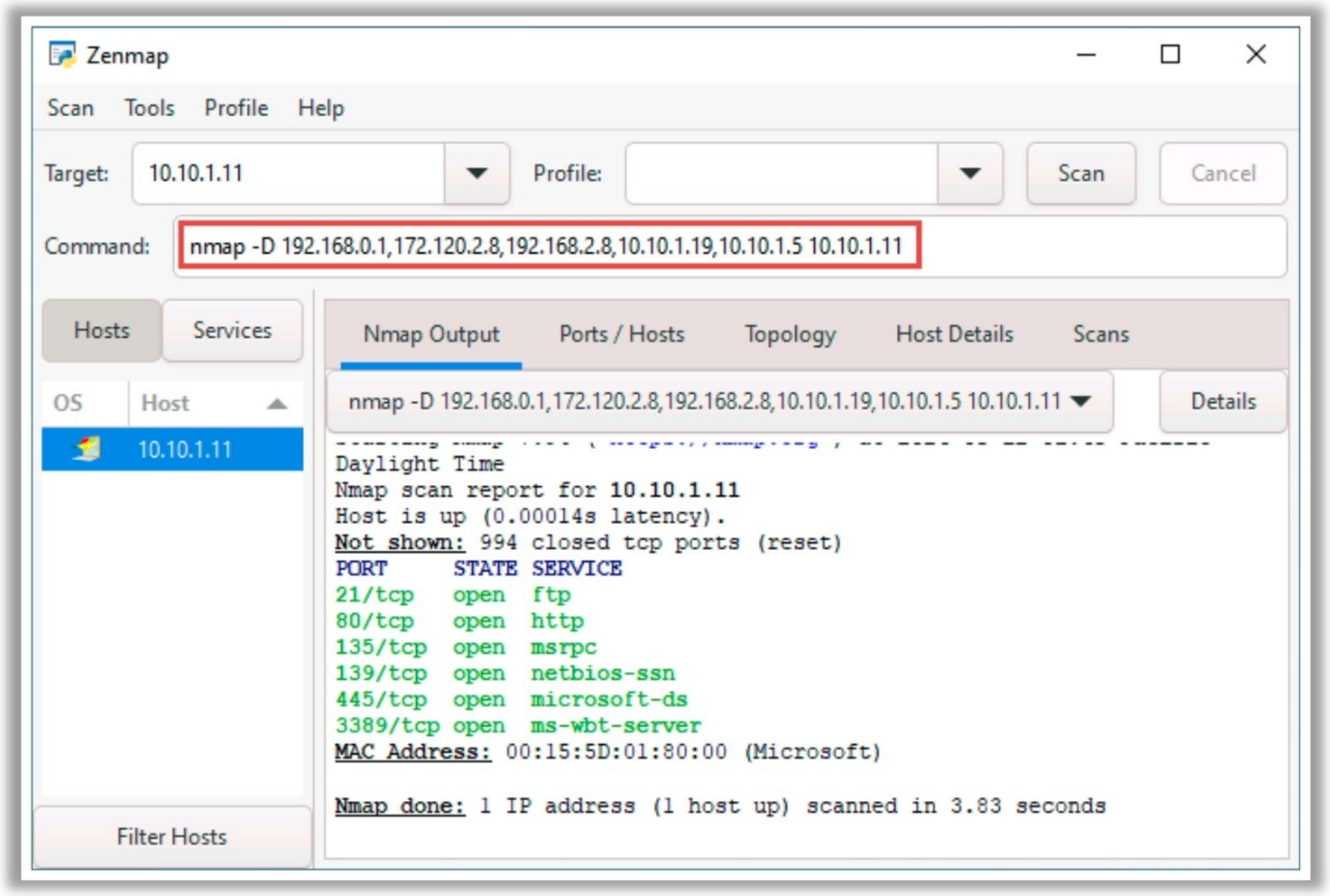


Figure 3.110: Decoy using Nmap with manual decoy list

These decoys can be generated in both initial ping scans such as ICMP, SYN, ACK, etc., and during the actual port scanning phase.

IP address decoy is a useful technique for hiding your IP address. However, it will not be successful if the target employs active mechanisms such as router path tracing, response dropping, etc. Moreover, using many decoys can slow down the scanning process and affect the accuracy of the scan.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

IP Address Spoofing

- IP spoofing refers to **changing the source IP addresses** so that the attack **appears to be coming from someone else**
- When the victim replies to the address, it goes back to the **spoofed address** rather than the **attacker's real address**
- Attackers modify the **address information** in the IP packet header and the source address bits field in order to bypass the IDS or firewall

Note: You will not be able to complete the three-way handshake and open a successful TCP connection with spoofed IP addresses

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

IP Address Spoofing

Most firewalls filter packets based on the source IP address. These firewalls examine the source IP address and determine whether the packet is coming from a legitimate source or an illegitimate source. The IDS filters packets from illegitimate sources. Attackers use IP spoofing technique to bypass such IDS/firewalls.

IP address spoofing is a hijacking technique in which an attacker obtains a computer's IP address, alters the packet headers, and sends request packets to a target machine, pretending to be a legitimate host. The packets appear to be sent from a legitimate machine but are actually sent from the attacker's machine, while his/her machine's IP address is concealed. When the victim replies to the address, it goes back to the spoofed address and not to the attacker's real address. Attackers mostly use IP address spoofing to perform DoS attacks.

When the attacker sends a connection request to the target host, the target host replies to the spoofed IP address. When spoofing a nonexistent address, the target replies to a nonexistent system and then hangs until the session times out, thus consuming a significant amount of its own resources.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

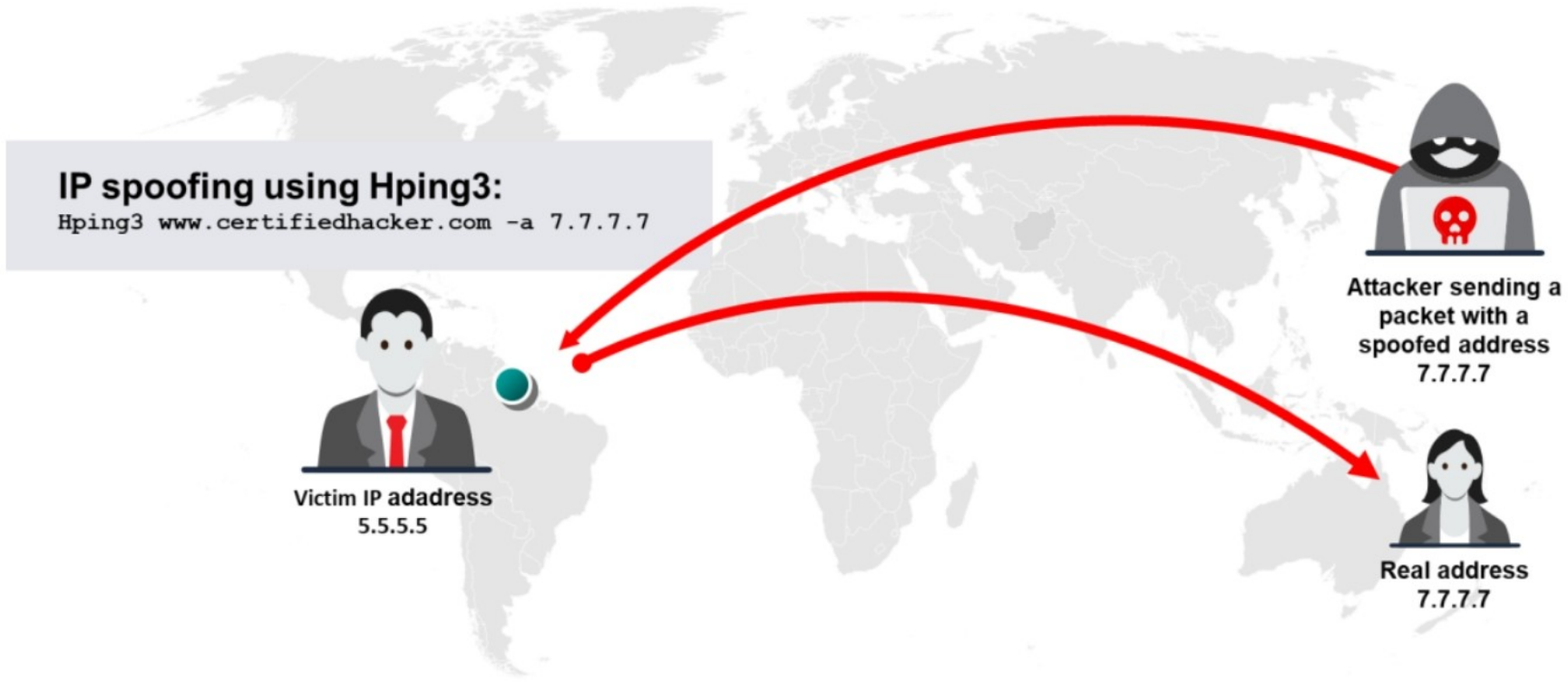


Figure 3.111: IP Spoofing using Hping3

IP spoofing using Hping3:

```
Hping3 www.certifiedhacker.com -a 7.7.7.7
```

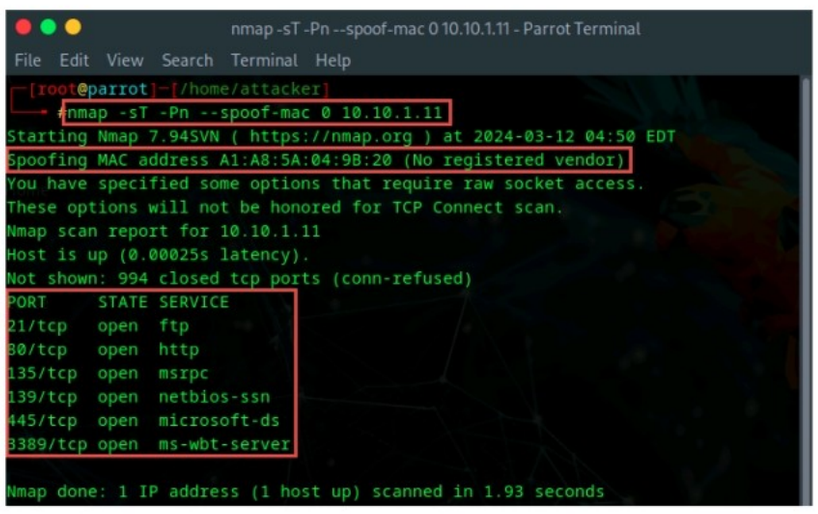
You can use Hping3 to perform IP spoofing. The above command helps you to send arbitrary TCP/IP packets to network hosts.

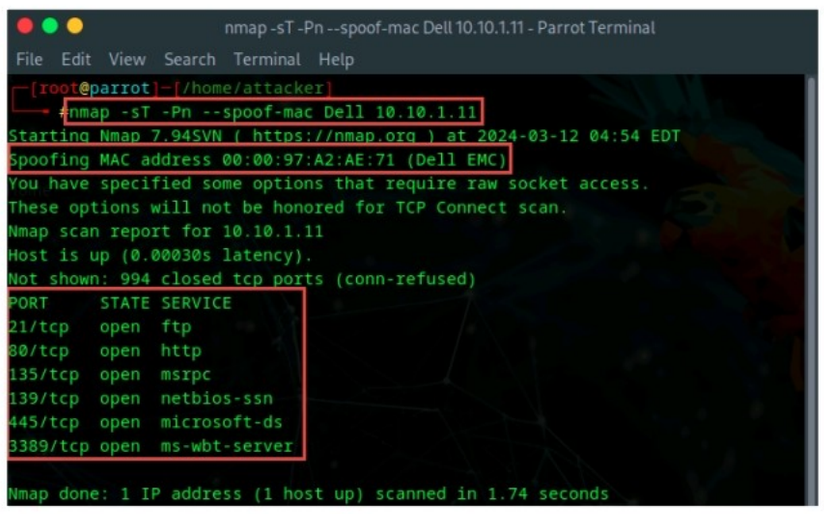
Note: You will not be able to complete the three-way handshake and open a successful TCP connection with spoofed IP addresses.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

MAC Address Spoofing

- The MAC address spoofing technique involves spoofing a MAC address with the MAC address of a legitimate user on the network
- Attackers use the **--spoof-mac** Nmap option to set a specific MAC address for the packets to evade firewalls





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

MAC Address Spoofing

Network firewalls filter packets based on the source media access control (MAC) address. They examine the MAC address in the packet header and determine whether the packets originate from a legitimate source. Firewalls allow traffic from specific sources using MAC filtering rules and restrict packets that do not satisfy the filtering rules. To avoid these restrictions, attackers use MAC spoofing techniques, in which they employ fake MAC addresses and masquerade as legitimate users to scan the hosts located behind the firewall.

The MAC address spoofing technique allows attackers to send request packets to the target machine/network, pretending to be a legitimate host. Attackers use the Nmap tool to evade firewalls via MAC address spoofing.

Performing MAC Address Spoofing to Scan Beyond IDS and Firewall Using Nmap:

Attackers use the **`--spoof-mac`** Nmap option to choose or set a specific MAC address for packets and send them to the target system/network.

- **`nmap -sT -Pn --spoof-mac 0 [Target IP]`**

  The above command automatically generates a random MAC address and attaches it to the packets in place of the original MAC address while performing host scanning. Here, **`--spoof-mac 0`** represents the randomization of the MAC address.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

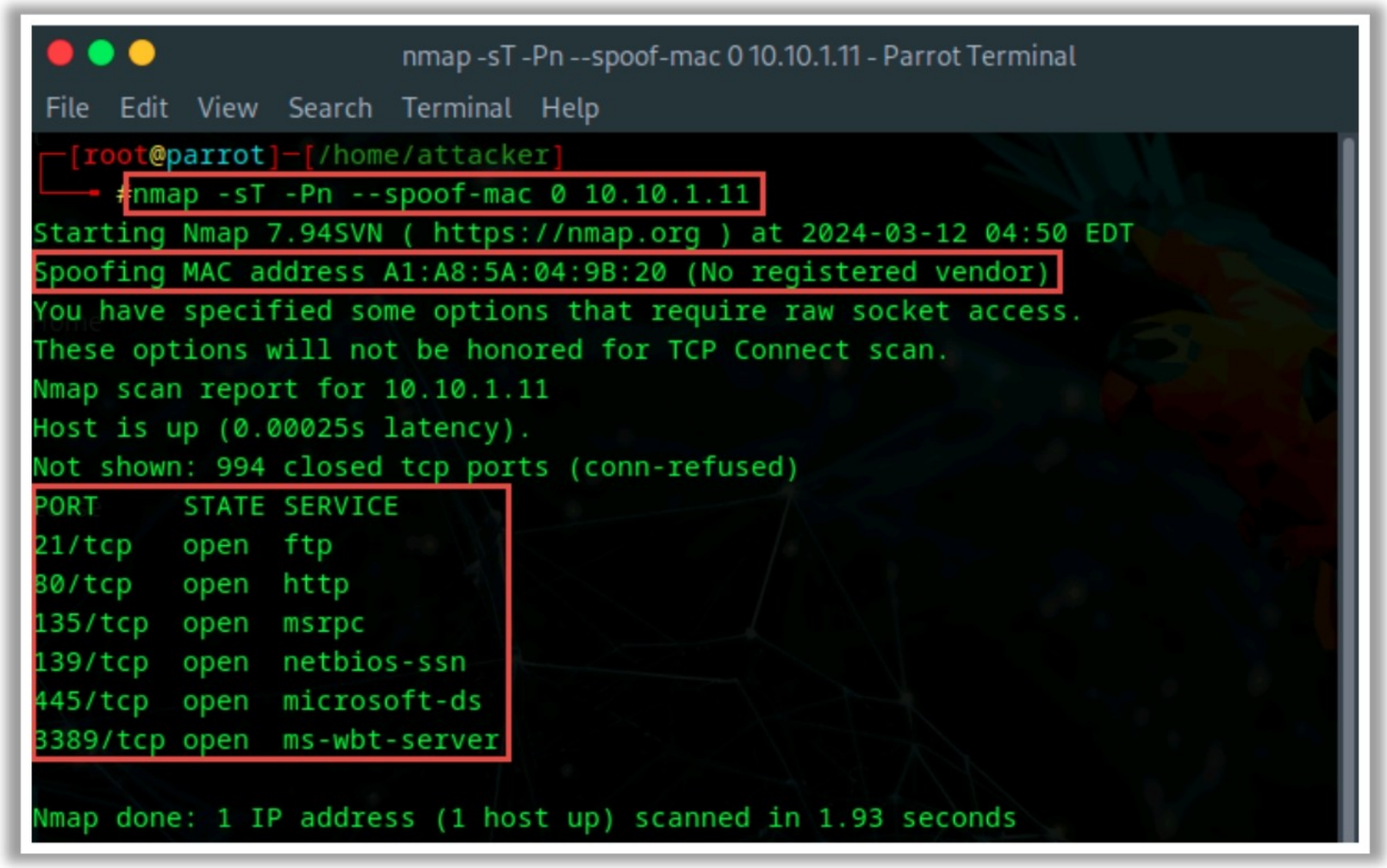


Figure 3.112: Screenshot of scanning using the Nmap –spoof-mac 0 option

- **`nmap -sT -Pn --spoof-mac [Vendor] [Target IP]`**

  The above command allows attackers to opt for a MAC address from the vendor and spoof it by attaching it to the packets in place of the original MAC address during the scan. This type of scan allows attackers to scan in the hidden mode, as the original MAC address is not recorded in the firewall logs. **`--spoof-mac [vendor]`** represents the randomization of the MAC address based on the specified vendor.

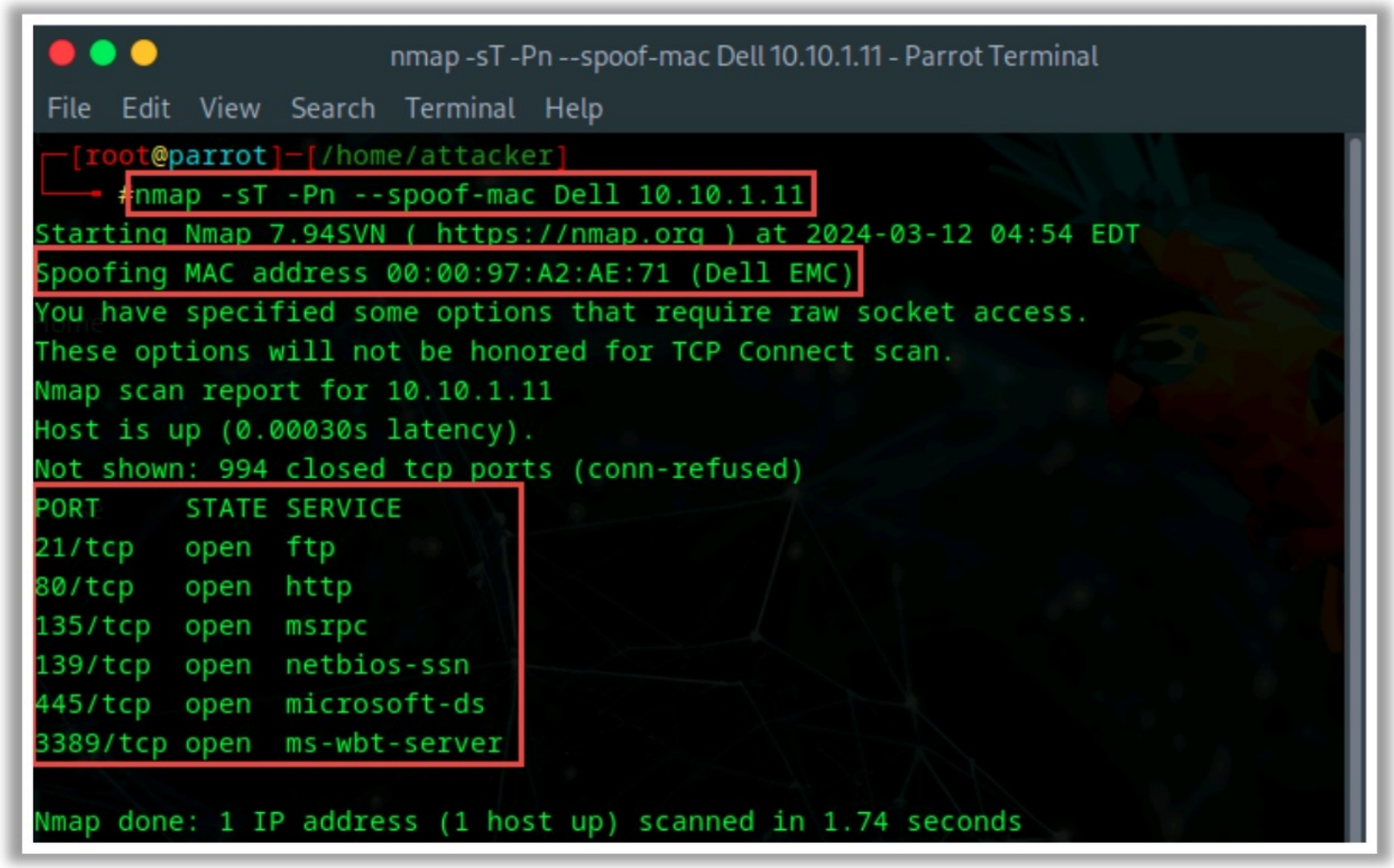


Figure 3.113: Scanning using the Nmap –spoof-mac [Vendor] option

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **`nmap -sT -Pn --spoof-mac [new MAC] [Target IP]`**

  The above command allows attackers to manually choose or set a new MAC address for the packets sent during the scanning process. **`--spoof-mac [new MAC]`** represents manually setting the MAC address.

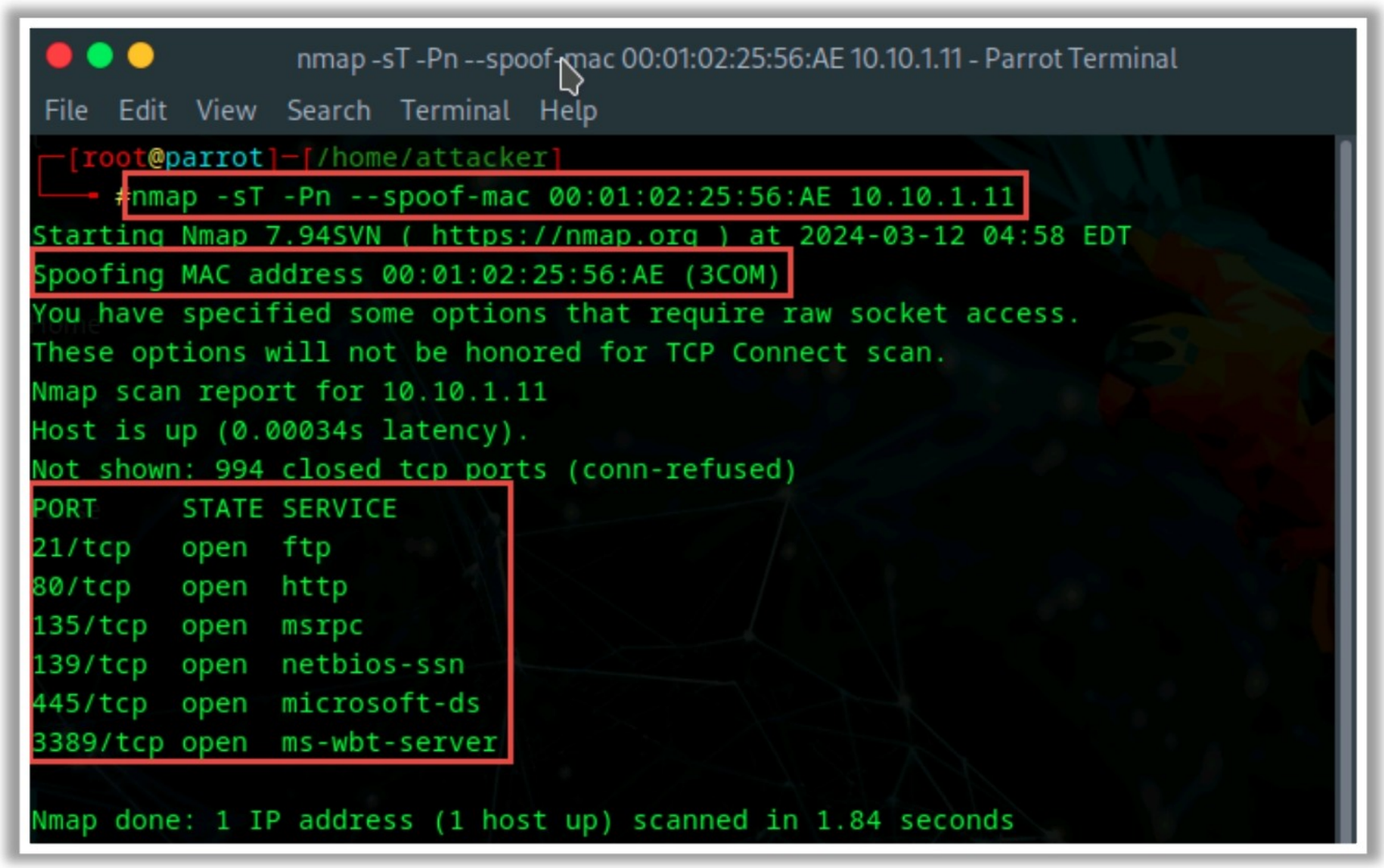


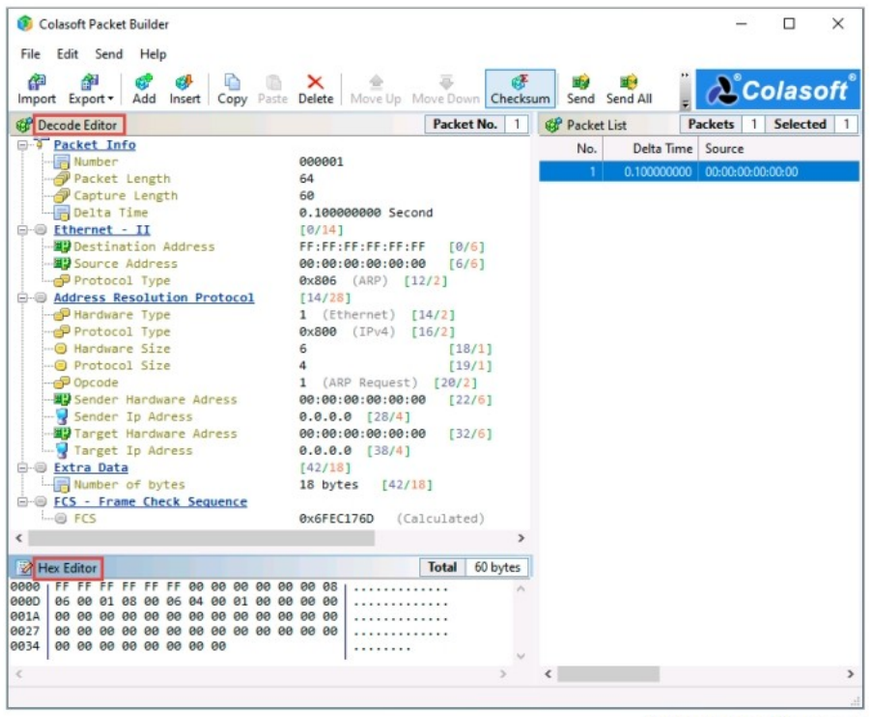
Figure 3.114: Scanning using the Nmap –spoof-mac [new MAC] option

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Creating Custom Packets

Creating Custom Packets by using Packet Crafting Tools

- Attackers **create custom TCP packets** using various packet crafting tools like **Colasoft Packet Builder**, **NetScanTools Pro**, etc. to scan a target beyond a firewall



https://www.colasoft.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Creating Custom Packets

The attacker creates and sends custom packets to scan the intended target beyond the IDS/firewalls. Various techniques are used to create custom packets. Some of them are mentioned below:

- **Creating Custom Packets by using Packet Crafting Tools**

  Attackers create custom TCP packets to scan the target by bypassing the firewalls. Attackers use various packet crafting tools such as Colasoft packet builder (*https://www.colasoft.com*), NetScanTools Pro (*https://www.netscantools.com*), etc., to scan the target that is beyond the firewall. Packet crafting tools craft and send packet streams (custom packets) using different protocols at different transfer rates.

  - **Colasoft Packet Builder**

    Source: *https://www.colasoft.com*

    Colasoft Packet Builder is a tool that allows an attacker to create custom network packets and helps security professionals assess the network. The attacker can select a TCP packet from the provided templates and change the parameters in the decoder, hexadecimal, or ASCII editor to create a packet. In addition to building packets, Colasoft Packet Builder supports saving packets to packet files and sending packets to the network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

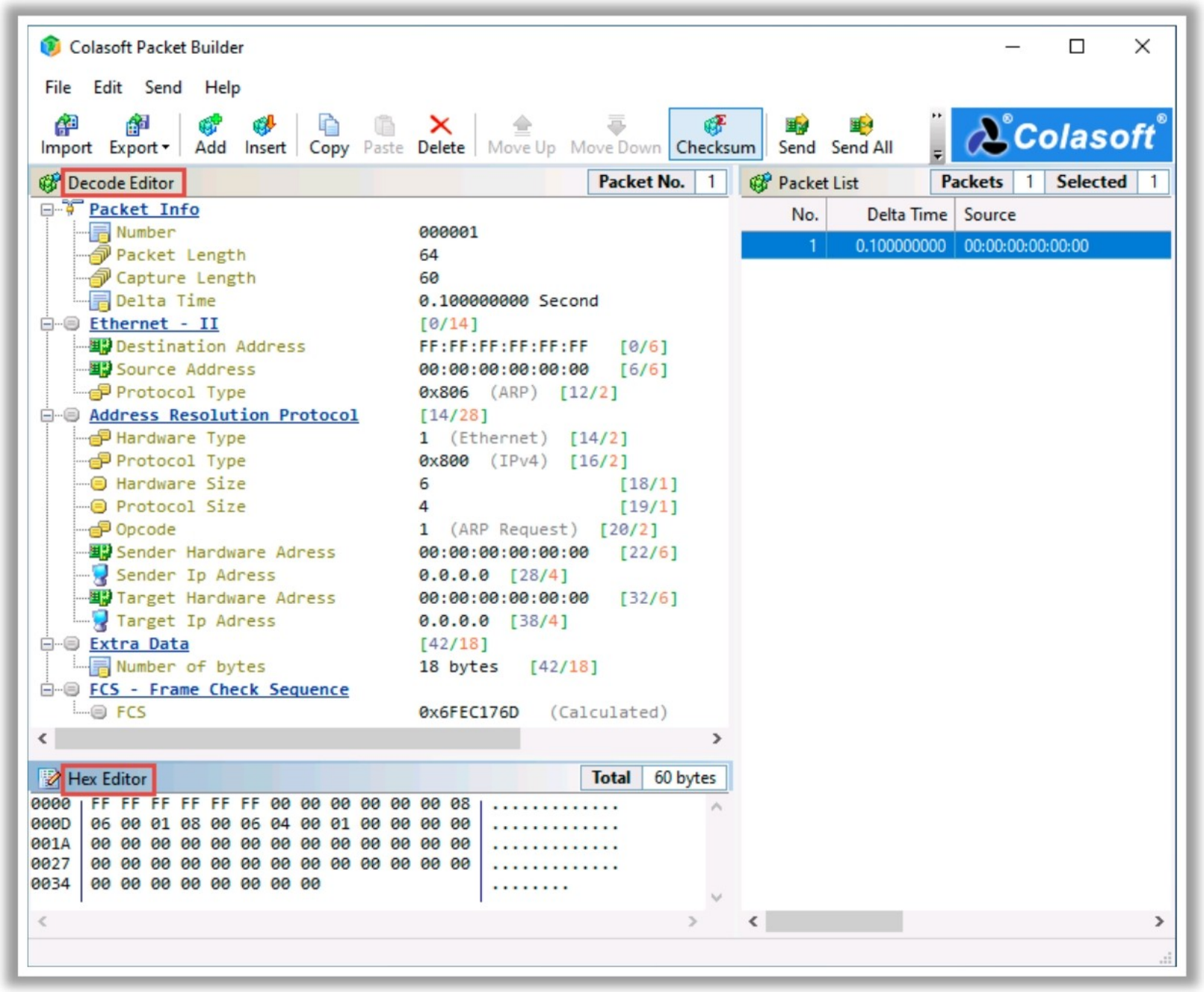


Figure 3.115: Screenshot of Colasoft Packet Builder

There are three views in the Packet Builder: Packet List, Decode Editor, and Hex Editor.

- Packet List displays all the constructed packets. When you select one or more packets in Packet List, the first highlighted packet is displayed in both Decode Editor and Hex Editor for editing.
- In Hex Editor, the data of the packet are represented as hexadecimal values and ASCII characters; nonprintable characters are represented by a dot (".") in the ASCII section. You can edit either the hexadecimal values or the ASCII characters.
- Decode Editor allows the attacker to edit packets without remembering the value length, byte order, and offsets. You can select a field and change the value in the edit box.

For creating a packet, you can use the add or insert packet command in the Edit menu or the Toolbar to create a new packet.

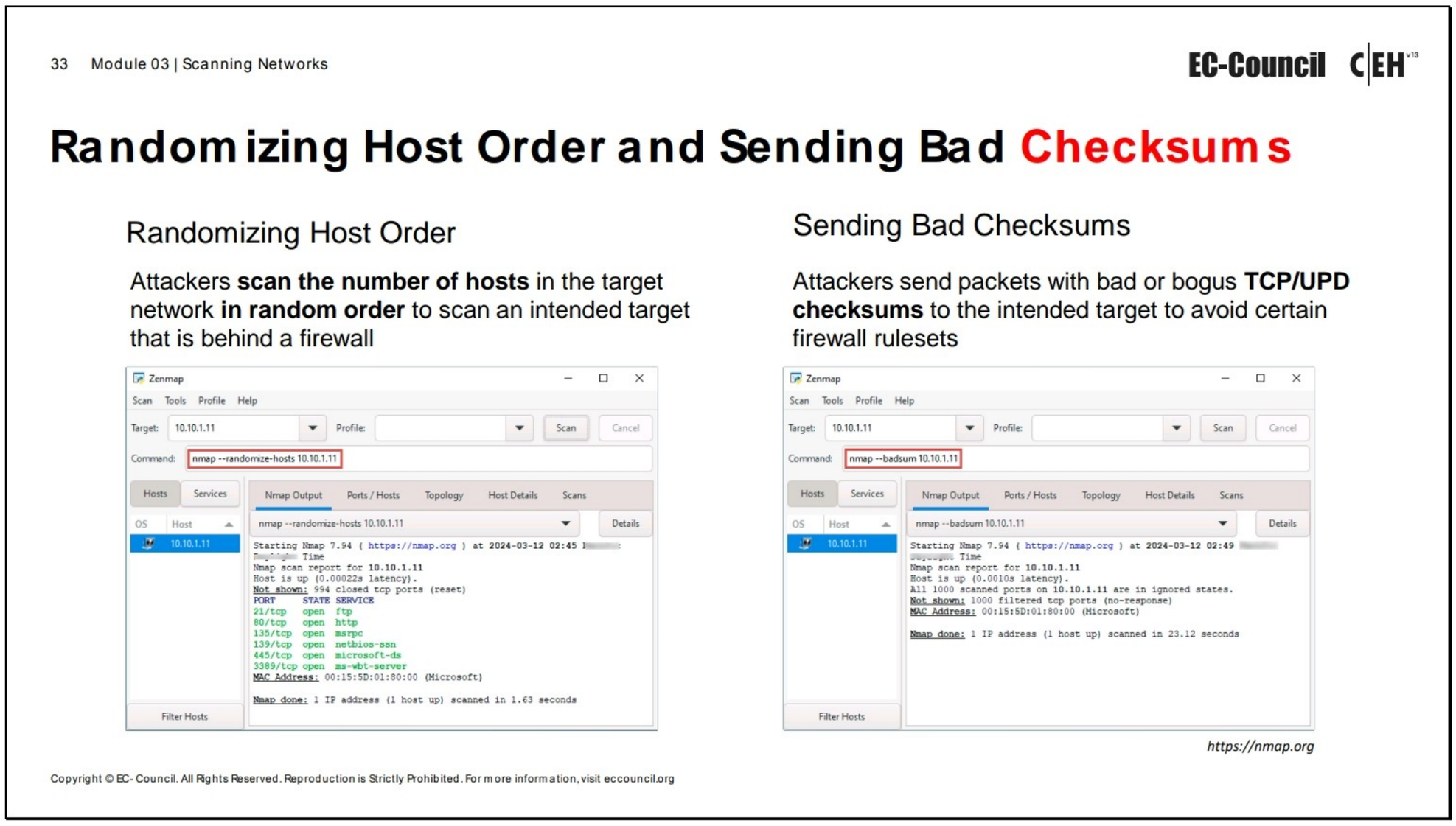
The attacker can send a constructed packet to wire directly and control how Colasoft Packet Builder sends the packets, specifying, for example, the interval between packets, loop times, and delay between loops.

This packet builder audits networks and checks the network protection against attacks and intruders. Attackers may use this packet builder to create fragmented packets to

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

bypass network firewalls and IDS systems. They can also create packets and flood the victim with a very large number of packets, which could result in DoS attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Randomizing Host Order and Sending Bad Checksums

Randomizing Host Order

The attacker scans the number of hosts in the target network in a random order to scan the intended target that is lying beyond the firewall. The option used by Nmap to scan with a random host order is **`--randomize-hosts`**.

This technique instructs Nmap to shuffle each group of 16384 hosts before scanning with slow timing options, thus making the scan less notable to network monitoring systems and firewalls. If larger group sizes are randomized, the **`PING_GROUP_SZ`** should be increased in **`nmap.h`** and it should be compiled again. Another method can be followed by generating the target IP list with the list scan command **`-sL -n -oN <filename>`** and then randomizing it with a Perl script and providing the whole list to Nmap using the **`-iL`** command.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

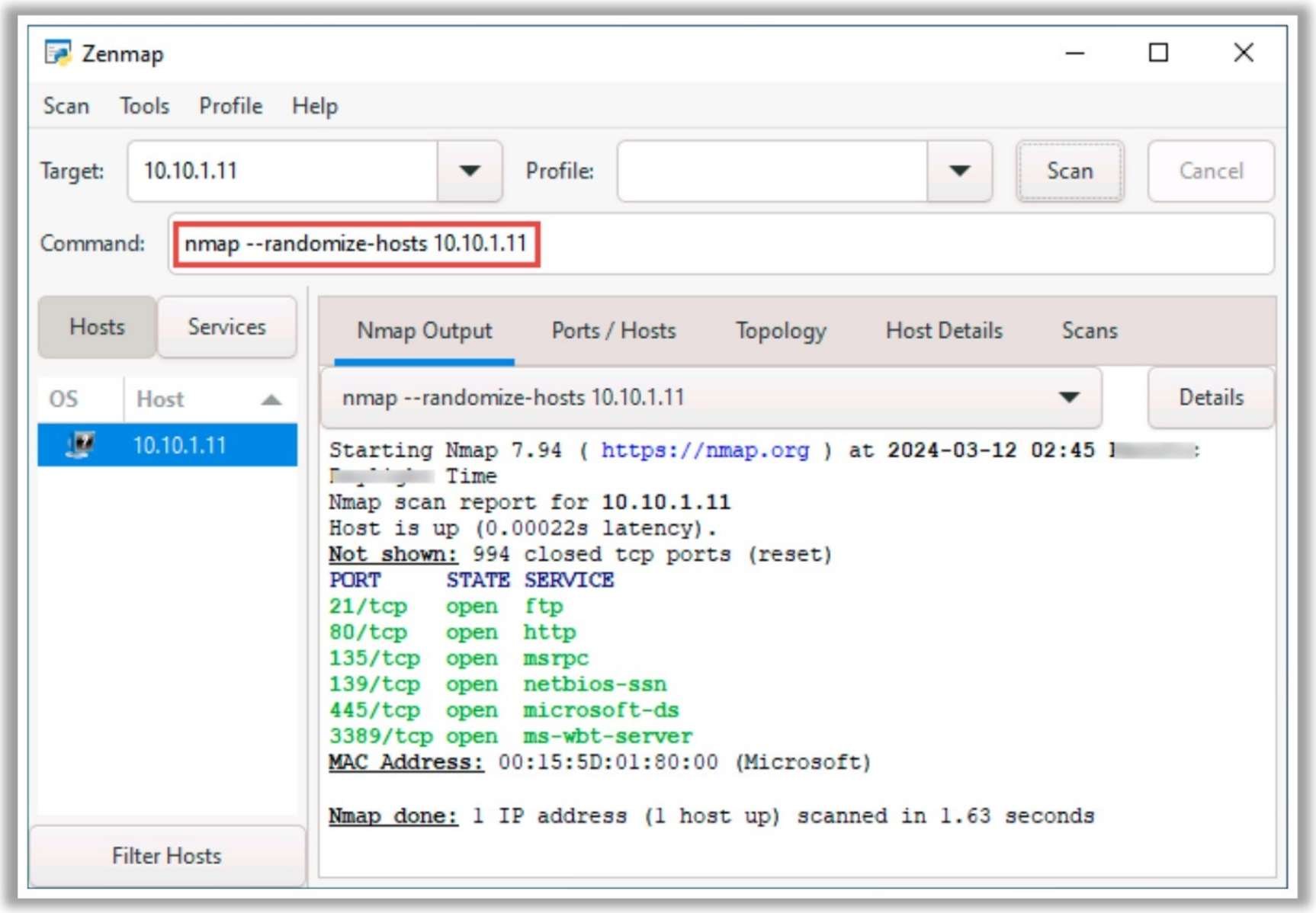


Figure 3.116: Screenshot of randomizing hosts in Zenmap

Sending Bad Checksums

The attacker sends packets with bad or bogus TCP/UDP checksums to the intended target to avoid certain firewall rule sets. TCP/UDP checksums are used to ensure data integrity. Sending packets with incorrect checksums can help attackers to acquire information from improperly configured systems by checking for any response. If there is a response, then it is from the IDS or firewall, which did not verify the obtained checksum. If there is no response or the packets are dropped, then it can be inferred that the system is configured. This technique instructs Nmap to send packets with invalid TCP, UDP, or SCTP checksums to the target host. The option used by Nmap is **`--badsum`**.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

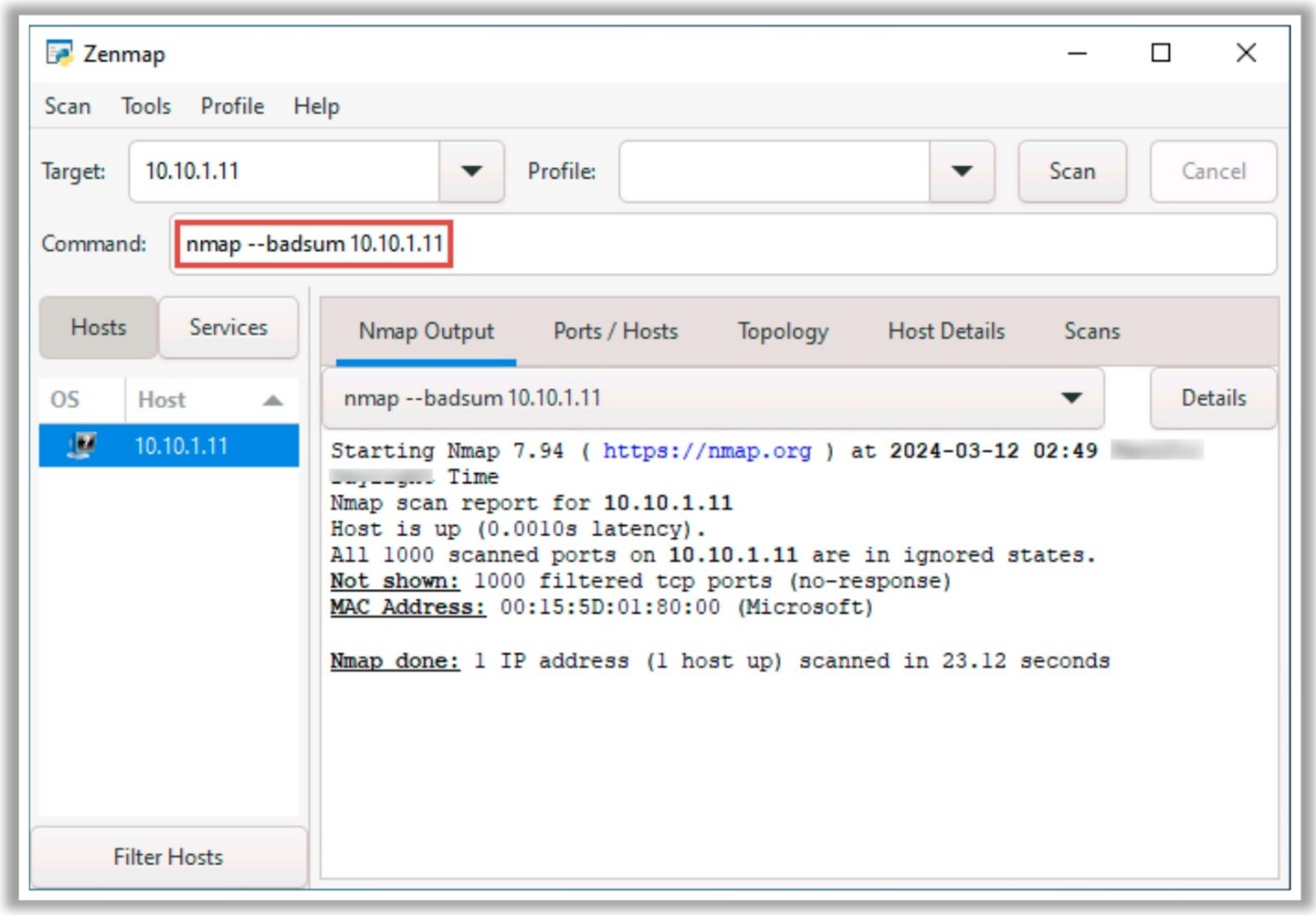
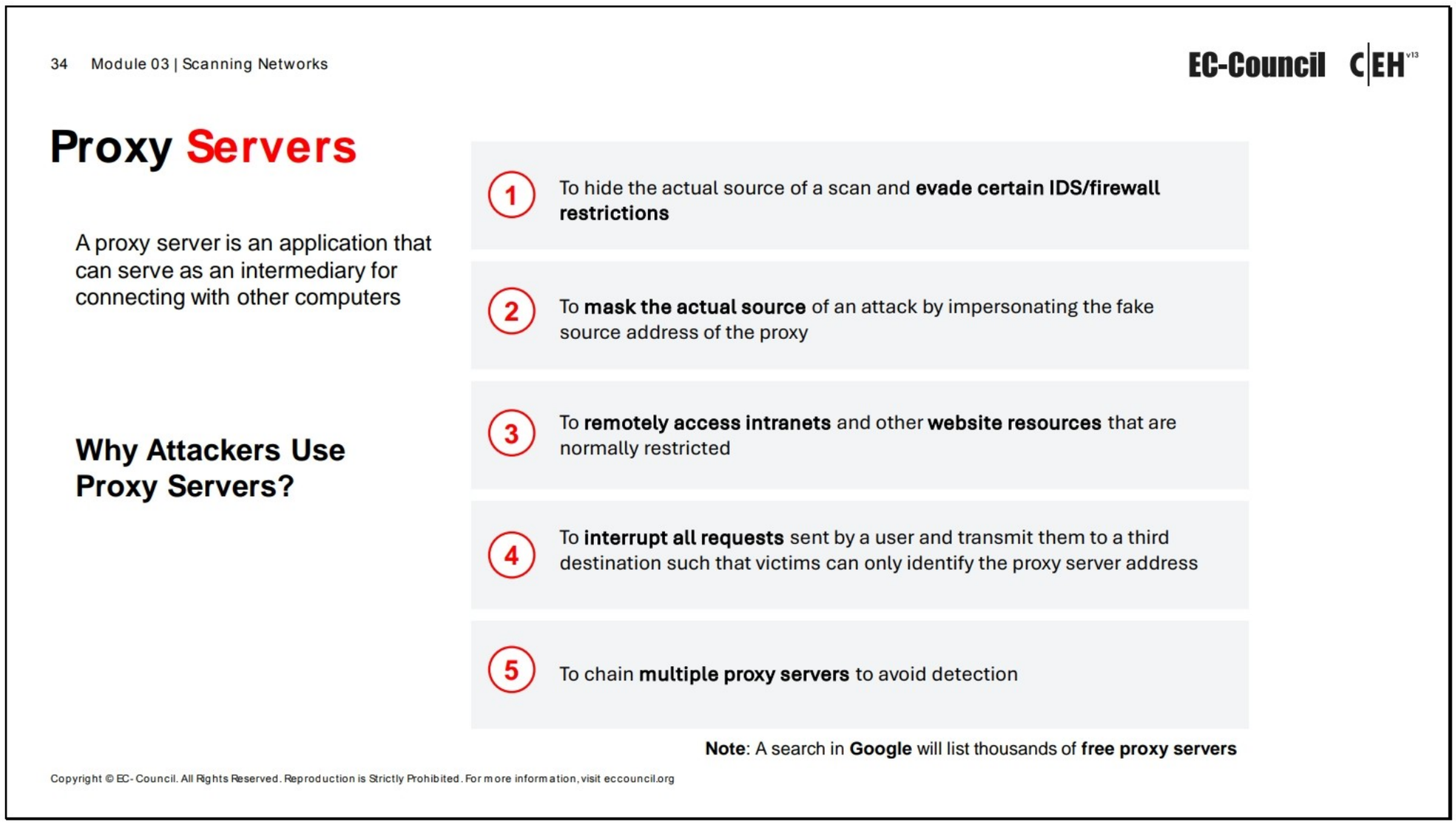


Figure 3.117: Screenshot of scanning by sending bad checksums in Zenmap

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Proxy Servers

A proxy server is an application that can serve as an intermediary for connecting with other computers.

A proxy server is used:

- As a firewall and to protect the local network from external attacks.
- As an IP address multiplexer that allows several computers to connect to the Internet when you have only one IP address (NAT/PAT).
- To anonymize web surfing (to some extent).
- To extract unwanted content, such as ads or "unsuitable" material (using specialized proxy servers).
- To provide some protection against hacking attacks.
- To save bandwidth.

How does a proxy server work?

Initially, when you use a proxy to request a particular web page on an actual server, the proxy server receives it. The proxy server then sends your request to the actual server on your behalf. It mediates between you and the actual server to transmit and respond to the request, as shown in the figure below.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

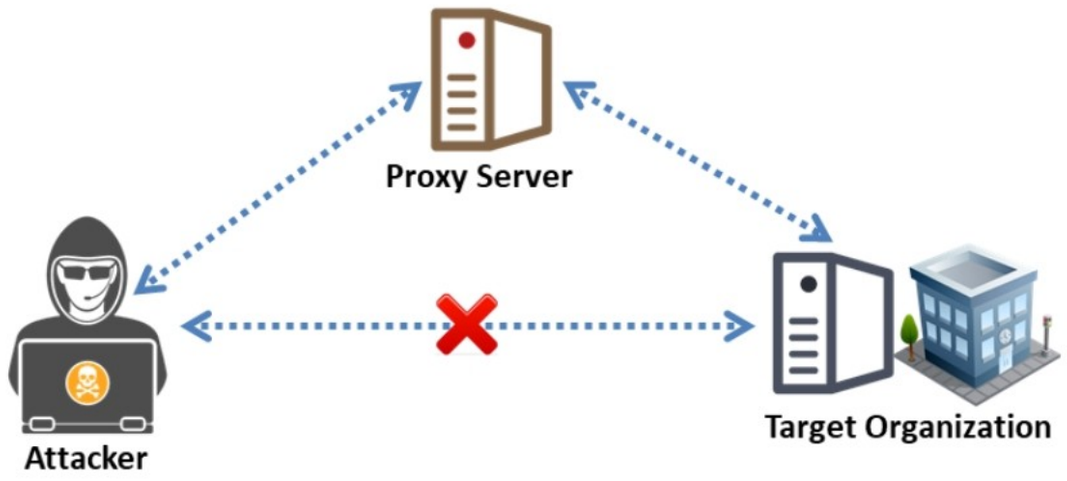


Figure 3.118: Attacker using a proxy server for connecting to the target

In this process, the proxy receives the communication between the client and the destination application. To take advantage of a proxy server, an attacker must configure client programs so that they can send their requests to the proxy server instead of the final destination.

Why Attackers Use Proxy Servers?

It is easier for an attacker to attack or hack a particular system than to conceal the attack source. Therefore, the primary challenge for an attacker is to hide his/her identity so that he/she cannot be traced. Thus, the attacker uses a proxy server to avoid attack detection by masking his/her IP address. When the attacker uses a proxy to connect to the target system, the server logs will record the proxy's source address rather than the attacker's source address.

Proxy sites help the attacker to browse the Internet anonymously and access blocked sites (i.e., evade firewall restrictions). Thus, the attacker can surf restricted sites anonymously without using the source IP address.

Attackers use proxy servers:

- To hide the actual source of a scan and evade certain IDS/firewall restrictions.
- To hide the source IP address so that they can hack without any legal corollary.
- To mask the actual source of the attack by employing a fake source address of the proxy.
- To remotely access intranets and other website resources that are normally off limits.
- To interrupt all the requests sent by a user and transmit them to a third destination; hence, victims will only be able to identify the proxy server address.
- To chain multiple proxy servers to avoid detection.

Free Proxy Servers

Some free proxy servers available on the Internet, which can help you to access restricted sites without revealing your IP address. In the **Google** search engine, type "**Free Proxy Servers**" to see a list of such servers. Select one from this list and download and install it to browse anonymously without revealing your legitimate IP address.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

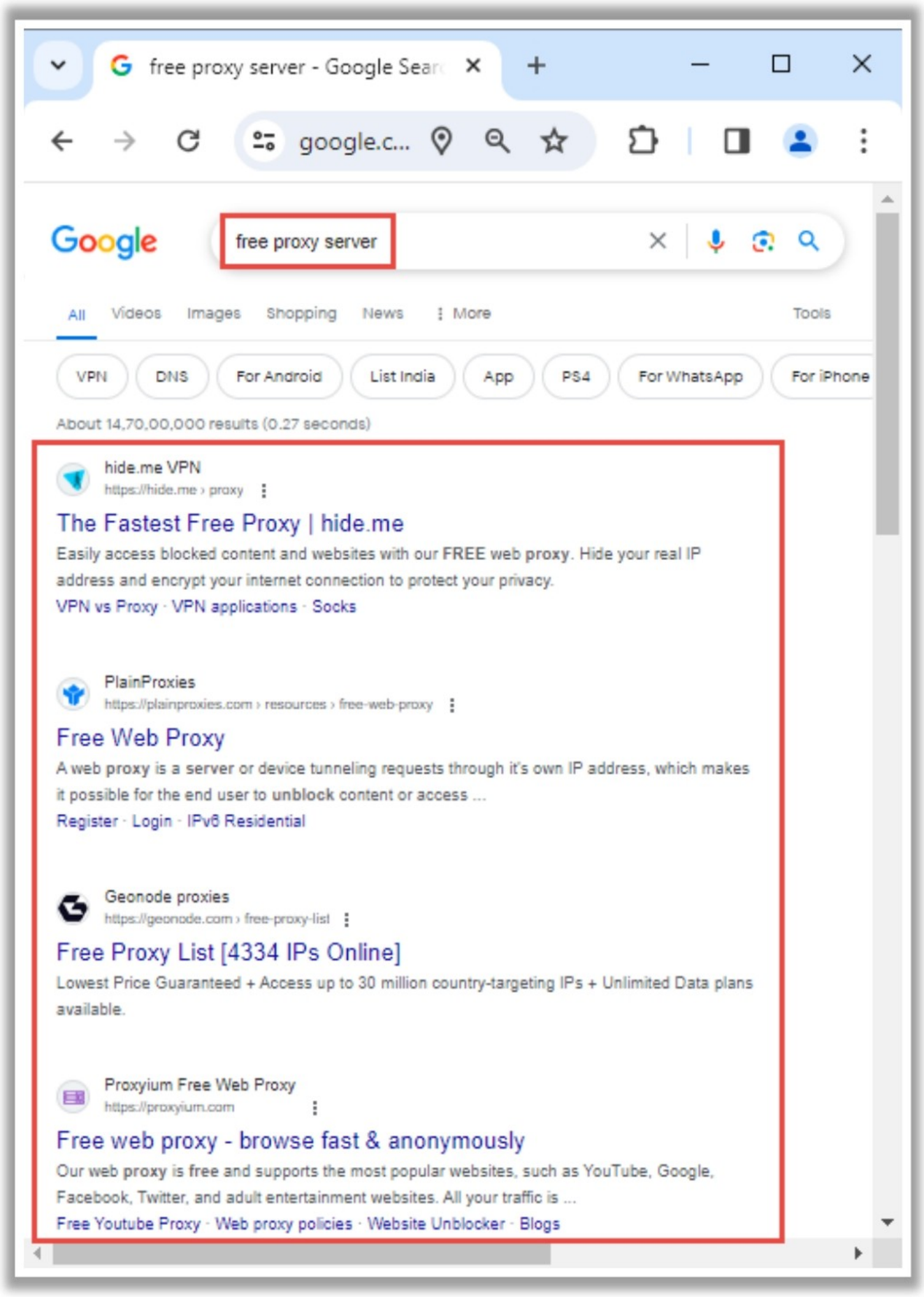


Figure 3.119: Free Proxy Servers

Proxy Chaining

Proxy chaining helps an attacker to increase his/her Internet anonymity. Internet anonymity depends on the number of proxies used for fetching the target application; the larger the number of proxy servers used, the greater is the attacker's anonymity.

The proxy chaining process is described below:

- The user requests a resource from the destination.
- A proxy client in the user's system connects to a proxy server and passes the request to the proxy server.
- The proxy server strips the user's identification information and passes the request to the next proxy server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- This process is repeated by all the proxy servers in the chain.
- Finally, the unencrypted request is passed to the web server.

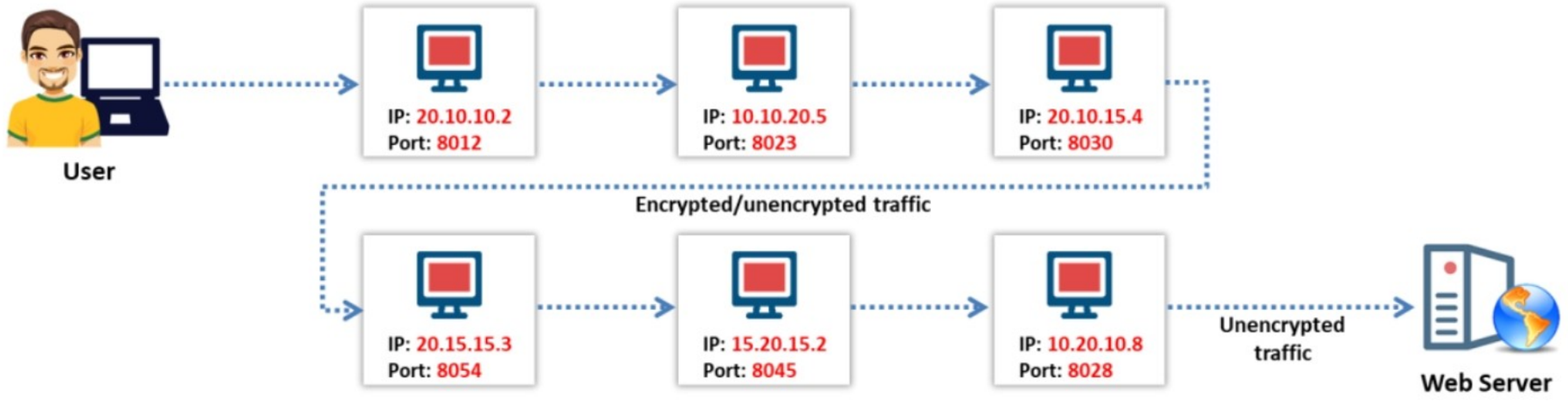


Figure 3.120: Proxy Chaining

Proxy Tools

Proxy tools are intended to allow users to surf the Internet anonymously by keeping their IP hidden through a chain of SOCKS or HTTP proxies. These tools can also act as HTTP, mail, FTP, SOCKS, news, telnet, and HTTPS proxy servers.

- **Proxy Switcher**

  Source: *https://www.proxyswitcher.com*

  Proxy Switcher allows attackers to surf the Internet anonymously without disclosing their IP address. It also helps attackers to access various blocked sites in the organization. In addition, it avoids all sorts of limitations imposed by target sites.

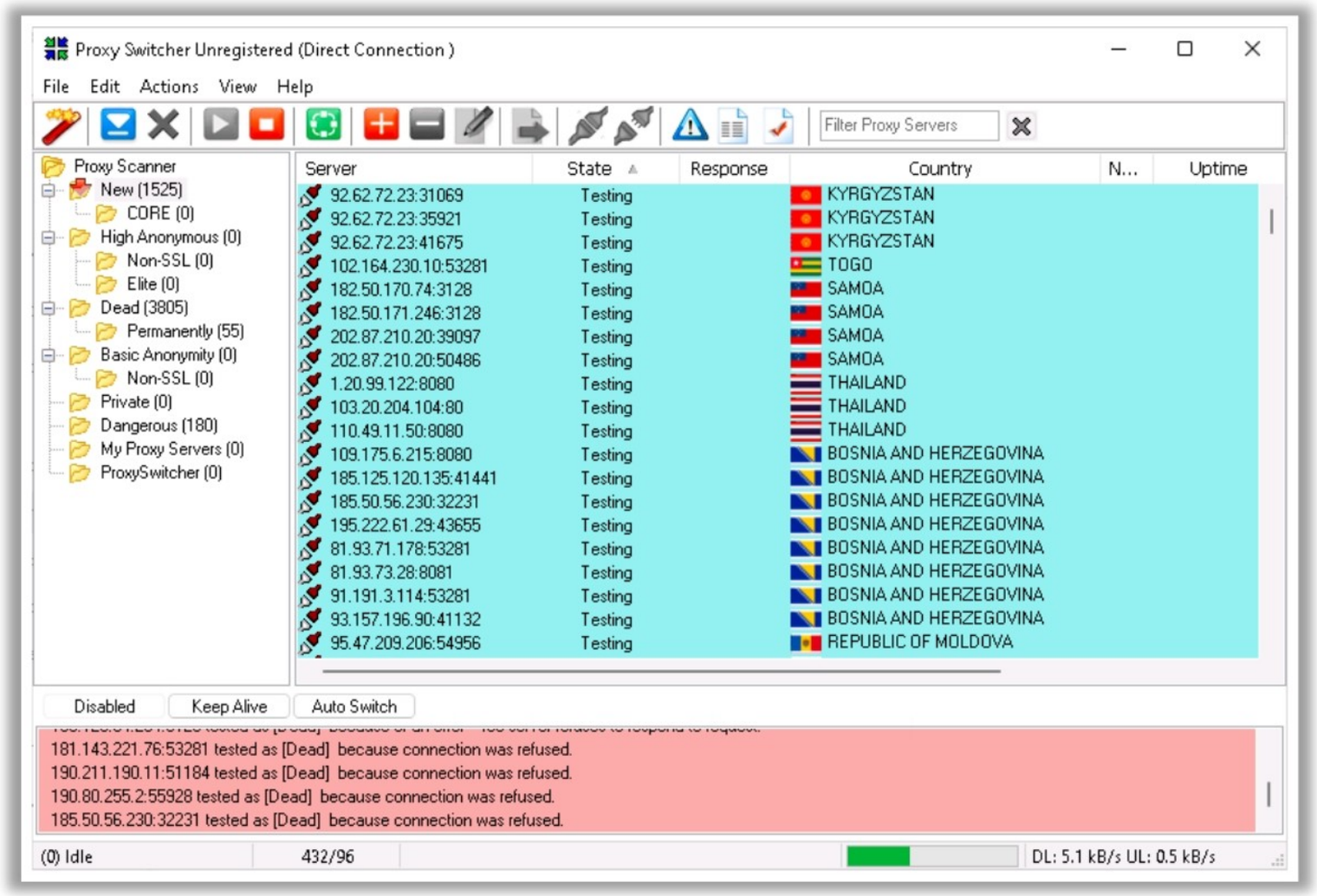


Figure 3.121: Screenshot of Proxy Switcher

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **CyberGhost VPN**

  Source: *https://www.cyberghostvpn.com*

  CyberGhost VPN hides the attacker's IP and replaces it with a selected IP, allowing him or her to surf anonymously and access blocked or censored content. It encrypts the connection and does not keep logs, thus securing data.

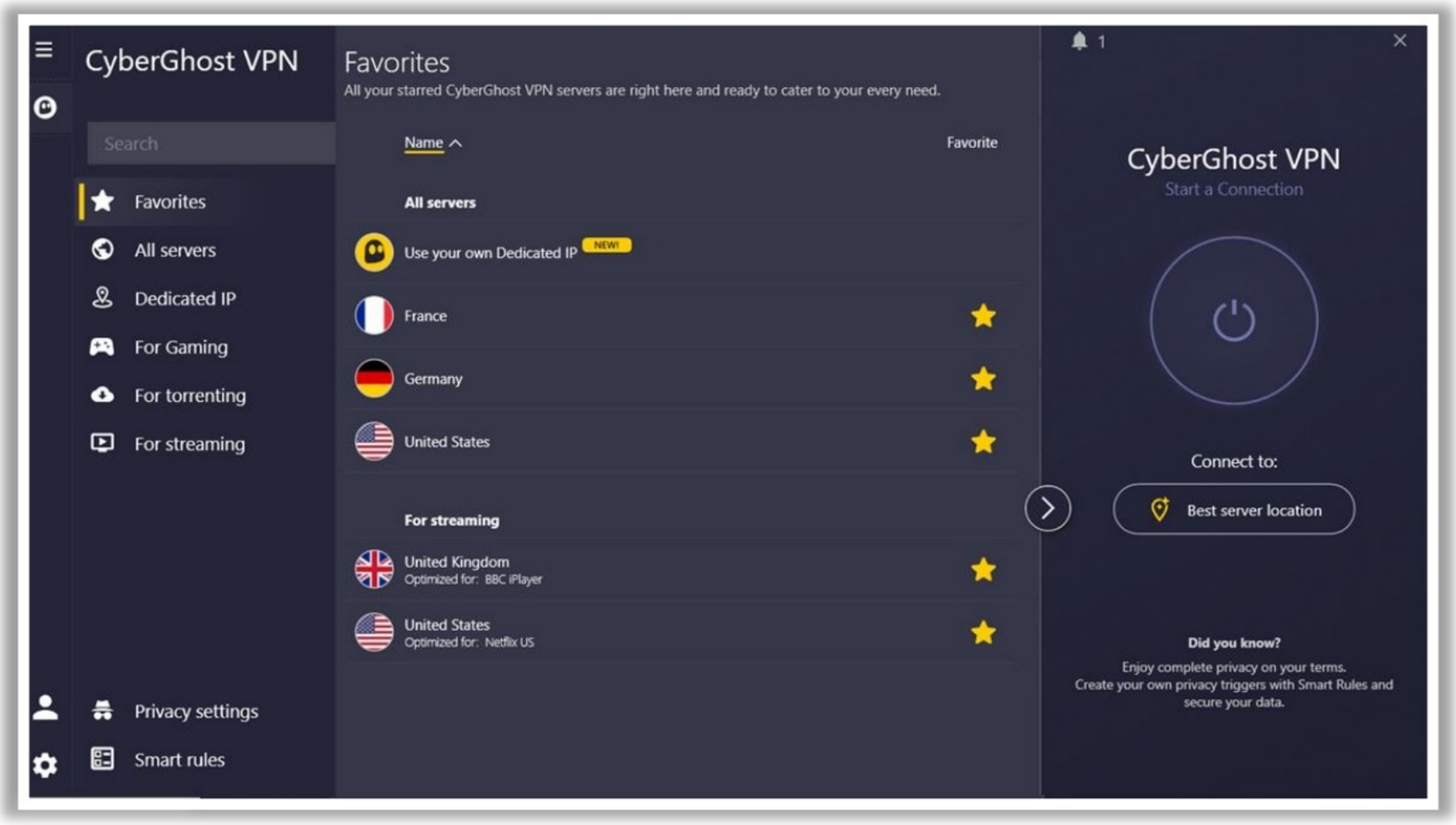


Figure 3.122: Screenshot of CyberGhost

In addition to the proxy tools mentioned above, there are many other proxy tools intended to allow users to surf the Internet anonymously. Some additional proxy tools are listed below:

- Burp Suite (*https://www.portswigger.net*)
- Tor (*https://www.torproject.org*)
- Hotspot Shield (*https://www.hotspotshield.com*)
- Proxifier (*https://www.proxifier.com*)
- IPRoyal Residential Proxy (*https://iproyal.com*)

Anonymizers

An anonymizer is an intermediate server placed between an end user and a website that accesses the website on their behalf and makes web surfing activities untraceable. Anonymizers allow users to bypass Internet censorship. An anonymizer eliminates all identifying information (IP address) from the system while surfing the Internet, thereby ensuring privacy. It encrypts the data transferred from a computer to the Internet service provider (ISP). Most anonymizers can anonymize web (HTTP:), File Transfer Protocol (FTP:), and gopher (gopher:) Internet services.

To visit a page anonymously, you can visit your preferred anonymizer site and enter the name of the target website in the anonymization field. Alternatively, you can set your browser home page to point to an anonymizer to anonymize subsequent web access. In addition, you can choose to

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

anonymously provide passwords and other information to sites without revealing any additional information, such as your IP address. Attackers may configure an anonymizer as a permanent proxy server by making the site name the setting for the HTTP, FTP, Gopher, and other proxy options in their application configuration menu, thereby cloaking their malicious activities.

Why Use an Anonymizer?

The reasons for using anonymizers include:

- **Ensuring privacy**: Protect your identity by making your web navigation activities untraceable. Your privacy is maintained until and unless you disclose your personal information on the web, for example, by filling out forms.
- **Accessing government-restricted content**: Most governments prevent their citizens from accessing certain websites or content deemed inappropriate or sensitive. However, these sites can still be accessed using an anonymizer located outside the target country.
- **Protection against online attacks**: An anonymizer can protect you from all instances of online pharming attacks by routing all customer Internet traffic via its protected DNS server.
- **Bypassing IDS and firewall rules**: Firewalls are typically bypassed by employees or students accessing websites that they are not supposed to access. An anonymizer service gets around your organization's firewall by setting up a connection between your computer and the anonymizer service. Thus, firewalls see only the connection from your computer to the anonymizer's web address. The anonymizer will subsequently connect to any website (e.g., Twitter) with the help of an Internet connection and then direct the content back to you. To your organization, your system appears to be simply connected to the anonymizer's web address but not to the actual site that you are browsing.

In addition to protecting users' identities, anonymizers can also be used to attack a website without being traced.

Types of Anonymizers

Anonymizers are of two basic types: networked anonymizers and single-point anonymizers.

- **Networked Anonymizers**

  A networked anonymizer first transfers your information through a network of Internet-connected computers before passing it on to the website. Because the information passes through several Internet computers, it becomes cumbersome for anyone trying to track your information to establish the connection between you and the anonymizer.

  Example: If you want to visit any web page, you have to make a request. The request will first pass through A, B, and C Internet computers before going to the website.

  Advantage: Complication of the communications makes traffic analysis complex.

  Disadvantage: Any multi-node network communication incurs some degree of risk of compromising confidentiality at each node.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Single-Point Anonymizers**

  Single-point anonymizers first transfer your information through a website before sending it to the target website and then pass back the information gathered from the target website to you via the website to protect your identity.

  Advantage: Arms-length communication hides the IP address and related identifying information.

  Disadvantage: It offers less resistance to sophisticated traffic analysis.

Anonymizer tools use various techniques such as SSH, VPN, and HTTP proxies, which allow access to blocked or censored content on the Internet with advertisements omitted.

- **Whonix**

  Source: *https://www.whonix.org*

  Whonix is a desktop OS designed for advanced security and privacy. It mitigates the threat of common attack vectors while maintaining usability. Online anonymity is realized via fail-safe, automatic, and desktop-wide use of the Tor network. It consists of a heavily reconfigured Debian base that is run inside multiple virtual machines, providing a substantial layer of protection from malware and IP address leaks.

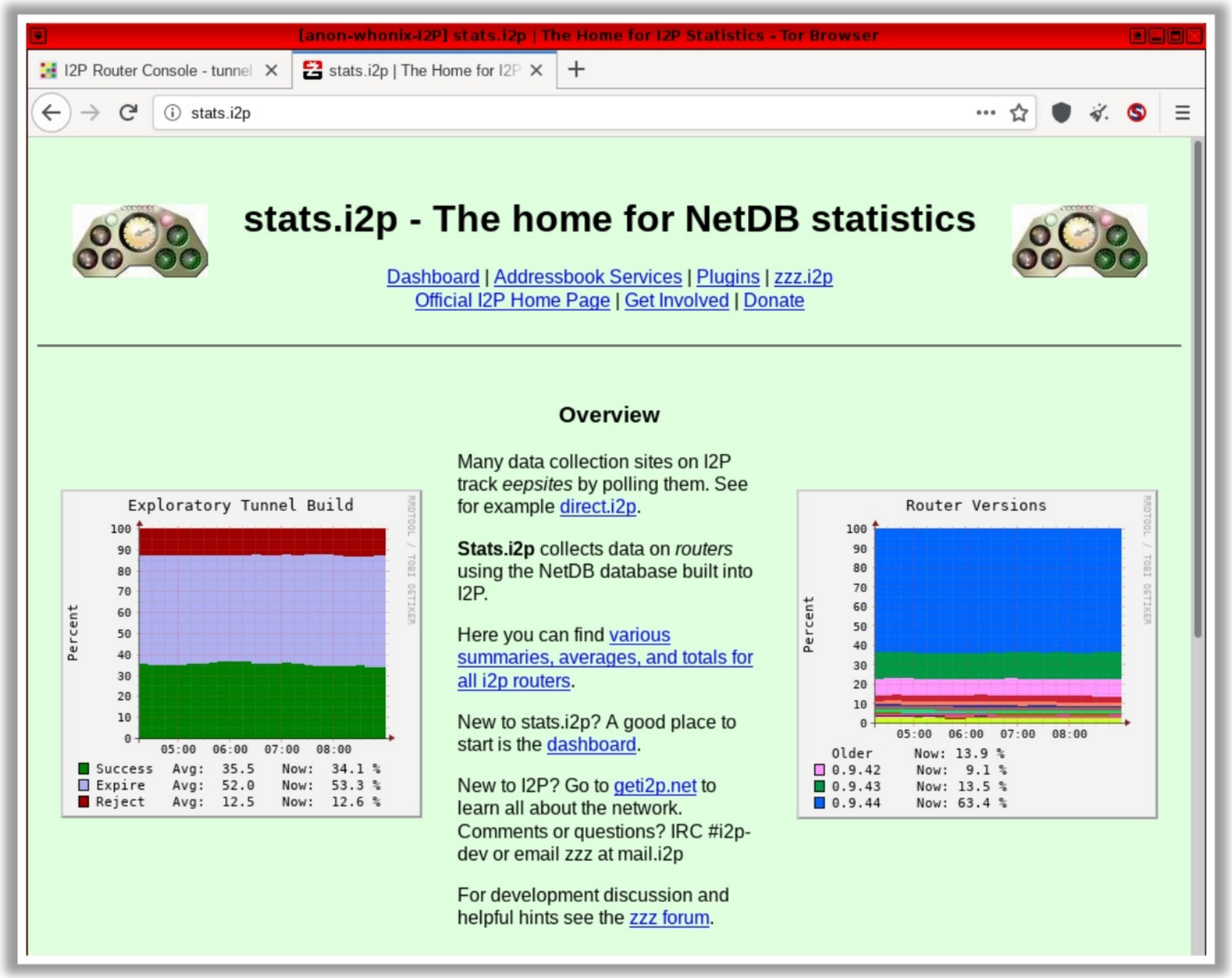


Figure 3.123: Screenshot of Whonix

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some additional anonymizers are listed below:

- Psiphon (*https://psiphon.ca*)
- TunnelBear (*https://www.tunnelbear.com*)
- Invisible Internet Project (I2P) (*https://geti2p.net*)
- Bright Data Proxy API (*https://brightdata.com*)

Censorship Circumvention Tools

- **AstrillVPN**

  Source: *https://www.astrill.com*

  AstrillVPN is a VPN software that enables attackers to bypass Internet censorship and access geo-blocked websites, apps, and services by hiding their IP and location. It offers data encryption and transmission technology and avoids logging traffic data and DNS queries to prevent tracking of browsing activity and metadata.

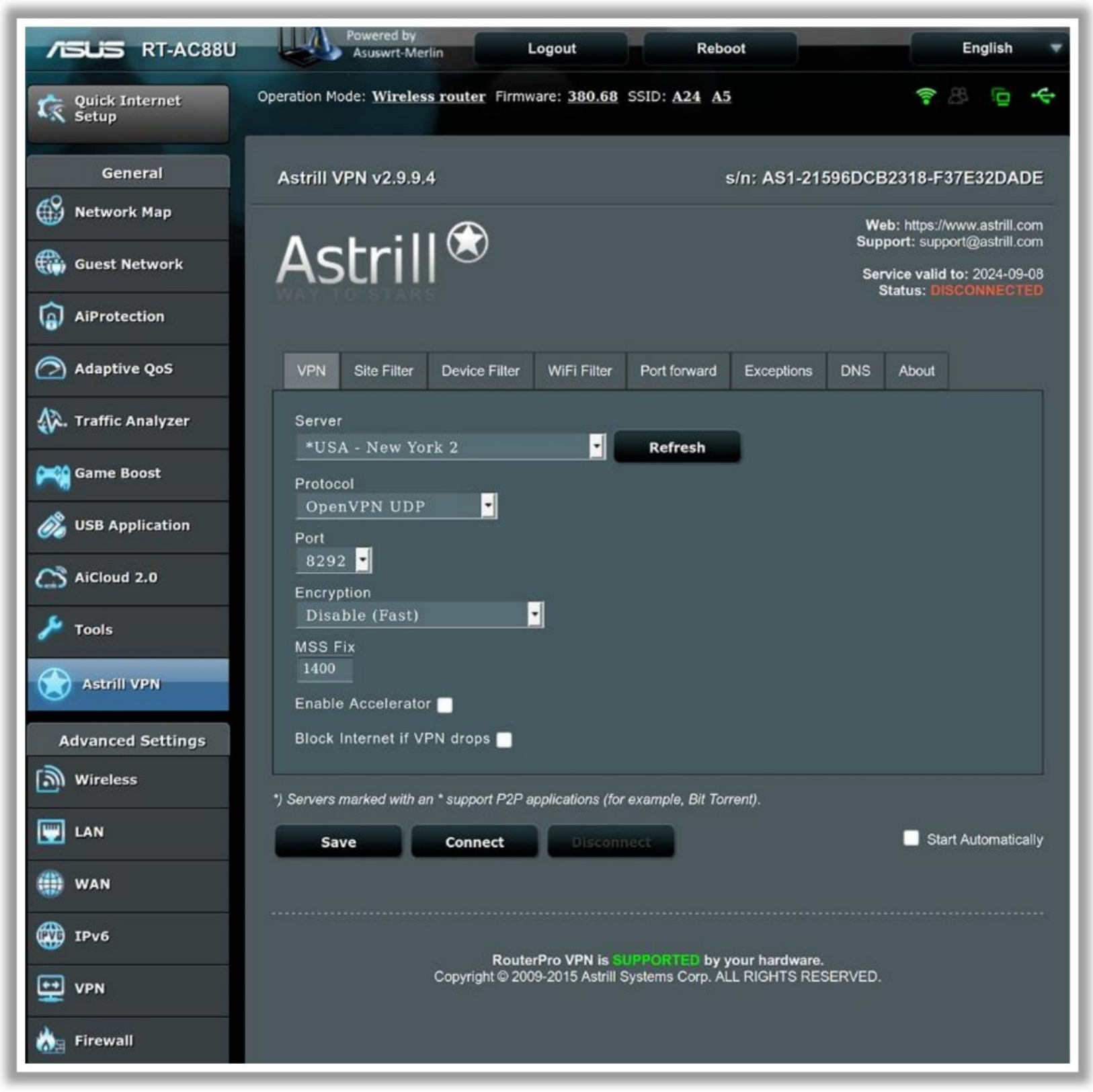


Figure 3.124: Screenshot of AstrillVPN

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Tails**

  Source: *https://tails.net*

  Tails is a live OS that users can run on any computer from a USB stick or SD card. It uses state-of-the-art cryptographic tools to encrypt files, emails, and instant messaging. It allows attackers to use the Internet anonymously and circumvent censorship. It leaves no trace on the computer.

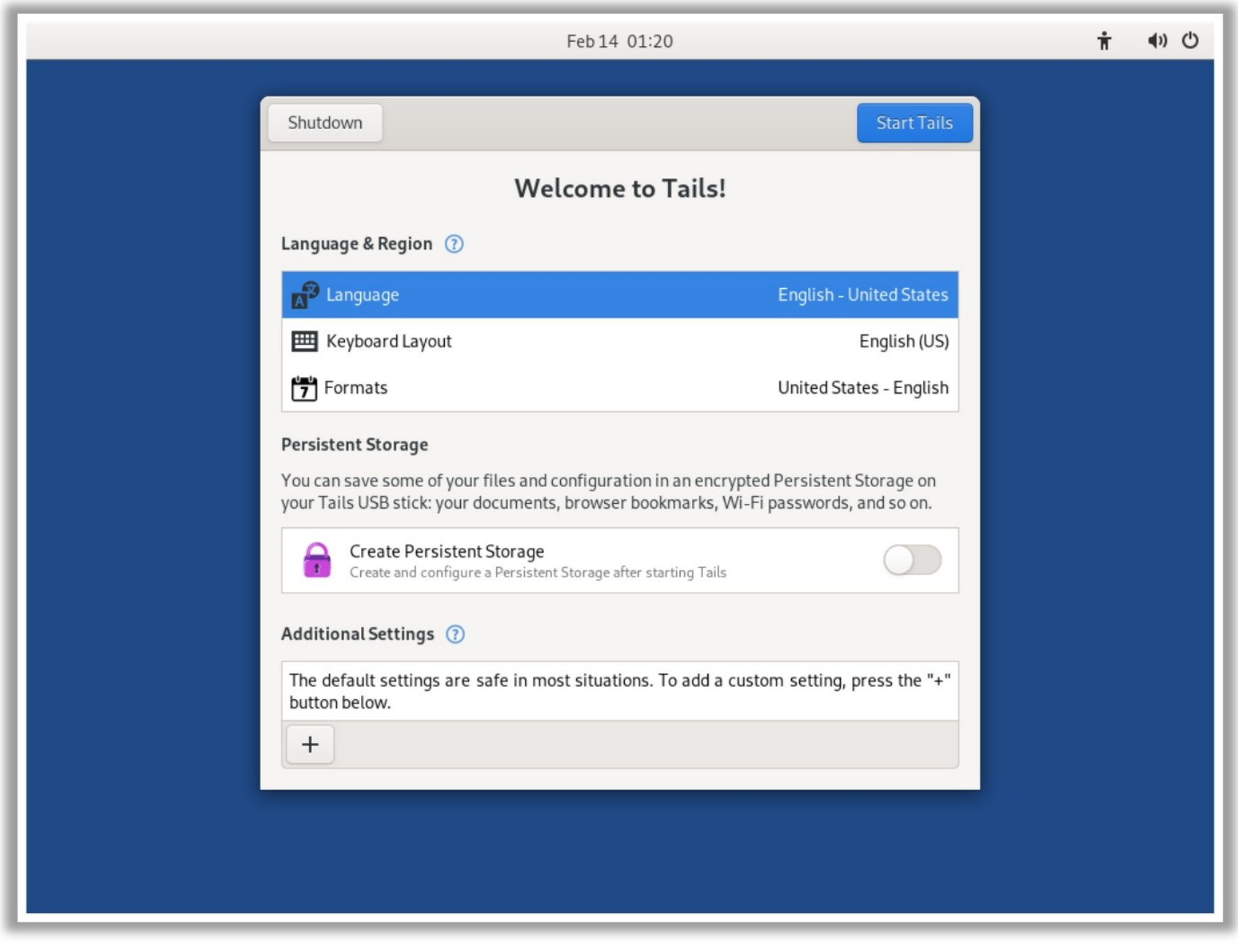
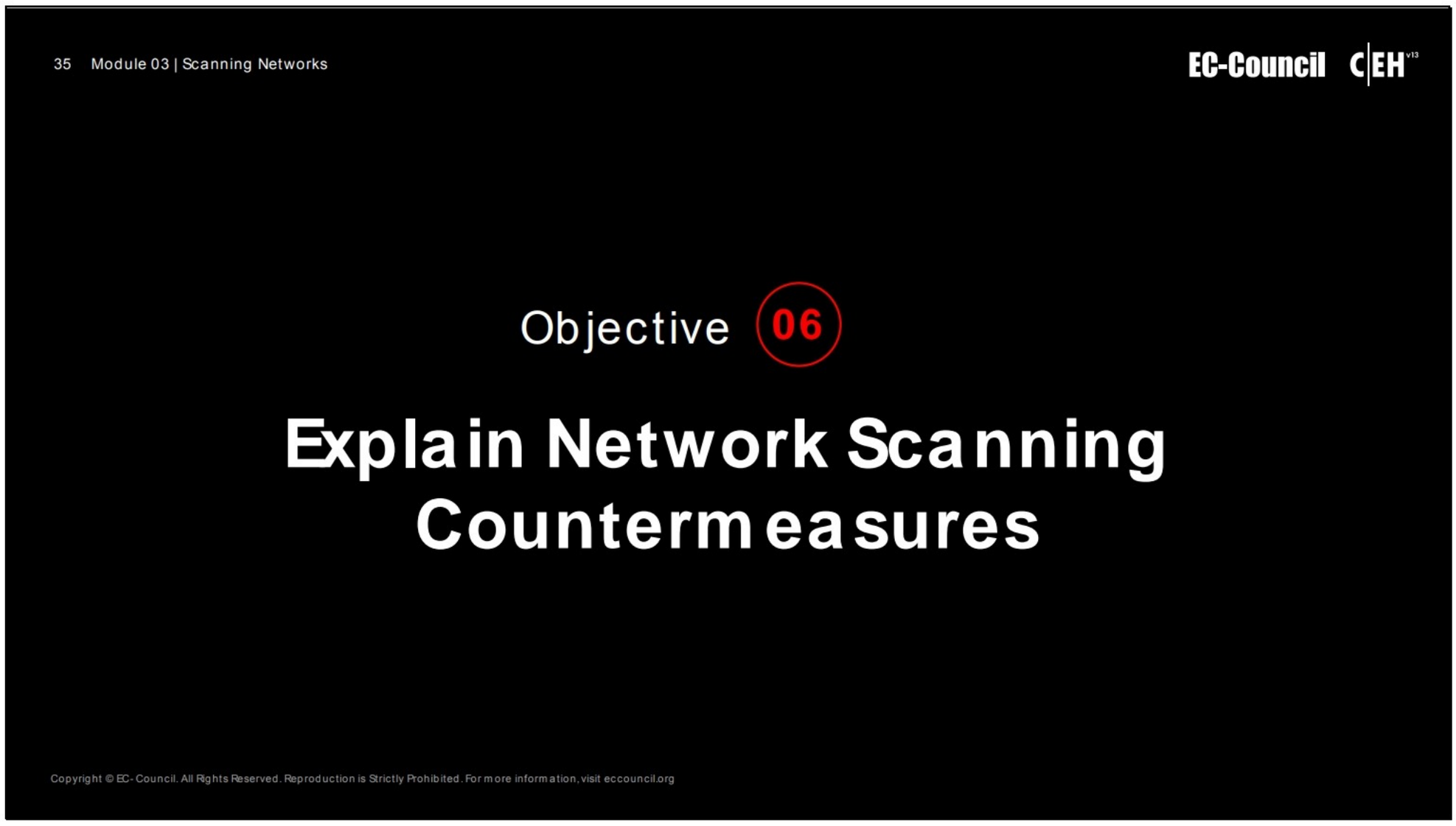


Figure 3.125: Screenshot of Tails

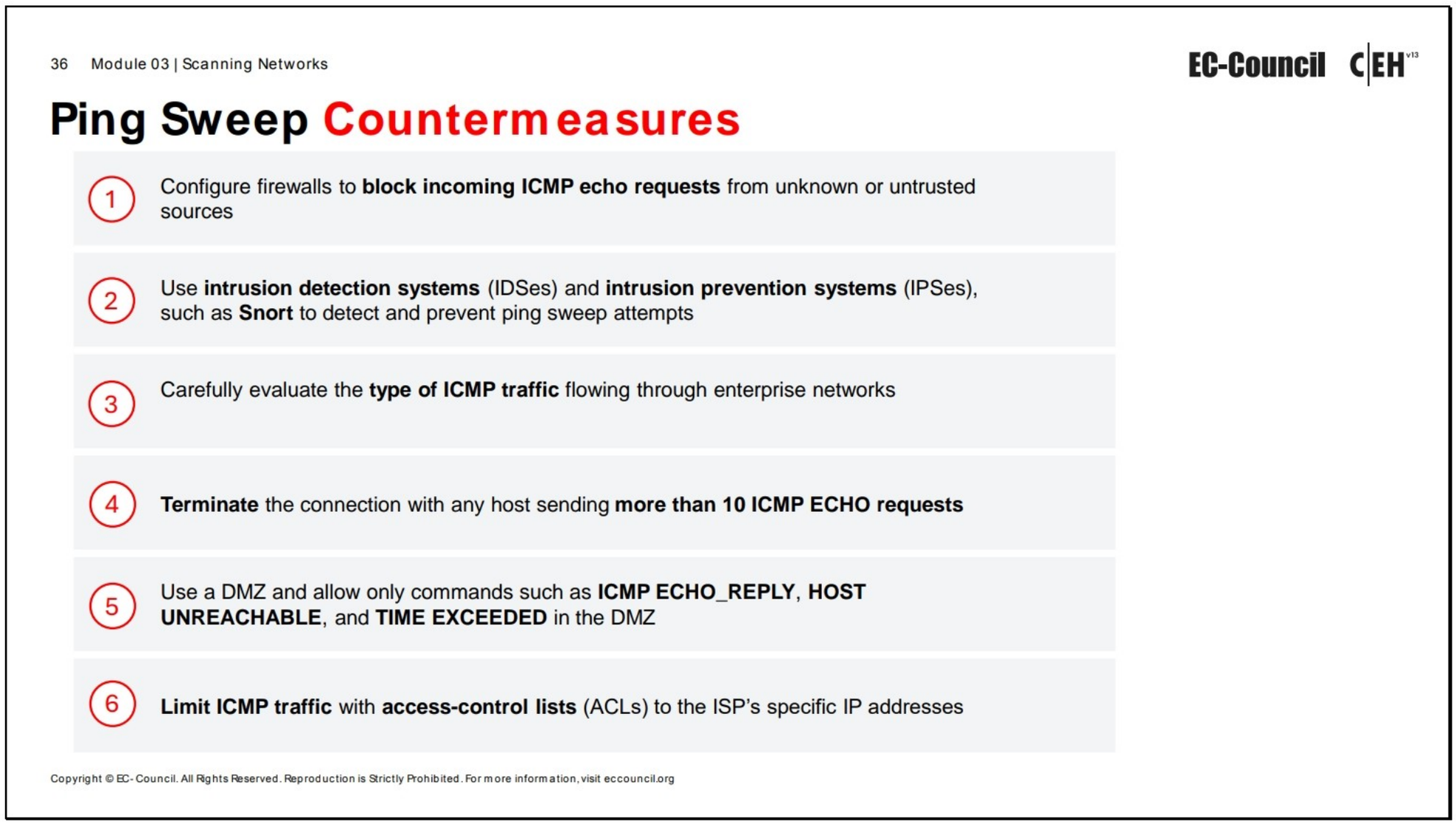
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Network Scanning Countermeasures

In ethical hacking, the ethical hacker, also known as the "pen tester," has to perform an additional task that a normal hacker does not follow (i.e., adopting countermeasures against the respective vulnerabilities determined through hacking). This is essential because knowing security loopholes in your network is worthless unless you adopt measures to protect them against real hackers. This section discusses various countermeasures to defend against network scanning attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

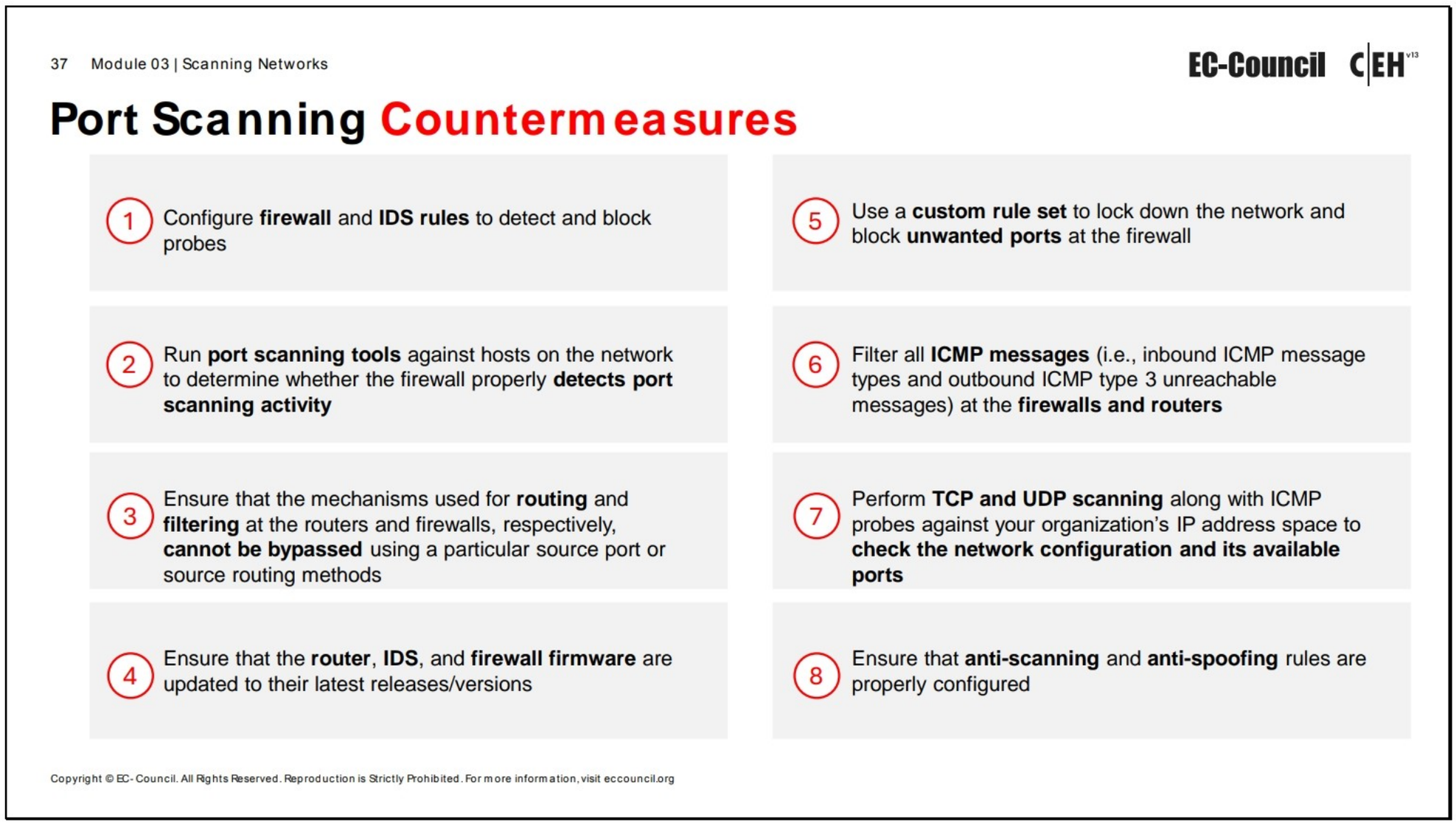


Ping Sweep Countermeasures

Some countermeasures for preventing ping sweep attempts are as follows:

- Configure firewalls to block incoming ICMP echo requests from unknown or untrusted sources.
- Use intrusion detection systems (IDSes) and intrusion prevention systems (IPSes), such as Snort (*https://www.snort.org*), to detect and prevent ping-sweep attempts.
- Carefully evaluate the type of Internet Control Message Protocol (ICMP) traffic flowing through enterprise networks.
- Terminate the connection with any host sending more than 10 ICMP ECHO requests.
- Use a demilitarized zone (DMZ) and allow only commands such as **`ICMP ECHO_REPLY`**, **`HOST UNREACHABLE`**, and **`TIME EXCEEDED`** in the DMZ.
- Limit ICMP traffic with access-control lists (ACLs) to the ISP's specific IP addresses.
- Implement rate limiting for ICMP packets to reduce the efficacy of ping sweeps and other ICMP-based scanning techniques.
- Break the network into smaller, isolated segments. This limits the scope of what an attacker can discover through a ping sweep and makes lateral movement more difficult if the network is compromised.
- Utilize private IP address ranges for internal network devices and implement network address translation (NAT) at the network boundary. This hides internal IP addresses from external observers.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Port Scanning Countermeasures

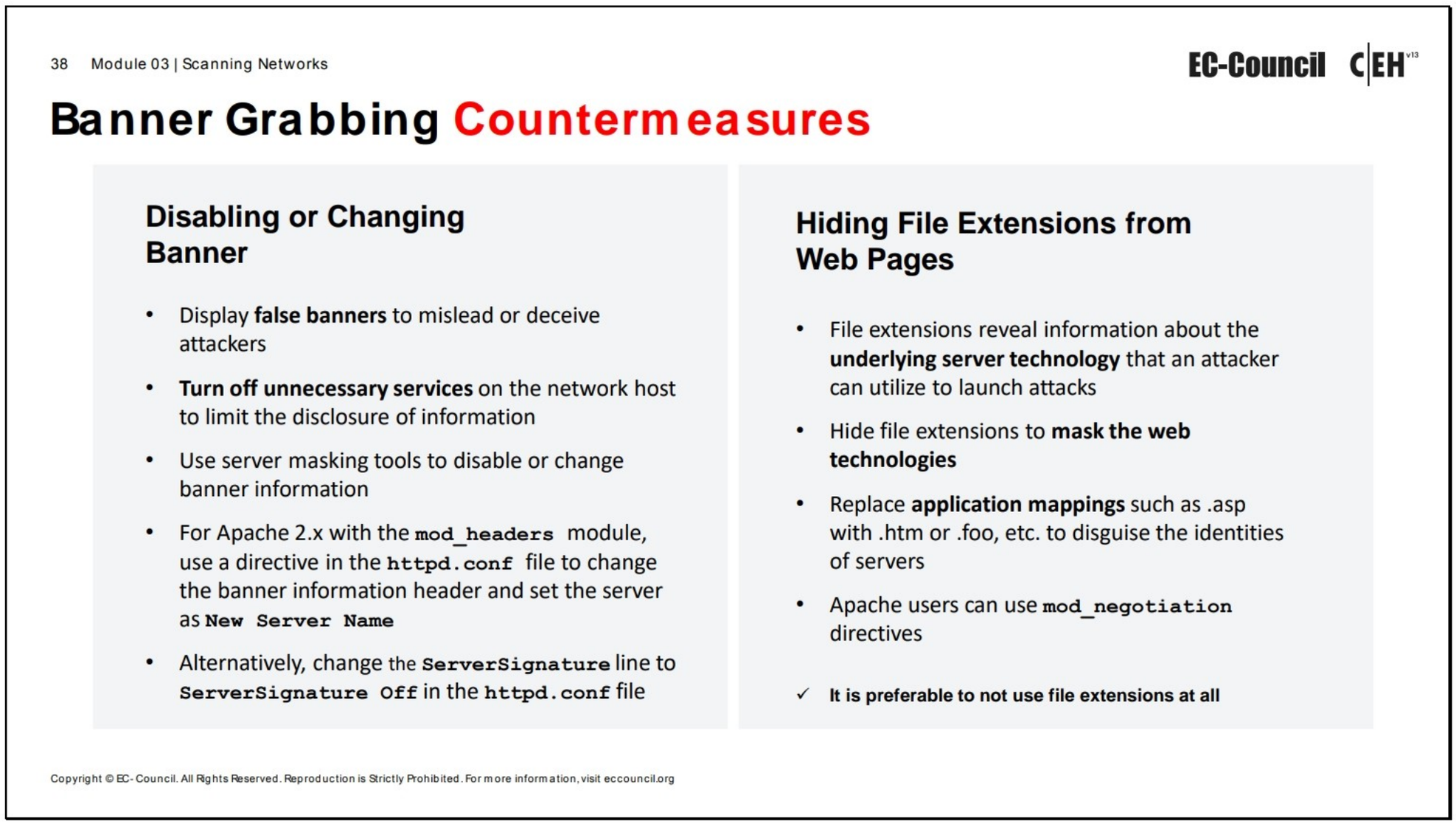
As discussed previously, port scanning provides a large amount of useful information to attackers, such as IP addresses, host names, open ports, and services running on ports. Open ports specifically offer an easy means for an attacker to break into the network. However, there is no cause for concern, provided that the system or network is secured against port scanning by adopting the following countermeasures:

- Configure firewall and intrusion detection system (IDS) rules to detect and block probes.
- The firewall should be capable of detecting the probes sent by attackers using port-scanning tools. It should not allow traffic to pass through after simply inspecting the TCP header. The firewall should be able to examine the data contained in each packet before allowing traffic to pass through it.
- Run the port scanning tools against hosts on the network to determine whether the firewall accurately detects the port scanning activity.
- Ensure that the router, IDS, and firewall firmware are updated with their latest releases/versions.
- Configure commercial firewalls to protect the network against fast port scans and SYN floods.
- Hackers use tools such as Nmap and perform OS detection to sniff the details of a remote OS. Thus, it is important to employ an IDS in such cases. Snort (*https://www.snort.org*) is a very useful intrusion detection and prevention technology, mainly because signatures are frequently available from public authors.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Keep as few ports open as possible and filter the rest, as an intruder may attempt to enter through any open port. Use a custom rule set to lock down the network, block unwanted ports at the firewall, and filter the following ports: 135–159, 256–258, 389, 445, 1080, 1745, and 3268.
- Block unwanted services running on the ports and update the service versions.
- Ensure that the versions of services running on the ports are non-vulnerable.
- Block inbound ICMP message types and all outbound ICMP type-3 unreachable messages at border routers arranged in front of the company's main firewall.
- Attackers attempt to perform source routing and send packets to the targets, which may not be reachable via the Internet, using an intermediate host that can interact with the target. Hence, it is necessary to ensure that the firewall and router can block such source-routing techniques.
- Ensure that the mechanisms used for routing and filtering at the routers and firewalls, respectively, cannot be bypassed using a particular source port or source routing methods.
- Test the IP address space using TCP and UDP port scans as well as ICMP probes to determine the network configuration and accessible ports.
- Ensure that the anti-scanning and anti-spoofing rules are configured.
- If a commercial firewall is in use, then ensure the following:
  - It is patched with the latest updates.
  - It has correctly defined anti-spoofing rules.
  - Its fast-mode services are unusable.
- Ensure that TCP wrappers limit access to the network based on domain names or IP addresses.
- Use proxy servers to block fragmented or malformed packets.
- Ensure that the firewalls forward open port scans to empty hosts or honeypots to make the port-scanning task difficult and time-consuming.
- Employ an intrusion prevention system (IPS) to identify port scan attempts and blacklist IP addresses.
- Implement port knocking to hide open ports.
- Use network address translation (NAT) to hide the IP addresses of internal systems.
- Implement egress filtering to control outbound traffic, which can help in identifying and stopping malicious internal hosts from scanning external targets.
- Implement virtual local area networks (VLANs) to isolate different types of traffic and restrict access between them.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Banner Grabbing Countermeasures

- **Disabling or Changing Banner**

  An open port indicates that a service/banner is running on it. When attackers connect to an open port using banner grabbing techniques, the system presents a banner containing sensitive information such as the OS, server type, and version. Using the information gathered, the attacker identifies specific vulnerabilities to exploit and then launches attacks. The countermeasures against banner grabbing attacks are as follows:

  - Display false banners to mislead or deceive attackers.
  - Turn off unnecessary services on the network host to limit information disclosure.
  - Use server masking tools to disable or change banner information.
  - Remove unnecessary HTTP headers and response data and camouflage the server by providing false signatures. This also provides the option of eliminating file extensions such as **.asp** and **.aspx**, which clearly indicate that the site is running on a Microsoft server.
  - For Apache 2.x with the **mod_headers** module, use a directive in the **httpd.conf** file to change the banner information header and set the server as **New Server Name**.
  - Alternatively, change the **ServerSignature** line to **ServerSignatureOff** in the **httpd.conf** file.
  - Disable the details of the vendor and version in the banners.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Modify the value of **`Server Tokens`** from **`Full`** to **`Prod`** in Apache's **`httpd.conf`** file to prevent disclosure of the server version.
- Modify the value of **`RemoveServerHeader`** from **`0`** to **`1`** in the **`UrlScan.ini`** config file found at **`C: WindowsSystem32inetservUrlscan`**. This method prevents disclosure of the server version.
- Trick attackers by modifying the value of **`AlternateServerName`** to values such as **`xyz`** or **`myserver`**.
- Disable HTTP methods such as Connect, Put, Delete, and Options from web application servers.
- Remove the **`X-Powered-By`** header only with the **`customHeaders`** option in the **`<system.webServer>`** section of the **`web.config`** file.

- **Hiding File Extensions from Web Pages**

  File extensions reveal information about the underlying server technology that an attacker can use to launch attacks. The countermeasures against such banner grabbing attacks are as follows:

  - Hide file extensions to mask the web technology.
  - Replace application mappings such as .asp with .htm, .foo, etc. to disguise the identities of servers.
  - Apache users can use **`mod_negotiation`** directives.

- **Other Banner Grabbing Countermeasures**

  - Use packet filtering to block or restrict access to ports that might reveal banner information unnecessarily.
  - Use IDS/IPS systems to monitor and alert on scanning activities that could indicate banner grabbing attempts.
  - Replace protocols that send clear-text banners (such as HTTP, FTP, and Telnet) with their secure counterparts (HTTPS, SFTP/FTPS, SSH) to encrypt the connection and banner information.
  - Use transport layer security (TLS) for services to encrypt the banner information during the handshake process, making it more difficult for unauthorized parties to grab banners.

Note: It is preferable to not use file extensions at all.

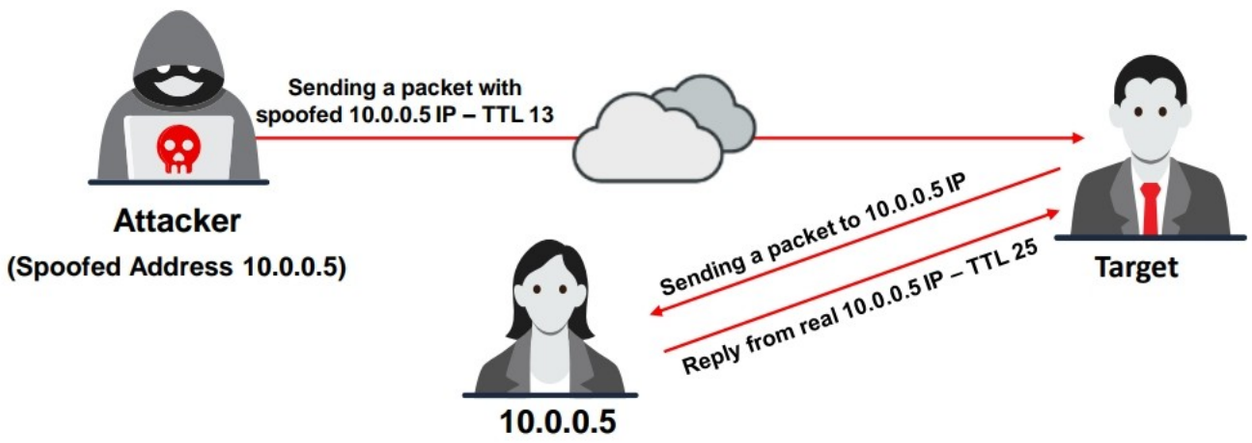
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

39 Module 03 | Scanning Networks

EC-Council CEH v13

IP Spoofing Detection Techniques: Direct TTL Probes

- Send a packet to the host of a suspected spoofed packet that triggers a reply and compare the TTL with that of the suspected packet; if the **TTL in the reply is not the same** as the packet being checked, this implies that it is a spoofed packet
- This technique is successful when the attacker is in a **different subnet** from that of the victim



Note: Normal traffic from one host can contrast TTLs depending on traffic patterns

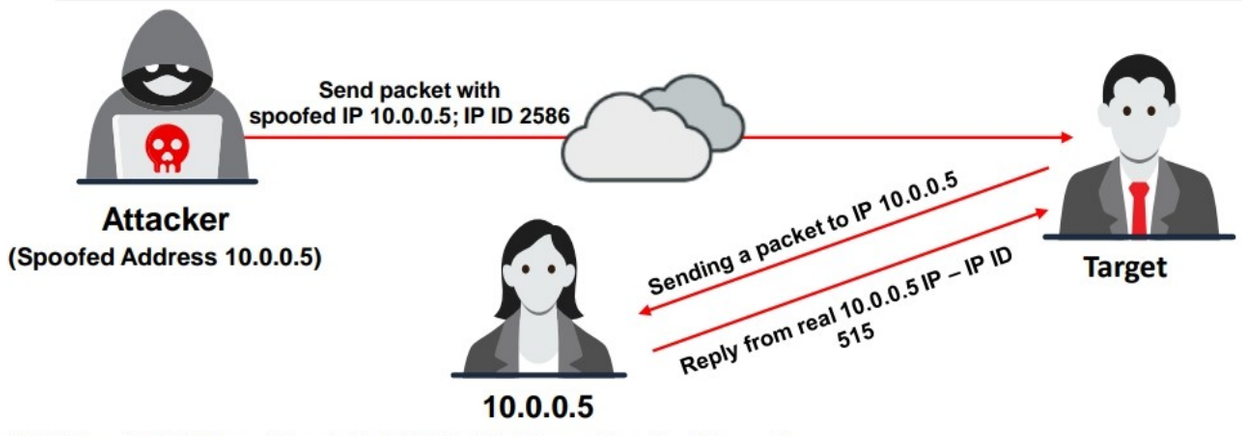
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

40 Module 03 | Scanning Networks

EC-Council CEH v13

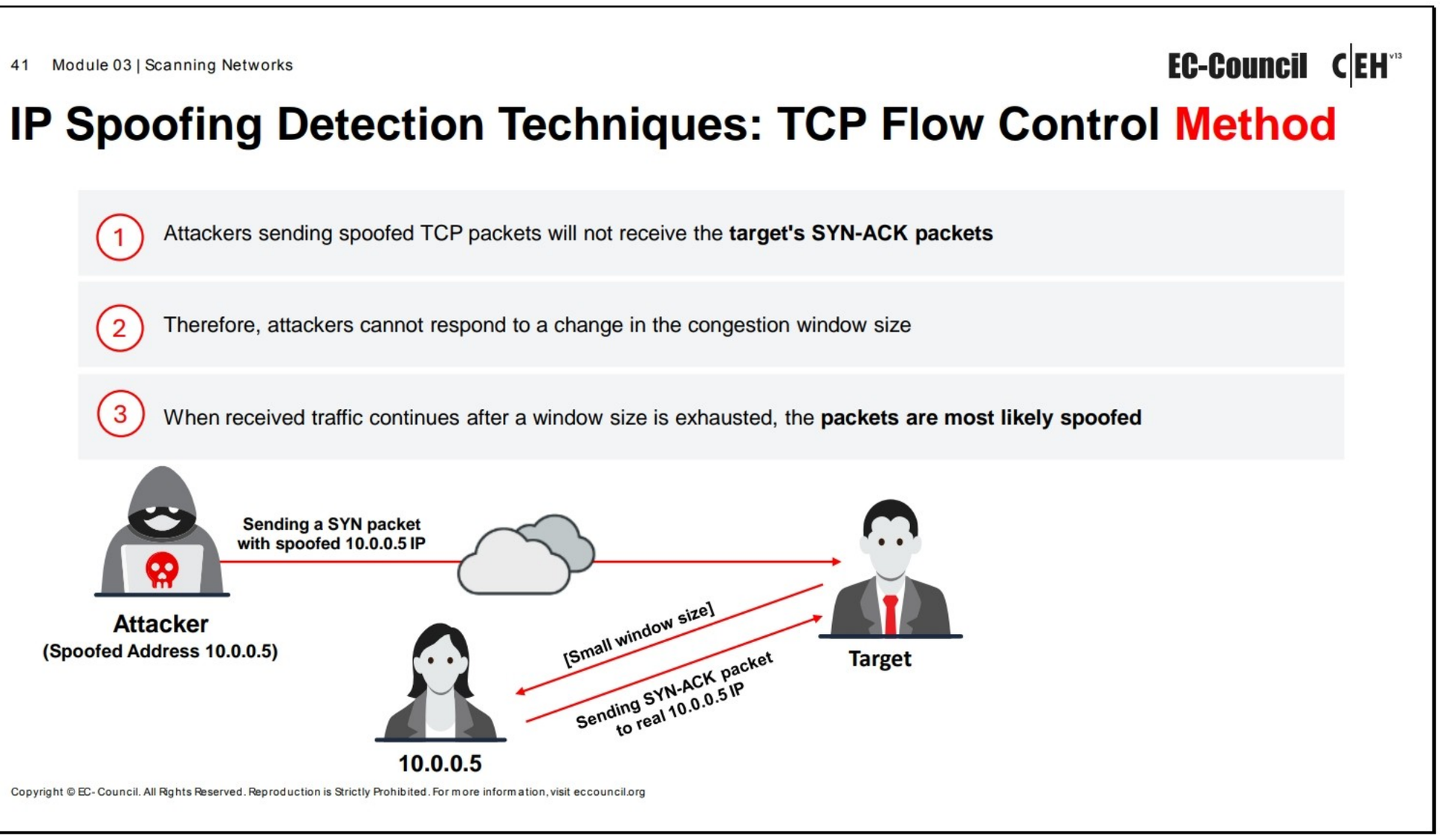
IP Spoofing Detection Techniques: IP Identification Number

1. Send a probe to the host of a suspected spoofed traffic that triggers a reply and **compare the IPID** with the suspected traffic
2. If the IPIDs are **not close in value** to the packet being checked, then the suspected traffic is spoofed
3. This technique is considered reliable even if the attacker is in the **same subnet**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



IP Spoofing Detection Techniques

- **Direct TTL Probes**

  In this technique, you initially send a packet (ping request) to the legitimate host and wait for a reply. Check whether the TTL value in the reply matches with that of the packet you are checking. Both will have the same TTL if they are using the same protocol. Although the initial TTL values vary according to the protocol used, a few initial TTL values are commonly used. For TCP/UDP, the values are 64 and 128; for ICMP, they are 128 and 255.

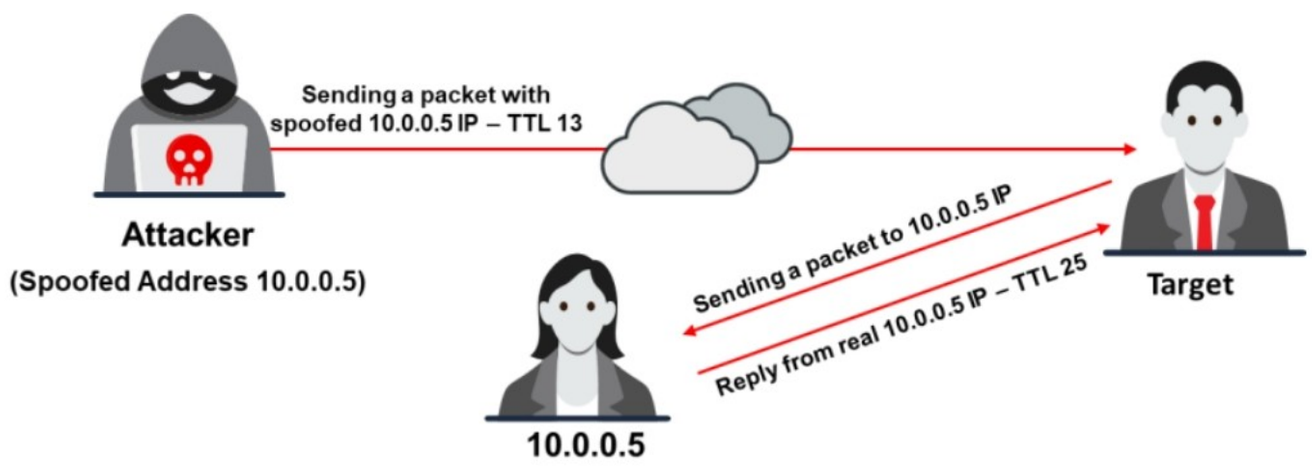


Figure 3.126: IP Spoofing detection technique: Direct TTL Probes

If the reply is from a different protocol, then you should check the actual hop count to detect the spoofed packets. Deduct the TTL value in the reply from the initial TTL value to determine the hop count. The packet is a spoofed packet if the reply TTL does not match the TTL of the packet. It will be very easy to launch an attack if the attacker knows the hop count between the source and the host. In this case, the test result is a false negative. This technique is successful when the attacker is in a different subnet from that of the victim.

Note: Normal traffic from one host can contrast TTLs depending on traffic patterns.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **IP Identification Number**

  Users can identify spoofed packets by monitoring the IP identification (IPID) number in the IP packet headers. The IPID increases incrementally each time a system sends a packet. Every IP packet on the network has a unique "IP identification" number, which is increased by one for every packet transmission. To identify whether a packet is spoofed, send a probe packet to the source IP address of the packet and observe the IPID number in the reply. The IPID value in the response packet must be close to but slightly greater than the IPID value of the probe packet. The source address of the IP packet is spoofed if the IPID of the response packet is not close to that of the probe packet.

  This method is effective even when both the attacker and the target are on the same subnet.

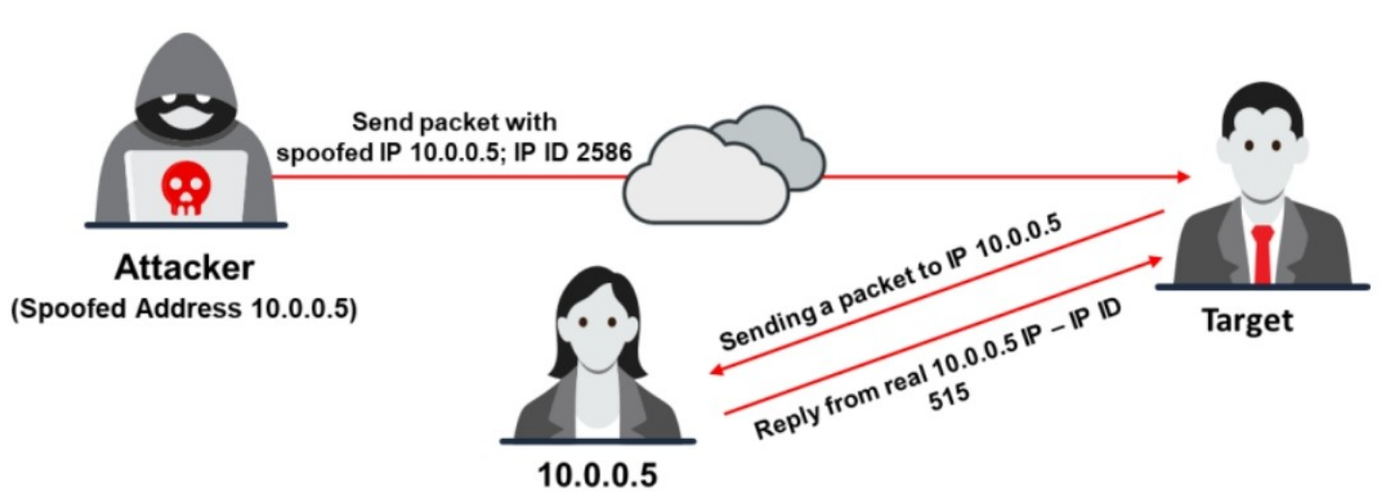


Figure 3.127: IP Spoofing detection technique: IP Identification Number

- **TCP Flow Control Method**

  The TCP can optimize the flow control on both the sender's and the receiver's end with its algorithm. The algorithm accomplishes flow control using the sliding window principle. The user can control the flow of IP packets by the window size field in the TCP header. This field represents the maximum amount of data that the recipient can receive and the maximum amount of data that the sender can transmit without acknowledgement. Thus, this field helps to control data flow. The sender should stop sending data whenever the window size is set to zero.

  In general flow control, the sender should stop sending data once the initial window size is exhausted. The attacker, who is unaware of the ACK packet containing window size information, might continue to send data to the victim. If the victim receives data packets beyond the window size, they are spoofed packets. For effective flow control and early detection of spoofing, the initial window size must be very small.

  Most spoofing attacks occur during the handshake, as it is challenging to build multiple spoofing replies with the correct sequence number. Therefore, apply the flow control spoofed packet detection method to the handshake. In a TCP handshake, the host sending the initial SYN packet waits for SYN-ACK before sending the ACK packet. To check whether you are getting the SYN request from a genuine client or a spoofed one, set SYN-ACK to zero. If the sender sends an ACK with any data, it means that the sender is a spoofed one. This is because when SYN-ACK is set to zero, the sender must respond to it only with the ACK packet, without additional data.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

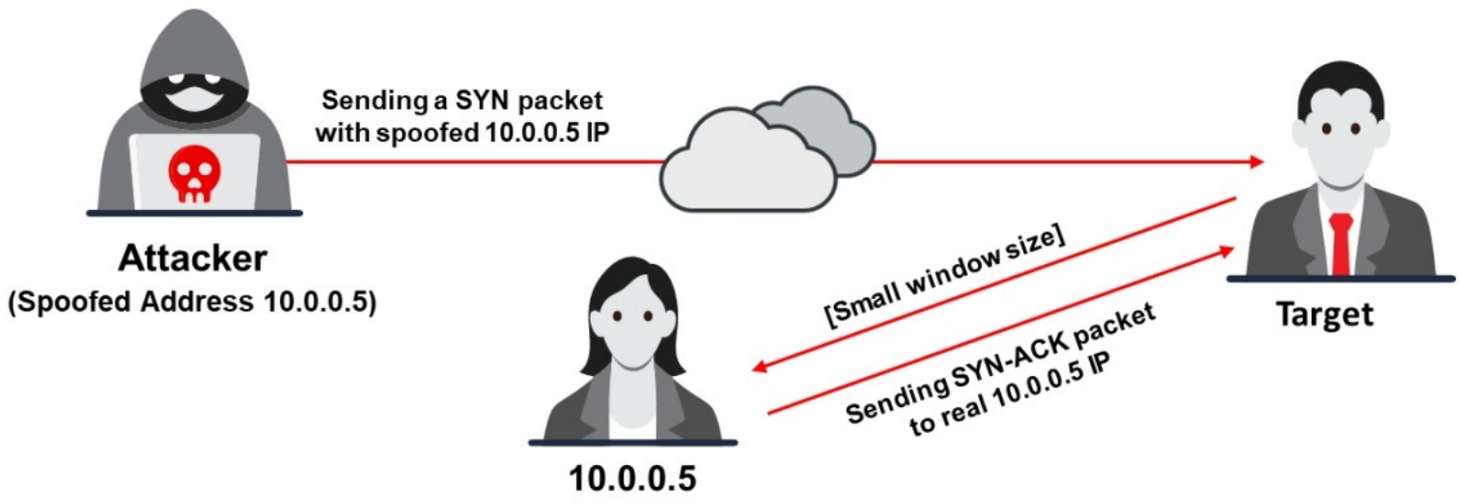
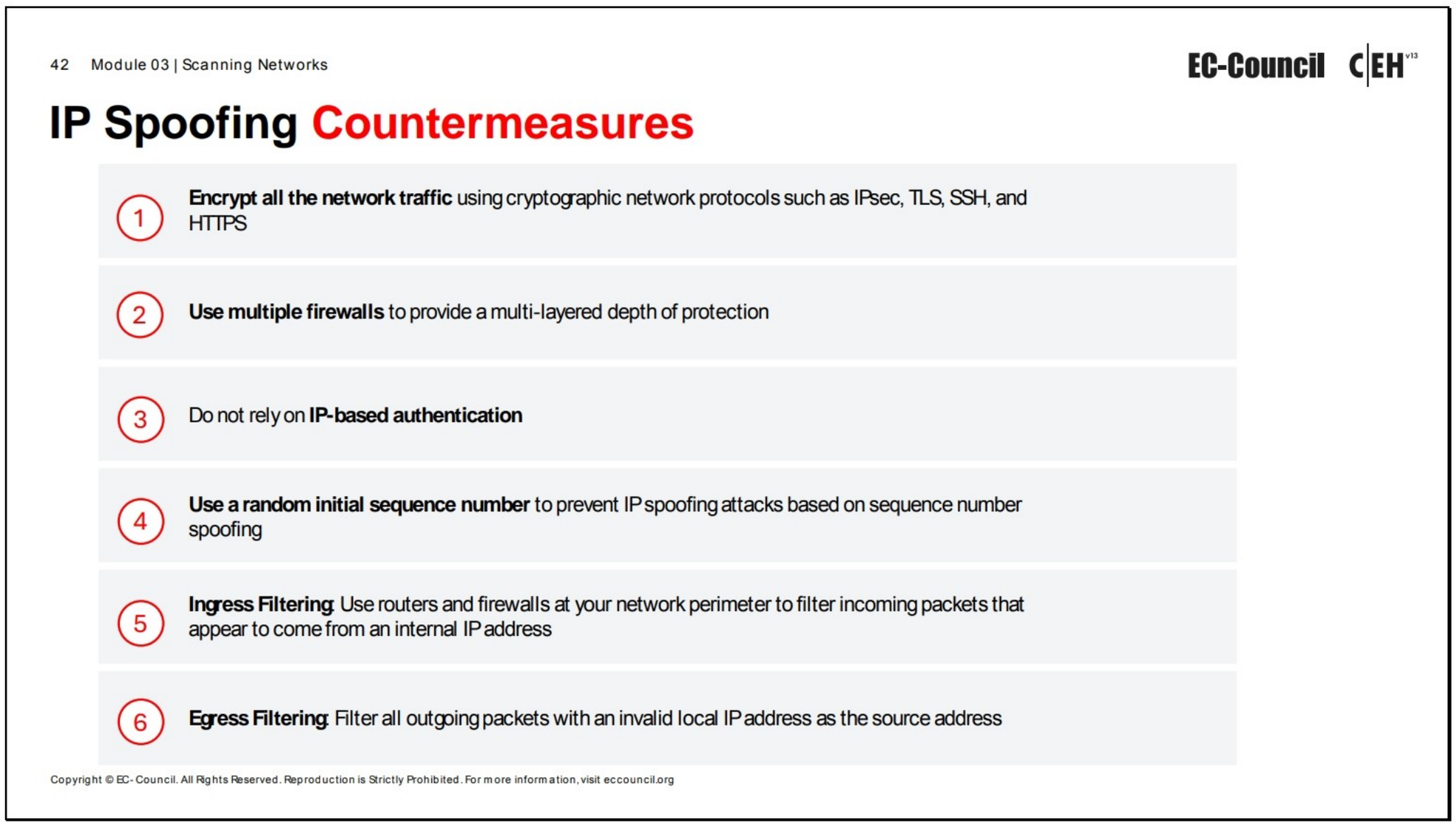


Figure 3.128: IP Spoofing detection technique: TCP Flow Control Method

Attackers sending spoofed TCP packets will not receive the target's SYN-ACK packets. Attackers cannot respond to changes in the congestion window size. When the received traffic continues after a window size is exhausted, the packets are most likely spoofed.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



IP Spoofing Countermeasures

As mentioned previously, IP spoofing is a technique adopted by a hacker to break into a target network. Therefore, to protect the network from external hackers, IP spoofing countermeasures should be applied in network security settings. Some IP spoofing countermeasures that can be applied are as follows:

- **Avoid Trust Relationships**

  Do not rely on IP-based authentication. Attackers may masquerade as trusted hosts and send malicious packets. If these packets are accepted under the assumption that they are "clean" because they are from a trusted host, malicious code will infect the system. Therefore, it is advisable to test all packets, even when they originate from a trusted host. This problem can be avoided by implementing password authentication along with trust relationship–based authentication.

- **Use Firewalls and Filtering Mechanisms**

  As stated above, all incoming and outgoing packets should be filtered to avoid attacks and loss of sensitive information. A firewall can restrict malicious packets from entering a private network and prevent severe data loss. Access-control lists (ACLs) can be used to block unauthorized access. However, the possibility of an insider attack also exists. Inside attackers can send sensitive information about the business to competitors, which could lead to financial loss and other issues. Another risk of outgoing packets is that an attacker may succeed in installing a malicious sniffing program running in a hidden mode on the network. These programs gather and send all the network information to the attacker without any notification after filtering out the outgoing packets. Therefore, the scanning of outgoing packets must be assigned the same importance as that of incoming packets.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Use Random Initial Sequence Numbers**

  Most devices choose their initial sequence numbers (ISNs) based on timed counters. This makes the ISNs predictable, as it is easy for an attacker to determine the concept of generating an ISN. The attacker can determine the ISN of the next TCP connection by analyzing the ISN of the current session or connection. If the attacker can predict the ISN, then they can establish a malicious connection to the server and sniff network traffic. To avoid this risk, use random ISNs.

- **Ingress Filtering**

  Ingress filtering prevents spoofed traffic from entering the Internet. It is applied to routers because it enhances the functionality of the routers and blocks spoofed traffic. Configuring and using ACLs that drop packets with a source address outside the defined range is one method of implementing ingress filtering.

- **Egress Filtering**

  Egress filtering is a practice that aims to prevent IP spoofing by blocking outgoing packets with a source address from the outside.

- **Use Encryption**

  To maximize network security, use strong encryption for all traffic placed on transmission media without considering its type and location. This is the best method to prevent IP spoofing attacks. IPSec can be used to drastically reduce the IP spoofing risk, as it provides data authentication, integrity, and confidentiality. Encryption sessions should be enabled on the router so that trusted hosts can communicate securely with local hosts. Attackers tend to focus on targets that are easy to compromise. If an attacker desires to break into an encrypted network, they must decrypt the entire slew of encrypted packets, which is a difficult task. Therefore, an attacker is likely to move on and attempt to find another target that is easy to compromise or simply abort the attempt. Moreover, use the latest encryption algorithms that provide strong security.

- **SYN Flooding Countermeasures**

  Countermeasures against SYN flooding attacks can also help avoid IP spoofing attacks.

- **Other IP Spoofing Countermeasures**

  - Enhance the integrity and confidentiality of websites by migrating from IPv4 to IPv6 during development.
  - Implement digital certificate authentication mechanisms such as domain and two-way auth certificate verification.
  - Use a secure VPN while accessing any type of public Internet service such as free Wi-Fi and hotspots.
  - Employ application-specific mitigation devices such as Behemoth scrubbers for deep-level packet investigation at a high speed of nearly 100 million packets/s.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Implement dynamic IPv6 address variation using a random address generator to reduce the time of active vulnerability.
- Configure routers to send encoded information about fragmented packets entering the network.
- Configure routers to verify the data packets using their signatures by storing the arriving data packet digests.
- Configure routers to hide intranet hosts from the external network by implementing modifications to the network address translation (NAT).
- Configure internal switches to table the DHCP static addresses to filter malicious spoofed traffic.
- Use secure versions of communication protocols (such as HTTPS, SFTP, and SSH) that offer encryption and authentication.

Scanning Detection and Prevention Tools

Security professionals use various sophisticated tools such as ExtraHop and Splunk Enterprise Security to detect active networks and port scanning attempts initiated by attackers.

- **ExtraHop**

  Source: *https://www.extrahop.com*

  ExtraHop provides complete visibility, real-time detection, and intelligent response to malicious network scanning. This tool allows security professionals to automatically discover and identify every device and its vulnerabilities, including unmanaged Internet of things (IoT) devices in a network. Further, this tool allows security professionals to analyze all network interactions in real time, including all cloud transactions and SSL/TLS encrypted traffic, to provide complete visibility inside the network perimeter.

  ExtraHop also assists in the auto-discovery and classification of every device in the network, using which security teams can analyze all communication.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

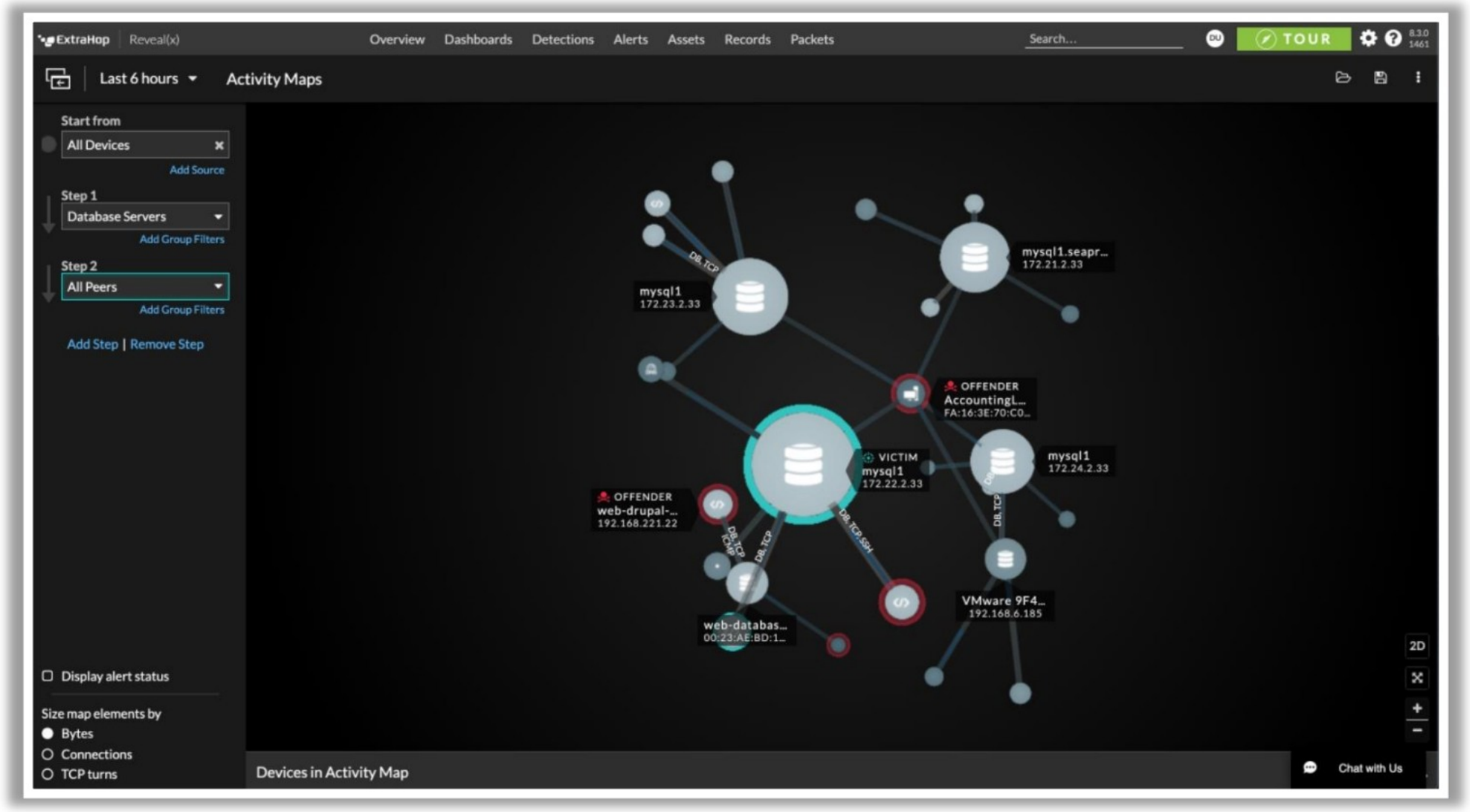


Figure 3.129: Screenshot of ExtraHop

Some of the additional scanning detection and prevention tools are listed below:

- Splunk Enterprise Security (*https://www.splunk.com*)
- Scanlogd (*https://github.com*)
- Vectra Detect (*https://www.vectra.ai*)
- IBM Security QRadar XDR (*https://www.ibm.com*)
- Cynet 360 AutoXDR™ (*https://www.cynet.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Module Summary

- In this module, we have discussed the following:
  - How attackers discover live hosts from a range of IP addresses by sending various ping scan requests to multiple hosts
  - How attackers perform different scanning techniques to determine open ports, services, service versions, etc. on the target system
  - How attackers perform banner grabbing or OS fingerprinting to determine the operating system running on a remote target system
  - Various scanning techniques that attackers can employ to bypass IDS/firewall rules and logging mechanisms, and disguise themselves as regular network traffic
  - Network scanning countermeasures to defend against network scanning attacks
- In the next module, we will discuss in detail how attackers, as well as ethical hackers and pen-testers, perform enumeration to collect information about a target before an attack or audit

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Module Summary

This module discussed how attackers determine live hosts from a range of IP addresses by sending various ping scan requests to multiple hosts. It also described how attackers perform different scanning techniques to determine open ports, services, service versions, etc., on the target system. Furthermore, it explained how attackers perform banner grabbing or OS fingerprinting to determine the OS running on a remote target system. It also illustrated various scanning techniques that attackers can adopt to bypass IDS/firewall rules and logging mechanisms and hide themselves as usual under network traffic. Finally, it ended with a detailed discussion on network scanning countermeasures to defend against network scanning attacks.

In the next module, we will discuss in detail how attackers as well as ethical hackers and pen-testers perform enumeration to collect information about a target before an attack or audit.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.